

- 国内首部面向初学者系统介绍工业控制网络安全的著作
- 工业控制网络安全领域的专家合作编写，从学术与工程视角全面涵盖工业控制网络的原理、技术与实践，帮助读者深度理解和掌握工业控制网络安全的精髓

工业控制网络 安全技术与实践

姚羽 祝烈煌 武传坤 编著



INDUSTRIAL
CONTROL
NETWORK SECURITY
TECHNOLOGY AND PRACTICE

机械工业出版社
China Machine Press

本书既有对工业控制网络安全理论和技术的介绍,又有企业实战的经典案例,特别适合高校教学和技术培训使用。希望本书的出版能对我国工业控制网络安全领域的人才培养和技术发展起到积极作用,也希望更多的高校和企业加入到工控网络安全人才培养的队伍中来,产学研合作,为我国网信事业发展培养更多人才。

—— 封化民 教育部高等学校信息安全专业教学指导委员会秘书长

目前国内工业控制网络安全产业要解决的问题很多,其中一方面就是专业人才的培养。本书的出版恰逢其时,它填补了我国在工业控制网络安全领域教材的空白。本书既有理论价值,又汇集了实践经验,相信本书的出版能为工控网络安全的教学和研究提供有益的参考。

—— 孙一桢 北京国 [redacted] 会主席

随着工业化与信息化的深度融合,工业控制系统中的信息化程度越来越高,随之而来的网络安全风险也越来越大,加之工业控制网络安全问题的独特性,导致掌握工业控制网络安全知识和工业控制网络漏洞分析与安全防护技术的专业人才极其缺乏,本书正是为满足这一需求而编写的。

主要特色

- 聚焦工业控制网络安全。本书以工业控制网络安全为核心,系统介绍了工业控制系统、工业控制网络、工业控制系统整体安全性、SCADA系统的安全性、工业控制系统网络漏洞、协议、安全防护等,旨在帮助读者全面了解工业控制网络安全领域的知识。
- 理论与实践深度融合。由于工业控制网络安全是跨学科的交叉领域,本书采取了高校和企业联合编写的新模式,将工业控制网络安全的基本原理、概念系统展现出来,并辅以企业由真实项目凝练而来的案例,能够满足读者从理论到实践的多层次学习需求。
- 丰富的教学辅助资源。为了帮助高校开展课程教学,本书还提供了PPT、习题答案、实验手册等教学辅助资源,需要的教师可登录华章网站(www.hzbook.com)下载。

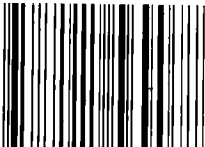


投稿热线: (010) 88379604
客服热线: (010) 88379426 88361066
购书热线: (010) 68326294 88379649 68995259

华章网站: www.hzbook.com
网上购书: www.china-pub.com
数字阅读: www.hzmedia.com.cn

上架指导: 计算机/网络安全

ISBN 978-7-111-56907-7



9 787111 569077 >

定价: 69.00元

工业控制网络 安全技术与实践

姚羽 祝烈煌 武传坤 编著



机械工业出版社
China Machine Press

图书在版编目 (CIP) 数据

工业控制网络安全技术与实践 / 姚羽, 祝烈煌, 武传坤编著. —北京: 机械工业出版社, 2017.5

(信息安全技术丛书)

ISBN 978-7-111-56907-7

I. 工… II. ①姚… ②祝… ③武… III. 工业控制计算机—计算机网络—信息安全—高等学校—教材 IV. TP273

中国版本图书馆 CIP 数据核字 (2017) 第 113756 号

本书是一本关于工业控制系统网络安全技术的专业教材。本书首先介绍工业控制系统与工业控制网络的概念、SCADA 和 DCS 两个典型的工业控制系统、一般工业控制系统的重要组成单元, 然后介绍工业控制网络常见的安全威胁、工业控制系统各组成部分的脆弱性和安全防护技术、工业控制网络的常用通信协议和安全防护技术以及工业控制网络的漏洞特征、漏洞挖掘和攻击检测等技术, 最后针对工业控制的几个典型领域进行了安全分析并给出了解决方案。

本书内容系统深入, 可作为高等院校工业自动化、计算机科学与技术、信息安全等相关专业本科生和研究生的教材, 也可以作为工业控制网络安全领域的研究人员和工程技术人员的培训用书及参考书。

工业控制网络安全技术与实践

出版发行: 机械工业出版社 (北京市西城区百万庄大街 22 号 邮政编码: 100037)

责任编辑: 余 洁

责任校对: 殷 虹

印 刷: 北京市荣盛彩色印刷有限公司

版 次: 2017 年 7 月第 1 版第 1 次印刷

开 本: 186mm×240mm 1/16

印 张: 16.5

书 号: ISBN 978-7-111-56907-7

定 价: 69.00 元

凡购本书, 如有缺页、倒页、脱页, 由本社发行部调换

客服热线: (010) 88379426 88361066

投稿热线: (010) 88379604

购书热线: (010) 68326294 88379649 68995259

读者信箱: hzit@hzbook.com

版权所有·侵权必究

封底无防伪标均为盗版

本书法律顾问: 北京大成律师事务所 韩光 / 邹晓东

本书编写委员会

顾 问：封化民 陈性元 李春升 陆余良 王 伟
诸葛建伟 雷 敏 张 磊

主 任：姚 羽 祝烈煌 武传坤

副主任：何宛馨 王 亮 王志威 张彬哲 张记卫

委 员：(以汉语拼音为序)

白 波 冯文博 黄 伟 李明政 刘 爽
刘昕蕊 马文杰 汪义舟 王 行 王中东
邢 鹏 杨 革 杨 莹 杨应军 张大江
张子剑 赵 杰 周家豪

序 — *Forward*

随着德国的“工业 4.0”、美国的“再工业化”风潮、“中国制造 2025”等国家战略的推出，以及云计算、大数据、物联网等新技术、新应用的大规模使用，工业控制系统逐渐由封闭独立走向开放、由单机走向互联、由自动化走向智能化。伴随这一趋势，工业控制系统网络安全的隐患日益凸显，伊朗核电站遭受“震网”攻击事件和乌克兰电网遭受持续攻击事件等更为我们敲响了警钟。工业控制系统已成为国家关键基础设施的“中枢神经”，其安全关系到国家的战略安全、社会稳定。

工业控制系统所面临的安全威胁是全世界面临的一个共同难题。工业设备的高危漏洞、后门、工业网络病毒、高级持续性威胁以及无线技术应用带来的风险，给工业控制系统的安全防护带来巨大挑战。

目前，我国工业控制网络安全形势不容乐观，主要表现在：一是传统上注重硬件方面的投入，对工业控制安全的投入较少；二是工业控制网络安全软硬件和服务资源不足，工业控制网络安全从业人员的数量极度匮乏，难以满足行业需求；三是随着工业化和信息化的深度融合以及物联网的快速发展，工业控制系统以前所未有的速度发展，工业控制网络安全问题更加突出，对工业控制网络安全的技术、人才建设等不断提出新的要求。工业控制网络作为关键基础设施的重要组成部分，其安全问题不容忽视。从目前工业控制网络安全检查情况来看，行业一线真正懂得工业控制网络安全的人才非常缺乏，网络空间的竞争归根结底是人才竞争，要进一步推动工业控制网络安全事业的发展，关键在于加快相关人才的培养，让安全人才真正成为信息网络安全的核心驱动力量。

我们也要看到，工业控制网络安全是典型的工业自动化、通信网络、电子信息与行业融合的应用安全。工业控制网络安全涉及多领域知识的应用，有其特殊性，主要体现在：一是一般网络安全技术人员由于不了解工业控制现场，对工业控制理论和工业控制的实时、不可

停滞等特殊要求了解不深入，往往很难涉足工业控制安全领域；二是绝大多数工业控制自动化相关技术人员对网络安全了解不多，无法从事工业控制网络安全的相关工作。因此，工业控制网络安全人才的培养既迫切，又极具难度。我国网络空间安全学科建设刚刚起步，作为网络空间安全的重要部分，应该将工业控制网络安全纳入网络空间安全学科之中，以加快工业控制网络安全复合型人才的培养。

国内已有一批关注工业控制网络安全的教师和专家投入到工业控制网络安全人才培养工作中，但目前的问题是鲜有将工业控制和网络安全结合的书籍。本书基于作者在工业控制网络安全领域的研究成果和实践经验，系统地对工业控制系统网络基础知识、工业控制系统安全性及典型行业的工业控制网络安全应用案例进行了介绍，可帮助读者建立对工业控制网络安全的全面认知。该书既有工业控制网络安全前沿理论和技术的知识，又对当前常用工业控制技术和网络安全技术进行了总结，并有企业实战经验案例，特别适合高校教学和技术培训使用。希望本书的出版能对我国工业控制网络安全领域人才培养和工业控制网络安全技术发展起到积极作用，也希望更多的高校和企业加入到工业控制网络安全人才培养的队伍中来，产学研合作，为我国网信事业发展培养更多优秀人才！

封化民

教育部高等学校信息安全专业教学指导委员会 秘书长

序 二 *Foreword*

工业控制网络安全正在成为网络空间对抗的主战场和反恐新战场，工业网络安全领域的对抗正在改变当今世界格局。

工业控制系统广泛应用于各个领域，包括基础设施（金融、能源、通信、电力、交通）、民生（水、电、燃气、医院、智慧城市、智能汽车）、工业生产（冶金、电力、石油化工、核能等）和军工等。超过 80% 的涉及国计民生的关键基础设施依靠工业控制系统来实现自动化作业。网络信息安全防护理念正在发生深刻演变，以工业控制系统为中枢神经的国家关键基础设施安全和关键信息基础设施安全面临更为严峻的全新挑战。

当前，我国在工业控制系统安全的认知、感知、防护、标准等方面都存在很多亟待完善的地方。国内工业控制系统主要面临如下威胁：设备存在大量的高危漏洞，越来越普遍的设备后门实施，高级持续性威胁，无线技术的广泛应用给工业控制系统的安全防护带来巨大挑战。积极应对网络安全威胁，有效防范网络安全风险，是网络时代维护国家安全、社会稳定、公众利益的重要使命。

随着“中国制造 2025”和“智慧城市”建设的推进，网络安全问题随之产生，工业控制网络安全形势日趋严峻。近年来，世界各国发生了众多工业基础设施网络安全事件，工业控制系统安全已经由量变到了质变的阶段。以先进的网络技术攻击关键基础设施已经成为国家间攻防对抗以及恐怖主义威胁的新形式和新手段，看不见硝烟的战争已经打响，安全形势很严峻。

在智能化社会背景下，代码即武器。依靠工业控制系统实现自动化的基础设施和智能制造，以及在智慧城市建设中越来越普遍采用基于嵌入式技术的智能终端，都极有可能成为“武器”。在网络强国战略的背景下，工业控制系统网络安全、基础设施安全势必成为我国网络安全发展的主攻方向之一。目前，国内工业控制网络安全产业要解决的问题还很多，其中

一方面就是专业人才的培养，因为工业控制网络安全产业的发展离不开大量的专业技术人才。

本书的出版适逢其时，它填补了我国工业控制网络安全领域教材的空白。本书既有理论价值，又汇集了实践经验，可作为高等院校自动化类、信息安全类等相关专业的课程教材，也可作为工业控制网络安全培训教材以及专业教师、工业控制网络安全工程师的参考书。相信本书的出版能够给工业控制网络安全研究者提供有益的参考。

作为率先投身工业控制网络安全研究的专业人员与相关专业的企业领导者，我深知工业控制网络安全复合型人才稀缺与企业对这部分人才的渴求。因此，该书必将为保障国家关键信息基础设施网络安全培养更多、更优秀、更专业的工业控制网络安全人才，对促进国内工业控制网络安全的研究与发展发挥重要的推动作用。

孙一桢

北京匡恩网络科技有限公司 技术委员会主席

前 言 Preface

随着信息技术和网络技术的迅猛发展，国家安全边界已经超越地理空间限制，延伸到信息网络，网络空间成为继陆、海、空、天之后的第五大国家主权空间。作为网络空间安全的重要组成部分，工业控制网络安全涉及国家关键基础设施和经济社会稳定，辐射范围广泛，应当予以充分重视。

工业控制系统广泛应用于电力、水利、污水处理、石油化工、冶金、汽车、航空航天等诸多现代工业，其中超过 80% 涉及国计民生的关键基础设施（如铁路、城市轨道交通、给排水、通信等）。随着工业化与信息化的深度融合、“互联网+”及国务院“中国制造 2025”战略的提出，工业控制系统中信息化程度越来越高，通用软硬件和网络设施的广泛使用打破了工业控制系统与信息网络的“隔离”，带来了一系列网络安全风险。其中涉及的不仅仅是信息泄露、信息系统无法使用等“小”问题，而是会对现实世界造成直接的、实质性的影响，如设备故障、环境污染、人员伤亡甚至危害国家安全，其后果是无法预计的。

我国政府对工业控制系统的安全性予以高度重视，在国家战略、规范管理、信息共享、技术支撑等方面不断突破，致力于构建完善的工业控制网络安全保障体系。但是，目前国内网络安全研究团队的研究对象多集中在互联网和传统信息系统上，掌握工业控制网络安全知识、了解工业控制网络漏洞分析与安全防御技术的人极少，远不能满足各行业对工业控制网络人才的渴求，不能适应国家的发展战略。

本书围绕工业控制系统的安全，对工业控制系统、工业控制网络、工业控制系统整体安全性、SCADA 系统安全性、工业控制网络漏洞、工业控制网络协议、工业控制网络安全防御等进行了详细的阐述。最后列举了几个典型工业控制安全案例，旨在帮助读者全面了解工业控制系统安全领域的相关知识，建立防护意识。

本书共分为 8 章，各章主要内容概述如下：

第1章介绍了工业控制系统与工业控制网络的概念,描述了国内工业控制行业的现状及工业控制网络安全的发展趋势,并说明了工业控制系统中常用的术语。

第2章介绍了工业控制系统中 SCADA 与 DCS 这两个典型系统、控制器、现场设备,着重描述了 PLC 设备,并介绍了几种典型的工业控制网络。

第3章介绍了工业控制网络常见的安全威胁,并针对工业控制系统不同网络层的脆弱性进行了分析。

第4章介绍了 SCADA 系统的组成、安全需求、安全目标及脆弱性,描述了 SCADA 系统边界防护、异常行为检测、安全通信及密钥管理、风险评估与安全管理,介绍了 SCADA 系统安全测试平台,最后简要介绍了 SCADA 系统典型案例及发展趋势。

第5章详细介绍了四种常见的工业网络协议,并说明了各协议存在的安全问题,并有针对性地提出安全防护技术。

第6章介绍了工业控制网络漏洞的特征、分类、发布平台及态势,描述了针对已知漏洞的检测技术和针对未知漏洞的挖掘技术,分析了上位机、下位机及工业控制网络设备漏洞。

第7章全面介绍了工业控制网络安全防护技术,描述了工业控制安全设备的引入和使用方法,详细说明了对于已知与未知工业控制安全威胁的处理方法。

第8章举例分析了几个典型的工业控制行业现状与安全趋势,并描述了相匹配的安全解决方案。

全书逻辑清晰,行文流畅,采用通俗易懂的方式介绍工业控制系统网络安全的相关知识,并提供了适当的图解,具有很强的可读性和实用性。

工业控制网络安全是集合了工业控制与网络安全的综合性、应用型方向,要求学习该方向的读者能够将系统知识与专业知识有机结合,在注重提升理论高度的前提下,将理论知识与工程实践紧密联系起来。本书结合工业控制网络安全领域的知识特点,充分考虑其知识体系、教育层次和课程设置,增设各行业典型实际案例,努力做到紧跟前沿技术的发展,使读者能够学以致用。教师可以基于本书增加实验课程,使学生更生动直观、深刻具体地掌握真实有效、切实可行的工业控制网络安全防护手段和思想。无论是初学者还是有一定经验的从业者,都可以从本书中找到所需要的内容。

本书可以作为高等院校自动化、计算机科学与技术、信息安全等相关专业的本科生、研究生教学用书,或工业控制系统安全相关人员的培训教材,也可以作为对工业控制网络安全感兴趣的普通读者和相关技术人员的参考资料。

希望更多的读者能通过学习本书更清晰、全面地掌握工业控制网络安全知识,为增强工业控制网络安全防护能力打下较为系统和扎实的基础。

在编写的过程中，本书除了借鉴多位专家的多年工作和研究内容外，还参考了大量的国内外优秀书籍、论文及网上公布的相关资料，并以参考文献的形式列出，可为读者进一步深入研究提供参考信息。

本书从策划到编写，得到了教育部高等学校信息安全专业教学指导委员会秘书长封化民教授的大力支持和指导，他对教材进行了审阅，提出了宝贵的建议，并欣然作序；解放军信息工程大学电子技术学院教授陈性元、北京航空航天大学博士生导师李春升、解放军电子工程学院博士生导师陆余良、国防科技大学电子工程所所长王伟、清华大学网络科学与网络空间研究院副研究员诸葛建伟、北京邮电大学副教授雷敏也审阅了本书，对本书内容提出了大量的意见和建议；机械工业出版社华章公司的各位编辑在本书的出版过程中给予了大力支持与帮助。在此深表感谢。

工业控制网络安全是自动化与信息安全结合演变的新兴领域，本书作为该领域的首本教材，在编写时虽力求全面、系统，但随着工业化和信息化大规模发展，工业控制系统网络安全技术日新月异，加之作者能力所限，书中难免有一些错误和不当之处，恳请读者提出宝贵意见，以期再版修订。

作 者

2017年5月

Suggestion 教学 / 学习建议

如采用本书作为课程教材或培训教材，可参考本部分给出的建议安排教学内容和授课时长。读者也可依据本部分的建议和进度安排进行自学。

章节	教学 / 学习要求	课时
第 1 章 绪论	熟悉工业控制系统概念 熟悉工业控制网络与传统 IT 信息网络的异同 了解工业控制系统的威胁、脆弱点 了解典型工业控制系统事件	1
第 2 章 工业控制系统基础	了解工业控制系统的内容 了解 SCADA 系统的组成部分及主要功能 熟悉 DCS 的组成部分及特点	1
	熟悉 PLC 的主要功能 熟悉 PAC 的主要功能及优点 了解 RTU 的主要功能及优点 熟悉 IED 的工作机制 熟悉 HMI 的组成及特点	2
	了解 PLC 的产生原因及特点 熟悉 PLC 的结构及工作原理 掌握 PLC 的主要指令系统类别 熟悉 PLC 的通信技术规程 熟悉 PLC 的接口电路要求	2
	了解钢铁、石化、电力、市政交通行业的主要系统组成及结构	1
第 3 章 工业控制网络安全威胁	了解工业控制网络结构与组成 熟悉常见的安全威胁 掌握现场总线控制网络的脆弱性 掌握过程控制与监控网络的脆弱性 掌握企业办公网络的脆弱性	3

(续)

章节	教学 / 学习要求	课时
第 4 章 SCADA 系统安全分析	掌握 SCADA 系统组成 熟悉 SCADA 系统安全需求 熟悉 SCADA 系统安全目标 熟悉 SCADA 系统脆弱性 掌握安全域及边界防护 掌握异常行为检测技术 掌握安全通信及密钥管理 掌握风险评估与安全管理要点	2
	了解 SCADA 系统安全测试平台 了解电力 SCADA 系统安全防护技术 了解 SCADA 系统安全发展趋势	1
第 5 章 工业控制网络通信协议的 安全性分析	了解 Modbus 总线协议 掌握 Modbus 协议安全缺陷 掌握 Modbus 协议安全防护技术 了解 DNP3 协议 掌握 DNP3 协议安全缺陷 掌握 DNP3 协议安全防护技术	3
	了解 IEC 系列协议 掌握 IEC 系列协议安全缺陷 掌握 IEC 系列协议安全防护技术 了解 OPC 协议 掌握 OPC 协议安全缺陷 掌握 OPC 协议安全防护技术	3
第 6 章 工业控制网络漏洞分析	掌握工控安全漏洞特征 掌握工控安全漏洞分类 了解工控安全漏洞标准化工作 了解工控安全漏洞态势分析 掌握已知漏洞的检测技术 掌握未知漏洞的挖掘技术	3
	掌握上位机概念与安全分析 掌握下位机概念与安全分析 掌握工控网络设备安全与漏洞分析	4
第 7 章 工业控制网络安全 防护技术	了解传统信息系统与工业控制网络安全的不同侧重点 熟悉边界防护的主要安全设备 熟悉准入控制的主要设备类型 精通安全设备的选择方法 精通防火墙设备的配置方法 精通边界隔离与访问控制原理 精通防火墙技术原理 掌握漏洞发现技术原理 掌握补丁管理方法	3

(续)

章节	教学 / 学习要求	课时
第 7 章 工业控制网络安全 防护技术	了解工业控制网络行为安全定义 了解工业控制网络中的行为类型 熟悉可信计算的内容 熟悉加解密算法原理 熟悉安全开发流程的内容 掌握运营安全的重要性 掌握运营安全的日常内容 熟悉违规行为分析方法 熟悉违规行为处理方法 掌握异常参量和异常行为的定义 掌握异常行为的分析方法 熟悉工业控制网络中白名单技术的应用原理 熟悉常用白名单技术类型 熟悉智能列表定义 熟悉事件关联技术的类型 熟悉系统关联的定义 了解蜜罐技术的意义 了解蜜罐技术的组成部分	2
第 8 章 综合案例分析	了解数控制造业工控网络安全现状及解决方案 了解城市燃气行业工控网络安全现状及解决方案 了解石油化工行业工控网络安全现状及解决方案	1
总课时	第 1 ~ 8 章建议课时	32
	综合实训课时	8

说明：1) 建议课堂教学全部在实验室内完成，实现“讲—练”结合。

2) 建议教学分为核心知识技能模块和技能提高模块，其中核心知识技能模块建议课时为 24，技能提高模块建议课时为 8，不同学校可以根据各自的教学要求和计划课时数对教学内容进行取舍。

目 录 Contents

本书编写委员会

序一

序二

前言

教学 / 学习建议

第1章 绪论 1

- 1.1 工业控制系统与工业控制网络
概述 1
 - 1.1.1 什么是工业控制系统 1
 - 1.1.2 什么是工业控制网络 3
 - 1.1.3 工业控制网络与传统 IT 信息
网络 4
- 1.2 国内工业控制行业现状 6
- 1.3 国内工业控制网络安全趋势
分析 7
- 1.4 工业控制系统常用术语 9
- 1.5 本章小结 10
- 1.6 本章习题 10

第2章 工业控制系统基础 11

- 2.1 数据采集与监视控制系统 11

- 2.1.1 什么是 SCADA 系统 12
- 2.1.2 SCADA 后台子系统的主要
功能 13
- 2.1.3 SCADA 系统未来的技术
发展 14

2.2 分布式控制系统 14

- 2.2.1 什么是 DCS 14
- 2.2.2 DCS 的组成 15
- 2.2.3 DCS 的特点 16

2.3 工业控制系统中的常用控制器 17

- 2.3.1 可编程逻辑控制器 17
- 2.3.2 可编程自动化控制器 19
- 2.3.3 远程终端单元 20

2.4 工业控制系统现场设备的种类 22

- 2.4.1 智能电子设备 22
- 2.4.2 人机界面 23

2.5 PLC 设备的技术原理 25

- 2.5.1 PLC 的产生与特点 25
- 2.5.2 PLC 的基本组成与工作原理 27
- 2.5.3 PLC 的基本指令系统 31
- 2.5.4 PLC 的通信技术 36
- 2.5.5 PLC 的接口技术 38

2.6	典型工业领域的工业控制网络	39	4.1.3	SCADA 系统的安全目标	64
2.6.1	钢铁行业的工业控制网络	39	4.1.4	SCADA 系统的脆弱性	65
2.6.2	石化行业的工业控制网络	39	4.2	SCADA 系统安全的关键技术	69
2.6.3	电力行业的工业控制网络	42	4.2.1	安全域划分及边界防护	69
2.6.4	市政交通行业的工业控制网络	43	4.2.2	SCADA 系统异常行为检测技术	75
2.7	本章小结	44	4.2.3	SCADA 系统安全通信及密钥管理	79
2.8	本章习题	45	4.2.4	SCADA 系统安全管理	84
第3章	工业控制网络安全威胁	46	4.3	SCADA 系统安全测试平台	91
3.1	工业控制网络概述	46	4.3.1	SCADA 系统安全测试平台的重要性	91
3.1.1	现场总线控制网络	46	4.3.2	SCADA 系统安全测试平台的分类	92
3.1.2	过程控制与监控网络	47	4.3.3	SCADA 系统安全测试平台的搭建	93
3.1.3	企业办公网络	48	4.3.4	基于 SCADA 系统安全测试平台的实验	94
3.2	工业控制网络常见的安全威胁	48	4.3.5	SCADA 系统安全测试平台实例——HoneyNet	95
3.2.1	高级持续性威胁攻击	49	4.4	SCADA 系统安全典型案例	97
3.2.2	工业控制网络病毒	50	4.5	SCADA 系统安全发展趋势	98
3.2.3	工业控制网络协议安全漏洞	55	4.6	本章小结	99
3.3	工业控制系统脆弱性分析	56	4.7	本章习题	100
3.3.1	现场总线控制网络脆弱性分析	57	第5章	工业控制网络通信协议的安全性分析	101
3.3.2	过程控制与监控网络脆弱性分析	57	5.1	工业控制网络常用通信协议概述	101
3.3.3	企业办公网络脆弱性分析	58	5.2	Modbus 协议	102
3.4	本章小结	59	5.2.1	Modbus 协议概述	103
3.5	本章习题	60			
第4章	SCADA 系统安全分析	61			
4.1	SCADA 系统安全概述	61			
4.1.1	SCADA 系统的组成	61			
4.1.2	SCADA 系统的安全需求	62			

5.2.2	Modbus 协议存在的安全 问题	108	6.2.2	未知漏洞的挖掘技术	148
5.2.3	Modbus 协议安全防护技术	109	6.3	上位机漏洞分析	152
5.3	DNP3 协议	110	6.3.1	上位机概念和简史	152
5.3.1	DNP3 协议概述	111	6.3.2	上位机常见安全问题	154
5.3.2	DNP3 协议存在的安全问题	112	6.3.3	上位机典型漏洞分析	155
5.3.3	DNP3 协议安全防护技术	114	6.4	下位机漏洞分析	161
5.4	IEC 系列协议	114	6.4.1	下位机概念和简史	162
5.4.1	IEC 系列协议概述	115	6.4.2	下位机常见安全问题	163
5.4.2	IEC 系列协议存在的安全 问题	121	6.4.3	下位机典型漏洞分析	164
5.4.3	IEC 系列协议安全防护技术	122	6.5	工控网络设备漏洞分析	169
5.5	OPC 协议	123	6.5.1	工控网络设备概念	169
5.5.1	OPC 协议概述	124	6.5.2	工控网络设备常见安全 问题	169
5.5.2	OPC 协议存在的安全问题	131	6.5.3	工控网络设备典型漏洞 分析	170
5.5.3	OPC 协议安全防护技术	133	6.6	本章小结	173
5.6	本章小结	135	6.7	本章习题	173
5.7	本章习题	135			
第6章	工业控制网络漏洞分析	136	第7章	工业控制网络安全防护技术	174
6.1	工业控制网络漏洞概述	136	7.1	工业控制网络安全设备的引入和 使用方法	174
6.1.1	工业控制网络安全漏洞挖掘 技术分析	136	7.1.1	从信息安全到工业控制网络 安全	174
6.1.2	工业控制网络安全漏洞分析	138	7.1.2	工业控制网络安全设备的 引入	175
6.1.3	工业控制网络安全漏洞标准化 工作	139	7.1.3	工业控制网络安全设备的 使用方法	179
6.1.4	工业控制网络安全漏洞态势 分析	141	7.2	对工业控制网络已知安全威胁的 防护方法	181
6.2	工业控制网络安全漏洞分析 技术	144	7.2.1	结构安全	182
6.2.1	已知漏洞的检测技术	144	7.2.2	设备与主机安全	185

7.2.3	行为安全	187	8.1.2	先进制造行业工控网络安全 解决方案	215
7.2.4	基础软硬件安全	189	8.2	城市燃气行业案例	220
7.2.5	安全时间持续性	196	8.2.1	城市燃气行业工控网络安全 分析	220
7.3	对工业控制网络未知安全威胁的 防护方法	198	8.2.2	城市燃气行业工控网络安全 解决方案	222
7.3.1	纵深防御技术	198	8.3	石油化工行业案例	226
7.3.2	异常行为检测	199	8.3.1	石油化工行业工控网络安全 分析	226
7.3.3	白名单技术	202	8.3.2	石油化工行业工控网络安全 解决方案	228
7.3.4	关联分析技术	205	8.4	本章小结	235
7.3.5	蜜罐技术	209	8.5	本章习题	235
7.4	本章小结	210			
7.5	本章习题	211			
第8章	综合案例分析	212	附录	国内外工控系统典型攻击 事件	236
8.1	先进制造行业案例	212	参考文献		242
8.1.1	先进制造行业工控网络安全 分析	212			



第 1 章

Chapter 1

绪 论

当前，我国正处在以信息技术、智能制造、新能源和新材料等战略新兴产业为代表的新一轮技术创新浪潮中，传统工业控制系统与信息技术的结合日益紧密。工业控制网络（简称工控网络）的价值巨大，但是如果电力、石油、钢铁、轨道交通等行业使用的工控网络出现问题，将造成严重后果。因此，工控网络安全成为学术界、工业界关注的热点话题。

本章首先介绍工业控制系统（简称工控系统）与工业控制网络的基本概念，并将工业控制网络与传统 IT 信息网络加以对比；其次介绍并分析国内工控行业的现状；最后对书中的重要术语进行说明。

1.1 工业控制系统与工业控制网络概述

为了全面理解工业控制网络和工业控制系统，我们需要首先了解其基本概念，本节主要介绍工业控制系统和工业控制网络的基本概念，以及二者的区别和联系，然后介绍工业控制网络 and 传统 IT 信息网络的差别。

1.1.1 什么是工业控制系统

工业控制系统（Industrial Control System，ICS）是指由计算机与工业过程控制部件组成的自动控制系统，它由控制器、传感器、传送器、执行器和输入 / 输出接口等部分组成。这些组成部分通过工业通信线路，按照一定的通信协议进行连接，形成一个具有自动控制

能力的工业生产制造或加工系统。控制系统的结构从最初的 CCS（计算机集中控制系统），到第二代的 DCS（分布式控制系统），发展到现在流行的 FCS（现场总线控制系统）。随着智能化工业的发展，基于以太网的工业控制系统得以迅速发展^[1]。

根据中华人民共和国公共安全行业标准中的信息安全等级保护工业控制系统标准，可将通用的工业企业控制系统层次模型按照不同的功能从上到下划分为 5 个逻辑层，依次为企业资源层、生产管理层、过程监控层、现场控制层和现场设备层。

根据不同的层次结构划分，各个层次在工控系统中发挥不同的功能。

在通用的工业企业控制系统中，各层次的功能单元和资产组件映射模型如图 1-1 所示。

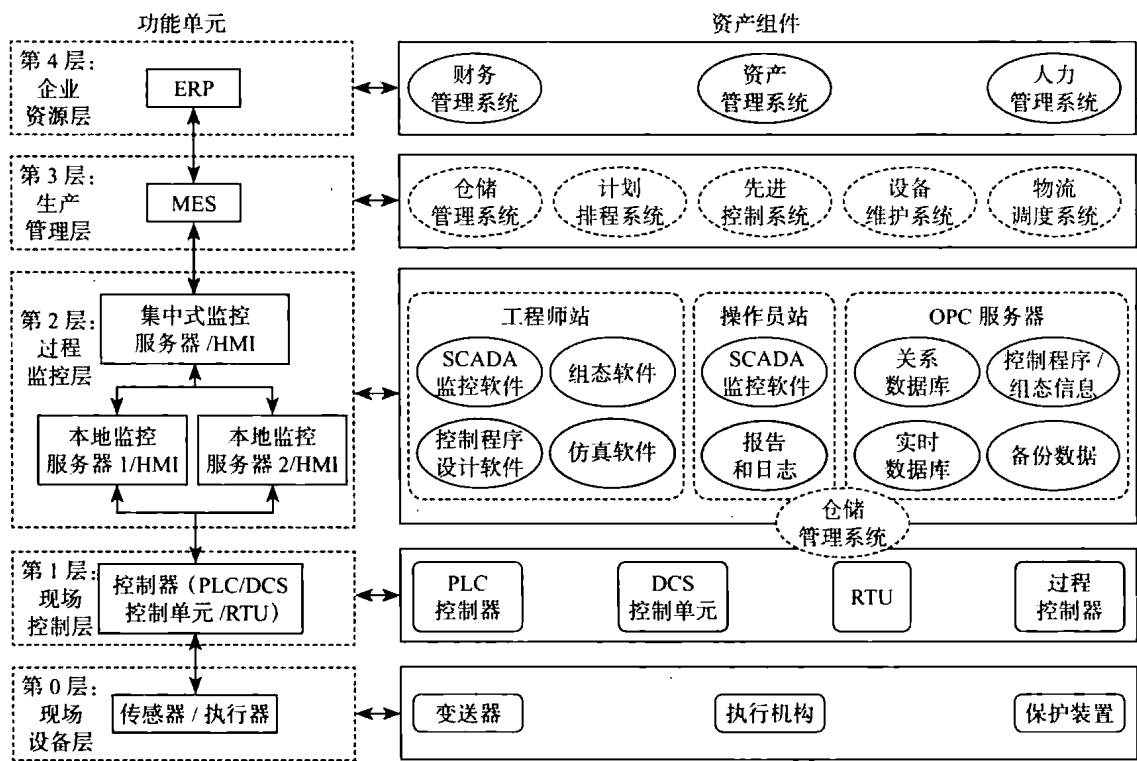


图 1-1 通用工业企业功能单元和资产组件映射模型

- 企业资源层主要通过 ERP 系统为企业决策层及员工提供决策运行手段。该层次应重点保护与企业资源相关的财务管理、资产管理、人力管理等系统的软件和数据资产不被恶意窃取，硬件设施不遭到恶意破坏。
- 生产管理层主要通过 MES 为企业提供包括制造数据管理、计划排程管理、生产调度管理等管理模块。该层次应重点保护与生产制造相关的仓储管理、先进控制、工艺管理等系统的软件和数据资产不被恶意窃取，硬件设施不遭到恶意破坏。

- 过程监控层主要通过分布式 SCADA 系统采集和监控生产过程参数，并利用 HMI 系统实现人机交互。该层次应重点保护各个操作员站、工程师站、OPC 服务器等物理资产不被恶意破坏，同时应保护运行在这些设备上的软件和数据资产，如组态信息、监控软件、控制程序 / 工艺配方等不被恶意篡改或窃取。
- 现场控制层主要通过 PLC、DCS 控制单元和 RTU 等进行生产过程的控制。该层次应重点保护各类控制器、控制单元、记录装置等不被恶意破坏或操控，同时应保护控制单元内的控制程序或组态信息不被恶意篡改。
- 现场设备层主要通过传感器对实际生产过程的数据进行采集，同时，利用执行器对生产过程进行操作。该层次应重点保护各类变送器、执行机构、保护装置等不被恶意破坏。

1.1.2 什么是工业控制网络

目前，工业控制网络还没有一个标准的定义。在一些学术文章和相关文献中，通常将工业控制网络定义为以具有通信能力的传感器、执行器、测控仪表作为网络节点，以现场总线或以太网等作为通信介质，连接成开放式、数字化、多节点通信，从而完成测量控制任务的网络。

工业控制网络就是工业控制系统中的网络部分，是一种把工厂中各个生产流程和自动化控制系统通过各种通信设备组织起来的通信网络。工业控制系统包括工业控制网络和所有的工业生产设备，而工业控制网络只侧重工业控制系统中组成通信网络的元素，包括通信节点（包括上位机、控制器等）、通信网络（包括现场总线、以太网以及各类无线通信网络等）、通信协议（包括 Modbus、Profibus 等）。

从前面的定义可以看出，工控网络由多个“网络节点”构成，这些网络节点是指分散在各个生产现场，具有相应数字通信能力的测量控制仪器。它采用规范、公开的通信协议，把现场总线当作通信连接的纽带，从而使现场控制设备可以相互沟通，共同完成相应的生产任务。

实现测量监控是工业控制网络的基本任务，因此工业控制网络特别强调数据传输的完整性、可靠性和实时性，这就要求工业控制网络能够提供相应的实时通信功能。

从发展过程来看，工控网络经历了从传统控制网络到现场总线，再到目前研究非常广泛的无线网络以及工业以太网的道路。

20 世纪 90 年代以前，大多数控制系统一般采用专用硬件、软件和通信协议，有独立的操作系统，系统之间的互联要求也不高，因此几乎不存在网络安全风险。随着科技的发展，

现场总线技术兴起，并已被广泛应用于连接现场设备，如控制器、传感器与执行器等，其定义、规格、实现和市场等日趋成熟。

随着应用需求的提高，现场总线的高成本、低速率、难于选择以及难于互连、互通、互操作等问题逐渐显露，将以太网应用于工控网络构成工业以太网成为解决上述问题的有效手段。现有的工业以太网大致可以分为软实时工业以太网、硬实时工业以太网、同步硬实时工业以太网以及非实时工业以太网。不同类型的以太网在传输率、传输距离、实时和非实时调度以及应用模式方面各有不同，可在不同工业场景下发挥其作用。

随着无线通信技术的发展以及工业生产的需求，无线通信技术也逐渐进入工业控制领域，降低了设备的安装复杂度，减少了线缆，配置灵活，使用方便。特别是在“智能制造 2025”国家战略的牵引下，智慧工厂蓬勃发展，无线工控网络将大展拳脚。

目前，我国各领域的关键基础设施、各行业的自动化控制均依赖工业控制系统和工业控制网络。如工控网络总线技术应用于先进的城市轨道交通中，它不仅被应用于牵引、制动、空调、照明和通风等系统的控制，还应用于系统的故障诊断分析以及车辆行为安全相关的一些检测设备，如火灾报警等，并能根据需要对设备进行远程控制。因此，工控网络的安全性是一切涉及国计民生事件平稳运行的前提。

但是，多年来企业更关注管理传统网络领域的安全问题，许多企业对工业控制网络安全存在认识上的误区：认为工业控制网络没有直接接入互联网，入侵者无法通过工业控制网络攻击工业控制系统。而实际的情况是，企业的许多控制网络都是“开放的”，系统之间没有有效的隔离。进一步，采用最新技术的黑客和恶意软件甚至可以有效入侵物理隔离的网络。因此，随着信息化的推动和工业化进程的加速，工厂信息网络、移动存储介质、因特网等其他因素导致的信息安全问题正逐渐向工业控制网络扩散，这将直接影响工控网络的安全与稳定，必须引起足够的重视。

1.1.3 工业控制网络与传统 IT 信息网络

从大体上看，工业控制网络与传统 IT 信息网络在网络边缘、体系结构和传输内容三大方面有着主要的不同^[2]。

- 网络边缘不同：工控系统在地域上分布广阔，其边缘部分是智能程度不高的含传感和控制功能的远动装置，而不是 IT 系统边缘的通用计算机，两者之间在物理安全需求上差异很大。
- 体系结构不同：工业控制网络的结构纵向高度集成，主站节点和终端节点之间是主从关系。传统 IT 信息网络则是扁平的对等关系，两者之间在脆弱节点分布上差异很大。

- 传输内容不同：工业控制网络传输的是工业设备的“四遥信息”，即遥测、遥信、遥控、遥调。

此外，还可以从性能要求、部件生命周期和可用性要求等多方面，进一步对二者进行对比，详细内容如表 1-1 所示。

表 1-1 工业控制网络与传统 IT 信息网络的对比^[3]

	工业控制网络	传统 IT 信息网络
性能要求	实时通信 响应时间很关键 延迟和抖动都限定在一定的水平 适度的吞吐量	不要求实时性 可以忍受高时延和延迟抖动 高吞吐量
部件生命周期	15 ~ 20 年	3 ~ 5 年
可用性要求	高可用性 连续工作，一年 365 天不间断 若有中断必须要提前进行规划并制定严格的时间表	可以有重新启动系统等反应 可用性缺陷经常是可以容忍的
风险管理要求	最先关注员工人身安全，以防危害公众的健康和信心，违反法律法规等 其次最关注的就是对整个生产过程的保护和容错，不允许暂时停机	数据机密性和完整性是至关重要的 容错比较次要，暂时的停机也不是一个主要风险，它的主要风险是延迟企业运作
系统操作	操作较复杂 修改或升级需要不同程度的专业知识	操作较简单 利用自动部署工具可较为简单地进行升级等系统操作
资源限制	资源受限 多数不允许使用第三方信息安全解决方案	指定足够的资源来支持增加的第三方应用程序，安全解决方案是其中的一种
变更管理	变更前必须进行彻底的测试和部署增量 中断必须要提前数天 / 数周进行详细计划并确定时间表，系统也要求把再确认作为更新过程的一部分内容	通常可以自动地进行软件更新，包括信息安全补丁的及时变更
技术支持	专门的协议 目前常见的总线协议包括 Modbus、Profibus、CC-Link、EtherCAT、HSE 等	TCP/IP 等通用协议
通信方式	供应商之间互不支持，各自有许多专门的通信协议 多种类型的通信介质中，大体包括专用线和无线（无线电和卫星）两种	有标准的通信协议，主要在有局部无线功能的有线网络之间进行通信

工业控制系统安全涉及计算机、自动化、通信、管理、经济、行为科学等多个学科，同时拥有广泛的研究和应用背景。

两化融合后，IT 系统的信息安全也被融入了工控系统安全中。不同于传统的生产安全（Safety），工控系统网络安全（Security）是要防范和抵御攻击者通过恶意行为人为制造生产事故、损害或伤亡。可以说，没有工控系统网络安全就没有工业控制系统的生产安全。只有保证了系统不遭受恶意攻击和破坏，才能有效地保证生产过程的安全。虽然工业控制网

络安全问题同样是由各种恶意攻击造成的,但是工业控制网络安全问题与传统 IT 系统的网络安全问题有着很大的区别。

1.2 国内工业控制行业现状

对国内的工业控制系统行业来讲,2016 年是意义重大的一年。“互联网+”、“智能制造”和“工业 4.0”等概念不断为人们所提及。习近平总书记于 2016 年 4 月 19 日在网络安全和信息化工作座谈会上发表了重要讲话,进一步表明工控行业的相关问题已经上升到国家高度。下面将对国内工控行业的现状作简要介绍与分析。

首先,在协议方面,目前国外工控网络协议依然占据主流,国内协议难以撼动其地位。虽然国内已开发了如 HSE 等工业以太网协议,但是由于受设备技术水平、品牌实力等因素影响很难在工控市场争取到较高的市场份额。

其次,在设备厂商方面,西门子、施耐德、罗克韦尔和三菱电机分别依靠其自主研发的主流网络协议绑定设备,占据大部分的工控领域市场。企业一旦选择供应商,将会在运营维护、工控设备升级等环节被第三方牢牢地控制,无法轻易更换供应商。

再次,在资金方面,工控系统大多由外资主导,国产系统仍需加快自主进程。在电力、冶金、石化、交通、建筑等 22 个行业中,900 套工业控制系统主要由国外厂商提供;在数据采集与监控(SCADA)系统、分布式控制系统(DCS)、过程控制系统(PCS)和大型可编程控制器(PLC)中国外厂商也占据了大多数份额。国内工控企业则由于起步较晚,同时受技术水平、品牌效应等因素影响,仅能在工控领域中提供相对低端的设备产品,占据 20% 左右的市场份额。

最后,在技术方面,国内企业尚未掌握工控核心技术。工控机(如 PLC)、网关、协议变换器、集线器和人机交互设备(HMI)是构成工控系统的五大设备,其中工控机为核心设备,国内企业仅有 5% 的市场份额,而西门子在全球 PLC 市场占据 31% 的份额,且集中在大中型 PLC 方面。工控 MCU、DSP、FPGA 等核心元器件技术均由国外企业垄断。我国虽在整机方面有一定的基础,但局限在低端环节,而核心元器件(如敏感芯片、外围芯片等)均由国际企业主导,形成自己产业优势仍然任重道远。

2010 年 10 月,伊朗核电站爆发“震网”(Stuxnet)病毒,为工业生产控制系统安全敲响了警钟。近年来工控安全事件频发,促使企业考虑“安全”和“效益”之间的平衡。一方面,企业为了提高生产执行效率,打通了生产控制系统和企业管理系统,实现了数据的实时交互,但也导致了工控设备与互联网直接相连,存在极大的网络病毒入侵风险。另一

方面,企业为了加快自动化的脚步、提高生产效率,采购了大批高精尖的自动化生产设备,如德国库卡机器人、发那科机床、西门子电机等。这些设备的运行维护,一般都是通过互联网工程师远程实现,这更大大提升了病毒侵入的可能性。因此,企业如何在先进制造设备应用与工控安全两者之间进行权衡,是需要政府、行业协会、企业和研究机构相互协同、共同解决的问题^[4,5]。

1.3 国内工业控制网络安全趋势分析

工业控制领域正在发生重大的变革,德国和美国相继提出“工业 4.0”、“工业互联网”概念,我国也提出了“中国制造 2025”战略,在两化深度融合的基础上继续进行产业结构调整 and 升级转型。作为工业控制网络重要的组成部分,工业控制网络安全深刻地影响着工业控制网络及相关产业的发展,具有极强的产业关联度和产业渗透能力,因此工业控制网络安全产业得到了各国极大的关注。本节将对国内工业控制网络安全趋势加以简单介绍与分析。

从国家战略方面来看,我国政府对工控系统的安全性予以高度重视,国家发改委自 2010 年起开始组织信息安全专项;将工业控制系统安全问题作为独立领域重点支持。2011 年年底,工信部下发《关于加强工业控制系统信息安全管理的通知》(工信部协[2011]451 号)的通知,强调加强工业信息安全的重要性、紧迫性。国家发展和改革委员会等部门也开始从政策和科研层面上积极部署工业控制系统的安全保障工作,研究和制定相关规范及要求,其中对电力行业、石油石化行业、烟草行业及先进制造业的规范尤为突出。

2015 年,随着“互联网+”、“中国制造 2025”等国家战略方针的出台,随着“两化融合”政策的深入推进,国内工业控制网络的网络化、智能化水平快速提高。工业控制网络的信息安全持续被政府组织、科研机构、安全厂商、自动化厂商密切关注。虽然国内工控系统依然比较脆弱,整体安全形势面临严峻挑战,但我们也能看到政府、企业、厂商各方都在积极推进国内工控安全的发展。

2016 年 4 月 19 日,中共中央总书记、国家主席、中央军委主席、中央网络安全和信息化领导小组组长习近平在北京主持召开会议,并发表了重要讲话。中央网络安全和信息化领导小组办公室的官方网站上第一时间发布了题为《习近平:让互联网更好造福国家和人民》的文章。文章中指出,网络安全和信息化是相辅相成的。安全是发展的前提,发展是安全的保障,安全和发展要同步推进。要树立正确的网络安全观,加快构建关键信息基础设施安全保障体系,全天候全方位感知网络安全态势,增强网络安全防御能力和威慑能力。网

络安全为人民，网络安全靠人民，维护网络安全是全社会共同责任，需要政府、企业、社会组织、广大网民共同参与，共筑网络安全防线。

2016年7月8日，中共中央网络安全和信息化领导小组办公室发表了文章《全国范围关键信息基础设施网络安全检查工作启动》。文章中指出，经中央网络安全和信息化领导小组批准，首次全国范围的关键信息基础设施网络安全检查工作已经启动，这是落实习近平总书记重要讲话精神的重要举措，也是在网络安全新形势下，针对全国关键信息基础设施网络安全保护开展的全局性、基础性工作。

当前，我国关键信息基础设施面临的网络安全形势严峻复杂。根据东北大学“谛听”网络安全团队的数据显示，全球存在大量暴露在 Internet 上的工业控制系统，其中占比较多的包括电力行业、石油石化行业及先进制造业，这些都与国家的发展密切相关。

以中国视角分析工控设备的暴露情况，中国台湾占比最大，其次分别为北京，浙江、江苏、上海的长江三角洲地区，黑龙江、吉林、辽宁的东三省地区，这些都是典型的工业区。越是工业发达地区，工控系统的暴露数量越多，也就越容易成为攻击的目标，需引起高度重视。

在暴露的工控设备中，工业控制 SCADA 系统和联网安保摄像头占据了绝大部分。其中，国内暴露的 SCADA 系统中占比较多的行业有水利、市政、环境保护、工业制造、电力、医疗卫生、交通、煤炭和石油化工。这些重要基础设施互相关联，构成复杂、庞大的体系，为国防安全、经济运行提供不可替代的物质和服务。而对于其中的 SCADA 系统来说，一旦出现攻击，造成的损失可能是无法估量的。在联网安保摄像头方面，暴露在 Internet 上的安保摄像头中有 70% 以上使用默认密码，使用默认密码的安保摄像头中 50% 左右用来监控工业控制系统相关设备厂房，从这些摄像头内可以清晰地看到厂房监控设备和工业生产过程。

由此可见，我国工控系统网络安全面临严峻的挑战，开展关键信息基础设施网络安全检查，是从涉及国计民生的关键业务入手，厘清可能影响关键业务运转的信息系统和工业控制系统，准确把握我国关键信息基础设施的安全状况，科学评估面临的网络安全风险的一项重要工作。通过该项检查，以查促管、以查促防、以查促改、以查促建，为构建关键信息基础设施安全保障体系提供重要的基础性数据。

一批国内厂商致力于工控系统网络安全的发展，提出了一些工控安全的解决方案。如绿盟科技的新一代威胁防御整体解决方案 NGTP，能够在发现高级恶意软件威胁的基础上控制、清除威胁，提升应对新一代威胁及高级恶意软件的安全能力。二零卫士的“固隔监”，

将工控领域头等重要的稳定性放在首位，面对工控系统工作连续性要求高的特点，以监视作为主要手段，提高攻击早期的预警响应能力。匡恩的“K 鹰”、“K 巡”等，海天炜业的工控防火墙，中科网威的“时空防御模型”以及威努特的“安全白环境”等，都走在国内工控领域的安全前列。

1.4 工业控制系统常用术语

本节主要介绍本书中涉及的较为重要的部分术语，包括定义、缩略语和组织等。

ICS (Industry Control System, 工业控制系统) 也称工业自动化与控制系统，是由计算机设备与工业过程控制部件组成的自动控制系统。广泛应用于电力、燃气、交通运输、建筑、化工、制造业等行业。

SCADA (Supervisory Control And Data Acquisition, 数据采集与监视控制系统)，可应用于电力、化工、冶金、燃气、石油、铁路等诸多领域的数据采集与监视控制以及过程控制等方面。

PLC (Programmable Logic Controller, 可编程逻辑控制器) 是一种采用一类可编程的存储器，用于其内部存储程序，执行逻辑运算、顺序控制、定时、计数与算术操作等面向用户的指令，并通过数字或模拟式输入 / 输出控制各种类型的机械或生产过程。

CISO (Chief Information Security Officer, 首席信息安全官) 也称为 IT 安全主管、安全行政官等，主要负责对机构内的信息安全进行评估、管理和实现。

HMI (Human Machine Interface, 人机界面) 又称用户界面或使用界面，是系统和用户之间进行交互和信息交换的媒介。它将信息的内部形式和人类可以接受的形式互相转换，凡参与人机信息交流的领域都存在着人机界面。

DCS (Distributed Control System, 分布式控制系统) 是一个由过程控制级和过程监控级组成的以通信网络为纽带的多级计算机系统，综合了计算机、通信、显示和控制等 4C 技术，其基本思想是分散控制、集中操作、分级管理、配置灵活以及组态方便。

APT (Advanced Persistent Threat, 高级持续性威胁) 是利用先进的攻击手段对特定目标进行长期持续性网络攻击的攻击形式，APT 攻击的原理相对于其他攻击形式更为高级和先进，其高级性主要体现在 APT 在发动攻击之前需要对攻击对象的业务流程和目标系统进行精确的收集。在此收集的过程中，此攻击会主动挖掘被攻击对象受信系统和应用程序的漏洞，利用这些漏洞组建攻击者所需的网络，并利用 0day 漏洞进行攻击。

NASA (National Aeronautics and Space Administration, 美国国家航天局) 是美国联邦

政府的一个行政性科研机构，负责制定、实施美国的民用太空计划与开展航空科学暨太空科学的研究。

PID (Proportion Integral Derivative, 比例 – 积分 – 微分) 控制是一个在工业控制应用中常见的反馈回路部件。比例控制是 PID 控制的基础，积分控制可消除稳态误差，微分控制可加快大惯性系统响应速度以及减弱超调趋势。

CII (Critical Information Infrastructure, 关键信息基础设施) 是保障电力、电信、金融、国家机关等国家重要领域基础设施正常运作的信息网络。

信息安全 (Information Security) 是指能够免于非授权访问和非授权或意外的变更、破坏或者损失的系统资源的状态。基于计算机系统的能力，能够提供充分的把握使非授权人员和系统既无法修改软件及其数据，也无法访问系统功能，且保证授权人员和系统不被阻止；防止对工业自动化和控制系统的非法或有害的入侵，或者干扰其正确和计划的操作。不法分子通过对生产过程中关键信息和指标的篡改、误发等造成生产安全风险的行为属于信息安全范畴。

1.5 本章小结

本章首先提出了工业控制系统的基本概念，介绍了什么是工业控制系统。其次，介绍了工业控制网络这一概念，由此提出所有相关人员必须对工控网络安全给予足够的重视。再次，对比分析了工业控制网络与传统 IT 信息网络的异同点。

本章最后介绍了国内工控行业的现状，阐明了工控网络的安全问题已经受到各国和各领域的关注，学习了解最前沿的相关技术刻不容缓。

1.6 本章习题

1. 什么是工业控制系统和工业控制网络？二者之间又有怎样的联系？
2. 通用的工业控制系统可划分为哪几层？每一层的功能单元和包含的资产组件分别是什么？
3. 请简述工业控制网络与传统 IT 信息网络在网络边缘、体系结构和传输内容三大方面的不同。谈一谈二者产生不同类型的安全问题的原因。
4. 结合你所查阅的资料，介绍并分析一个典型的工控网络安全事件。



工业控制系统基础

本章介绍工业控制系统的基本知识，并详细介绍数据采集与监视控制（SCADA）系统、分布式控制系统（DCS）、控制器、现场设备等工业控制系统的重要组成部分。

工业控制系统（也称工业自动化与控制系统）被广泛应用于电力、水处理、石油与天然气、楼宇自动化、化工、交通运输、制造业等行业，是由计算机设备与工业过程控制部件组成的自动控制系统。

通常情况下，工业控制系统的子系统或功能组件包括但不限于数据采集与监视控制（SCADA）系统、分布式控制系统（DCS）、可编程逻辑控制器（PLC）、远程测控单元（RTU）等相关信息系统，下面将分别加以介绍。

2.1 数据采集与监视控制系统

工业控制数据采集与监视控制（Supervisory Control And Data Acquisition，SCADA）系统是由计算机设备、工业过程控制组件和网络组成的控制系统，对工业生产过程进行数据采集、监测和控制，保证工业生产过程的正常运转，它是电力、石油、冶金、天然气、铁路、供水、化工等关系国家命脉的基础产业的神经中枢。

SCADA 系统主要用于控制分散设备。这些系统用在配电系统中，如水分分配和废水收集系统、石油和天然气管道、电网传输和分配系统、铁路等公共交通系统。SCADA 系统集成数据采集系统、数据传输系统和 HMI 软件，以提供一个集中的监视和控制系统，用于许

多过程的输入和输出。SCADA 系统可收集现场信息，将信息传递到一个中央计算机设备，并以图形或文本方式给操作员显示该信息，以便操作员监视或从实时的中心位置控制整个系统。

典型的 SCADA 系统架构如图 2-1 所示。

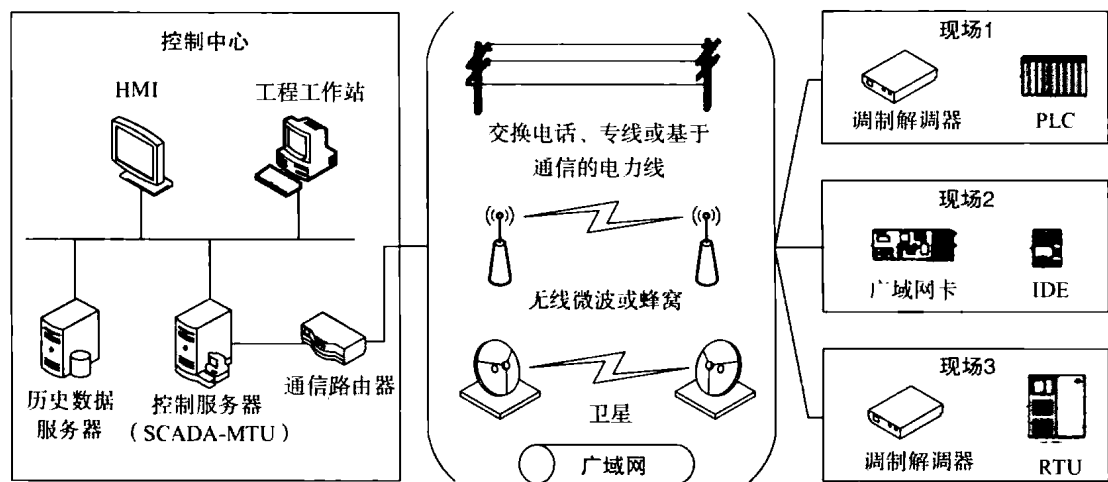


图 2-1 典型的 SCADA 系统架构

图 2-2 显示的是 SCADA 系统实现的一个例子。这种 SCADA 系统主要由区域控制中心、主控制中心、冗余控制中心和多个远程站点构成。控制中心和所有远程站点之间采用远程通信技术进行点对点连接，区域控制中心提供比主控制中心更高级别的监督控制，企业管理网络可以通过广域网访问所有控制中心，并且站点也可以被远程访问以进行故障排除和维护操作。

2.1.1 什么是 SCADA 系统

SCADA 系统是工业控制网络调度自动化系统的基础和核心。SCADA 负责采集和处理工控系统运行中的各种实时和非实时数据，是工业控制网络调度中心各种应用软件的主要数据来源。SCADA 系统包括实时数据采集、数据通信、SCADA 系统支撑平台、前置子系统、后台子系统等。

一个 SCADA 系统通常由一个主站和多个子站（远方终端装置 RTU 或其他自动化系统）组成。主站通常在调度控制中心（主站端），子站安装在厂站端，主站通过广域网实现与子站的通信，完成数据采集和监视控制。主站除了接收子站的信息外，还以数据通信的方式接收从下级调度控制中心主站转发来的信息，又向上级调度控制中心主站转发本站的信息。

厂站端是 SCADA 系统的实时数据源，又是进行控制的目的地。SCADA 所采集的数据包括模拟量测量、状态测点和脉冲累加量。SCADA 系统的主站分为前置子系统和后台子系统，二者通过局域网相连并相互进行通信。

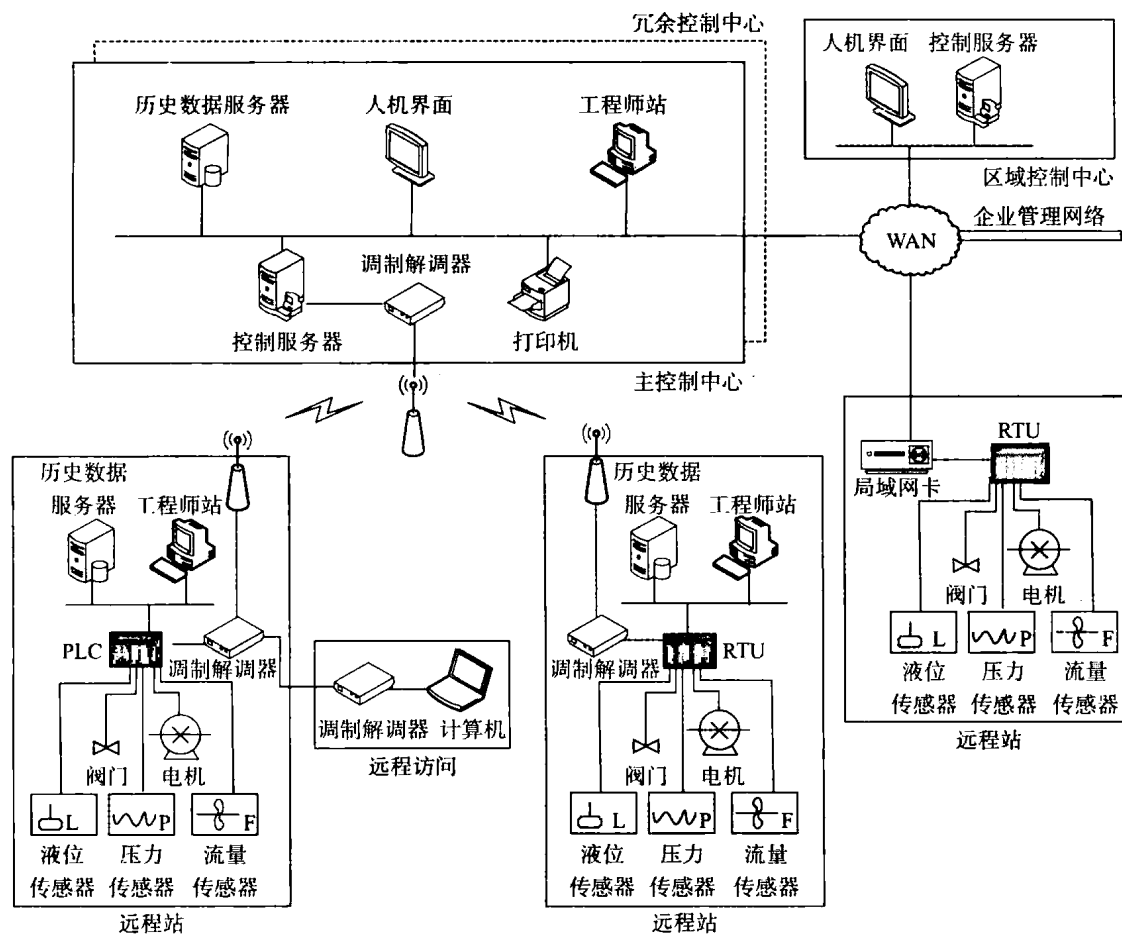


图 2-2 SCADA 系统实现例子

前置子系统主要完成与厂站端及其他调度控制中心的通信，并将获得的数据发送给后台子系统，后台子系统进行数据处理。SCADA 把这些最近扫描的已经被监视系统处理完的反映状态的数据存储在数据库中。画面数据直接连接到数据库，因此画面可以直观地给出该系统状态的实际景象。

2.1.2 SCADA 后台子系统的主要功能

SCADA 后台子系统的主要功能有数据处理和控制调节、历史数据存储、与其他子系统

的计算机通信和人机界面交互等。

数据处理和控制调节是 SCADA 应用的基本功能，主要实现与前置子系统的通信，并完成 SCADA 系统基本的遥信、遥测、遥控和遥调功能。历史数据存储软件采集并存储了历史数据，用以作为制作调度计划的数据基础和制作运行报表的根据。SCADA 后台子系统计算机与其他子系统计算机之间的通信能便利而安全地实现信息交换和数据共享。人机界面交互软件使操作者通过人机界面与应用程序进行交互，以实现各种应用所需的功能。

2.1.3 SCADA 系统未来的技术发展

随着计算机技术和通信技术的快速发展，SCADA 系统也将不断发展。总体趋势是：监控的空间范围更广，监控处理的速度更快，监控的物理量更全面。同时，人机交互更友好，系统更加智能化。

- 全球定位系统（GPS）将广泛应用在数据采集环节，使 RTU 的遥测量带有时标以消除采样非同时性误差。
- 随着调度中心各种应用功能的增多，需要调度中心进行的数据集成和整合也随之增加，这就需要将传统的 SCADA 系统的历史数据库和其他应用子系统的数据库统一规划，以满足调度中心全局功能的要求。
- SCADA 系统的数据传输和应用软件接口更加标准化，SCADA 系统更开放，可扩展性和可移植性更好。
- 各种人工智能技术、可视化技术、人机工程技术也将更多地应用到 SCADA 系统中，以提高系统的易用性，提高调度员在事故情况下的快速反应能力。

2.2 分布式控制系统

分布式控制系统（Distributed Control System, DCS）又称为集散式控制系统，是工业控制系统的组成部分。本节主要介绍分布式控制系统相关知识，包括 DCS 的基本概念、组成机构和特点。

2.2.1 什么是 DCS

DCS 是一个由过程控制级和过程监控级组成的以通信网络为纽带的多级计算机系统，综合了计算机（Computer）、通信（Communication）、终端显示（CRT）和控制（Control）技术而发展起来的新型控制系统。其基本思想是分散控制、集中操作、分级管理、配置灵活

以及组态方便。它满足了大型工业生产和日益复杂的过程控制要求,从综合自动化的角度出发,按功能分散、管理集中的原则构思,采用了多层分级、合作自治的结构形式。

DCS 网络是整体的基础和核心。网络对于 DCS 整个系统的实时性、可靠性和扩充性起着决定性作用,因此对于 DCS 网络来说,它必须满足实时性的要求,即在确定的时间限度内完成信息的传送。这里所说的“确定”的时间限度,是指无论在何种情况下,信息传送都能在这个时间限度内完成,而这个时间限度则是根据被控制过程的实时性确定的。因此,衡量系统网络性能的指标并不是网络的速率,即通常所说的每秒比特数(bit/s),而是系统网络的实时性,即能在多长的时间内确保所需信息的传输得以完成。

2.2.2 DCS 的组成

DCS 是以微处理器和网络为基础的集中分散型控制系统。它包括操作员站、工程师站、监控计算机、现场控制站、数据采集站、通信系统。DCS 的基本构成如图 2-3 所示。

(1) 操作员站

操作员站是操作人员对生产过程进行显示、监视、操作控制和管理的主要设备。操作员站提供了良好的人机交互界面,用以实现集中监视、操作和信息管理等功能。在一些小 DCS 中,操作员站兼有工程师站的功能,在操作员站上也可以进行系统组态和维护的部分或全部工作。

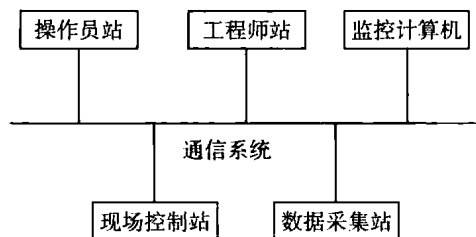


图 2-3 DCS 的基本构成

(2) 工程师站

工程师站用于对 DCS 进行离线的组态工作和在线的系统监督、控制与维护。工程师能够借助于组态软件对系统进行离线组态,并在 DCS 在线运行时,可以实时地监视通信网络上各工作站的运行情况。

(3) 监控计算机

监控计算机通过网络收集系统中各单元的数据信息,根据数学模型和优化控制指标进行后台计算、优化控制等,它还用于全系统信息的综合管理。

(4) 现场控制站

现场控制站通过现场仪表直接与生产过程相连接,采集过程变量信息,并进行转换和运算等处理,产生控制信号来驱动现场的执行机构,最终实现对生产过程的控制。现场控制站可控制多个回路,具有极强的运算和控制功能,能够自主地完成回路控制任务,实现反馈控制、逻辑控制、顺序控制和批量控制等功能。

(5) 数据采集站

数据采集站与生产过程相连接，对过程非控制变量进行数据采集和预处理，并对实时数据进一步加工；为操作员站提供数据，实现对过程的监视和信息存储，为控制回路的运算提供辅助数据和信息。

(6) 通信系统

通信系统连接 DCS 的各操作员站、工程师站、监控计算机、现场控制站、数据采集站等部分，传递各工作站之间的数据、指令及其他信息，使整个系统协调一致地工作，从而实现数据和信息资源的共享。

DCS 自下而上通常分为控制级、监控级和管理级，每级之间分别由控制网络（Control Network, Cnet）、监控网络（Supervision Network, Snet）、管理网络（Management Network, Mnet）把相应的设备连接在一起，进行数据和命令的传输。DCS 的结构如图 2-4 所示。

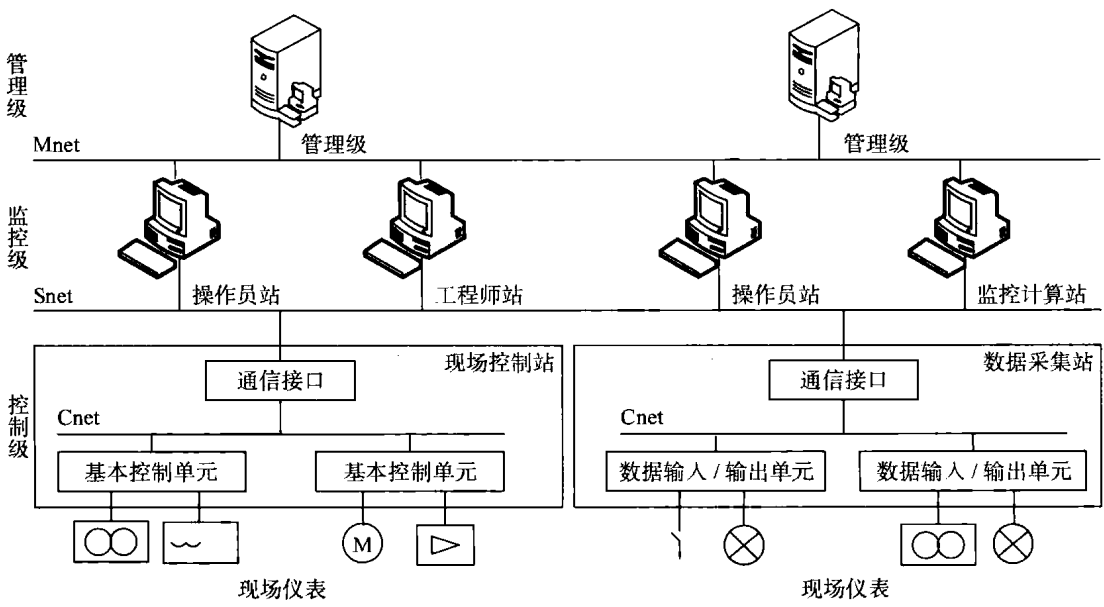


图 2-4 DCS 的结构图

2.2.3 DCS 的特点

DCS 具有如下特点。

(1) 高可靠性

DCS 采用容错设计，当某一台计算机出现故障时并不会导致系统丧失其他功能。此外，由于系统中各台计算机所承担的任务比较单一，因此可以针对需要实现的功能采用具有特

定结构和软件的专用计算机,从而提高系统中每台计算机的可靠性。

(2) 开放性

DCS 采用开放式、标准化、模块化和系列化设计,系统中各台计算机采用局域网方式通信,实现信息传输,当需要改变或扩充系统功能时,可将新增计算机方便地连入系统通信网络或从网络中卸下,几乎不影响系统其他计算机的工作。

(3) 灵活性

通过组态软件根据不同的流程应用对象进行软硬件组态,即确定测量与控制信号及相互间连接关系,从控制算法库选择适用的控制规律以及从图形库调用基本图形组成所需的各种监控和报警画面,从而方便地构成所需的控制系统。

(4) 易于维护

功能单一的小型或微型专用计算机,具有维护简单、方便的特点,当某一局部或某个计算机出现故障时,可以在不影响整个系统运行的情况下在线更换,迅速排除故障。

(5) 协调性

各工作站之间通过通信网络传送各种数据,整个系统信息共享,协调工作,以完成控制系统的总体功能和优化处理。

(6) 控制功能齐全

控制算法丰富,集连续控制、顺序控制和批处理控制于一体,可实现串级、前馈、解耦、自适应和预测控制等先进控制,并可方便地加入所需的特殊控制算法。

2.3 工业控制系统中的常用控制器

控制器(Controllor)是指按照预定顺序通过改变主电路或控制电路的接线和改变电路中电阻值来控制电动机的启动、调速、制动和反向的主令装置,是发布命令的“决策机构”,完成协调和指挥整个计算机系统的操作。

在工业控制系统中,常见的控制器有可编程逻辑控制器(PLC)、可编程自动化控制器(PAC)、远程终端单元(RTU)等,下面分别加以介绍。

2.3.1 可编程逻辑控制器

可编程逻辑控制器(Programmable Logic Controller, PLC)是一种特殊的控制器,是专为工业环境应用而设计的数字运算电子系统。

PLC 控制系统主要有以下 6 个特点:

- 1) 通信性和灵活性强, 应用广泛。
- 2) 可靠性高, 抗干扰的能力极强。
- 3) 产品系列化、规模化, 功能完备, 性能优良。
- 4) 编制程序简单、容易。
- 5) 设计、安装、调试周期短, 扩充容易。
- 6) 体积小、重量轻, 维护方便。

近年来, 随着大规模集成电路技术的迅猛发展, 功能更强大、规模不断扩大而价格日趋低廉的元器件不断涌现, 促使 PLC 产品亦随之功能大增但成本下降。目前 PLC 的应用已经远远超越了早期仅用于开关量控制的局面, 现将其应用领域简述如下。

(1) 开关量逻辑控制

这是 PLC 最广泛的应用。开关量逻辑控制已逐步取代传统的继电器逻辑控制装置, 被用于单机或多机控制系统以及自动生产线上。PLC 控制开关量的能力是很强的, 所控制的人、出点数有时多达几万点。由于可以联网, 所以点数几乎不受限制。所控制的如组合的、时序的、要考虑延时的、需要进行高速计数等的逻辑问题都可以解决。

(2) 运动控制

目前很多厂商已经开发出大量运动控制模块, 且功能是给步进电动机或伺服电动机等提供单轴或多轴的位置控制, 并在控制中满足适当的速度和加速度, 以保证运动的平滑水准。

(3) 过程控制

当前 PLC 产品中, 还有一大类是针对生产过程参数, 如温度、流量、压力、速度等的检测和控制而设计的。常用的有模拟量 I/O 模块, 通过这些模块不仅可以实现 A/D 和 D/A 转换, 还可以进一步构成闭环, 实现 PID 一类的生产过程调节。而针对 PID 闭环调节, 又有专门的模块, 可以更方便地实施。这些产品往往还引入了智能控制。

(4) 数据处理

现代的 PLC 已具有数据传送、排序、查表搜索、位操作以及逻辑运算、函数运算、矩阵运算等多种数据采集、分析、处理功能。目前还有不少公司, 将 PLC 的数据处理功能与计算机数值控制 (CNC) 设备的功能紧密结合在一起, 开发了用于 CNC 的 PLC 产品。

(5) 通信

随着网络的发展和计算机集散控制系统的逐步普及, PLC 的网络化通信产品也在大量被推出。这些产品解决了 PLC 之间、PLC 与其扩展部分之间、PLC 与上级计算机之间或其他网络间的通信问题。

需要注意的是, 并非所有 PLC 都具有上述全部功能, 越小型的 PLC 其功能相应也越少^[6]。

2.3.2 可编程自动化控制器

可编程自动化控制器（PAC）的定义为：由一个轻便的控制引擎支持，且对多种应用使用同一种开发工具。PAC 系统保证了控制系统功能的统一集成，而不仅仅是一个完全无关的部件拼凑的集成。

PAC 定义了几种特征和性能：

- 1) 多领域的功能，包括逻辑控制、运动控制、过程控制和人机界面。
- 2) 一个满足多领域自动化系统设计和集成的通用开发平台。
- 3) 允许 OEM（Original Equipment Manufacturer，原始设备制造商）和最终用户在统一平台上部署多个控制应用。
- 4) 有利于开放、模块化控制架构来适应高度分布性自动化工厂环境。
- 5) 对于网络协议、语言等，使用既定事实标准来保证多供应商网络的数据交换^[7]。

虽然 PAC 形式与传统 PLC 很相似，但其性能却比 PLC 广泛和全面得多。PAC 是一种多功能控制器平台，它包含多种用户可按照自己意愿组合搭配和实施的技术和产品。与其相反，PLC 是一种基于专有架构的产品，仅仅具备了制造商认为必要的性能。

PAC 与 PLC 根本的不同在于它们的基础不同。PLC 的性能依赖于专用硬件，应用程序的执行是依靠专用硬件芯片实现的。硬件的非通用性会导致系统的功能前景和开放性受到限制，由于是专用操作系统，其实时可靠性与功能都无法与通用实时操作系统相比，这样导致了 PLC 整体性能的专用性和封闭性。

PAC 的性能基于其轻便控制引擎，标准、通用、开放的实时操作系统，嵌入式硬件系统设计以及背板总线。PLC 的用户应用程序执行是通过硬件实现的，而 PAC 设计了一个通用、软件形式的控制引擎用于应用程序的执行。控制引擎位于实时操作系统与应用程序之间，这个控制引擎与硬件平台无关，可在不同平台的 PAC 系统间移植。因此对于用户来说，同样的应用程序不需修改即可下载到不同 PAC 硬件系统中，用户只需根据系统功能需求和投资预算选择不同性能的 PAC 平台。这样，根据用户需求的迅速扩展和变化，用户系统和程序无须变化，即可无缝移植^[8]。

PAC 具有如下优点。

1) 提高生产率和操作效率：一个通用轻便控制引擎和综合工程开发平台允许快速地开发、实施和迁移；且由于它的开放性和灵活性，确保了控制、操作、企业级业务系统的无缝集成，优化了工厂流程。

2) 降低操作成本：使用通用、标准架构和网络，降低了操作成本，让工程师们能为一个体现成本效益、使用现货供应的平台选择不同系统部件，而不是专有产品和技术（只要求

用户在一个统一平台和开发环境上培训，而不是几种)；且为用户提供了一个无缝迁移路径，保护在 I/O 和应用开发方面的投资。

3) 使用户对其控制系统拥有更多控制力：使用户拥有更多灵活性来选择适合每种特殊应用的硬件和编程语言，以他们自己的时间表来规划升级，并且可在任何地方设计、制造产品。

随着市场的需要，PAC 技术在未来的几年内将朝着以下几个方向进一步发展。

(1) 设备规格的多样化

为了满足各种实际生产状况的需要，PAC 的规格将会呈现出多样化的发展趋势。在具体的生产环境中，选择合适的控制系统要求的 PAC，有利于降低成本。

(2) 支持更多的控制功能

目前，PAC 已经将逻辑、运动、过程控制等高级功能集成到了单一的平台。而未来，PAC 将进一步融合更多的功能，如对于安全性的考虑、批处理等。当信息被越来越广泛地使用时，其安全性将成为需要考虑的第一因素。

(3) 商业系统的集成

为了实现真正的实时性，自动化设备供应商将在 PAC 内部继续创建商业系统的连接通道而不依赖于其他连接设备。PAC 将内嵌制造执行系统 (MES) 的一些属性，如标准接口的建立，它将有更好地解决控制层和管理层之间的连接问题。

(4) 简单的系统维护

PAC 将往更小化、更智能化的方向发展，但同时它将拥有更出众的数据处理能力。其软件可以监控机器运转状况，硬件可以完成复杂的自检工作。为了提高生产率、增加利润，企业就必须及时有效地传递数据信息。PAC 的这种数据处理能力可以满足用户在任何时间通过任何形式 (如 E-mail、网页) 对数据进行维护。

(5) 延长产品的生命周期

通过采用新技术来获得更高生产效率固然十分重要，但是新技术的使用是否会大幅增加成本和培训费也是厂家十分关注的问题。PAC 未来平台将仍然采用标准化的设计，其买主可以继续使用原来的商业技术和以太网等标准，从而有效地降低对成本的投入^[9]。

2.3.3 远程终端单元

远程终端单元 (Remote Terminal Unit, RTU) 是安装在远程现场的电子设备，用来对远程现场的传感器和设备状态进行监视和控制，负责对现场信号、工业设备的监测和控制，获得设备数据，并将数据传给 SCADA 系统的调度中心^[10]。

RTU 作为一种远程测控单元装置, 可以用各种不同的硬件和软件来实现, 这取决于被控现场的性质、系统的复杂性、对数据通信的要求、实时报警报告、模拟信号测量精度、状态监控、设备的调节控制和开关控制。通常, RTU 要具有优良的通信能力和更大的存储容量, 适用于更恶劣的温度和湿度环境, 实现复杂的特殊算法, 提供更多的计算功能和控制能力^[11]。

RTU 具有以下 4 个特点:

- 1) 通信距离较长。
- 2) 用于各种恶劣的工业现场。
- 3) 模块结构化设计, 便于扩展。
- 4) 在具有遥信、遥测、遥控、遥调领域的水利、电力调度、市政调度等行业广泛使用。

在远程测控系统中, RTU 是实现远程通信的关键设备, 承担着中心站和测站间信息的上传下达工作, 它主要有遥信、遥测、遥控和遥调 4 个功能^[12]。

- 遥信功能: 要求采用无源接点方式即某一路遥信量的输入应是一对继电器的触点, 或者是闭合, 或者是断开。通过遥信端子板将继电器触点的闭合或断开转换为低电平或高电平信号送入 RTU。遥信功能通常用于测量开关的位置信号、变压器内部故障综合信号、保护装置的动作信号、通信设备运行状态信号、调压变压器抽头位置信号等。
- 遥测功能: 通过采集现场各种传感器和变送器的信号获得现场各种物理参数, 将采集到的变量存储、编码成遥测信息, 按通信规约传送给监控中心。遥测量可以是水情测报系统中的温度、压力、液位、流量, 以及变电站参数监控中的电流、电压、功率等模拟量。
- 遥控功能: 由监控中心对现场设备实行远程操控, 如启动或关停某设备、打开或关闭某阀门。在遥控过程中, 监控中心发往 RTU 的命令有 3 种, 即遥控选择命令、遥控执行命令和遥控撤销命令。遥控选择命令包括两个部分, 一是选择的对象, 用对象码指定对哪一个对象进行操作; 另一个是遥控操作的性质, 用操作性质码指示。遥控执行命令指示 RTU 按接收到的选择命令执行指定操作。遥控撤销命令指示 RTU 撤销已下达的选择命令。
- 遥调功能: 监控中心对被控站某些设备的工作状态和参数的调整。

除了在传统的工业生产过程中大量应用之外, 在测控点特别分散的场合, 远程终端单元也得到广泛的应用, 例如, 城市供水自动化控制系统, 城市废水处理系统, 城市煤气管

网综合调度系统, 天然气、石油行业自动化系统, 电力远程数据集控系统, 热网管道自动化控制, 大气 / 水质等环保监测, 水情水文测报系统, 灯塔信标、江河航运、港口、矿山调度系统等, RTU 发挥着越来越重要的作用^[12]。

随着国内工业企业 SCADA 系统的应用与发展, RTU 产品在市场上越来越多, 但国外 RTU 产品占有较大的份额。目前这种状况日益得到改善, 国内的 RTU 产品正在不断发展和成熟中。

RTU 的发展历程是与“四遥”工程技术相联系的。所谓“四遥”工程技术是指遥信、遥测、遥控、遥调技术, 是对人们不易到达地点的物理变化过程、生产过程等进行检测、调节、控制的技术。“四遥”系统工程是多学科、多专业的高新技术系统工程, 涉及计算机、机械、无线电、自动控制等技术, 还涉及传感器技术、仪器仪表技术、非电量测量技术、软件工程、无线电通信技术、数据通信技术、网络技术、信息处理技术等高新技术。因此, RTU 的发展将必然会随着“四遥”工程技术的发展而发展^[13]。

随着测控技术、通信技术、计算机技术等新技术的发展; 远程测控终端向着通用性强、灵活性高、小型化、更加智能化方向发展; 能够检测多种类型物理参数, 具有更快响应速度、更大存储能力、有线和无线多种通信方式、更强的信息交互能力、更加灵活的组态配置能力, 适应各种不同应用场合的 RTU 产品将被开发出来, 给现代工业生产、管理、科学研究等领域带来更大的便利, 对人们的生活方式产生更大的影响。

2.4 工业控制系统现场设备的种类

现场设备是工业控制系统的基本组成部分, 本节以智能电子设备 (Intelligent Electronic Device, IED) 和人机界面 (HMI) 为例, 介绍其基本概念、组成部分、工作原理和主要功能。

2.4.1 智能电子设备

IEC 61850 标准对智能电子设备的定义如下: “由一个或多个处理器组成, 从外部源接收和传送数据或控制外部源的任何设备 (即电子多功能仪表、微机保护、控制器), 在特定的环境下接口所限定范围内能够执行一个或多个逻辑节点任务的实体”。^[14]

IED 处理流程如图 2-5 所示。检测的信号主要是三相电压、三相电流信号。信号前端电路将执行低通滤波功能, 滤除对信号影响比较大的杂波。随后信号被高速 A/D 转换器 (模数转换器) 采集, 通过 A/D 转换器 +CPLD (Complex Programmable Logic Device, 复杂可

编程逻辑器件) 电路实现, 最后通过数据总线送至 DSP。完成参数计算后, DSP 把数据格式进行统一打包上传给主控 IED, 其主要功能是接收检测 IED 的数据, 并上传给数据库。

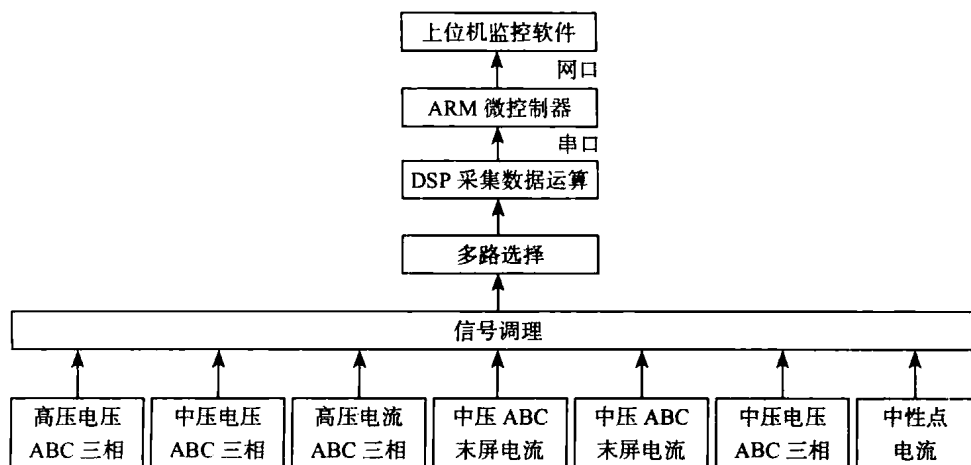


图 2-5 IED 处理流程

2.4.2 人机界面

人机界面 (Human-Machine Interface, HMI) 是连接可编程逻辑控制器 (PLC)、变频器、直流调速器、仪表等工业控制设备, 利用显示屏显示, 通过输入单元 (如触摸屏、键盘、鼠标等) 写入工作参数或输入操作命令, 实现人与机器信息交互的数字设备。

人机界面产品由硬件和软件两部分组成, 硬件部分包括处理器单元、显示单元、输入单元、通信接口、数据存储单元等, 其中处理器的性能决定了 HMI 产品的性能高低, 是 HMI 的核心单元。根据 HMI 的产品等级不同, 处理器可分别选用 8 位、16 位、32 位的处理器。HMI 软件一般分为两部分, 即运行于 HMI 硬件中的系统软件和运行于 PC Windows 操作系统下的画面组态软件 (如 JB-HMI 画面组态软件)。使用者都必须先使用 HMI 的画面组态软件制作 “工程文件”, 再通过 PC 和 HMI 产品的串行通信口, 把编制好的 “工程文件” 下载到 HMI 的处理器中运行^[15]。人机界面硬件构成如图 2-6 所示。

目前市场上流行的人机界面产品的品牌和种类比较繁多, 但都具有以下基本功能:

1) 设备工作状态显示, 如指示灯、按钮、文字、图形、曲线等。

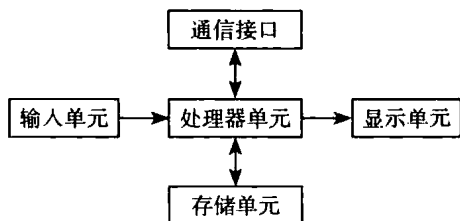


图 2-6 人机界面硬件构成

- 2) 数据、文字输入操作, 打印输出。
- 3) 生产配方存储, 设备生产数据记录。
- 4) 简单的逻辑和数值运算。
- 5) 可连接多种工业控制设备组网。

人机界面的特点包括如下几个方面。

1) 实时性: 人机界面对各种事件的响应具有一定的时限要求, 具有实时处理事件的特性。

2) 并发处理: 在实际环境中, 需实时处理的外部事件往往不是单一的, 而这些事件都是随机发生的, 有可能同时出现。因此, 需具有分布和并发处理的特点。

3) 系统可裁剪: 由于人机界面在各种设备上使用的功能不同, 且存储的容量非常有限, 因此需尽量把一些冗余的功能删除。这就要求系统设计是模块化的, 能够根据不同的需求选择不同的模块。

4) 可靠性: 人机界面产品一般都安装在特定的机器设备上, 有些机器需要长时间运行, 工作环境恶劣, 必须保证设备在运行的过程中不出错。

5) 通用性: 人机界面应用广泛, 在不同的机器设备上所需要的功能都有所不同, 开发人员不可能为不同的应用开发不同的产品, 因此需要开发的人机界面适应于不同的工作环境。

人机界面产品的种类很多, 包括如下几种。

1) 薄膜键输入的人机界面, 显示尺寸小于 5.7 寸 (1 寸 = 3.33cm), 画面组态软件免费, 属初级产品。如 POP-HMI 小型人机界面。

2) 触摸屏输入的人机界面, 显示屏尺寸为 5.7 ~ 12.1 寸, 画面组态软件免费, 属中级产品。

3) 基于平板计算机的、多种通信口的、高性能的人机界面, 显示尺寸大于 10.4 寸, 画面组态软件收费, 属高端产品。

随着数字电路和计算机技术的发展, 未来的人机界面产品在功能上的高、中、低划分将越来越不明显, HMI 的功能将越来越丰富; 5.7 寸以上的 HMI 产品将全部是彩色显示屏, 屏的寿命也将更长。由于计算机硬件成本的降低, HMI 产品将以平板计算机为 HMI 硬件的高端产品为主, 因为这种高端的产品在处理器速度、存储容量、通信接口种类和数量、组网能力、软件资源共享上都有较大的优势, 是未来 HMI 产品的发展方向。当然, 对于小尺寸的 (显示尺寸小于 5.7 寸) HMI 产品, 由于其在体积和价格上的优势, 随着其功能的进一步增强 (如增加 I/O 功能), 将在小型机械设备的人机交互应用中得到广泛应用。

2.5 PLC 设备的技术原理

前面简单介绍了 PLC 的基本概念、应用领域和特点,本节将详细介绍 PLC 设备的产生与特点、基本组成、工作原理及其使用的指令系统、通信技术和接口技术。

2.5.1 PLC 的产生与特点

在可编程逻辑控制器问世之前,继电器控制在工业控制领域占主导地位。继电器控制系统采用固定接线的硬件实现控制逻辑。如果生产任务或工艺发生变化,就必须重新设计和改变硬件结构,这样就会造成时间和资金的浪费。另外,大型控制系统用继电器、接触器控制,使用的继电器数量多、体积大、耗电多,且继电器触点为机械触点,工作频率较低,在频繁动作情况下寿命较短,容易造成系统故障,系统的可靠性差。1968年,美国最大的汽车制造商通用汽车公司(GM公司)为了适应汽车型号不断翻新的需求,以求在激烈竞争中占优势地位,提出以一种新型的控制装置取代继电器、接触器控制装置,并且对未来的新型控制装置做出了具体设想——利用计算机的完备功能,以及灵活性、通用性好等优点,要求新的控制装置编程简单,即使不熟悉计算机的人员也能很快掌握它的使用技术。为此,拟定了以下公开招标的10项技术要求:

- 1) 编程简单方便,可在现场修改程序。
- 2) 硬件维护方便,采用插件式结构。
- 3) 可靠性高于继电器、接触器控制装置。
- 4) 体积小于继电器、接触器控制装置。
- 5) 可将数据直接送入计算机。
- 6) 用户程序存储器容量至少可以扩展到4 KB。
- 7) 输入可以是交流115 V。
- 8) 输出为交流115 V,能直接驱动电磁阀、交流接触器等。
- 9) 通用性强,扩展方便。
- 10) 成本上可与继电器、接触器控制系统竞争。

美国数字设备公司(Digital Equipment Corporation, DEC)根据GM公司的招标技术要求,于1969年研制出世界上第一台可编程控制器,并在GM公司汽车自动装配线上使用且获得成功。其后,日本、德国相继引入这项新技术,可编程控制器由此迅速发展起来^[6]。

PLC综合了继电器、接触器控制以及计算机灵活、方便的优点而设计、制造和发展的,因此与其他控制器相比,PLC具有以下8个特点。

(1) 高可靠性

1) 所有的 I/O 接口电路均采用光电隔离, 使工业现场的外电路与 PLC 内部电路之间电气上隔离。

2) 各输入端均采用 R-C 滤波器, 其滤波时间常数一般为 $10 \sim 20 \text{ ms}$ 。

3) 各模块均采用屏蔽措施, 以防止辐射干扰。

4) 采用性能优良的开关电源。

5) 对采用的器件进行严格的筛选。

6) 良好的自诊断功能, 一旦电源或其他软、硬件发生异常情况, CPU 立即采用有效措施, 以防止故障扩大。

7) 大型 PLC 还可以采用由双 CPU 构成冗余系统或由三 CPU 构成表决系统, 使可靠性更进一步提高。

(2) 通用性强, 方便使用

PLC 产品已系列化和模块化, PLC 的开发制造商为用户提供了品种齐全的 I/O 模块和配套部件。用户在进行控制系统设计时, 不需要自己设计和制作硬件装置, 只需要根据控制要求进行模块的配置。用户所做的工作只是设计满足控制对象控制要求的应用程序。对于一个控制系统, 当控制要求改变时, 只需要修改程序就能变更控制功能。

(3) 采用模块化结构, 系统组合灵活方便

为了适应各种工业控制, 需要除了单元式的小型 PLC 以外的绝大多数 PLC 均采用模块化结构。PLC 的各个部件包括 CPU、电源、I/O 等均采用模块化设计, 由机架及电缆将各模块连接起来, 系统的规模和功能可根据用户的需要自行组合。

(4) 编程语言简单易学, 便于掌控

PLC 是由继电器、接触器控制系统发展而来的一种新型的工业自动化控制装置, 其主要的使用对象是广大的电气技术人员。为了使工程技术人员方便学习和掌握 PLC 的编程, PLC 的开发制造商采取了与继电器、接触器控制原理相似的梯形图语言。

(5) 系统设计周期短

系统硬件的设计任务仅仅是根据对象的控制要求配置适当的模块, 而不是去设计具体的接口电路, 这样大大缩短了整个设计所花费的时间, 加快了整个工程的进度。

(6) 对生产工艺改变适应性强

PLC 的核心部件是微处理器, 它实际上是一种工业控制计算机, 其控制功能是通过软件编程来实现的。当生产工艺发生变化时, 不必改变 PLC 硬件设备, 只需改变 PLC 中的程序, 这对现代化的小批量、多品种的生产尤其适合。

(7) 安装简单, 调试方便, 维护工作量小

PLC 控制系统的安装接线工作量比继电器、接触器控制系统少得多, 只需将现场的各种设备与 PLC 相应的 I/O 端相连。PLC 软件设计和调试大多可在实验室进行, 用模拟实验开关代替输入信号, 其输出状态可以观察 PLC 上相应的发光二极管, 也可以另接模拟实验板。模拟调试好后, 再将 PLC 控制系统安装到现场, 进行联机调试, 这样既节省时间又很方便。PLC 本身的可靠性高, 又有完善的自诊断功能, 一旦发生故障, 可以根据报警信息, 迅速查明原因。如果是 PLC 本身发生故障, 则可用更换模块的方法排除故障。这样提高了维护的工作效率, 以保证生产的正常进行。

(8) I/O 接口模块丰富

PLC 针对不同的工业现场信号(如交流或直流、开关量或模拟量、电压或电流、脉冲或电位和强电或弱电等)有相应的 I/O 模块与工业现场的器件或设备(如按钮、行程开关、接近开关、传感器及变送器、电磁线圈和控制阀)直接连接。另外为了提高操作性能, 它还有多种人机对话的接口模块; 为了组成工业局部网络, 它还有多种通信联网的接口模块, 等等。

2.5.2 PLC 的基本组成与工作原理

典型 PLC 的组成如图 2-7 所示, 分别是中央处理单元(CPU)、存储器、输入/输出(I/O)模块、电源和编程器, 下面将对其进行详细的介绍^[16]。

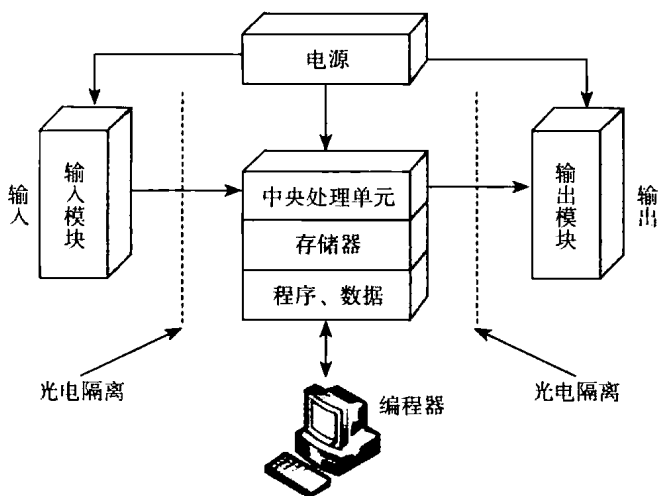


图 2-7 PLC 的组成结构示意图

1. 中央处理单元

中央处理单元是 PLC 的控制中枢。它按照 PLC 系统程序赋予的功能接收并存储从编程

器键入的用户程序和数据：检查电源、存储器、I/O 以及警戒定时器的状态，并能诊断用户程序中的语法错误，当 PLC 投入运行时，首先它以扫描的方式接收现场各输入装置的状态和数据，并分别存入 I/O 映像区，然后从用户程序存储器中逐条读取用户程序，经过命令解释后将按指令的规定执行逻辑或算术运算的结果送入 I/O 映像区或数据寄存器内。等所有的用户程序执行完毕之后，最后将 I/O 映像区的各输出状态或输出寄存器内的数据传送到相应的输出装置，如此循环运行，直到停止运行。

为了进一步提高 PLC 的可靠性，近年来对大型 PLC 还采用双 CPU 构成冗余系统，或采用三 CPU 的表决式系统。这样，即使某个 CPU 出现故障，整个系统仍能正常运行。

2. 存储器

存放系统软件的存储器称为系统程序存储器，存放应用软件的存储器称为用户程序存储器。

PLC 常用的存储器类型主要有 RAM、EPROM 和 EEPROM。

- RAM (Random Access Memory) 是一种读 / 写存储器 (随机存储器)。用户可以用编程器读出 RAM 中的内容，也可以将用户程序写入 RAM。它是易失性的存储器，将它的电源断开后存储的信息将会丢失。
- EPROM (Erasable Programmable Read Only Memory) 是一种可擦除的只读存储器，在断电情况下存储器内的所有内容保持不变 (在紫外线连续照射下可擦除存储器内容)。
- EEPROM (Electrical Erasable Programmable Read Only Memory) 是一种电可擦除的只读存储器。使用编程器就能很容易地对其所存储的内容进行修改。

有关 PLC 的存储空间分配，虽然各种 PLC 的 CPU 的最大寻址空间各不相同，但是根据 PLC 的工作原理其存储空间一般包括以下 3 个区域：系统程序存储区、系统 RAM 存储区 (包括 I/O 映像区和系统软设备等) 和用户程序存储区。

- 系统程序存储区：在系统程序存储区中存放着相当于计算机操作系统的系统程序，包括监控程序、管理程序、命令解释程序、功能子程序、系统诊断子程序等。由制造厂商将其固化在 EPROM 中，用户不能直接存取。它和硬件一起决定了该 PLC 的性能。
- 系统 RAM 存储区：系统 RAM 存储区包括 I/O 映像区以及各类软设备 (如逻辑线圈、数据寄存器、计时器、计数器、变址寄存器、累加器等存储器存储区)。
- I/O 映像区：由于 PLC 投入运行后，只是在输入采样阶段才依次读入各输入状态和数据，在输出刷新阶段才将输出的状态和数据送至相应的外设。因此，它需要一定

数量的存储单元 (RAM) 以存放 I/O 的状态和数据, 这些单元称作 I/O 映像区。

一个开关量 I/O 占用存储单元中的一个位 (bit), 一个模拟量 I/O 占用存储单元中的一个字 (16 bit)。因此整个 I/O 映像区可看作由两个部分组成: 开关量 I/O 映像区和模拟量 I/O 映像区。

除了 I/O 映像区以外, 系统 RAM 存储区还包括 PLC 内部各类软设备 (逻辑线圈、计时器、计数器、数据寄存器和累加器等) 的存储区。该存储区又分为具有失电保持的存储区域和无失电保持的存储区域。前者在 PLC 断电时由内部的锂电池供电, 数据不会遗失; 后者当 PLC 断电时, 数据被清零。

- 逻辑线圈: 与开关输出一样, 每个逻辑线圈占用系统 RAM 存储区中的一个位, 但不能直接驱动外设, 只供用户在编程中使用, 其作用类似于电器控制线路中的继电器。另外, 不同的 PLC 还提供数量不等的特殊逻辑线圈, 具有不同的功能。
- 数据寄存器: 与模拟量 I/O 一样, 每个数据寄存器占用系统 RAM 存储区中的一个字 (16 bit)。另外, PLC 还提供数量不等的特殊数据寄存器, 具有不同的功能。

用户程序存储区则是用于存放用户编制的用户程序。不同类型的 PLC 其存储容量各不相同。

3. 电源模块

电源模块为机架上的模块提供直流电源。PLC 的电源在整个系统中起着十分重要的作用。如果没有一个良好的、可靠的电源系统是无法正常工作的, 因此 PLC 的制造商对电源的设计和制造也十分重视。

一般交流电压波动在 $\pm 10\%$ ($\pm 15\%$) 范围内, 可以不采取其他措施而将 PLC 直接连接到交流电网上。

最初研制生产的 PLC 主要用于代替由继电器、接触器构成的传统控制装置, 但这两者的运行方式并不是相同的。继电器控制装置采用硬逻辑并行运行的方式, 即如果这个继电器的线圈通电或断电, 该继电器所有的触点 (包括其常开或常闭触点) 无论在继电器控制线路的哪个位置上都会立即同时动作。PLC 的 CPU 则采用顺序逻辑扫描用户程序的运行方式, 即如果一个输出线圈或逻辑线圈被接通或断开, 该线圈的所有触点 (包括其常开或常闭触点) 不会立即动作, 必须等扫描到该触点时才会动作。

为了消除二者之间由于运行方式不同而造成的差异, 考虑继电器控制装置各类触点的动作时间一般在 100 ms 以上, 而 PLC 扫描用户程序的时间一般均小于 100 ms, 因此, PLC 采用了一种不同于一般微型计算机的运行方式——扫描技术。这样在对于 I/O 响应要求不高的场合, PLC 与继电器控制装置的处理结果就没有什么区别了。

(1) 扫描技术

当 PLC 投入运行后, 其工作过程一般分为 3 个阶段, 即输入采样、用户程序执行和输出刷新 3 个阶段。完成上述 3 个阶段称作一个扫描周期。在整个运行期间, PLC 的 CPU 以一定的扫描速度重复执行上述 3 个阶段。

在输入采样阶段, PLC 以扫描方式依次读入所有输入状态和数据, 并将它们存入 I/O 映像区中的相应单元内。输入采样结束后, 转入用户程序执行和输出刷新阶段。在这两个阶段中, 即使输入状态和数据发生变化, I/O 映像区中的相应单元的状态和数据也不会改变。因此, 如果输入是脉冲信号, 则该脉冲信号的宽度必须大于一个扫描周期, 才能保证在任何情况下该输入均能被读入。

在用户程序执行阶段, PLC 总是按由上而下的顺序依次扫描用户程序 (梯形图)。在扫描每一条梯形图时, 又总是先扫描梯形图左边的由各触点构成的控制线路, 并按先左后右、先上后下的顺序对由触点构成的控制线路进行逻辑运算, 然后根据逻辑运算的结果, 刷新该逻辑线圈在系统 RAM 存储区中对应位的状态; 或者刷新该输出线圈在 I/O 映像区中对应位的状态; 或者确定是否要执行该梯形图所规定的特殊功能指令。

也就是说, 在用户程序执行过程中, 只有输入点在 I/O 映像区内的状态和数据不会发生变化, 而其他输出点和软设备在 I/O 映像区或系统 RAM 存储区内的状态和数据都有可能发生变化, 而且排在上面的梯形图, 其程序执行结果会对排在下面的凡是用到这些线圈或数据的梯形图起作用; 相反, 排在下面的梯形图, 其被刷新的逻辑线圈的状态或数据只能到下一个扫描周期才能对排在其上面的程序起作用。

当扫描用户程序结束后, PLC 就进入输出刷新阶段。在此期间, CPU 按照 I/O 映像区内对应的状态和数据刷新所有的输出锁存电路, 再经输出电路驱动相应的外设。这时才是 PLC 的真正输出。

一般来说, PLC 的扫描周期包括自诊断、通信等, 如图 2-8 所示, 一个扫描周期等于自诊断、通信、输入采样、用户程序执行、输出刷新等所有时间的总和。

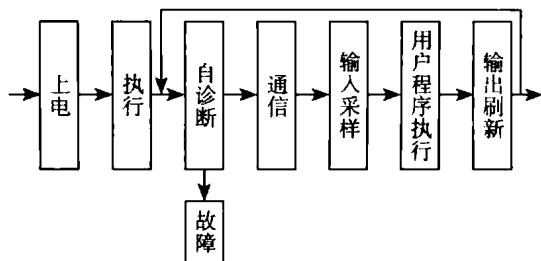


图 2-8 PLC 的扫描周期

(2) PLC 的 I/O 响应时间

为了增强 PLC 的抗干扰能力, 提高其可靠性, PLC 的每个开关量输入端都采用光电隔离等技术。

为了能够实现继电器控制线路的硬逻辑并行控制, PLC 采用了不同于一般微型计算机的运行方式 (扫描技术)。

以上两个主要原因,使得 PLC 的 I/O 响应比一般微型计算机构成的工业控制系统慢得多,其响应时间至少等于一个扫描周期,一般均大于一个扫描周期甚至更长。

所谓 I/O 响应时间指从 PLC 的某一输入信号变化开始到系统有关输出端信号的改变所需的时间。其最短的 I/O 响应时间与最长的 I/O 响应时间如图 2-9 和图 2-10 所示。

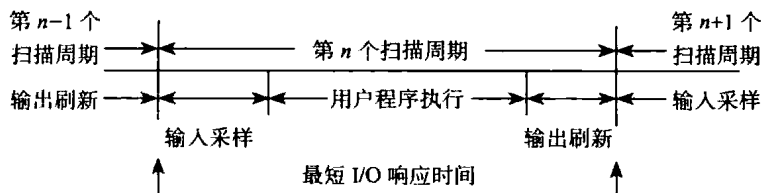


图 2-9 最短 I/O 响应时间

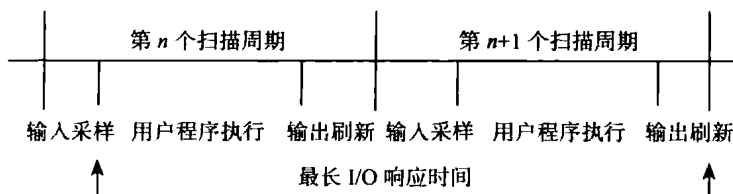


图 2-10 最长 I/O 响应时间

2.5.3 PLC 的基本指令系统

PLC 的编程语言与一般计算机语言相比,具有明显的特点,它既不同于高级语言,也不同于一般的汇编语言,它既要满足易于编写,又要满足易于调试的要求。目前,还没有一种对各厂家产品都能兼容的编程语言。各公司的产品有它们自己的编程语言,分别介绍几种典型的编程语言如下。

1. 欧姆龙 CPM 系列小型 PLC 的基本指令^[17]

(1) LD 和 LD NOT 指令

LD 和 LD NOT 指令用于决定指令执行的第一个条件。LD 指令表示指令执行的条件;LD NOT 指令表示将指令执行的条件取反。LD、LD NOT 指令只能以位为单位进行操作,且不影响标志位。

(2) OUT 和 OUT NOT 指令

OUT 和 OUT NOT 用于输出指定位的状态。OUT 指令输出逻辑运算结果,OUT NOT 指令将逻辑运算结果取反后再输出。

(3) AND 和 AND NOT 指令

AND 指令表示操作条件和它的位操作数之间进行逻辑“与”运算；AND NOT 指令表示将它的位操作数之间取“反”后再与其前面的操作条件进行逻辑“与”运算。

(4) OR 和 OR NOT 指令

OR 指令表示操作条件和它的位操作数之间进行逻辑“或”运算；OR NOT 指令表示后面的位操作数取“反”后再与其前面的操作条件进行逻辑“或”运算。

(5) AND LD 指令

AND LD 指令用于两个逻辑块的串联连接，即对逻辑块进行逻辑“与”操作。

(6) OR LD 指令

OR LD 指令用于两个逻辑块的并联连接，即对逻辑块进行逻辑“或”操作。

(7) 置位和复位指令 (SET 和 RESET)

当 SET 指令的执行条件为 ON 时，使指定继电器位置为 ON；当执行条件为 OFF 时，SET 指令不改变指定继电器的状态。当 RESET 指令的执行条件为 ON 时，使指定继电器复位为 OFF；当执行条件为 OFF 时，RESET 指令不改变指定继电器的状态。

(8) 保持指令 (KEEP (11))

根据置位输入和复位输入条件，KEEP 用来保持指定继电器 M 保持为 ON 状态或 OFF 状态。当置位输入端为 ON 时，继电器 M 保持为 ON 状态，直至复位输入端为 ON 时使其变为 OFF。

(9) 上升沿微分和下降沿微分指令 (DIFU (13) / DIFD (14))

当执行条件由 OFF 变为 ON 时，上升沿微分 DIFU 使指定继电器在一个扫描周期内为 ON；当执行条件由 ON 变为 OFF 时，下降沿微分 DIFD 使指定继电器在一个扫描周期内为 ON。

(10) 空操作指令 (NOP (00))

空操作指令用来取消某一步操作。此指令无操作数，无梯形符号。

(11) 结束指令 (END (01))

END (01) 指令表示程序结束，放在程序的最后。

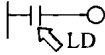
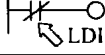
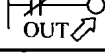
2. FX 系列 PLC 指令

FX 系列 PLC 共有基本指令 20 条，步进指令 2 条，应用指令 85 条。基本指令和应用指令可通过增加后缀或前缀进行扩充，若考虑此种情况，则实际基本指令有 27 条，应用指令有 245 条。

(1) 逻辑取、输出线圈驱动指令 (LD、LDI、OUT)

3 个指令的介绍如表 2-1 所示。

表 2-1 LD、LDI、OUT 指令说明

符号名称	功能	梯形图	程序步数
LD (取)	运算开始 (常开触点)		1
LDI (取反)	运算开始 (常闭触点)		1
OUT (输出)	线圈驱动输出		见说明④

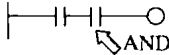
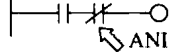
说明:

- ① LD、LDI 指令用于将触点连接到母线上, 逻辑运算开始, 连接触点可以是 X、Y、M、S、T、C 继电器的触点。与 ANB 指令配合, 在分支起点处也可使用。
- ② OUT 指令是对 Y、M、S、T、C 继电器线圈的驱动指令。
- ③ 并行输出指令可以多次使用。
- ④ LD、LDI 指令的程序步数为 1 步。OUT 指令的程序步数与输出元件有关, 若为输出继电器及通用辅助继电器, 其步数为 1; 若为特殊辅助继电器, 其步数为 2; 若为定时器及 16 位计数器, 其步数为 3; 若为 32 位计数器, 其步数为 5。
- ⑤ 对定时器的定时线圈和计数器的计数线圈, 在 OUT 指令后还必须设定常数 K。

(2) 触点串联指令 (AND、ANI)

AND、ANI 指令用于触点的串联连接, 对串联触点的个数没有限制。具体如表 2-2 所示。

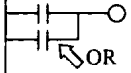
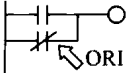
表 2-2 AND、ANI 指令说明

符号名称	功能	梯形图	程序步数
AND (与)	串联常开触点		1
ANI (取反)	串联常开触点		1

(3) 触点并联指令 (OR、ORI)

OR、ORI 指令用于 1 个触点的并联连接。OR、ORI 指令是从当前步开始, 对前面的 LD、LDI 指令并联连接, 对并联的次数没有限制。具体如表 2-3 所示。

表 2-3 OR、ORI 指令说明

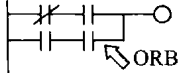
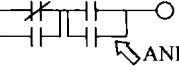
符号名称	功能	梯形图	程序步数
OR (或)	并联常开触点		1
ORI (或非)	并联常开触点		1

(4) 电路块串、并联指令 (ANB、ORB)

ORB、ANB 指令均为无操作对象的指令。ORB、ANB 指令可以重复使用, 但由于 LD、LDI 指令的重复次数有限制, 注意电路块的串、并联应在 8 次以下。两个以上触点串

联连接的电路称为串联电路块。串联电路块并联连接时，分支的开始用 LD、LDI 指令，分支的结束用 ORB 指令。两个以上触点并联连接的电路称为并联电路块。分支电路并联电路块与前面电路串联连接时，使用 ANB 指令。分支的开始用 LD、LDI 指令，并联电路块结束后用 ANB 指令，表示与前面的电路串联。具体如表 2-4 所示。

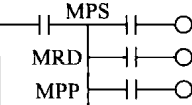
表 2-4 ANB、ORB 指令说明

符号名称	功能	梯形图	程序步数
ORB (电路块或)	串联电路块的并联连接		1
ANB (电路块与)	并联电路块的串联连接		1

(5) 多重输出指令 (MPS、MRD、MPP)

在 PLC 中有 11 个存储器，用来存储运算的中间结果，称作堆栈存储器。其中，使用一次 MPS 指令便将此时的运算结果压入堆栈的第一层，同时原来存在第一层的数据被压入第二层，以此类推。使用一次 MPP 指令，将第一层的数据读出，同时其他数据依次上移。MRD 指令只是用来读第一层的数据，堆栈内的所有数据均不移动。MPS、MPP 指令必须成对使用，而且连续使用次数应少于 11 次。MPS、MPP、MRD 指令都是不带操作对象的指令。具体如表 2-5 所示。

表 2-5 MPS、MRD、MPP 指令说明

符号名称	功能	梯形图	程序步数
MPS (入栈)	将结果压入堆栈		1
MPP (出栈)	将结果弹出堆栈		1
MRD (读栈)	读出当前堆栈数据		1

(6) 置位与复位指令 (SET、RST)

对同一元件可多次使用 SET、RST 指令，但最后一次执行的结果才有效。SET 指令使元件的结果置位 (置“1”)，其操作对象可以是 Y、M、S。RST 指令使元件的结果复位 (清“0”)，其操作对象可以是 Y、M、S、T、C、D、V、Z。具体如表 2-6 所示。

表 2-6 SET、RST 指令说明

符号名称	功能	梯形图	程序步数
SET (置位)	元件置位并保持		Y、M (通用): 1 S、T、C、M (特殊): 2
RST (复位)	元件或寄存器清零		D、V、Z: 3

(7) 脉冲输出指令 (PLS、PLF)

PLS、PLF 指令的操作元件为输出继电器及通用辅助继电器。使用 PLS 指令, 其后的 Y、M 元件仅在驱动输入接通后的 1 个扫描周期内动作 (置“1”), 随后立即清零。使用 PLF 指令, 其后的 Y、M 元件仅在驱动输入断开后的 1 个扫描周期内动作 (置“1”), 随后立即清零。具体如表 2-7 所示。

表 2-7 PLS、PLF 指令说明

符号名称	功能	梯形图	程序步数
PLS(上升沿脉冲)	上升沿微分输出		2
PLF(下降沿脉冲)	下降沿微分输出		2

(8) NOP 及 END 指令

NOP 指令主要用于预先插入程序中, 在修改或追加程序时可减少步序号的变化。将程序全部清除时, 全部指令变为空操作指令。END 指令表示程序的结束。在调试程序时, 可分段加入 END 指令, 以便进行分段检查。具体如表 2-8 所示。

表 2-8 NOP 及 END 指令说明

符号名称	功能	梯形图	程序步数
NOP(空操作)	无动作	无	1
END(结束)	程序结束, 回到第 0 步		1

(9) 其他基本指令

1) 9 个基本指令。

MC、MCR 指令: 主控及主控复位指令, 可用于公共串联触点的连接及清除。

INV 指令: 反转指令, 即对前面的运算结果取反。

LDP、LDF、ANDP、ANDF、ORP、ORF 指令: 分别由 LD、AND、OR 3 个指令加后缀而来, 其中“P”表示上升沿 (“0”变为“1”), “F”表示下降沿 (“1”变为“0”), 这几个指令分别表示在前面结果的上升沿或下降沿接通一个扫描周期。

2) 步进指令。

步进指令只有 STL、RET 两条, 用来进行流程图程序的编制。步进阶梯指令 (STL) 是利用内部软元件 S 在顺控程序上面进行工序步进式控制的指令, STL 指令的意义为激活某状态, 有建立子母线的功能。返回指令 (RET) 表示状态 (S) 流程的结束, 用于返回主母线, 状态转移程序的结尾必须使用 RET 指令。

3) 应用指令。

应用指令又称功能指令，主要包括程序流向控制指令、算术与逻辑运算指令、循环与移位指令、数据处理指令、高速处理指令、外部输入输出处理指令、浮点运算指令等。这些功能指令实际上就是一个一个功能不同的子程序，某些复杂运算只需一条功能指令即可完成，大大提高了 PLC 的实用性。

2.5.4 PLC 的通信技术

1. 概述

PLC (Power Line Communication) 技术也称为“电力线通信技术”，它是通过电力线为媒介，用来传输数据、语音、图像等信号的一种通信方式。早在 20 世纪 20 年代就已经出现了电力线通信的记载，PLC 技术在发展的各个阶段被应用在高压输电网、中压输电网和低压输电网等领域；传输速率已由 1 Mbit/s 发展到 2 Mbit/s、24 Mbit/s 等，甚至高达 200 Mbit/s 和 500 Mbit/s，有的甚至更高，是被业界看好的宽带接入技术之一。

2. PLC 通信技术工作原理

信号发送时，利用 GMSK（高斯滤波最小频移键控）以及 OFDM（正交频分多路复用）调制技术将待传输信号的频率加载到电流上，通过电力线将该电流传输至用户。在接收端，用户需要安装一个特制的调制解调器（也称为无线电力猫），调制解调器的一端与常规电源相连，另一端与计算机的网卡接通，计算机即可上网。

无线电力猫是电力调制解调模块与无线接入点 AP 的融合，使用终端就是家庭用户，与电源插座相连接，即插即用。当无线电力猫终端接通电源后，系统能够自动搜寻局端电力网桥，注册属于自己的 MAC 地址，与此同时，局端电力网桥会给每一个无线电力猫终端分配唯一的 TEI。PLC 中局端电力网桥与每一个无线电力猫终端之间是主从关系，均采用点对多的拓扑结构。

3. PLC 通信技术的应用

目前，国内外对于电力线上网技术可以分为两种模式：一是用户内联网技术模式，通过室内安装的电力线，实现整个家庭的互联互通；二是户外接入技术模式，利用配电柜与用户的有效连接方式，达到信息高速输送给用户的目的。

电力线上网技术与日常生活接触最早的工作方式是自动完成远程水表、电表、煤气表数据的读取工作，节省了大量的人力物力，同时也方便了用户。预计今后电力线上网技术还可以实现有电源插座的任何地方，不用拨号就可以享受高速的网络服务，保证了数字化

生活的舒适和便利,同时还可以实现家庭智能监控系统,利用 PLC 技术将家中的电气设备连接起来^[18]。

4. 通信规程

PLC 串行通信采用半双工异步传送,支持 CCM 通信协议,并具有以下功能:①上位通信功能;②主局功能;③一对一功能;④无协议串行通信功能。这些功能可以实现 PLC 的寄存器和内部继电器的读入和写出、传送状态的跟踪等。由于 CCM 协议采用主从通信方式,所以通信过程中由主局保持主动权,向子局发出呼叫,并通过向子局发送命令帧来控制数据传送的方向、格式和内容;子局对得到的主局呼叫做出响应,并根据命令帧要求进行数据传输。

数据传输过程以主局向子局写入数据为例,如图 2-11 所示,通信从主局向子局提出呼叫开始,子局做出应答以建立连接,主局接到应答后,向子局发送首标,子局将依据首标各项要求与主局进行数据传输,在子局做出响应后,开始传送数据,数据以 128 字节(ASCII 方式)为单位进行分组传送,最后主局发送 EOF 信号结束本次通信。其中,首标作为命令帧,规定了数据传送方向、数据操作起始地址及数据传送量等。

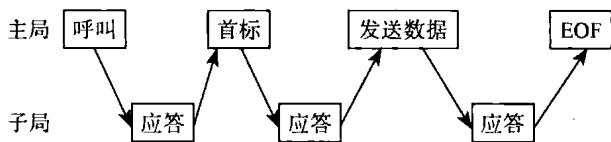


图 2-11 数据传输过程

在进行数据通信时,通信应答时间决定了系统读写速度,而作为主局的计算机通信时间因上位计算机类型、PC 扫描时间、PLC 数据通信接口模块应答延迟时间设定值、波特率、数据传送量的不同而不同。其中,PC 扫描时间与应答延迟时间对通信时间的影响为当 PC 扫描时间比应答延迟时间短时,前者对通信时间没有影响;反之,当 PC 扫描时间比应答延迟时间长时,在计算总通信时间时,采用 PC 扫描时间,计算公式如下:

$$\text{总通信时间} = A + B + C + D$$

其中, A 为呼叫发送 / 应答时间, B 为首标发送 / 应答时间, C 为数据发送 / 应答时间, D 为通信结束应答时间。

以数据发送时间为例:

$$\text{数据发送时间} = \text{数据传送字符数} \times \text{通信时间} / \text{字符} + \text{PC 扫描时间}$$

数据通信中,数据传送量因采用的传送方式不同而不同。传送方式支持 ASCII 码和二进

制两种。其中 ASCII 码是用 8 位表示数字、字母等，因此采用它来进行数据通信时，一字节二进制数要由两字节 ASCII 码来表示，实际传输量就是采用二进制数据通信的两倍。而在某些要求较强的可靠性和实时性的系统中，为提高通信速率和更好地实现实时监控，应选用二进制传输方式，波特率选用 9600 bit/s，并采用奇校验，通信时间 / 字符为 1 ms / 字符^[19]。

2.5.5 PLC 的接口技术

1. 对接口电路的要求

1) 能够可靠地传送控制机床动作的相应控制信息，并能够输入控制机床所需的有关状态信息。信息形式有数字量（以 8 位二进制形式表示的数字信息）、开关量（以 1 位二进制数“0”或“1”表示的信息）和模拟量 3 种。

2) 能够进行相应的信息转换，以满足 CNC（数控装置）系统的输入与输出要求（常把数控机床分为 CNC 侧和 MT（Machine Tool，机床）侧，PLC 位于 CNC 侧和 MT 侧之间，对 CNC 和机床的输入输出信号进行处理）。输入时必须将机床的有关状态信息转换成数字形式，以满足计算机的输入信息要求，输出时应满足机床各种有关执行元件的输入要求。

3) 具有较强的抗干扰能力，提高系统的可靠性。

2. I/O 接口

(1) 输入信号

典型的直流输入信号接口如图 2-12 所示，图中 RV 表示信号接收器。RV 可以是无隔离的滤波和电平转换电路，也可以是光电耦合转换电路。直流输入信号是机床侧的开关、按钮、继电器触点、检测传感器等采集的闭合 / 断开状态信号。这些状态信号需经上述接口电路处理，才能变成 PLC 或 CNC 能够接收的信号。

(2) 输出信号

典型的直流输出信号接口电路如图 2-13 所示。图中 DV 为信号驱动器。直流输出信号来自 CNC 或 PLC，经驱动电路送至 MT 侧以驱动继电器线圈、指示灯等信号。

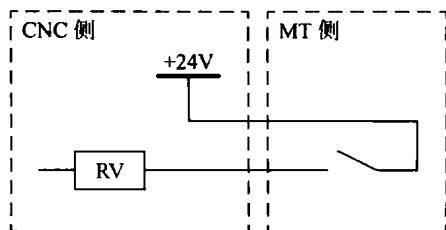


图 2-12 输入信号接口电路

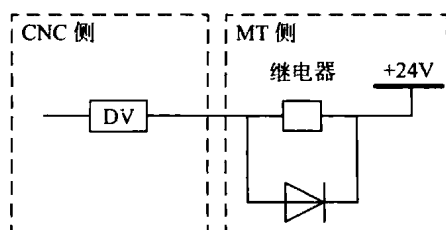


图 2-13 输出信号接口电路

图 2-14 和图 2-15 分别为指示灯和继电器线圈的典型信号输出电路。当 CNC 有信号输出时, DV 基极为高电平, 晶体管导通。此时输出信号状态为“1”, 电流将流过指示灯或继电器线圈, 使指示灯亮或继电器动作。当 CNC 无输出时, 基极为低电平, 晶体管不导通, 输出信号状态为“0”, 不能驱动负载。

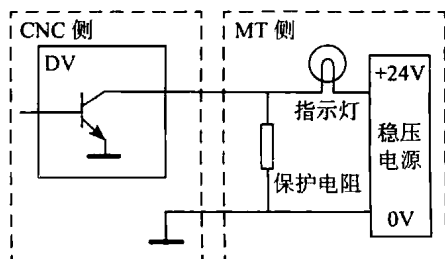


图 2-14 指示灯信号输出电路

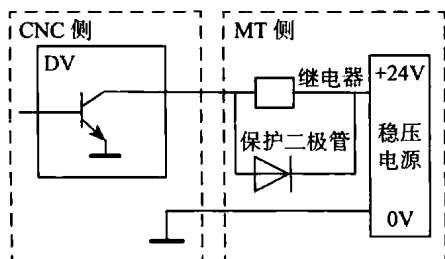


图 2-15 继电器线圈信号输出电路

2.6 典型工业领域的工业控制网络

工业控制系统是工业控制网络的服务对象。一些通过信息技术手段对工业控制系统实施的攻击都是通过工业控制网络完成的, 因此保护好工业控制网络的安全, 就能预防工业控制系统的非法入侵等攻击行为。为此, 有必要了解一些具体行业的工业控制网络。

2.6.1 钢铁行业的工业控制网络

钢铁行业工业以太网一般采用环网结构, 为实时控制网, 负责控制器、操作员站及工程师站之间过程控制数据实时通信, 网络上所有操作员站、数采机及 PLC 都使用以太网接口并设置为同一网段 IP 地址, 网络中远距离传输介质为光缆, 本地传输介质为网线 (如 PLC 与操作员站之间)。生产监控主机利用双网卡结构与管理网相连。图 2-16 是典型钢铁厂网络拓扑图。

- 1) 垂直划分为互联网层、办公网层、监控层、控制层及现场层 (仪表)。
- 2) 水平划分为不同功能区域 (烧结、炼铁、炼钢、轧钢等)。

2.6.2 石化行业的工业控制网络

典型情形下, 现有的炼化厂生产控制系统的网络拓扑图如图 2-17 所示。大型石油化工产业控制系统庞大, 安全要求高, 现场由多个控制系统完成控制功能。大型石油化工工程全厂 DCS 采用大型局域网架构, 网络架构较为复杂。现场的主要控制功能都是由 DCS 来

完成的，其他系统的集中控制在某种程度上可以完全由 DCS 监控。DCS 含有大量的数据接口，是构建企业信息化的数据来源与执行机构。除 DCS 外的其他系统一般对外并没有数据接口（无生产数据），且相对独立，网络结构简单。

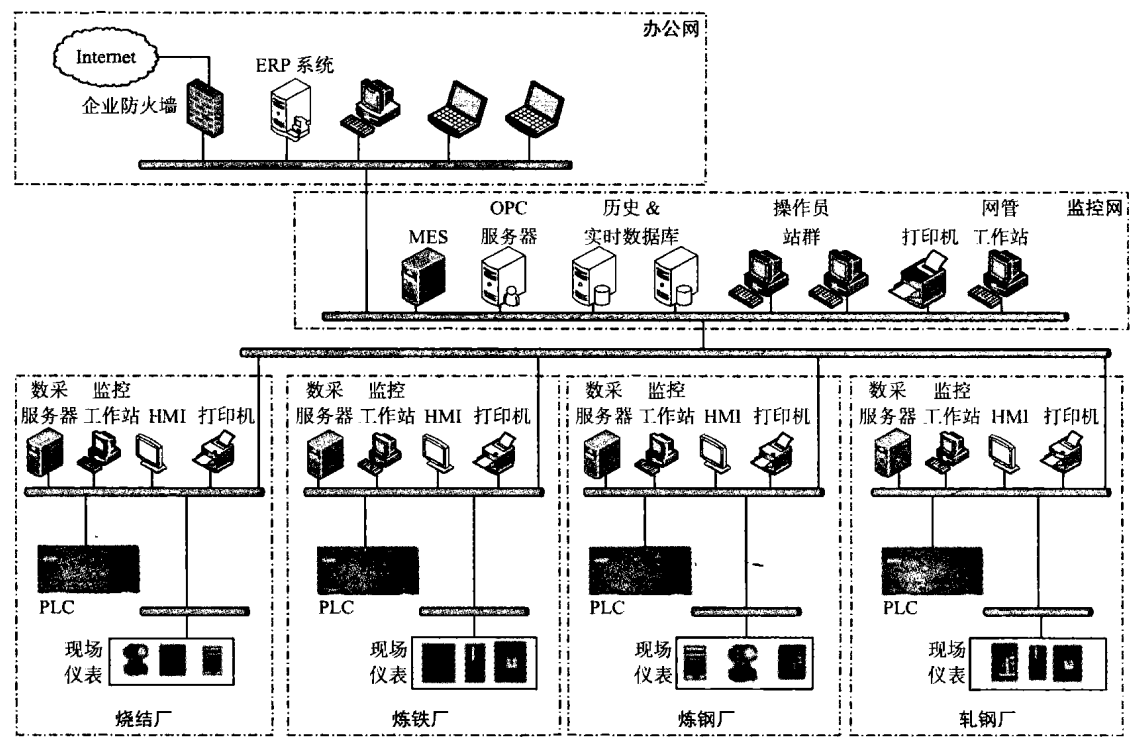


图 2-16 典型钢铁厂网络拓扑图

主要控制系统的功能如下所示。

(1) 分布式控制系统（DCS）

DCS 完成生产装置的基本过程控制、操作、监视、管理、顺序控制、工艺连锁，部分先进过程控制也在 DCS 中完成。大型石油化工工程全厂 DCS 采用大型局域网架构。根据生产需求、系统规模和总图布置划分为若干独立的局域网，确保每套生产装置独立开停车和正常运行。

(2) 安全仪表系统（SIS）

SIS 设置在现场机柜室（FAR），与 DCS 独立设置，以确保人员及生产装置、重要机组和关键设备的安全。SIS 按照故障安全型设计，与 DCS 实时数据通信，在 DCS 操作员站上显示。大型石油化工工程全厂 SIS 采用局域网架构。根据生产需求、系统规模和总图布置划分为若干独立的局域网，确保采用 SIS 的生产装置独立开停车和安全运行。

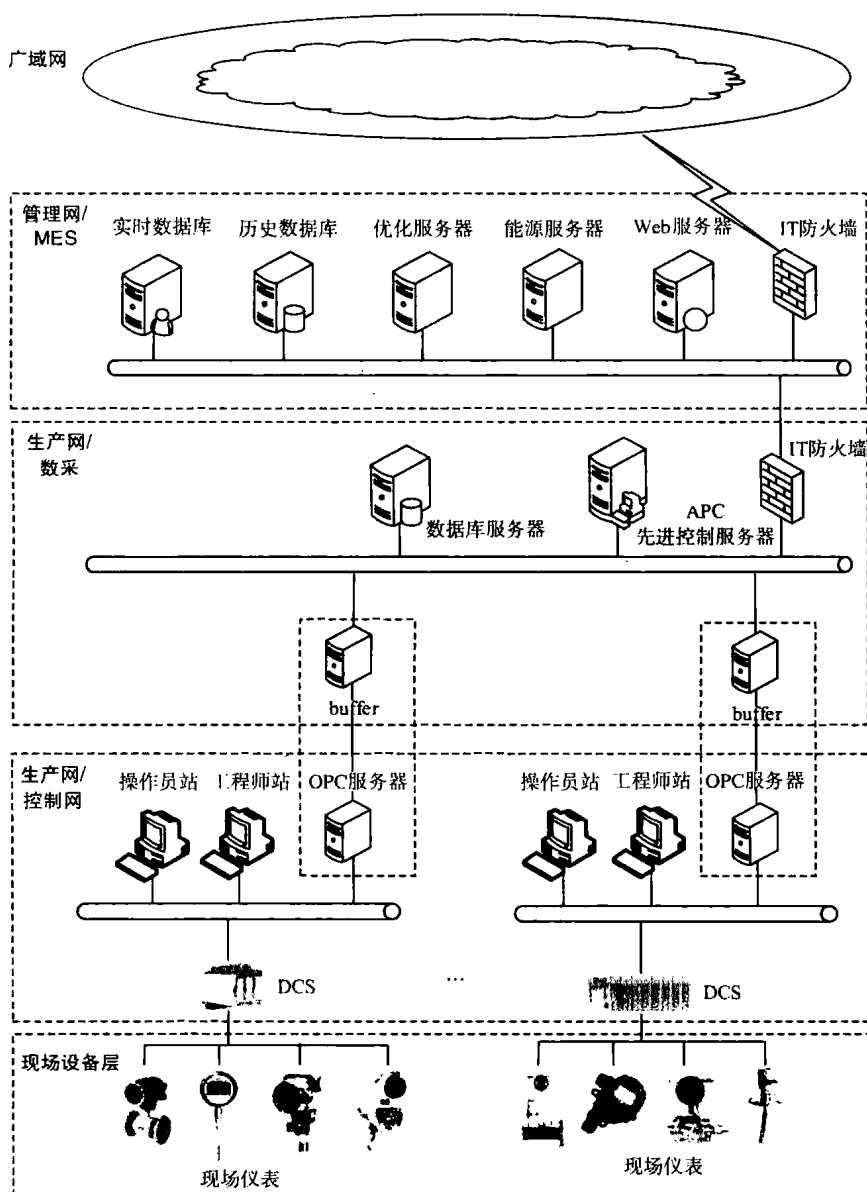


图 2-17 典型炼化厂网络拓扑图

（3）可燃/有毒气体检测系统（GDS）

生产装置、公用工程及辅助设施内可能泄漏或聚集可燃、有毒气体的地方分别设有可燃、有毒气体检测器，并将信号接至 GDS。

（4）压缩机控制系统（CCS）

压缩机控制系统完成压缩机组的调速控制、防喘振控制、负荷控制及安全联锁保护等功能，并与装置的 DCS 进行通信，操作人员能够在 DCS 操作员站上对机组进行监视和操作。

（5）转动设备监视系统（MMS）

MMS 用于主要透平机、压缩机和泵等转动设备参数的在线监视，同时对转动设备的性能进行分析和诊断，对转动设备的故障预测维护进行有力的支持。

（6）可编程逻辑控制系统（PLC）

操作控制相对比较独立或特殊的设备的控制监视和安全保护功能原则上采用独立的 PLC 控制系统。与 DCS 进行数据通信，操作人员能够在 DCS 操作员站上对设备的运行进行监视与操作。

（7）在线分析仪系统（PAS）

在线分析仪（工业色谱仪、红外线分析仪等）应包括采样单元、采样预处理单元、分析器单元、回收或放空单元、微处理器单元、通信接口（网络与串行）、显示器（LCD）单元和打印机等。

2.6.3 电力行业的工业控制网络

大型电厂全厂 DCS 采用大型局域网架构，网络架构较为复杂。以下是 DCS 网络的架构说明。

（1）L1 基础控制层

该层网络完成控制生产过程的功能，主要由工业控制器、数据采集卡件，以及各种过程控制输入输出仪表组成，也包括现场所有的系统间通信。可以本地实现连续控制调节和顺序控制、设备检测和系统测试与自诊断、过程数据采集、信号转换、协议转换等功能。

（2）L2 监控层

该层包含各个分装置的工程师站以及操作员站，可以对生产过程进行生产过程的监控、系统组态的维护、现场智能仪表的管理。事实上，由 L1 和 L2 层就能进行产品的正常生产，但是在大型电厂中，为了实现生产管理智能化以及信息化，通常都会设置 L3 及以上的网路层。

（3）L3 操作管理层（集控 CCR）

DCS 管理层网络通过 L3 级交换机汇聚各分区 L2 层的 LAN。设置全局工程师站可以对分区内所有装置的组态进行维护，查看网络内各装置的监控画面、趋势和报警。L3 层设置的中心 OPC 服务器，可以实现对各装置实时数据的采集。

（4）L4 调度管理层（厂级 SIS）

SIS 是实行生产过程综合优化服务的实时管理和监控系统，它将全厂 DCS、PLC 以及其他计算机过程控制系统（Process Control System, PCS）汇集在一起，并与管理信息系统

(Management Information System, MIS) 有机结合, 在整个电厂内实现资源共用、信息共享, 做到管控一体化。

典型情形下, 现有的火电厂生产控制系统的网络拓扑图如图 2-18 所示。

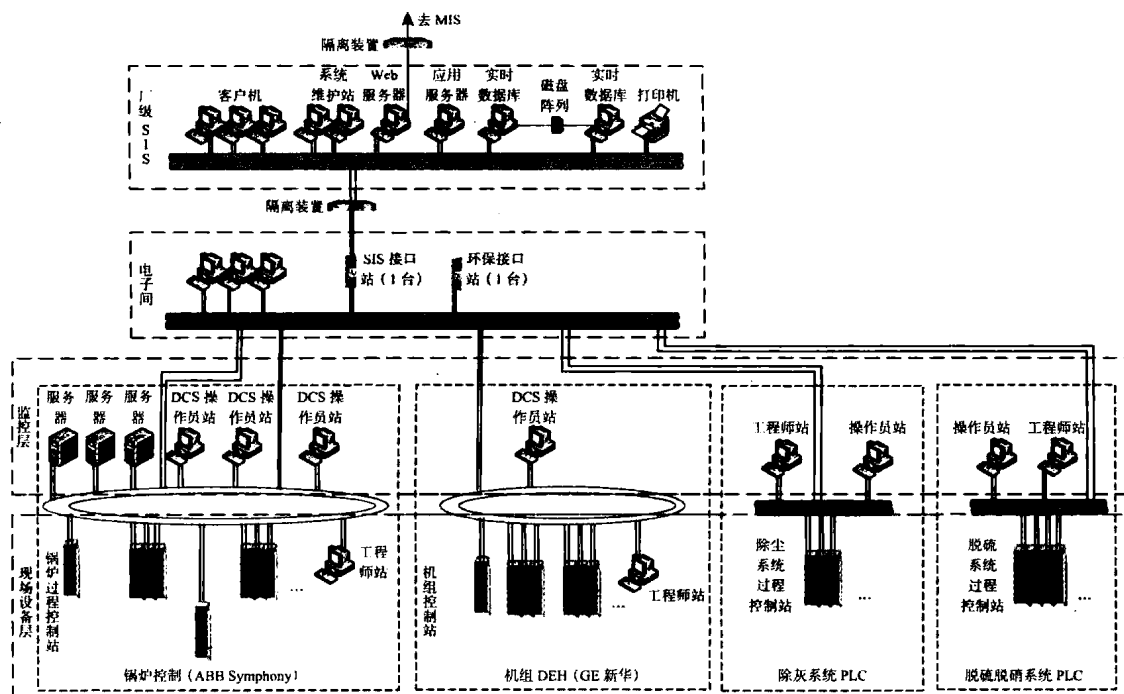


图 2-18 现有的火电厂生产控制系统的网络拓扑图

2.6.4 市政交通行业的工业控制网络

地铁综合监控系统的总体架构如图 2-19 所示。它由中央综合监控系统、车站综合监控系统（包括车辆段综合监控系统）以及将它们连接的综合监控系统骨干网组成。

（1）中央综合监控系统

中央综合监控系统安装在线路监控中心，用于监视全线各个车站（包括车辆段）的各个子系统的运行状态，完成中心级的操作控制功能。中央综合监控系统由中央监控网、OCC（Operating Control Center，运行控制中心）实时服务器、历史和事件服务器、磁盘阵列、磁带记录装置、各类操作员工作站、中心互联系统、UPS、打印机、机柜和附件等部分组成。此外，还有全系统的网络管理系统（NMS）、大屏幕系统（OPS）。

（2）车站综合监控系统

车站级监控网为双冗余高速交换式以太网，数据传输率为 100 Mbit/s 或 1 000 Mbit/s，

遵循 IEEE 802.3 标准、使用 TCP/IP 协议，网络交换机为冗余配置。

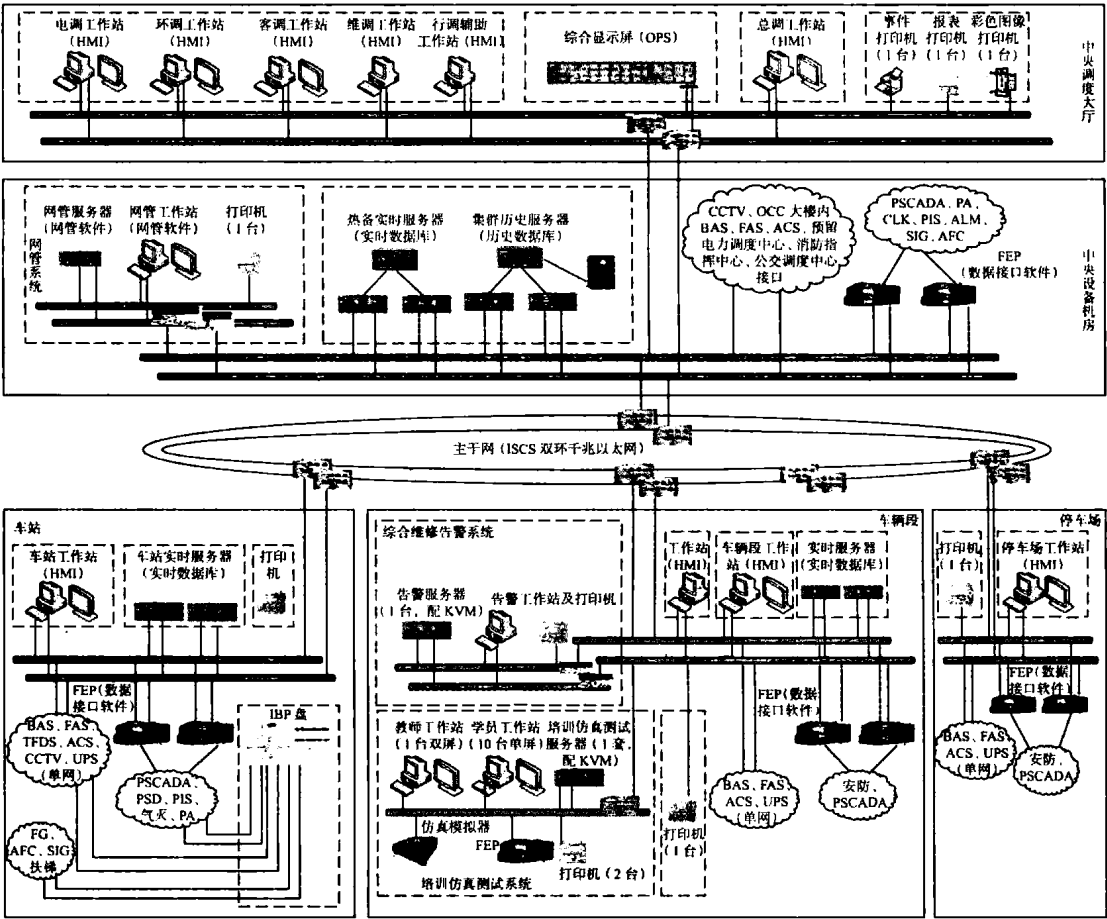


图 2-19 典型的综合监控系统架构图

(3) 综合监控系统骨干网

综合监控系统骨干网 (MBN) 可采用地铁工程通信骨干网的传输信道，也可单独组建骨干网。地铁综合监控系统是一个地理分散的大型 SCADA 系统。它构建在分布于方圆几十千米的广域网上。

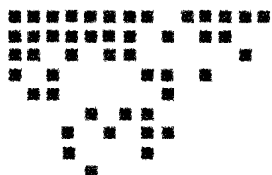
2.7 本章小结

本章主要是关于工业控制系统基础知识的介绍。首先，按照工业控制系统的体系结构，分别介绍了数据采集与监视控制系统、分布式控制系统、控制器以及现场设备。其中控制器包括可编程逻辑控制器、可编程自动化控制器以及远程终端单元，本章对这些控制器在

定义、功能和特点等方面分别进行了介绍。然后，阐述了 PLC 设备的产生与特点、组成与工作原理、基本指令系统、通信技术以及接口技术等。最后，对钢铁、石化、电力、市政交通这几个典型工业领域中的工业控制网络进行了介绍，内容包括整体架构、网络拓扑等。

2.8 本章习题

1. 什么是工业控制系统？工业控制系统应用于哪些行业？
2. SCADA 系统和工业控制系统是什么关系？
3. SCADA 系统的功能是什么？基本架构是什么？
4. DCS 有哪些组成结构？有什么特点？
5. 控制器在工业控制系统中有什么作用？
6. 简述 PLC 的基本组成部分和工作原理。
7. 工业控制系统在不同工业领域中的应用有什么异同？



工业控制网络安全威胁

第 2 章介绍了工业控制系统的相关知识。本章主要介绍工业控制网络的基本知识，并详细介绍工业控制网络的常见安全威胁。之后，分析工业控制系统的脆弱性。

3.1 工业控制网络概述

在两化融合和智能制造的趋势下，利用计算机全自动化采集展示现场数据的方式在工业控制行业中越来越受欢迎——通过利用集成化智能 I/O 单元进行数据采样，产生的实时数据会被操作人员监控和调配，同时还能向工厂管理者提供数据对比，方便其决策分析。这种模式便于合理集中地处理分散的现场数据，但是必须依赖可靠稳定的网络结构。因此合理构建适合工业现场复杂环境的稳定网络是工控系统的重要设计内容。图 3-1 是工业控制网络详细分层图，主要将工业控制网络分为现场总线控制网络、过程控制与监控网络和企业办公网络，以下将分别加以介绍^[20]。

3.1.1 现场总线控制网络

工业控制网络最底层的是现场总线控制网络，包含图 3-1 中的现场控制层和现场设备层，是自动化系统与现场设备相连的唯一网络，是整个控制系统的关键环节。该层网络通常包含 PLC（可编程逻辑控制器）、DCS（分布式控制系统）等现场控制站，以及各种传感器、继电器、电动机、调节阀等现场设备。

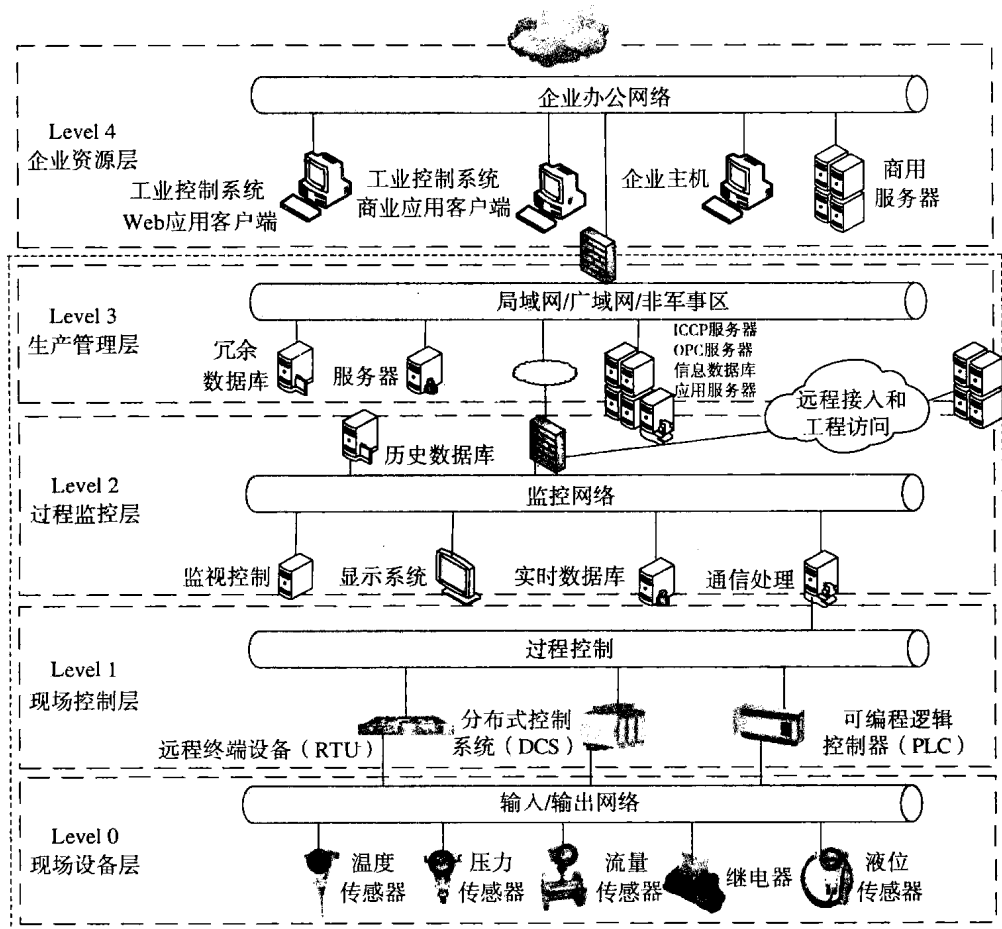


图 3-1 工业控制网络详细分层图

现场总线控制网络利用诸如 PRIFIBUS（过程现场总线）、FF-BUS（基金会现场总线）、CAN-BUS（控制器局域网总线）等现场总线技术将传感器、继电器等现场设备与一些 PLC 控制器或者 RTU 等现场控制设备相连，直接采集现场数据到现场控制站 FCS 或 DCS 或 PLC 控制系统，完成基本的数据采集，提供生产调度的重要数据源。

为保证现场总线控制网络的数据采集的可靠性，该层网络通常采用两重冗余的控制器和双网甚至四网的物理容错方式，同时控制器内置智能故障处理机制，即只要通信链路发生网络故障如数据流拥堵、网卡故障、网线故障，控制器就可智能切换到备用通信链路，确保数据采集不因网络节点故障而中断。

3.1.2 过程控制与监控网络

现场总线控制网络的上一层是过程控制与监控网络层，这一层包含图 3-1 中的生产管

理层和过程监控层。生产管理层主要实现系统管理、监视控制的功能，为上层的企业网络提供数据支持，通常包含一些应用服务器、信息数据库和冗余数据库。过程监控层负责监控、现场监测以及现场数据展示，是现场总线控制网络和企业网络之间数据交互与展示的桥梁，该网络通常内含有 SCADA 服务器、历史数据库、实时数据库以及人机界面等关键工业控制组件。

该层网络负责接收来自现场控制层的数据，现场总线控制网络通过 PLC 控制器处理数据，由远程数据单元 RTU 和 SCADA 服务器 MTU 组成远程传输链路，将数据传输至过程控制与监控网络中的监控设备。系统操作员便可通过操作 HMI 人机界面了解控制系统的运行状态，实时监测 PLC、RTU 以及一些现场设备的运行，并依据进行调整或控制工艺参数，这些监控到的数据信息会传送到历史数据服务器，供以后分析使用，为上层的任务决策提供数据支持。

3.1.3 企业办公网络

最上面一层是企业办公网络层，即图 3-1 中的企业资源层，负责公司日常的商业计划和物流管理、工程系统等，主要涉及企业应用资源，如企业资源配置（ERP）、生产制造执行系统（MES）和办公自动化（OA）等与企业运营息息相关的系统，通常由各种功能的计算机构成。为防止外部网络对生产工况造成不必要的外部干扰，如病毒攻击、木马侵入、人员误操作等外部不利因素，工业企业通常也具有较完备的典型安全边界防护措施，如网络层级连接设备增加的防火墙等。

该层网络根据公司所需功能配置相应的管理软件，每个软件有不同的通信协议，对应不同的物理接口。该层网络通过开放式通信协议从控制网络采集生产数据，通过管理软件自身的功能模块从人力资源、机具配置、材料仓储等角度对控制网络采集到的生产数据进行分类处理，最终形成工厂管理方法和决策数据。

3.2 工业控制网络常见的安全威胁

随着工业信息化进程的快速推进，信息、网络以及物联网技术在智能电网、智能交通、工业生产系统等工业控制领域得到了广泛的应用，极大地提高了企业的综合效益。为实现系统间的协同和信息分享，工业控制系统也逐渐打破了以往的封闭性：采用标准、通用的通信协议及硬软件系统，甚至有些工业控制系统也能以某些方式连接到互联网等公共网络中。这使得工业控制网络面临病毒、木马、黑客入侵等传统的信息安全威胁，本节将从 ATP 攻击、漏洞、病毒等方面介绍工业控制网络常见的安全威胁。

3.2.1 高级持续性威胁攻击

近年来,工控系统广泛互联,逐步同生产管理、ERP系统、电子商务系统等相连,纳入到统一的信息系统中。直接暴露在网络空间的工控设备增多,带来的风险也不断增加。针对工控网络的攻击多为有组织的行为,采用了针对性极强的软件或硬件恶意代码渗透的高级持续性威胁(Advanced Persistent Threat, APT)攻击体系。

APT是一种以商业和政治为目的的网络犯罪类别,通常使用先进的攻击手段对特定目标进行长期持续性的网络攻击,这种攻击不会追求短期的收益或单纯的破坏,而是以步步为营的渗透入侵策略,低调隐蔽地攻击每一个特定目标,不做其他多余的活动来打草惊蛇。APT攻击多针对国家战略基础设施,其攻击目标包括政府、金融、能源、制药、化工、媒体和高科技企业。APT攻击综合多种先进的攻击手段,多方位地对重要目标的基础设施和部门进行持续性攻击,其攻击手段包含各种社会工程攻击方法,常利用重要目标内部人员作为跳板进行攻击,且攻击持续时间和潜伏时间可能长达数年,很难进行有效防范。

APT攻击的主要特征是攻击持续性、信息收集广泛性、针对性、终端性、渗透性、潜伏控制性、隐蔽性与未知性,这些特性使得攻击者利用工控系统的漏洞进行有特定目标和多种方式组合的攻击,从而使传统的防御手段失效,带来更为严重的安全问题。一般来说,APT攻击包含5个阶段,分别为情报收集、突破防线、建立据点、隐秘横向渗透和完成任务^[21],具体过程如图3-2所示。



图3-2 APT攻击各阶段的任务描述

前文提到的伊朗核电站遭到“震网”病毒的攻击就是工控网络遭受到 APT 攻击的典型案例。迄今为止，许多国家或地区都受到过 APT 攻击的威胁。2014 年 12 月，德国联邦信息安全办公室（BSI）发布了一份 2014 年信息安全报告，公布了德国一家钢铁厂遭受高级持续性威胁（APT）网络攻击并造成重大物理伤害。攻击者使用鱼叉式钓鱼邮件和社会工程手段，获得钢铁厂办公网络的访问权，然后利用这个网络，设法进入钢铁厂的生产网络。攻击者的行为导致工控系统的控制组件和整个生产线被迫停止运转，由于不是正常关闭炼钢炉，从而给钢铁厂带来了重大的破坏。

表 3-1 列举了近年来影响较大的 APT 攻击事件。

表 3-1 典型 APT 攻击事件			
时间	名称	目标	重要影响或显著特征
2010 年 6 月	震网（Stuxnet）	中东能源行业	- 使用可移动设备实现“摆渡”攻击 - 攻击物理设备 - 使用了 5 个微软漏洞
2011 年 9 月	Duqu	中东和欧洲能源行业	- 大量重用 Stuxnet 代码 - 利用微软零日漏洞 - 利用 C-Media 公司的数字签名
2012 年 5 月	Flame	中东能源行业	- 创建屏幕快照 ~ - 使用麦克风收集信息 - 通过 SSH 和 HTTPS 建立安全连接 - 加密压缩窃取数据
2013 年 2 月	SCASEF	美国军方的供应链厂商	- 专业提供 APT 攻击服务的组织操作 - 固件后门 - 供应链攻击
2013 年 9 月	Icefog	日本、韩国	- 使用匿名网络 - 针对 Windows 和 Mac OS X - 使用直接受攻击者控制的交互式工具
2014 年	海莲花（OceanLotus）	中国海域	- 对国内某海洋建设机构的官方网站进行了篡改和挂马，形成了第一轮规模较大的水坑攻击 - 向中国渔业资源相关机构团体发起鱼叉攻击 - 利用更具攻击性和隐蔽性的云控木马发动攻击
2015 年	BlackEnergy	乌克兰	通过 Excel、Word 宏病毒进行攻击

3.2.2 工业控制网络病毒

在信息技术与传统工业融合的过程中，工业控制正面临越来越多的网络安全威胁，其中工控网络病毒就是主要的威胁之一，据统计，在 2014 年的网络安全事件中，因病毒事件造成的工控系统停机的企业高达 19.1%。

以下是近年来活跃在工控领域的病毒介绍。

1. 震网 (Stuxnet) 病毒

2010 年 10 月, 国内外多家媒体相继报道了 Stuxnet 蠕虫病毒对数据采集与监视控制系统进行攻击的事件, 并称其为“超级病毒”、“超级工厂病毒”, 并形容成“超级武器”、“潘多拉的魔盒”。

Stuxnet 病毒在 2010 年 7 月开始爆发。它利用了微软操作系统中至少 4 个漏洞, 伪造驱动程序的数字签名; 通过一套完整的入侵和传播流程, 突破工业专用局域网的物理限制; 利用 WinCC 系统的两个漏洞, 对其开展破坏性攻击。它是第一个直接破坏现实世界中工业基础设施的恶意代码。

伊朗政府已经确认该国的布什尔核电站遭到 Stuxnet 蠕虫病毒的攻击。该病毒利用了 USB 使用上的管理漏洞渗透进入目标系统, 从而修改西门子控制器所连接的变频器, 攻击者通过检测变频器的工作状态, 改变了变频器的工作参数, 欺骗控制中心, 使得离心机无法正常工作。

2. Duqu 病毒

Duqu 是一种复杂的木马病毒。2011 年 10 月 14 日, 卡巴斯基实验室提取了一个看上去与 Stuxnet 非常类似的病毒样本, 它们创建文件都以“~ DQ”作为文件名的前缀, 便将这个威胁命名为“Duqu”。它的主要目的是为私密信息的盗取提供便利, 主要攻击目标是伊朗工业控制系统, 目的是盗窃信息, 手法包括收集密码、抓取桌面截图、暗中监视用户操作、盗取各类文件等。

Duqu 架构所使用的语言高度专业化, 能够让有效负荷 DLL 同其他 Duqu 模块独立, 通过多种途径包括 Windows HTTP、网络端口和代理服务器同 C&C 建立连接; 还能够让有效负荷 DLL 直接处理来自 C&C 的 HTTP 服务器请求, 甚至可以在网络中的其他计算机上传播辅助恶意代码, 实现可控制并且隐蔽的感染手段, 殃及其他计算机^[22]。

3. “火焰”病毒

2012 年 5 月, 俄罗斯安全专家发现一种威力强大的计算机病毒“火焰”(Flame) 在中东地区大范围传播。“火焰”病毒最早可能于 2010 年 3 月就被攻击者放出, 但一直未被其他网络安全公司发现。除卡巴斯基外, 匈牙利的两家反计算机病毒实验室和伊朗反计算机病毒机构也发现了上述全新的蠕虫病毒。

Flame 病毒是由许多独立模块组成的非常大的攻击工具包。它能执行各种恶意行为, 其中大部分与数据窃取和网络间谍有关。除此之外, 它还能使用计算机扩音器来录下对话, 提取应用程序细节的截屏, 探测网络流量, 并能与附近的蓝牙设备进行交流。当感染被反

病毒程序保护的计算机时，Flame 会停止进行某种行动或执行恶意代码，隐藏自身，以待下次攻击。

4. Havex 病毒

Havex 病毒的发现来源于网络安全公司 CrowdStrike 的报告。Havex 病毒通过垃圾邮件、漏洞利用工具、木马植入等方式感染 SCADA 系统和工控系统中使用的工业控制软件，主要攻击对象是欧洲的许多使用和开发工业应用程序和机械设备的公司，影响了水电、核电、能源在内的多个行业。这种木马有可能做到禁用水电大坝，使核电站过载，甚至可以做到按一下键盘就能关闭一个国家的电网。

Havex 被命名为 W32/Havex.A，存在超过 88 个变种，其通信用的 C&C 服务器多达 146 个，并且有 1500 多个 IP 地址向 C&C 服务器通信。Havex 利用 OPC DA 协议来收集网络和联网设备的信息，然后将这些信息反馈到 C&C 服务器上，其通信行为如图 3-3 所示。OPC DA 是一种基于 Windows 操作系统的 DCOM 通信扩展的应用标准，它允许基于 Windows 的 SCADA 应用与过程控制硬件进行交互。

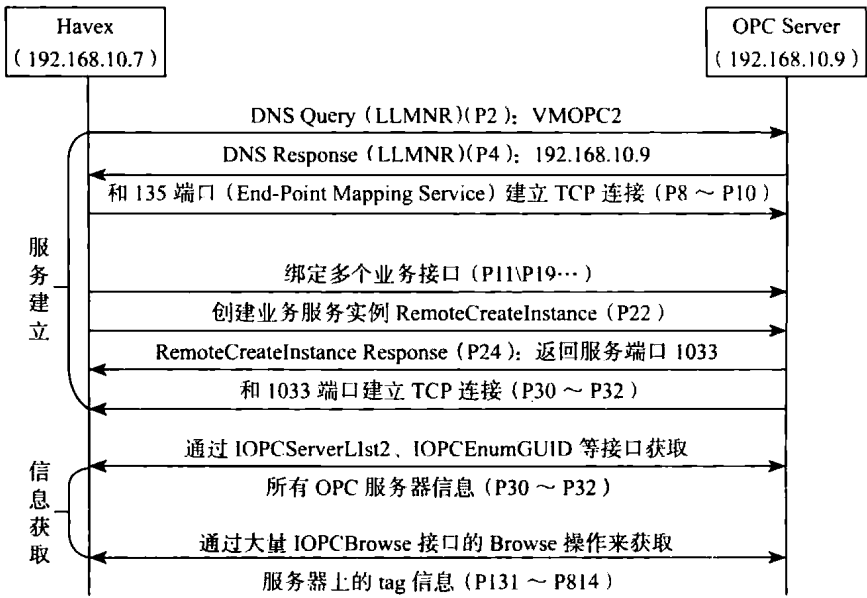


图 3-3 Havax 病毒的通信行为

5. Sandworm 病毒

国外厂商 iSIGHT Partners 2014 年 10 月 14 日发布公告称发现了 Sandworm（沙虫）漏洞。Sandworm 病毒利用的漏洞几乎影响所有微软 Windows Vista 以上装有 Microsoft Office

软件的主机操作系统，通俗地说，这类攻击是通过发送附件文档的方式发起的，受害者只要打开文档就会自动中招，也就是只要计算机中安装了 Microsoft Office 软件，都有可能受到该漏洞的影响，轻则信息遭到窃取，严重的则成为高级可持续威胁的攻击跳板。该漏洞还具有绕开常见的杀毒软件的特点，漏洞风险性较高。

TrendMicro 报告发现 Sandworm 病毒发起后续攻击的恶意载荷包含了对工控企业的人机界面软件的攻击（主要是 GE Cimplicity HMI），目的是进一步控制 HMI，并且放置木马。该攻击利用了 GE Cimplicity HMI 软件的一个漏洞，打开攻击者恶意构造的 .cim 或者 .bcl 文件，允许在用户机器上执行任意代码，以及安装木马文件 .cim 或者 .bcl 文件。

6. 格盘病毒

2014 年 12 月，一名黑客通过 Twitter 向韩国水电与核电公司发出严重警告，要求官方立即停止运行核电站，同时黑客还公开了包括两座核电站部分设计图在内的 4 份压缩档案。这次事件中所用的木马是格盘病毒——MBR Wiper。

格盘病毒通过发送钓鱼邮件，使用大量的社会工程学诱使受害者打开这些文件，从而感染病毒。格盘病毒分为两部分，一部分是系统的感染程序，另一部分是 MBR 区的改写程序。系统感染程序结束用户系统指定进程，删除注册表中“安全模式”相关的项，使系统无法进入安全模式，同时进行映像劫持，在用户执行被劫持的程序时，会运行指定的程序。感染程序还能篡改系统文件，关闭 Windows 系统文件保护，同时查找安全软件进程，运行后删除自身，利用输入法机制，注入文件到指定进程。MBR 区的改写程序主要修改磁盘 MBR，该手法常被病毒用于获取更早的控制权，同时查找安全软件进程并终止，最后提升系统权限，查找指定进程，启动指定服务。

7. “方程式”组织病毒库

作为破坏力强大的网络攻击组织，“方程式”拥有一个庞大而强悍的攻击武器库。传统的病毒往往是单兵作战，攻击手段单一，传播途径有限，而“方程式”动用了多种病毒工具协同作战，发动全方位立体进攻，其影响行业包括工业、军事、能源、通信、金融、政府等基础设施和重要机构。

“方程式”组织病毒在攻击时，首先诱使用户点击某个网站链接，当用户上当点击后，病毒就会被下载到用户计算机或 iPhone、iPad 等手持设备上。然后，病毒会将自己隐藏到计算机硬盘之中，并将自己的藏身之处设置为不可读，避免被杀毒软件探测到。隐藏起来的病毒就是“方程式”攻击的核心程序——Grayfish，这是一个攻击平台，其他攻击武器都通过该程序展开。它会释放另一些程序以收集用户的密码等信息，发送回 Grayfish 存储起来。同时，病毒也会通过网络和 USB 接口传播。病毒修改了计算机和手持设备的驱动程

序，一旦探测到有 U 盘插入，病毒就会自动传染到 U 盘上，并且同样把自己隐藏起来。当 U 盘又被插入到另一个网络时，如一个与外界隔离的工业控制网络，病毒就被引入到那个网络，并逐步传遍整个网络。

以上攻击方式中，尤其值得一提的是“方程式”开创了入侵硬盘的病毒技术。当它感染用户计算机后，会修改计算机硬盘的固件程序，在硬盘扇区中开辟一块区域，将自己存储于此，并将这块区域标记为不可读。这样，无论是操作系统重装，还是硬盘格式化，都无法触及这块区域，因此也就无法删除病毒。只要硬盘仍在使用，病毒就可以永远存活下去，并感染其所在的网络以及任何插入该计算机的 U 盘。

“方程式”组织的武器库中的 Fanny 蠕虫创建于 2008 年，它利用 USB 设备传播蠕虫，可攻击物理隔离网络并回传收集到的信息。

“方程式”组织的武器库中的 DoubleFantasy 是攻击前导组件，它用来确认被攻击目标，如果被攻击的目标“方程式”组织感兴趣，那么就会从远端注入更复杂的其他组件。DoubleFantasy 会检测 13 种安全软件，包括瑞星（Rising）和 360。鉴于 360 安全卫士和瑞星的用户均在中国，这也进一步验证了中国是“方程式”组织的攻击目标之一。

“方程式”组织的病毒家族如表 3-2 所示。

表 3-2 “方程式”组织病毒家族分析

组件名称	说明	时间
EquationLaser	“方程式”组织早期使用的植入程序，大约在 2001 至 2004 年间被使用，兼容 Windows 95/98 系统	2001 ~ 2003
EquationDrug	方程式组织使用的一个非常复杂的攻击组件，用于支持能够被攻击者动态上传和卸载的模块插件系统，怀疑是 EquationLaser 的升级版	2003 ~ 2013
DoubleFantasy	一个验证式的木马，旨在确定目标为预期目标。如果目标被确认，那么已植入恶意代码会升级到一个更为复杂的平台，如 EquationDrug 或 GrayFish	2004 ~ 2012
Fanny	创建于 2008 年的利用 USB 设备进行传播的蠕虫，可攻击物理隔离网络并回传收集到的信息。Fanny 被用于收集位于中东和亚洲的目标的信息。一些受害主机似乎已被升级到 DoubleFantasy，然后又升级为 EquationDrug。Fanny 利用了两个后来被应用到 Stuxnet 中的 Oday 漏洞	2008 ~ 2011
GrayFish	“方程式”组织中最复杂的攻击组件，完全驻留在注册表中，依靠 bootkit 在操作系统启动时执行	2008 年至今
TripleFantasy	全功能的后门程序，有时用于配合 GrayFish 使用。看起来像是 DoubleFantasy 的升级版，可能是更新的验证式插件	2012 年至今

8. 黑暗能量（BlackEnergy）黑客工具

BlackEnergy 是一款自动化的网络攻击工具，出现于 2007 年，2010 年已经添加到病毒样本库，主要影响行业是电力、军事、通信、政府等基础设施和重要机构。BlackEnergy 被各种犯罪团伙使用多年。其客户端采用了插件的方式进行扩展，第三方开发者可以通过增

加插件针对攻击目标进行组合，实现更多攻击能力，例如，有些人利用它发送垃圾邮件，另一些人用它来盗取银行凭证。BlackEnergy 工具带有一个构建器（builder）应用程序，可生成感染受害者机器的客户端。同时该工具还配备了服务器脚本，用于构建命令及控制（C&C）服务器。这些脚本也提供了一个接口，攻击者可以通过它控制“僵尸机”。该工具有简单易用的特点，意味着任何人只要能接触到这个工具，就可以利用它来构建自己的“僵尸”网络。

以乌克兰电网受攻击事件为例，该病毒的攻击者在微软 Office 文件（一个 .xls 文档）中嵌入了恶意宏文件，并以此作为感染载体来对目标系统进行感染。攻击者通过钓鱼邮件的方式，将恶意文档以附件形式发送到目标用户，目标用户在接收到这封含有恶意文件的钓鱼邮件之后，系统就会被病毒感染。攻击者将该邮件的发送地址进行了伪装，使用户认为这些邮件来自于合法渠道。在恶意文件中还包含一些文字信息，这样才能欺骗用户来运行文档中的宏。

如果攻击者成功地欺骗了目标用户，那么他们的计算机系统将会感染 BlackEnergy 恶意程序，再通过 BlackEnergy 释放出具有破坏性的 KillDisk 组件和 SSH 后门。KillDisk 插件能够破坏计算机硬盘驱动器中的核心代码，并删除指定的系统文件。利用 SSH 后门黑客可通过一个预留的密码（passDs5Bu9Te7）来远程访问并控制电力系统的运行，最终通过执行 shutdown 命令关机，此时系统遭到严重破坏，关机之后已经无法重启，导致电力系统无法恢复运行，致使出现大面积的断电事件。

除了以上提到的工控网络病毒之外，造成重大影响的著名工控网络病毒还有以下几种。

- 红色十月（Red October）病毒。
- 沙蒙（Shamoon）病毒。
- 雷因（Regin）病毒。
- 剁肉刀（Cleaver）系列病毒。

3.2.3 工业控制网络协议安全漏洞

工控网络有很多特定的协议，但是特定的行业通常仅使用其中的一种或几种特定的协议，很多企业也有专用的协议，如表 3-3 和表 3-4 所示。

表 3-3 行业专用协议

行业	细分	协议
电力	变电站自动化	Modbus、Profibus、DNP3、IEC 60870-5-101/104、ICCP（IEC 60870-6、TASE.2）、IEC 61850
	调度自动化	

(续)

行业	细分	协议
油气	油气管线、油气井	Modbus、Profibus、DNP3、MOXA NPORT 系列专用协议
	供电、供暖、供气	
市政	交通	MOXA NPORT 系列专用协议、ilon_Smartserver
	供水、水处理	Modbus、Profibus、DNP3、GE-SRTP
其他	轧钢	GE-SRTP
	楼宇控制系统（如照明、安保、消防系统）	Bacnet、Profibus、Tridium Niagara Fox 专用协议、MOXA NPORT 系列专用协议
	重电设备、卫星、防御系统、电梯及自动扶梯、汽车用电子产品、空调、通风设备	MELSEC-Q
	家庭智能化	ilon_Smartserver
	工矿自动化	proconos 协议

表 3-4 部分厂商的 PLC 以太网通信模块及其专用协议

厂商	产品	端口	协议
AB（罗克韦尔）	Control logix	TCP/44818	EtherNet/IP
	Compact logix	TCP/44818	EtherNet/IP
General Electric（通用电气）	RX3i	TCP/18245	GE SRTP
Mitsubishi Electric（三菱电机）	Q Series	TCP/5007	MELSOFT protocol
		UDP/5006	MELSOFT protocol
OPTO 22（奥普图）		TCP/44818	EtherNet/IP
OMRON（欧姆龙）	CJ2	TCP/2001	OPTO 22 EtherNet
		TCP/44818	EtherNet/IP
		TCP/9600	OMRON FINS
Schneider Electric（施耐德）	Quantum	TCP/502	Modbus/TCP
Siemens（西门子）	S7 Series	TCP/102	ISO-TSAP
MOXA（摩莎）	Nport	TCP/4800	MOXA NPORT 系列专用协议
ECHELON 公司	iLon_SmartServer	TCP/1628	iLon_SmartServer 专用协议
RedLion Controls（红狮控制系统制造公司）	Crimson3	TCP/789	Crimson3
KW-Software GmbH（德国科维公司）	ProConOs	TCP/20547	ProConOs 专用协议

协议最初设计的时候，为了兼顾工控系统通信的实时性，很多都忽略了协议通信的机密性、可认证性等在当时看起来不必要的附加功能。但是随着工控系统与信息网络的联系日益密切，工控协议的漏洞容易被有攻击意图的黑客所利用。传统观念认为工业内网与互联网物理隔离，所以几乎所有的现场总线协议都是明码通信，虽然明码通信方便设备之间交换数据，快速便捷，但是带来的安全问题也很多。

3.3 工业控制系统脆弱性分析

工业控制系统（ICS）与传统信息系统（IT）存在着巨大的区别，最鲜明的一个特点即

ICS 与 IT 对信息安全“CIA”三性的关注度不同。IT 系统更看重信息的机密性，而 ICS 为了保证工业过程的可靠、稳定，对可用性的要求达到了极高的程度。在 ICS 中，系统的可用性直接影响的是企业的生产，生产线的停机、简单的误操作都有可能造成不可估量的经济损失，在特定的环境下，甚至可能危害人员生命，造成环境污染。因此，工控系统的脆弱性是与生俱来的，每一年新公开的工控系统漏洞数量居高不下。在“两化融合”、“工业 4.0”的背景下，多种技术的融合会给工控安全带来“阵痛”，工控安全事件的频发也会给人们敲响警钟。

3.3.1 现场总线控制网络脆弱性分析

现场总线控制网络利用总线技术（如 Profibus 等）将传感器 / 计数器等设备与 PLC 以及其他控制器相连，PLC 或者 RTU 可以自行处理一些简单的逻辑程序，不需要主系统的介入即能完成现场的大部分控制功能和数据采集功能，如控制流量和温度或者读取传感器数据，使得信息处理工作实现了现场化。

现场总线控制网络由于通常处于作业现场，因此环境复杂，部分控制系统网络采用各种接入技术作为现有网络的延伸，如无线和微波，这也将引入一定的安全风险。同时 PLC 等现场设备在现场维护时，也可能因不安全的串口连接（如缺乏连接认证）或缺乏有效的配置核查，而造成 PLC 设备运行参数被篡改，从而对整个工业控制系统的运行造成危害（如伊朗核电站离心机转速参数被篡改造成的危害）。该网络包含了大量的工控设备，设备存在大量工控安全漏洞如 PLC 漏洞、DCS 系统漏洞等，同时在该网络内传输的工业控制系统数据没有进行加密，因此存在被篡改和泄露的威胁；也缺少工控网络安全审计与检测及入侵防御的措施，容易对该网络内的设备和系统数据造成破坏。

由于现场总线控制网络实时性要求及工业控制系统通信协议私有性的局限，在这些访问过程中多数情况并未能实现基本访问控制及认证机制，即使在企业办公网络与监控网络之间存在物理隔离设备（如防火墙、网闸等），仍然存在因策略配置不当而被穿透的问题。

3.3.2 过程控制与监控网络脆弱性分析

过程控制与监控网络中主要部署 SCADA 服务器、历史数据库、实时数据库以及人机界面等关键工业控制系统组件。在这个网络中，系统操作人员可以通过 HMI 界面、SCADA 系统及其他远程控制设备，对现场控制系统网络中的远程终端单元（RTU）、现场总线的控制和采集设备（PLC 或者 RTU）的运行状态进行监控、评估、分析；并依据运行状况对 PLC 或 RTU 进行调整或控制。监控网络负责工业控制系统的管控，其重要性不言而喻。对

现场设备的远程无线控制、监控网络设备维护工作及需要合作伙伴协同等现实需求，在监控网络中就需要考虑相应的安全威胁：

1) 不安全的移动维护设备（比如笔记本电脑、移动 U 盘等）的未授权接入，而造成木马、病毒等恶意代码在网络中的传播。

2) 监控网络与 RTU/PLC 之间不安全的无线通信，可能被利用以攻击工业控制系统。《工业控制系统的安全性研究报告》给出了一个典型的利用无线通信进行入侵攻击的攻击场景。因合作的需要，工业控制网络有可能存在外联的第三方合作网络并且在网络之间存在重要的数据信息交换。虽然这些网络之间存在一定的隔离及访问控制策略，但日新月异的新型攻击技术也可能造成这些防护措施的失效，因此来自合作网络的安全威胁也是不容忽视的。

3) 以 SCADA 系统为例，该系统的现场设备层和过程控制层主要使用现场总线协议和工业以太网协议。现场总线协议在设计时大多没有考虑安全因素，缺少认证、授权和加密机制，数据与控制系统以明文方式传递，工业以太网协议也只是对控制协议进行简单封装，如 CIP 封装为 EtherNet/IP，Modbus 封装为 Modbus/TCP，一些协议的设计给攻击者提供了收集 SCADA 系统信息、发动拒绝服务攻击的条件，而在协议实现中，常常又在处理有效 / 无效的格式化消息等方面存在缺陷。

3.3.3 企业办公网络脆弱性分析

随着国家工业化和信息化两化融合深入推进，传统信息技术广泛应用到工业生产的各个环节，信息化成为工业企业经营管理的常规手段。信息化进程和工业化进程不再相互独立进行，不再是单方的带动和促进关系，而是两者在技术、产品、管理等各个层面相互交融，彼此不可分割，传统 IT 在工业控制系统的广泛应用也势必会给工业控制系统引入更多的安全风险。“震网”、“Duqu”、“火焰”等针对工控系统的网络病毒渐渐为人们所知，工业控制网络安全越来越受到各方的关注。对工业用户而言，其根深蒂固的“物理隔离即绝对安全”的理念正在被慢慢颠覆。

在石油、化工企业中，随着 ERP、CRM 以及 OA 等传统信息系统的广泛使用，工业控制网络和企业网管理的联系越来越紧密，企业在提高公司运营效率、降低企业维护成本的同时，也随之带来了更多的安全问题。

1. 信息资产自身漏洞的脆弱性

随着 TCP/IP 协议、OPC 协议、PC 和 Windows 操作系统等通用技术和通用软硬件产品被广泛地用于石油、化工等工业控制系统，随之而来的通信协议漏洞、设备漏洞以及应用软件漏洞问题日益突出。2010 年发生的伊朗核电站“震网病毒”事件，就是同时利用了工

控系统、Windows 系统的多个漏洞。事件发生之后，大量高风险未公开漏洞通过地下经济出卖或被某些国家 / 组织高价收购，并被利用来开发 Oday 攻击或高级持久威胁（Advanced Persistent Threat, APT）的攻击技术，为未来可能的网络对抗做准备。因此，现有高风险漏洞以及 Oday 漏洞的新型攻击已经成为网络空间安全防护的新挑战，而涉及国计民生的石油、石化、电力、交通、市政等行业的国家关键基础设施及其工业控制系统，在工业化和信息化日益融合的今天，将极大可能成为未来网络战的重要攻击目标。

2. 网络互连给系统带来的脆弱性

根据风险敏感程度和企业应用场景的不同，企业办公网络可能存在与外部互联网通信的边界；而企业办公网络信息系统的通信需求主要来自用户请求，多用户、多种应用带来了大量不规律的流量，也导致了不同应用环境下通信流量的难以预测。一旦存在互联网通信，就可能存在来自互联网的安全威胁，例如，来自互联网的网络攻击、僵尸木马、病毒、拒绝服务攻击、未授权的非法访问等。这时通常就需要具有较完备的安全边界防护措施，如防火墙、严格的身份认证及准入控制机制等。

3. 内部管理机制缺失带来的脆弱性

工业控制系统的监控及采集数据也需要被企业内部的系统或人员访问或进行数据处理。这样在企业办公网络与工业控制系统的监控网络，甚至现场网络（总线层）之间就存在信息访问路径。由于工业控制系统通信协议的局限，在这些访问过程中多数情况并未能实现基本访问控制及认证机制，也同时存在设备随意接入、非授权访问、越权访问等多种风险。

4. 缺乏安全意识带来的脆弱性

由于工业控制系统不像互联网或与传统企业 IT 网络那样备受黑客的关注，在 2010 年“震网”事件发生之前很少有黑客攻击工业控制网络的事件发生。工业控制系统在设计时也多考虑系统的可用性，普遍对安全性问题的考虑不足，更不用提制定完善的工业控制系统安全政策、管理制度以及对人员的安全意识培养了。“和平日久”造成人员的安全意识淡薄。而随着工控系统在国计民生中的重要性日益提高，以及 IT 通用协议和系统在工控系统的逐渐应用，人员安全意识薄弱将是造成工业控制系统安全风险的一个重要因素，特别是社会工程学相关的定向钓鱼攻击可能使重要岗位人员沦为外部威胁入侵的跳板。

3.4 本章小结

本章首先介绍了工业控制网络的基本结构，从现场总线控制网络、过程控制与监控网

络和企业办公网络三个层面描述了各部分网络的控制组件、网络设备、基本功能和运作机制。其次，系统地分析了工业控制系统面临的安全问题，分别从 APT 攻击、工业控制网络病毒和工业控制网络协议安全漏洞等方面介绍了工控系统常见的安全威胁。最后，结合当前工业控制系统常见的三种网络（现场总线控制网络、过程控制与监控网络和企业办公网络），从不同层面说明了工控系统的脆弱性，分析了现场总线控制网络、过程控制与监控网络和企业办公网络存在的安全弱点。

3.5 本章习题

1. 在工控网络安全事故调查取证方面，常用的技术手段是什么？
2. 工控系统遭受攻击可以造成哪些方面的不良影响？
3. 工控系统的最主要攻击手段是什么？
4. 根据对工控系统典型攻击事件的了解，谈谈你对工控系统安全事件的看法。



SCADA 系统安全分析

SCADA 系统是一种分布范围广、现场站点（Field Site）分散的工业控制系统，广泛部署于智能电网输配电、油气长输管道、市政管网供水、污水处理、轨道交通等领域，实现对关键基础设施的数据采集与监视控制。SCADA 系统的安全性受到越来越广泛的关注和重视。本章首先对 SCADA 系统的安全需求、安全目标和脆弱性进行分析，然后介绍保障 SCADA 安全的安全域划分及边界防护、系统异常行为检测技术、系统安全通信及密钥管理、系统风险评估与安全管理等关键技术，接着介绍 SCADA 安全测试平台的意义、分类和典型案例，最后以电力 SCADA 系统说明 SCADA 系统安全的重要性。

4.1 SCADA 系统安全概述

本节首先介绍 SCADA 系统的 3 个主要组成网络的主要功能，然后通过对比传统信息网络分析 SCADA 系统的安全需求和安全目标，最后详细分析 SCADA 系统存在的 6 种主要脆弱性。

4.1.1 SCADA 系统的组成

SCADA 系统主要由现场网络（Field Network）、控制网络（Control Network）和通信网络（Communication Network）三部分组成，如图 4-1 所示。

现场网络主要是指分布在远端被监视和控制的远程站点，通过传感器等设备采集信息

并发送给控制网络，从控制网络接收控制指令并通过执行器对开关、阀门等现场设备进行操作。远程终端设备（RTU）为传感器和执行器提供通信接口，与通信网络进行数据和指令交换。为了降低网络通信的代价和控制网络主站处理数据的负担，目前的 RTU 也承担局部数据处理功能。在一些工控应用中，可编程逻辑控制器（PLC）承担 RTU 功能，除了提供基本的数据通信接口，还实现过程控制回路。

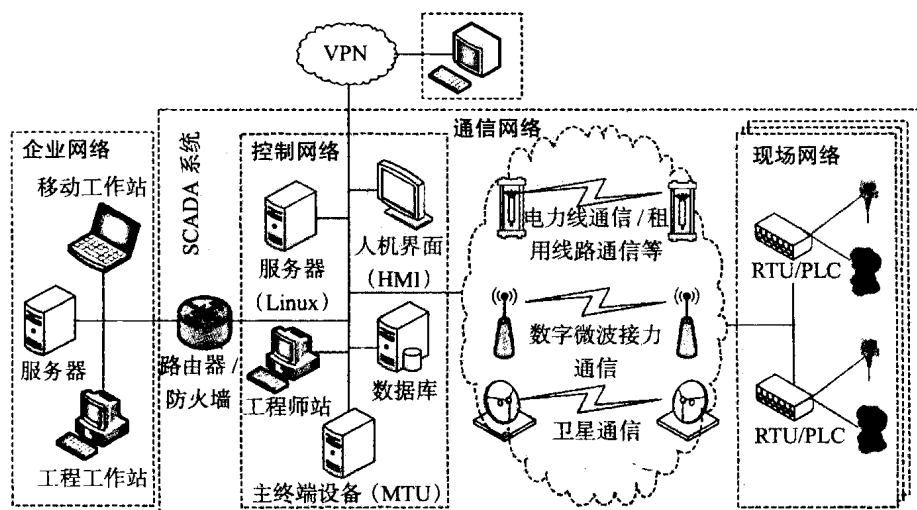


图 4-1 SCADA 系统结构

控制网络由主终端设备（Master Terminal Unit, MTU）、人机界面（HMI）、工程师站、操作员站、历史数据库等组成。MTU 集中接收和处理各个区域现场网络采集的数据，并向现场网络发送控制指令。HMI 提供监视控制及数据采集用户界面，允许操作人员监控现场设备的过程状态，修改控制设置以更改控制目标，并在发生紧急情况时采取手动代替自动控制操作，如图 4-2 所示。HMI 还允许控制工程师或操作员配置控制器中的设置点或控制算法和参数，向操作员、管理员、经理、业务伙伴和其他授权用户显示过程状态信息、历史信息、报告和其他信息。

通信网络连接控制网络和现场网络，负责传输采集数据和控制指令。由于 SCADA 的现场网络通常分散在数万平方公里的范围内，与分布式控制系统（DCS）、过程控制系统（Process Control System, PCS）相比分布更为广泛，SCADA 综合采集采用电力线通信、租用线路通信、卫星通信、数字微波接力通信等广域网通信技术。

4.1.2 SCADA 系统的安全需求

早期部署的 SCADA 系统采用工控系统专有的硬件、软件和通信协议，并与外部网络

进行物理隔离形成封闭型的专有网络系统。早期 SCADA 系统重点关注可靠性、可维护性和可用性，而不关注系统的安全性。但是随着工业化和信息化的广泛融合，以及对降低成本和提高效率的需求越来越迫切，现代 SCADA 系统发生如下变化：①提高了连通性，允许与外部企业网络进行通信，允许工程师和管理人员远程访问系统；②越来越多地采用价格便宜的通用硬件（PC、商用服务器等）和软件（Windows 操作系统、Linux 操作系统等）；③采用通用网络协议进行通信。这些变化使得 SCADA 系统面临前所未有的安全问题。

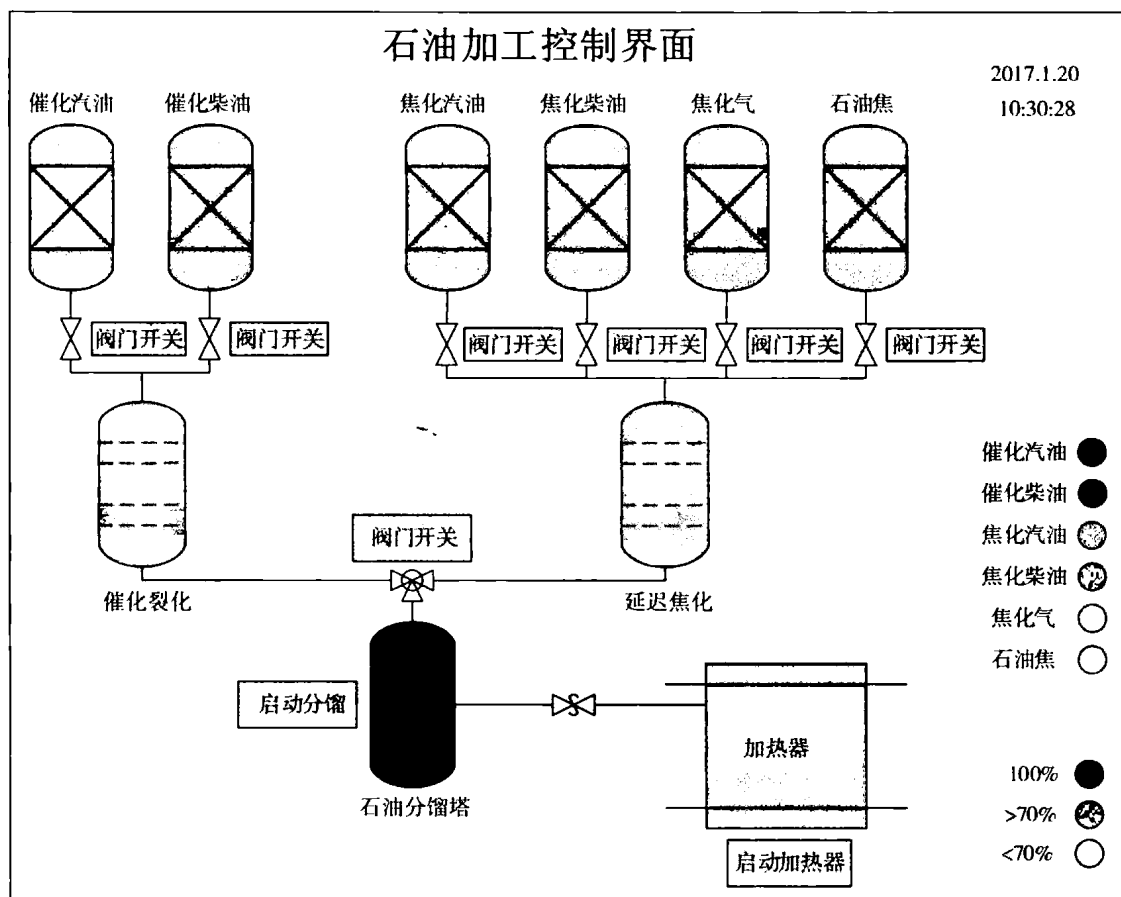


图 4-2 SCADA 系统人机界面示例

为了降低 SCADA 的连通性提高带来的安全威胁，通常使用防火墙实现 SCADA 系统与外包企业网络之间的逻辑隔离，阻断 SCADA 系统和企业网络之间的非授权网络连接。但是，这种通过防火墙实现的逻辑隔离往往会失效，通过互联网甚至可以直接搜索到连接到互联网的上百万个 SCADA 系统，如图 4-3 所示。即使完全物理隔离的 SCADA 系统也存在安全问题，例如，著名的震网（Stuxnet）就是通过感染 USB 渗透到内部 SCADA 控制网络，

并最终改变现场网络中的核电站离心机的发动机转速直至被摧毁。

通过隐藏系统和关键组件的实现细节提高 SCADA 系统安全性的方法已经慢慢失效。一方面，SCADA 系统越来越多地采用通用软硬件和通信协议，使得 SCADA 系统的实现细节更加透明，这些通用协议现存的各种安全漏洞也同时引入 SCADA 系统。另一方面，为了提高 SCADA 系统组件的兼容性，SCADA 组件厂家通过各种渠道发布 SCADA 系统的专有软硬件和通信协议的细节，国际组织发布了 IEC 60870.5、DNP3、Modbus 等标准规范。攻击者可以根据发布的技术细节和标准规范挖掘专有软硬件和通信协议存在的安全问题。

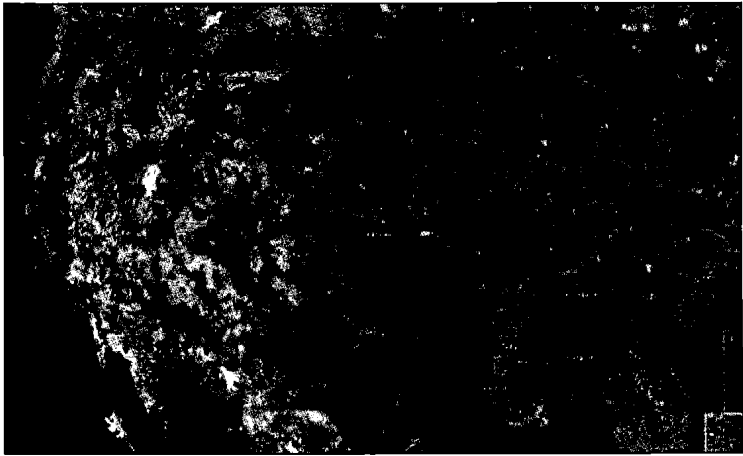


图 4-3 连接到互联网的工业控制系统

4.1.3 SCADA 系统的安全目标

SCADA 系统与传统信息系统一样，其核心安全目标都是机密性、完整性和可用性，即 CIA。机密性（Confidentiality）是指机密信息不被非授权的个人利用，或者被泄露给非授权的个人。完整性（Integrity）是指信息只能在指定或者被授权的情况下才能被改变。可用性（Availability）确保系统能够及时响应，并且不能拒绝授权用户的服务请求。

但是 SCADA 系统在性能要求、实时性要求、风险管理要求、物理相互作用等方面与传统信息系统存在巨大的区别，使得 SCADA 系统的机密性、完整性和可用性安全目标的优先级和传统信息系统正好相反，如图 4-4 所示。

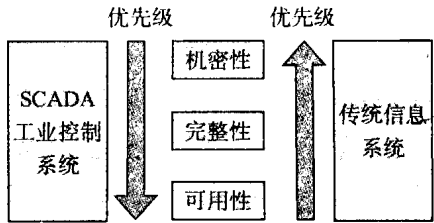


图 4-4 SCADA 系统与传统信息系统的安全目标优先级对比

SCADA 系统的可用性安全目标的优先级最高，这主要因为 SCADA 系统响应和服务中断不仅将带来巨

大的经济损失，还将引起设备损毁、工厂爆炸、人员伤亡等无可估量的灾难性后果。提高安全性不能以中断正常的业务运行为代价，不能降低系统的服务能力水平。SCADA 系统的高可用性要求使得传统的安全保护手段不能有效地在 SCADA 系统中实施。

SCADA 系统的完整性安全目标的优先级其次。在 SCADA 系统中，控制网络基于现场网络采集的数据进行分析决策，并向现场网络发送控制指令。如果采集数据在网络传输过程中被非授权修改，将使得控制网络基于错误的数据做出错误的决策。如果控制指令在传输过程中被非授权修改，将使得现场设备根据错误指令做出错误的决策。错误决策和指令将致使工控系统发生灾难性重大事故，造成无可挽回的损失。

SCADA 系统的机密性安全目标的优先级最低。SCADA 中传输的采集数据和控制指令的敏感性较低，少量泄露一般不会造成重大影响。例如，在市政管网供水应用中，泄露某个水箱采集的水位信息、关闭某个水站阀门的指令，对整个 SCADA 系统的安全性影响有限。但是如果攻击者获得大批量设备长期采集的数据，将分析出 SCADA 系统的运行规律和内部细节，并基于此发起进一步的安全攻击。

4.1.4 SCADA 系统的脆弱性

脆弱性（Vulnerability）指的是系统设计、实现、运行和管理中存在的缺陷和弱点，可以被威胁源利用以违反系统的安全策略、典型 SCADA 系统的脆弱性主要分成策略和程序脆弱性、架构和设计脆弱性、配置和管理脆弱性、物理脆弱性、软件开发脆弱性和通信网络脆弱性 6 种主要类型。对于任何特定的 SCADA 系统可能存在部分脆弱性，也可能存在所列 6 种类型之外的脆弱性，可以参考美国计算机应急小组（US-CERT）控制系统网站了解 SCADA 系统中出现的最新脆弱性。

1. 策略和程序脆弱性

SCADA 系统的脆弱性主要来自于系统安全策略的描述文档和实施指南的不完全和不适合，完善的安全策略和程序管理机制可以有效帮助信息部门员工和利益相关者正确判断各种行为是否有利于组织。通过正确的引导与实施，安全策略的完善能够有效减少系统安全脆弱性。为了引导各参与方遵守安全策略，还需要明确说明不遵守安全策略将带来的安全隐患。表 4-1 描述了 SCADA 系统的安全策略和程序方面存在的脆弱性。

表 4-1 SCADA 系统策略和程序脆弱性

脆弱性	描述
工业控制系统安全策略不当	由于安全策略不当或策略不具体，引入安全脆弱性到工业控制系统常有发生。为了确保一致性和可审计性，任何对应措施都应该可以追溯到安全策略

(续)

脆弱性	描述
没有正式的工业控制系统安全培训和安全意识培养	书面的、正式的安全培训以及安全意识培养设计的目的是为了使全体职员了解最新的计算机安全标准和最佳实践，并使组织的安全策略与程序同步更新
工业控制系统设备操作指南缺失或不足	设备操作指南应当及时更新并保持随时可用，这些操作指南是工业控制系统发生故障时安全恢复所必需的组成部分
安全策略实施的管理机制缺失	负有安全管理责任的员工应当对安全策略与程序文件的管理、实施负责
安全技术实施的有效性评估不足	应当准备程序和计划对安全技术实施的正确性、契合性和有效性进行审计和评估
工业控制系统安全应急预案缺失	应当准备工控系统应急方案，并进行定期演练，以防基础设施重大的软硬件故障发生。应急方案的缺失将导致 ICS 的故障时间延长和重大生产损失
配置管理策略缺失	应当严格制定 ICS 硬件、固件、软件的变更控制程序和相关程序文件，以保证 ICS 得到实时保护。配置变更管理程序的缺失将导致安全脆弱性的发生，增大安全风险
明确具体的、书面的安全策略或程序文件缺失	应当制定具体的、书面的安全策略或程序文件并对全体员工进行培训，这是一个正确的安全建设的根基
缺失足够的访问控制策略	访问控制正确实施依赖于正确的模型角色、职责和授权。访问控制策略模型满足组织的功能需求
缺失足够的认证策略	身份认证策略需要定义身份认证机制（如密码、智能卡）实施的时间、认证强度和管理方法。没有正确的身份认证策略，就难以实施合适的身份认证机制，从而造成对系统的未授权访问
缺失足够的事件检测和应急方案	事件响应能力需要必要的快速事件检测机制，尽量减少损失和破坏。提高系统事件响应能力需要提高监测异常能力、事故优先处理能力以及高效数据处理能力
缺失关键组件的冗余配置	缺少关键部件冗余将提高单点故障的可能性

2. 架构和设计脆弱性

SCADA 系统的架构和设计脆弱性主要包括系统架构设计中考虑安全性不足、不能适应网络系统进化的安全体系架构、安全边界定义不清晰、非控制网络流量管理不当、在控制网络中使用传统信息系统网络服务、安全事件历史数据的收集不足等方面，如表 4-2 所示。

表 4-2 SCADA 系统架构和设计脆弱性

脆弱性	描述
系统架构设计中考虑安全性不足	将安全架构纳入 SCADA 系统的整体架构设计中。安全架构是系统架构的一部分，必须明确用户的身份标识和认证方法、访问控制机制、网络拓扑、系统配置和完整性机制
不安全体系架构不能适应网络系统的进化	SCADA 网络基础设施环境常常是根据业务和运营需要进行不断完善的，而很少考虑这些变化带来的潜在的安全影响。随着时间的推移，安全漏洞可能会无意中引入到 SCADA 系统中，设置成为 SCADA 系统中的严重后门
没有清晰定义安全边界	如果 SCADA 系统没有明确的安全边界，它是不可能确保必要安全手段的正确部署和配置的，并可能导致未经授权访问系统和数据与其他安全问题

(续)

脆弱性	描述
控制网络传输非控制网络流量	控制和非控制业务流量具有不同的确定性和可靠性要求，使用同一种网络传输两种类型流量将增加网络配置的难度
在控制网络中使用传统信息系统网络服务	在控制网络中部署 DNS、DHCP 等传统 IT 系统中的网络服务，将降低 SCADA 系统所需的可靠性和可用性要求
安全事件历史数据的收集不足	取证分析取决于收集和保留足够的数据。如果没有正确和准确的数据集合，它可能无法确定是什么导致安全事件发生。事件可能会被忽视，导致额外的伤害或中断

3. 配置和管理脆弱性

SCADA 系统的配置和管理脆弱性主要包括：缺乏对系统软硬件及固件的正确配置管理，补丁程序更新不及时或没有正常维护，对安全变化的测试不足，远程访问控制不完善，网络服务配置不完善，关键配置备份手段缺乏，敏感数据的不正确存放，口令策略使用不当，易遭受 DoS 攻击，IDS/IPS 没有正确部署，没有正确的维护日志信息等，如表 4-3 所示。

表 4-3 SCADA 系统配置和管理脆弱性

脆弱性	描述
缺乏对硬件、固件和软件的配置管理	组织不清楚硬件、固件和软件的版本和补丁状况，导致不一致和无效的安全防御。实施对硬件、固件和软件的修改控制，以确保 SCADA 系统被保护，免受不足或不当修改
操作系统和商用软件的补丁程序更新不及时	因为 SCADA 软件与底层组件之间紧密耦合，所以任何更新必须经过费时费钱的全面回归测试。长时间测试以及软件补丁更新不及时，将导致 SCADA 系统处于长期不安全状态
操作系统和应用程序的安全补丁程序没有正确维护	长期未更新的操作系统和应用程序可能包含最新发现的漏洞。应制定修补程序规定维持安全修补的方法和程序
对安全变化的测试不足	对硬件、固件和软件部署的更新没有采取必要的安全测试，将损害 SCADA 系统的正常操作。需要撰写书面程序以指导系统变化后应该采取的测试。实时业务系统永远不应该被测试
远程访问控制不完善	为了便于供应商和集成商执行系统维护功能以及 SCADA 工程师远程访问系统组件，经常需要远程访问 SCADA 系统。必须充分控制远程访问功能，以防止未经授权的个人访问 SCADA 系统
网络服务配置不完善	未正确配置的系统可能开放不必要的端口和协议，从而带来不必要的漏洞，提高了系统的总体风险。使用默认配置将留下公开漏洞和可利用的服务，必须严格审查所有设置
关键配置没有存储或者备份	当遭受意外事故或者安全攻击而导致配置被更改时，应该有相应的手段还原 SCADA 系统的配置设置，从而保持系统的可用性，并防止数据丢失
数据不安全地保存在移动设备	当口令等敏感数据存储在笔记本电脑、移动硬盘等容易遗失的便携设备上时，将危及系统安全。需要相应的政策、程序和机制禁止或有效管理存放敏感数据到移动设备上
没有根据口令策略产生、使用和保护口令	在使用口令时需要定义口令强度、更改周期等口令策略，大量传统信息系统的口令策略适用于 SCADA 系统。必须遵守口令策略和程序以减少 SCADA 系统漏洞

(续)

脆弱性	描述
访问控制应用不完善	访问控制措施不当可能会导致给 ICS 用户过多或过少的特权。访问控制策略必须符合责任和特权分配给工作人员的方式
数据链接不恰当	SCADA 数据存储系统可能与非 SCADA 数据源链接, 如数据备份中允许到非 SCADA 数据库的链接。数据不恰当链接将带来新的安全漏洞, 可能产生未经授权的数据访问或操作
恶意软件防护软件没有安装或者实时升级	恶意软件是一种常见的攻击。恶意软件防护软件必须保持最新版本, 过时的恶意软件防护软件将不能阻断恶意软件的威胁
拒绝服务攻击	SCADA 软件可能受到 DoS 攻击, 导致不能正常访问系统资源或服务
入侵检测和防范软件没有安装	安全事件可能影响系统的可用性和完整性、数据被窃取或篡改以及控制命令不正确执行。IDS/IPS 软件可以防止各种类型的攻击, 并确定攻击的内部主机。IDS/IPS 软件在部署到 SCADA 系统之前, 需要被严格测试以确定不会损害 SCADA 系统的正常业务
没有维护日志	没有正确和准确的日志, 可能无法确定导致安全事件发生的原因

4. 物理脆弱性

SCADA 系统的物理脆弱性主要包括非授权个人接触物理设施、射频和电磁脉冲 (EMP)、没有备份电源、缺少环境控制手段、不安全的物理端口等方面, 如表 4-4 所示。

表 4-4 SCADA 系统物理脆弱性

脆弱性	描述
非授权个人接触物理设施	ICS 设备的物理访问应只限于必要的人员, 同时考虑安全的要求, 如紧急关机或重新启动
射频和电磁脉冲	用于控制系统的硬件是脆弱的无线电频率和电磁脉冲。影响范围可以从暂时中断的指令到控制电路板的永久性损害
没有备份电源	对于关键资产, 如果没有备用电源, 电力不足将关闭 ICS, 并可能产生不安全的情况。功率损耗也可能导致不安全的默认设置
缺少环境控制手段	环境控制的缺失可能会导致处理器过热。有些处理器将关闭以自我保护; 有些可能会继续工作, 但输出功率较小, 会产生间歇性的错误
不安全的物理端口	不安全的 USB、PS/2 等端口可能允许未经授权的接入

5. 软件开发脆弱性

SCADA 系统软件开发脆弱性主要包括不正确的数据验证、安全功能没有缺省启用、对软件的非授权访问等方面, 如表 4-5 所示。

表 4-5 SCADA 系统软件开发脆弱性

脆弱性	描述
不正确的数据验证	SCADA 系统软件可能无法正确验证用户输入或接收数据的有效性。无效的数据可能会导致缓冲区溢出、SQL 注入、跨站点脚本等安全漏洞
安全设备没有默认开启安全功能	随产品一起安装的安全功能没有默认启用, 失去了安全防护功能
对软件的非授权访问	对软件进行未经授权的配置和编程, 将损坏设备的能力

6. 通信网络脆弱性

SCADA 系统通信网络脆弱性如表 4-6 所示。

表 4-6 SCADA 系统通信网络脆弱性

脆弱性	描述
流量控制手段不足	基于数据特点的数据流量控制可以限制系统之间传输数据，从而防止数据泄露和非法操作
防火墙缺失或者不正确配置	防火墙配置不当可能允许不必要的数据传输，这可能会导致攻击数据包和恶意软件引入 SCADA 系统，造成未经授权的系统访问
防火墙和路由器的日志信息维护不足	如果没有合适、详细的日志信息，将不可能分析出导致安全事件发生的原因
用标准通信协议传输明文	敌手通过使用协议分析仪或其他实用程序解析 NFS、Telnet、FTP 等标准网络协议，解码得到传输的数据
用户、数据和设备的认证低于标准要求	许多 ICS 协议没有身份验证的任何级别。没有身份验证，就可能会遭到重放、篡改或伪造数据
使用不安全的工业控制协议	DNP、Modbus、Profibus 等常见的工控通信协议的细节是开放的，这些协议通常具有很少或没有安全功能以实现身份认证和数据加密功能
对通信的完整性检查不足	大多数工业控制协议缺少完整性检查。为了确保完整性，SCADA 系统可以使用 IPSEC 等低层协议提供数据完整性保护
无线终端和接入点之间认证不足	无线客户端和接入点之间需要进行强相互认证，以确保客户端不会连接到恶意接入点，确保攻击者不能连接到任何 SCADA 无线网络
无线终端和接入点之间的数据保护不足	应该使用强加密手段阻止敌手的未授权访问，保护无线客户端和接入点之间的敏感数据

4.2 SCADA 系统安全的关键技术

针对 SCADA 系统特有的安全需求和存在的脆弱性，需要综合实施 SCADA 安全防护技术，以实现安全防护目标。

4.2.1 安全域划分及边界防护

1. 安全域划分

SCADA 系统非常复杂，由控制网络、通信网络、现场网络组成。在很多工业控制应用中，SCADA 系统与企业办公网络互联，并可以被管理终端通过远程连接访问进行系统配置和维护。SCADA 系统的网络结构和网络连接的复杂性和异构性，使得为 SCADA 系统设计和实施整体安全防护方案变得非常困难。对复杂的 SCADA 系统进行安全域划分，在安全域之间边界部署安全防护装置，实现物理隔离或者逻辑隔离，是 SCADA 安全防护的重要手段，也是为 SCADA 系统建立纵深防御安全体系的基础。

安全域指同一网络系统内,根据信息属性、使用主体、安全目标划分,具有相同或相似的安全保护需求和安全防护策略,相互信任、相关关联、相互作用的网络区域。通过网络安全域的划分,可以将 SCADA 网络系统安全问题转化为各安全域的安全保护问题。由于各安全域网络结构相对简单,具有相近的安全防护需求和策略,可以在安全域内部以及安全域之间采用有效的安全防护手段,更好地控制网络安全风险,提高安全设备利用率。

IEC 62443-3 标准建议通过横向分区、纵向分域,对控制系统的各个子系统进行分段管理,区域之间的通信靠专用管道执行,通过对管道的管理来阻挡区域之间的非法通信,保护网络区域和其中的设备。

利用功能组识别的安全域划分技术,基于网络连接、控制回路、监控系统、控制流程、控制数据存储、关联通信、远程访问、用户和角色、通信协议、重要级别等,识别 SCADA 系统中直接参与或者负责特定功能的功能组,如图 4-5 和图 4-6 所示。由于许多设备支持多种协议、应用程序和服务,识别的功能组不可避免地存在重叠部分,有必要使用组间功能共享来简化功能组,从而有效合并重叠的功能组为一个边界、用户、设备和协议均清晰定义的安全域。

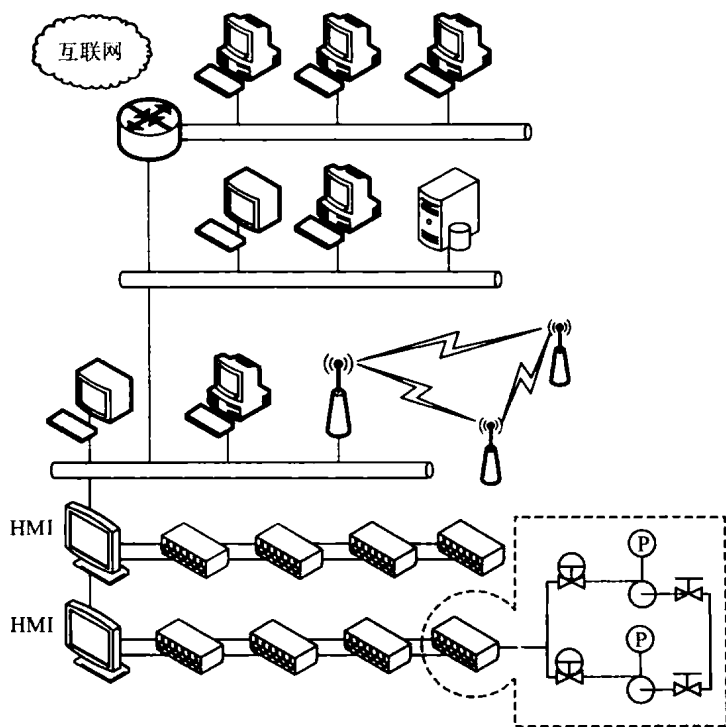


图 4-5 基于控制回路的功能组

2. 安全域边界防护

安全域划分并确定了安全域的边界之后,就要在安全域之间部署防火墙、路由器、入侵检测、隔离网闸等设备,实现网络隔离和边界安全防护。SCADA 控制网络与企业办公网络的边界,以及互联网(通过远程终端访问)与控制网络之间的边界,是外部网络连接 SCADA 内部的主要通道,是攻击者进行安全渗透的最主要目标。本节主要以这两类边界为例,说明如何进行安全域隔离。

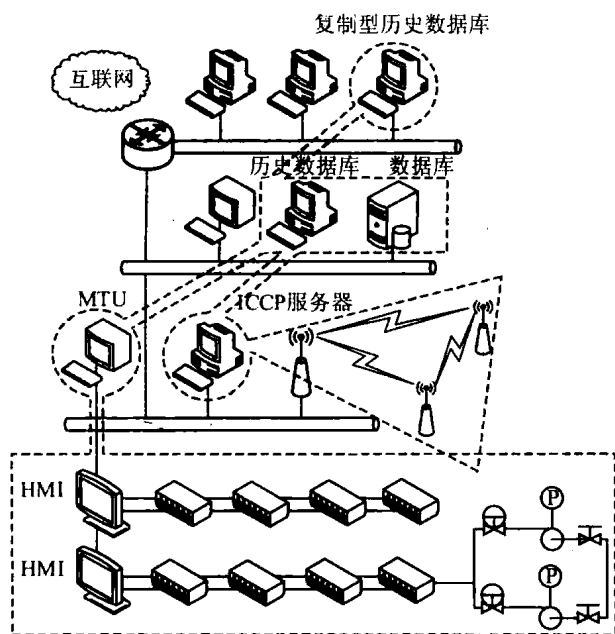


图 4-6 基于 HMI 的功能组

防火墙是实现区域隔离和边界防护的主要安全设备,包括网络层数据过滤、基于状态的数据过滤、基于端口和协议的数据过滤和应用层数据过滤等几种类型,主要可以实现如下功能。

1) 通过设置特定的规则允许安全域之间的网络通信,除此之外阻断所有其他安全域之间的网络通信。可以基于源 IP 地址和目的 IP 地址对、网络服务、端口、连接状态、特定应用、网络协议类型设定规则,从而阻断高风险的网络连接。

2) 对所有尝试连接 SCADA 网络的用户,实施安全认证。根据 SCADA 系统的脆弱性选择口令、智能卡、生物特征、双因子等安全认证手段。

3) 通过目标授权功能,限制或者允许特定用户可以访问 SCADA 系统的特定节点,从而降低用户有意或者无意访问非授权设备。

4) 记录安全域之间通信的流量, 用于后续流量监控、分析和入侵检测。

针对 SCADA 系统的特殊安全需求, 选择合适类型的防火墙并设置合适的安全策略, 主要原则如下:

1) 不仅仅依靠网络层来进行数据过滤, 如果可能的话尽可能综合使用网络层、传输层和应用层数据过滤技术。

2) 严格遵守最小权限原则。如果一个安全域不需要与其他安全域连接, 就不要在两个区域之间建立任何连接通道。如果两个区域之间只需要使用某个特定的端口和协议进行通信或者只能传输包含特定标志或者数据的数据流, 那就需要设定规则严格按需求建立连接通道。

3) 使用白名单设置防火墙过滤规则, 也就是在缺省情况下的任何网络连接, 只有符合白名单设置规则的数据流可以允许通过。SCADA 系统要求严格限制内外网通信, 所以允许建立网络连接的规则较少, 建立和维护白名单相对传统信息网络环境更为可行。

4) 在部署防火墙保护边界安全的时候, 需要认证评估对控制系统网络通信延迟的影响。

5) 需要经常审查过滤规则, 并根据安全需求和安全威胁的变化动态调整过滤规则。

3. 防火墙部署方案

根据安全需求和安全威胁, 研究合适的技术方案在 SCADA 系统与企业办公网络的边界之间部署防火墙。常用的防火墙部署方案包括办公网络与控制网络间配置单防火墙, 办公网络和控制网络之间部署带 DMZ 的防火墙, 办公网络和控制网络之间部署成对防火墙等。

(1) 办公网络与控制网络间配置单防火墙

在办公网络和控制网络之间部署一个双接口的防火墙, 通过认证配置防火墙规则可以有效降低安全威胁, 如图 4-7 所示。

在 SCADA 系统中, 通常都存在历史数据库存放从控制网络节点采集的各种传感器数据。为了提高效率, 通常允许管理员在办公网络访问历史数据库并进行分析处理。在单防火墙方案中, 需要认真考虑历史数据库部署在企业办公网络还是控制网络。无论哪种方案都存在一定的安全问题, 如下所示。

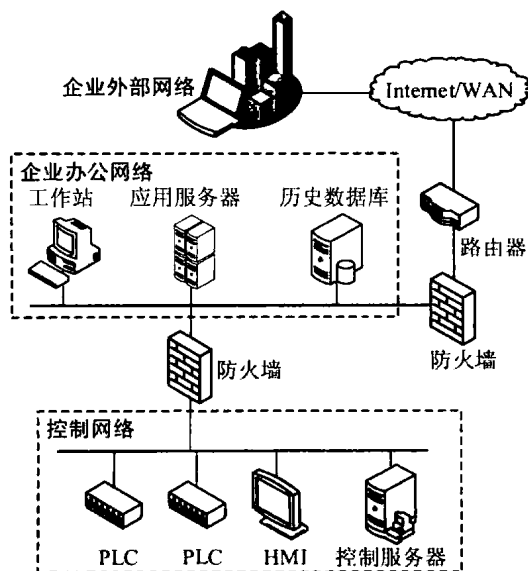


图 4-7 办公网与控制网络间配置单防火墙

1) 如果将历史数据库部署在控制网络, 然后对防火墙设置规则允许管理员访问控制网络内的历史数据库。管理员通常使用 SQL 和 HTTP 访问历史数据库, 从而容易引入 SQL 注入、脚本跨站攻击等安全攻击, 威胁控制网络的整体安全。

2) 如果将历史数据库部署在办公网络, 必须设置防火墙规则允许历史数据库与控制设备之间的网络通信。从办公网络恶意节点发起的数据包将传输到控制设备, 从而对控制设备的安全带来极大的影响。

(2) 办公网络和控制网络之间部署带隔离区的防火墙

在办公网络和控制网络之间部署带隔离区 (Demilitarized Zone, DMZ) 的防火墙, 将显著提高安全性, 并能较好地解决第一种方案中存在的问题。每个隔离区隔离出一个或多个重要组成部分, 如历史数据库、第三方接入系统等, 如图 4-8 所示。实际上, 能够制造隔离区的防火墙如同构建了一个中间网络。

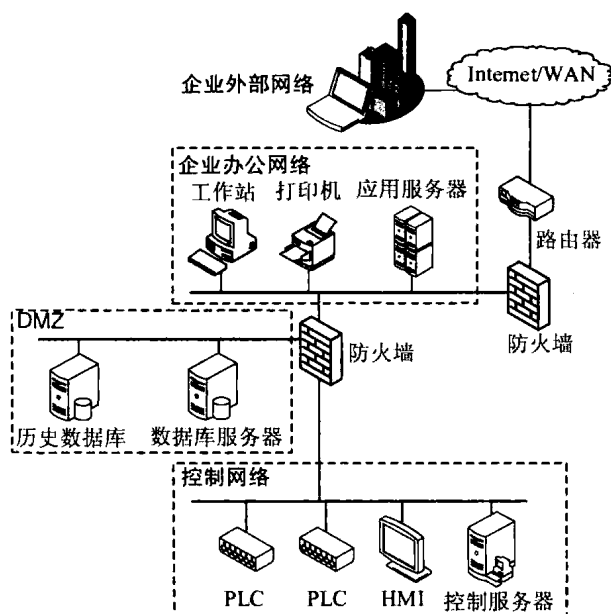


图 4-8 办公网络与控制网络间配置带 DMZ 的防火墙

为了构建隔离区, 除了传统的公共和私有接口外, 防火墙至少需要提供 3 个接口。一个接口连接办公网络, 一个接口连接控制网络, 剩余的接口则连接 DMZ 中那些共享的不安全的设备, 如历史数据库服务器、无线网络接入点。

由于把那些可存取部分分布在隔离区, 办公网络和控制网络之间不再直接通信, 转而都以隔离区为通信目标。大多数防火墙允许存在多个隔离区, 并规定隔离区之间通信的规

则。无论是办公网络输出还是控制网络输入数据包都可以被防火墙丢弃，另外防火墙还能够协调包括控制网络在内的链路。良好规则的制定、控制网络与其他网络间明确细分的实施，确保了办公网络和控制网络间几乎没有直接的通信。

这一部署方案的最主要风险在于，如果 DMZ 中的一台主机被攻陷，它将被用于制造控制网络和 DMZ 中的攻击。通过强化并及时更新 DMZ 中的服务器，规定防火墙只接收由控制网络设备发起的与 DMZ 的通信，则这种风险可以大大降低。这一部署方案的另一问题是额外的复杂性以及端口个数带来日益增加的防火墙消耗。

（3）办公网络和控制网络之间部署成对防火墙

该解决方案与带 DMZ 的防火墙解决方案相比较，其中一个变化是在办公网络和控制网络之间使用成对的防火墙，如图 4-9 所示。像历史数据库这样的公共服务器被布置于防火墙之间，被称为制造执行系统（Manufacturing Execution System, MES）层。在该部署方案中，一台防火墙负责阻断进入控制结构和公共数据的非授权连接，另一台防火墙则可以防止从被攻击的服务器连接到控制网络的网络连接，能更好地提高控制网络的安全性。

配置不同厂商的防火墙可以有效提高整个系统的安全性，通过独自管理和配置防火墙拥有明确分开的设备。这一部署方案的主要缺点在于代价高、管理复杂，比较适合那些对安全有严格要求或需要明确管理分离的环境。

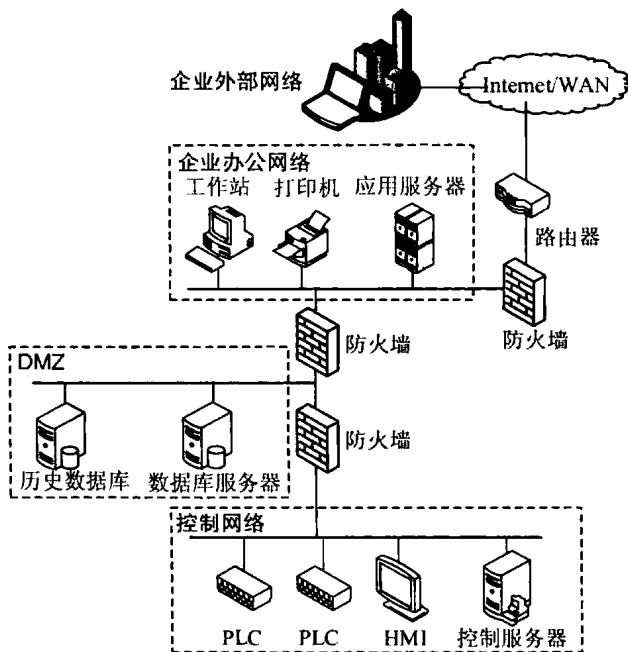


图 4-9 办公网络和控制网络之间部署成对防火墙

4.2.2 SCADA 系统异常行为检测技术

部署于安全域之间的防火墙能够有效地阻止外部攻击，但是由于防火墙存在规则配置错误、更新不及时等问题，以及防火墙本身有可能存在安全漏洞被利用，外部攻击者仍然可以绕过防火墙攻击 SCADA 内部网络。此外，防火墙等边界安全防护技术不能有效阻止来自 SCADA 系统内部的攻击，内部攻击是重要工控安全事件的主要攻击手段。入侵检测系统能在入侵攻击对系统产生危害前检测到内部攻击和外部攻击，发出报警并启动防御措施，被称为防火墙之后的第二道安全闸门。

1. SCADA 系统入侵检测技术分类

一个典型的入侵检测系统从功能上可以由感应器（Sensor）、分析器（Analyzer）和管理器（Manager）三部分组成，如图 4-10 所示。感应器负责从网络数据包、日志文件和系统调用记录等信息源收集信息并发送给分析器。分析器对感应器接收的信息进行分析以检测是否有入侵行为发生，并根据检测的入侵行为启动报警和防范措施。管理器通常也被称为用户控制台，以一种可视的方式向用户提供收集到的各种数据及相应的分析结果，用户可以通过管理器对入侵检测系统进行配置，设定各种系统的参数，从而对入侵行为进行检测以及对相应措施进行管理。

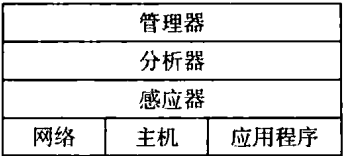


图 4-10 入侵检测系统架构

根据感应器采集数据的数据源来分，入侵检测系统主要可以分为基于主机（Host-Based）的入侵检测系统和基于网络（Network-Based）的入侵检测系统两类。

1）基于主机的入侵检测系统。通常，基于主机的入侵检测系统可监测系统、事件和操作系统下的安全记录以及系统记录。当有文件发生变化时，入侵检测系统将新的记录条目与攻击标记相比较，看它们是否匹配。如果匹配，系统就会向管理员报警，以采取措施。

在 SCADA 系统中，主机除了包括控制网络中的各种服务器外，还包括现场网络中的 RTU、PLC、IDE 等远程终端设备。在计算资源和存储资源非常受限的远程终端设备上部署感应器，将降低设备的运行性能，甚至影响系统的可用性。在 SCADA 系统中部署基于主机的入侵检测系统，需要认真分析此部署对系统性能的影响。

2）基于网络的入侵检测系统。基于网络的入侵检测系统使用原始网络数据包作为数据源。基于网络的入侵检测系统通常利用一个运行在混杂模式下的网络适配器来实时监视并分析通过网络的所有通信业务。

在 SCADA 系统中，网络通信主要包括现场网络内部通信数据、控制网络内部通信数据以及现场网络和控制网络之间的通信数据。由于控制网络与现场网络之间的通信通常会

采用多种广域网通信技术,分布又非常广泛,难以在通信网络内部部署感应器。为此,主要在控制网络和通信网络的边界部署感应器,采集控制网络和现场网络之间的通信数据包。

根据入侵检测分析方法的不同可将入侵检测系统分为误用入侵检测系统和异常入侵检测系统两类。

(1) 误用入侵检测系统

误用入侵检测系统根据已知入侵攻击的信息(知识、模式等)来检测系统中的入侵和攻击。在误用入侵检测中,假定所有入侵行为和手段(及其变种)都能够表达为一种模式或特征,那么所有已知的入侵方法都可以用匹配的方法来发现。误用入侵检测的关键是如何表达入侵的模式,把真正的入侵与正常行为区分开来。其优点是误报少,局限性是它只能发现已知的攻击,对未知的攻击无能为力。

误用入侵检测系统作为传统信息系统的一种主要安全防护手段,已经积累了大量非常完备和准确的入侵特征库。由于 SCADA 系统中逐渐采用了与传统信息系统一样的硬件和通信协议,原有的入侵检测库可以应用于 SCADA 系统的入侵检测中。但是,SCADA 系统存在的大量工控系统特有的设备和通信协议存在安全漏洞。面向 SCADA 系统的专有人侵特征库还非常匮乏,亟需不断完善和补充。

(2) 异常入侵检测系统

异常入侵检测系统利用被监控系统正常行为模型作为检测系统中入侵行为和异常活动的依据。在异常入侵检测中,假定所有的入侵行为将影响系统行为模型,通过与系统正常行为模型进行对比分析,计算两者之间的区分度,如果区分度超过预先设定的阈值就判定为系统遭受入侵。异常入侵检测的最大优点就是不需要预先设定入侵行为特征,可以检测出未知入侵行为。异常入侵检测的最大困难就是建立系统的正常行为模型和阈值设定。如果正常行为模型不准确,后续的所有入侵检测就没有任何依据。阈值设定的不准确将影响入侵检测的误报率和漏报率。

不同系统的正常行为模型差别很大,传统 IT 系统的正常行为模型不能直接应用于 SCADA 入侵检测系统中。例如,传统 IT 系统和 SCADA 系统的网络数据流模型存在明显区别,如图 4-11 所示。SCADA 系统的网络数据流在很长时间是比较平稳的,这主要是因为 SCADA 的正常流量主要由传感器自动采集产生的。而传统 IT 系统的网络数据流存在明显的周期性,根据人们的生活和工作规律,传统 IT 系统每天的网络流量呈现明显的规律。与传统 IT 系统相比,SCADA 系统的数据流量存在通信实体个数受限,而且通信实体双方具有明显的稳定性。

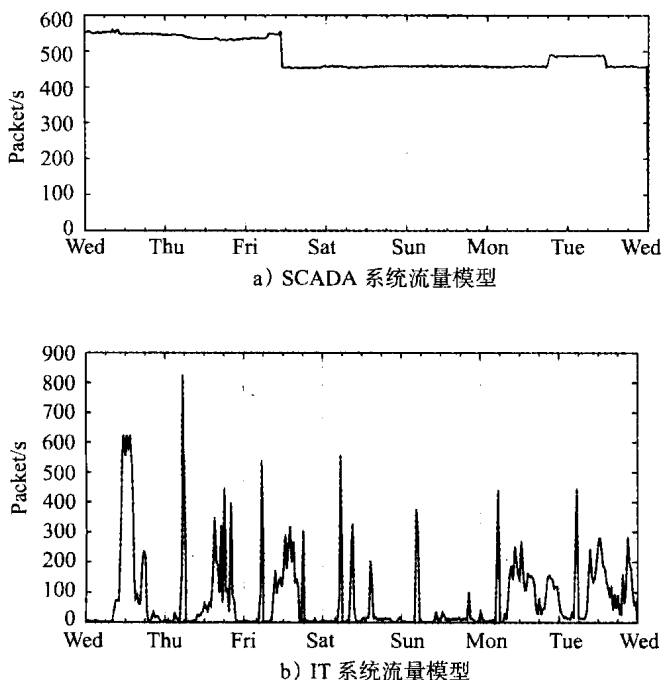


图 4-11 SCADA 系统与传统 IT 系统的流量模型对比

2. SCADA 系统入侵检测技术

总体而言,面向 SCADA 系统的入侵检测技术还是处于初始阶段,很多技术还在不断完善中。综合考虑入侵检测数据源和入侵分析方法,本节按基于主机的异常入侵检测、基于主机的误用入侵检测、基于网络的异常入侵检测和基于网络的误用入侵检测 4 种类型介绍 SCADA 系统入侵检测技术的发展现状。现有的 SCADA 入侵检测系统绝大多数属于基于网络的异常入侵检测技术。

(1) 基于主机的异常入侵检测

文献 [23] 中提出了一种基于异常检测的面向 SCADA 系统的入侵检测方法。它的前提假设在于,SCADA 系统在遭受网络攻击时,系统中的 CPU 占用率、内存占用率、I/O 使用率等参数将会有异常的波动。基于统计学模型,比较当前状态和正常情况的差别,监控关键参数的状态矩阵,当实际参数偏离正常状态的参数矩阵达到设定阈值时,将触发相应的报警。

Hadiosmanovic 等人提出了 MELISSA 入侵检测技术^[24],基于 SCADA 服务器中的日志文件分析异常并检测入侵行为,如图 4-12 所示。这些日志文件包括 PLC/MTU 的配置信息和报警信息、管理员和操作员的操作信息等。MELISSA 的数据预处理器 (Data Preparator)

对日志文件（SCADA System Log）进行归一化和数据融合处理，模板引擎（Pattern Engine）基于预设模型对预处理后的数据进行处理，挖掘得到极少发生的事件模板，并怀疑该事件为入侵行为。

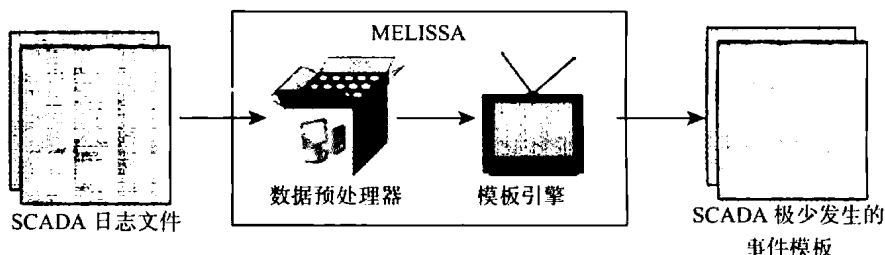


图 4-12 MELISSA 系统架构

（2）基于主机的误用入侵检测

由于 MTU、PLC 等控制器的存储资源和计算资源受限，为了防止影响 SCADA 系统的性能，不能直接在控制器记录安全事件。文献 [25] 提出并设计了一种 SCADA 控制器安全事件日志采集及管理系统 QuickDraw，记录从 MTU、PLC 等控制器发送过来的安全事件的事件类型和事件参数，并通过设定的规则检测安全攻击。

（3）基于网络的异常入侵检测

文献 [26] 提出了一种基于模型的面向工控网络协议的入侵检测技术。SCADA 系统中使用工业控制专有协议进行网络通信，这些工控协议相对简单，网络通信的拓扑关系相对简单，容易建立正常模型。根据工控协议规范，建立起工控协议可接受的行为模型，从而检测不符合该行为模型的潜在攻击。实验结果表明，基于模型的入侵检测方法是一种有效的攻击检测方法。但是它的缺陷在于，难以建立精确的行为模型，从而导致较高的误报率。

文献 [27] 提出了一种基于网络流层次信息的入侵检测方法，该方法使用了上下文抽取算法。文献只是给出了该方法的通用框架，没有给出具体的上下文抽取算法的细节。

文献 [28] 提出了一种基于神经网络的入侵检测方法，首先统计协议头信息中的 IP 地址个数和数据包个数，并构成一个窗口，然后使用神经网络算法构建窗口的正常模型。

文献 [29] 提出了一种基于网络数据包载荷的入侵检测框架，如图 4-13 所示。该框架通过网络感知（Network Sensor）、特征提取（Feature Extraction）、相似性计算（Similarity Computation）和异常检测（Anomaly Detection）4 个步骤完成入侵检测。网络感知使用网络安全监控器 Bro 在网络上抓取 TCP 载荷，并发送给特征提取器，通过特征提取将网络流序列映射到高维特征空间。相似性计算是入侵检测最为关键的部分，通过计算网络流字节序

列表达向量的距离来计算两个网络流的相似性。异常检测就是通过比较抓取的网络流和正常网络流模型之间的相似性来判断是否有异常并检测网络攻击。

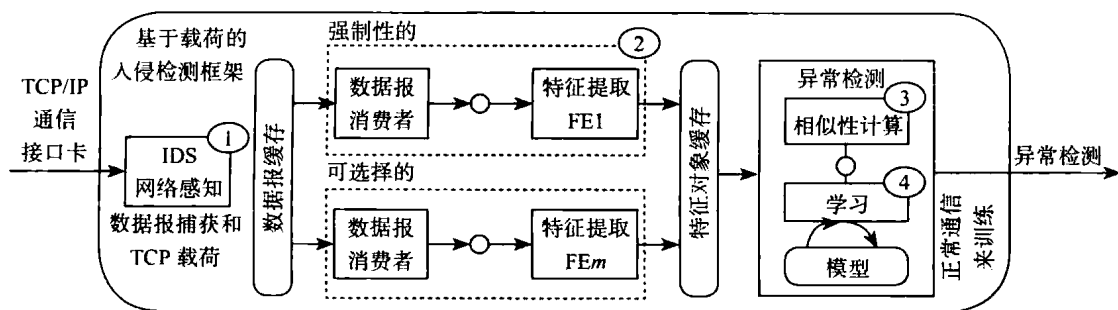


图 4-13 基于载荷的入侵检测框架

文献 [30] 提出了一种基于状态表有限状态机的 SCADA 入侵检测方法。确定型有限状态机 (Deterministic Finite Automata, DFA) 模型是描述 SCADA 系统网络流的有效模型，基于 DFA 的异常入侵检测系统具有低误报率的特点。但是 SCADA 系统中的 HMI 往往是多线程的，每个线程管理不同的设备并按不同的周期采集数据。使用 DFA 刻画多线程模式下的 SCADA 系统网络流量的模型将引起状态爆炸，检测效率非常低。文献 [31] 提出使用状态表有限机刻画多路 SCADA 网络流，将每路的网络流映射到单独的有限状态机。

(4) 基于网络的误用入侵检测

文献 [32] 提出了一种面向 IEC 61850 标准变电站的网络入侵检测方法。通过分析实际环境采集的真实数据和模拟产生的仿真数据，建立攻击行为的特征库，例如，大于 100 字节的 ICMP 包是一个 DoS 攻击，每秒 100 个 ICMP 包是一个 DoS 攻击，每秒 100 个 ARP 数据包是可疑行为等。但是文献并没有给出如何构建入侵规则库，以及如何通过扩展适合各种应用场景。

4.2.3 SCADA 系统安全通信及密钥管理

1. SCADA 安全通信

SCADA 系统的网络通信容易受到数据窃取、数据篡改、数据注入、中间人、重放、拒绝服务等攻击。

(1) 数据窃取攻击

SCADA 系统中现场网络和控制网络之间的网络通信跨度非常大，综合采用了卫星通信、移动通信等多种技术。攻击者可以非常容易地窃取传输的采集数据和控制指令。

（2）数据篡改攻击

Sridhar^[33] 等人将网络安全攻击的概念扩展到控制系统中，通过量化负载、发电失衡和频率偏差来评估 AGC 回路遭受攻击对物理系统的影响，并通过实验验证了完整性攻击的巨大破坏作用。Giani^[34] 通过两个额外的功率注入设备和一个任意数量功率表来发现网络中隐藏的数据完整性攻击。Xie^[35] 通过模拟数据完整性攻击，评估其对电力网络造成的经济损失及严重的物理后果。

（3）数据注入攻击

攻击者在完全掌握工业控制系统现场通信协议的原理后，通过发送错误的控制状态或信息，误导操作人员或控制组件的操作。Jia^[36] 研究如何通过操纵传感器收集的数据，发起恶意数据攻击，并基于凹目标函数优化提出最佳攻击策略，在攻击检测率小于 0.5 的限制下，取得最大的攻击收益。Cui^[37] 建立了数据注入攻击模型，讨论智能电网中协同数据注入攻击和检测问题，提出优化公式和启发式算法解决潜在攻击者和防御者的动态对抗问题。

（4）中间人攻击

攻击者伪装成合法的通信实体，与通信链路终端的用户进行数据交互。攻者可以对交互的数据进行篡改、拦截或删除。通过发起中间人攻击，对于实施弱认证和安全性低的密钥协商协议的系统，攻击者可以很容易地获取系统控制权。

（5）重放攻击

重放攻击是指攻击者拦截网络上传输的数据，记录一段时间内的数据信息，然后重放这些数据包。Mo 等人^[38] 提出了在基于线性二次高斯控制器 LQG 的离散线性时不变系统中实施重放攻击，并通过权衡检测延迟、LQG 性能和控制精度等措施来达到预期的检测率。

（6）拒绝服务攻击

DoS 攻击是指通过在网络中泛洪伪造的数据包，导致通信流量拥塞，造成重要数据损失，影响系统持续稳定的运行。文献 [39] 建立了针对控制回路的 DoS 攻击模型。Amin^[40] 等人形式化表述了离散线性动态控制系统的安全问题，引入 DoS 攻击模型，造成传感器和控制器数据丢包。

针对控制系统可能面临的攻击，研究人员基于安全的密码算法设计提出了各种数据安全传输方案，以提供端到端认证、数据完整性验证、机密性保护等功能。

1) 抵御完整性攻击和重放攻击。

Wright^[41] 等利用 SCADA 系统中设备自带的循环冗余码，提出了保护 SCADA 链路的改进密码协议，在最小化延迟的情况下实现强完整性。Tsang^[42] 提出了用于改进 SCADA 系统安全特性的 BITW 解决方案，将随机误差检测转化为数据认证。Solomahin^[43] 等提出了基

于计数器和消息校验的认证机制，在接收到完整的明文数据之前预先发送一小段密文数据。

2) 数据机密性保护。

Swaminathan^[44]等提出了安全现场总线（Secure Field Bus, SecFB）协议，保证了工业过程控制的网络通信安全，使用 DES 算法加密通信数据，提供机密性保护。He^[45]等提出了适用于智能电网的安全、高效的密码系统，用户向通信实体发送用户信息之前，利用同态加密方法保护用户隐私。

3) 抵抗中间人攻击。

Zhang 等人^[46]基于 ECC 加密算法设计了高效的认证协议，实现智能应用与变电站之间的双向认证，以抵抗中间人攻击。Kumar 等人^[47]提出了轻量级弹性协议，用于保护智能仪表和智能电网基础设施之间的安全通信，该协议能够实现控制中心和智能仪表的双向认证，实验证明该协议能够防止在智能电网中发生的重放攻击和中间人攻击等。

使用加密、认证、签名等密码技术为 SCADA 网络通信数据提供机密性和完整性安全保护，是 SCADA 系统安全的重要保证。为了尽可能不影响 SCADA 系统原有业务系统的性能和设备的可靠性，在提供数据机密性和完整性的同时，不影响 SCADA 系统的可用性，不在 SCADA 系统的组件上直接部署密码算法和协议，而是在 SCADA 系统组件（如 MTU、PLC、RTU 等）外侧串联安全设备（Security Device），如图 4-14 所示。

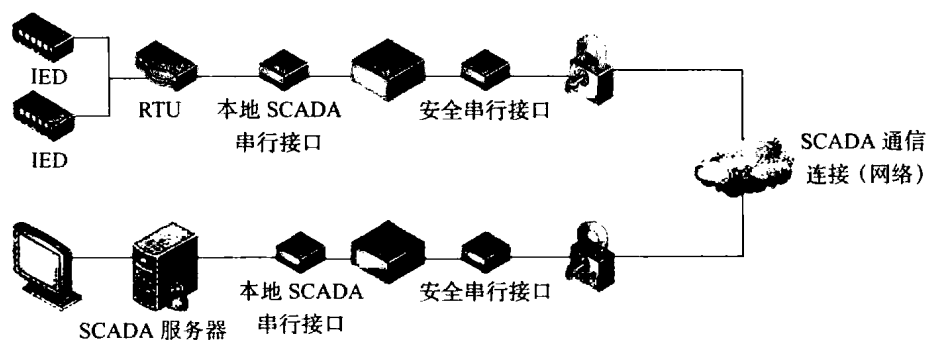


图 4-14 在 SCADA 系统中部署安全设备

2. SCADA 系统密钥管理特点

密钥管理包括密钥产生、分配、存储、保护和销毁，实现通信双方 / 多方实时共享相同的密钥。密钥管理是实现加密和认证的基础，也是确保 SCADA 系统安全通信的核心技术。与传统信息网络相比，面向 SCADA 系统的密钥管理具有其特殊性，这是基于 SCADA 系统存在的各种限制，如表 4-7 所示。

表 4-7 SCADA 系统的限制

限制	说明
RTU 资源受限	RTU 具有少量的内存空间和低处理能力
高可用性	SCADA 系统必须长期运行，不能停工
低带宽	SCADA 系统中的很多链路具有低带宽的特点
实时通信	SCADA 系统要求实时操作工业控制系统设备
结构化网络	SCADA 系统的网络结构是预先设计好的，比较固定
RTU 物理不安全	部署在远端的 RTU 有可能被攻击者俘获并攻击
设备数量多	SCADA 系统的设备非常多

根据 SCADA 系统的特点，SCADA 系统的密钥管理协议需要满足如下需求。

- 1) 密钥更新：SCADA 系统中传输的数据经常重复，如控制网络发送的控制指令经常会重复，传感器采集的数据经常会相同。如果长时间采用相同的会话密钥加密通信数据，攻击者通过分析历时数据容易跟踪相同的信息，所以需要经常更新密钥，保证密钥的新鲜性。
- 2) 组播通信：大多数 SCADA 系统具有组播通信能力。控制网络可以向现场网络中的所有终端设备组播相同的数据包，如通知所有终端设备紧急停机。SCADA 系统的组播通信可以有效降低网络通信代价，提高系统运行效率。因此 SCADA 系统的组播通信数据需要得到有效的安全防护，SCADA 组播密钥管理协议是实现 SCADA 系统安全通信的基础。
- 3) 协议的高效性：为了适应 SCADA 系统的 RTU 资源受限、低带宽、实时性等限制条件，SCADA 系统密钥管理协议必须高效，尽可能使用轻量级密码算法、减少协议交互轮数、减少消息长度等。

3. 典型 SCADA 系统密钥管理协议

文献 [48] 最早提出了一种 SCADA 系统密钥管理协议 SKE。SKE 协议的主要通信模式是“控制器 – 从属器”（Controller-to-Subordinate），例如，SCADA 系统中的 MTU 与 RTU、SUB-MTU 与 RTU 之间的通信，其密钥产生过程如图 4-15 所示。SKE 协议不支持群组安全通信，并且扩展性比较差。

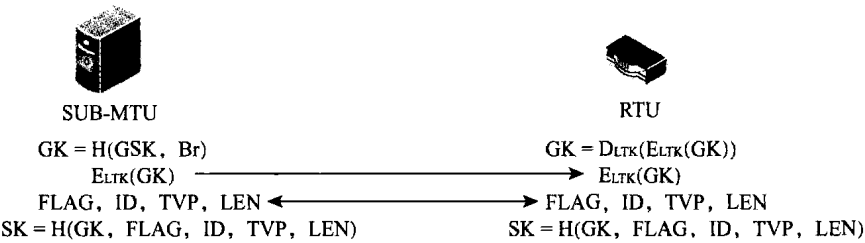


图 4-15 SKE 协议

文献 [49] 提出了一种基于 KDC (密钥分发中心) 的 SCADA 系统密钥分发协议 SKMA。SKMA 协议中将 MTU、SUB-MTU 以及 RTU 都作为节点 (Node), 通过 KDC 为各节点分配安全密钥。SKMA 中的密钥主要包括 KDC 与节点之间的长期共享密钥 (KDC-Node Key)、节点之间的长期共享密钥 (Node-Node Key) 以及节点之间的会话密钥 (Session Key) 3 种, 会话密钥用于加密和认证数据。当新的节点加入时, SKMA 协议基于 KDC 为节点之间建立长期密钥的过程如图 4-16 所示。只要建立节点之间的长期共享密钥, 就可以基于随机数和时戳为节点之间短期会话建立会话密钥。SKMA 协议也不支持安全组播。

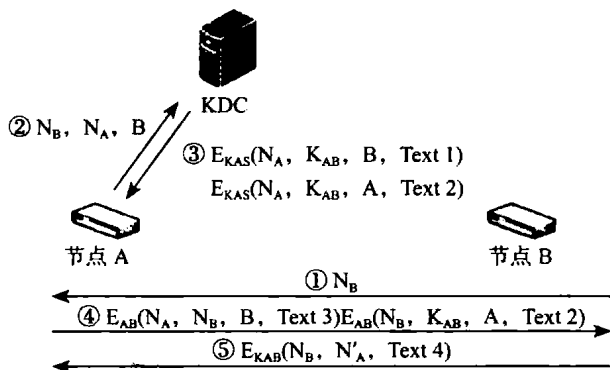


图 4-16 SKMA 协议

文献 [50] 提出了高级 SCADA 密钥管理架构 (ASKMA), 通过逻辑树实现了群组密钥管理, 可以支持 SCADA 安全组播, 如图 4-17 所示。

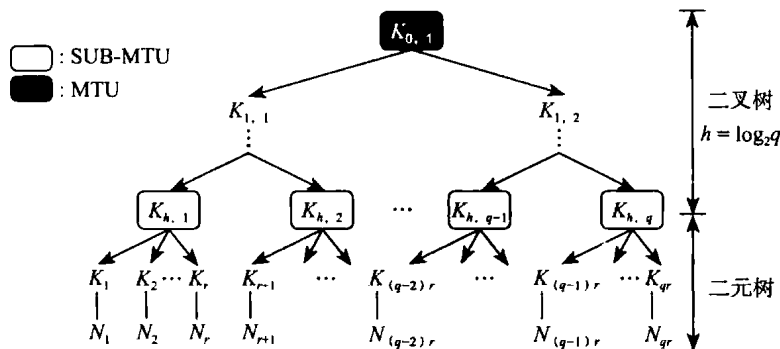


图 4-17 ASKMA 密钥管理架构

文献 [51] 在 ASKMA 的基础上提出了一种效率更高的 SCADA 密钥管理架构 ASKMA+, 如图 4-18 所示。ASKMA+ 减少了 RTU 需要存储的密钥个数, 更加符合 SCADA 实际应用场景。

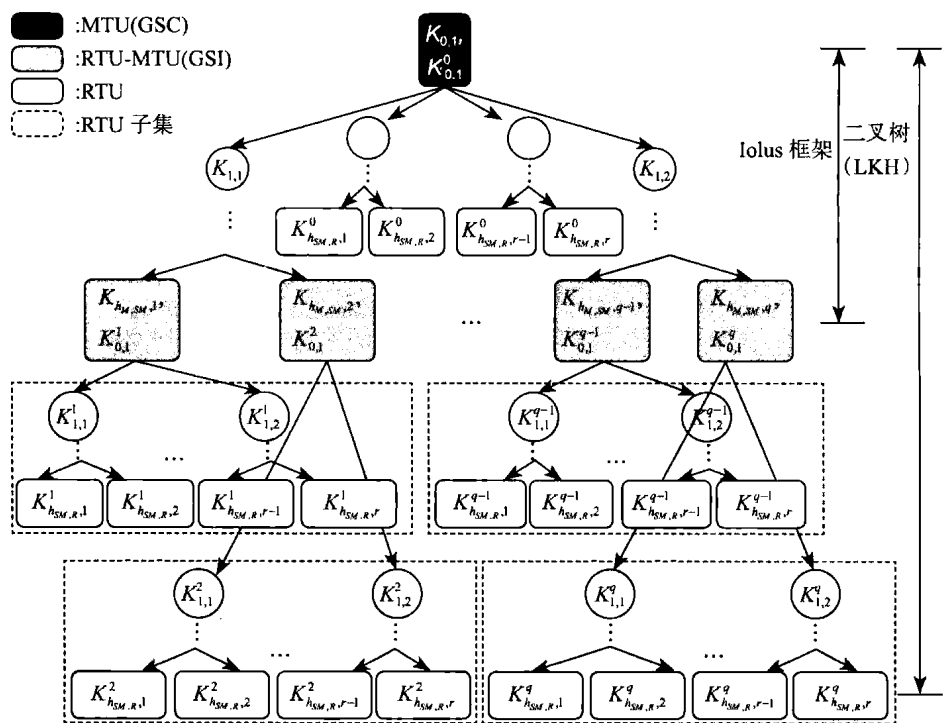


图 4-18 ASKMA+ 密钥管理架构

4.2.4 SCADA 系统安全管理

1. SCADA 系统安全管理控制

SCADA 系统管理控制集中于风险的管理和信息安全管理，是提升 SCADA 系统安全的重要对策。NIST SP 800-53 在管理控制等级中定义了 5 个控制成员。

(1) 安全评估和授权

安全评估和授权为执行周期性评估提供了基础，并提供了安全控制证书。在信息系统中，该证书决定了该控制能否得到正确实施，按照预期操作，并产生期望的结果来满足系统的安全需求。一个高级管理人员对授权系统操作负有责任。另外，所有的安全控制必须按照持续的原则进行监控。监控活动包括配置管理和信息系统组成控制、系统安全影响分析、安全控制持续评估和状态报告。

(2) 规划

一个安全的规划是一个正式的文档，它为信息系统提供了一个安全需求概况，并且在合适的位置描述安全控制，用于满足某些需求。隶属于 NIST SP 800-53 规划成员的安全控制，为开发安全计划提供了基础。这些安全控制也解决了周期性更新安全计划的问题。在

授权进入系统之前,有关信息系统的一系列规则描述了用户的责任和预期行为,用户签署同意使用条款表明他们已经读懂并同意遵守这些行为规则。

SCADA 系统的具体建议和指导:一个安全的规划应该建立在适当的现有 IT 安全方面的经验、计划和实践中;一个前瞻性的规划需要提供一个可持续安全改进的思想。无论新系统何时设计和安装,从结构到采购、安装、维护、解除,花时间解决遍及整个系统的安全问题非常必要。SCADA 安全是一个快速发展的领域,要求在安全规划过程中不断探索新兴的 SCADA 安全功能。

(3) 风险评估

风险评估是一种功能,给定威胁源利用潜在安全漏洞的可能性和成功利用该漏洞所造成的影响。风险评估是一个识别组织运作、资产和个人风险的过程,该过程由识别出的漏洞所造成影响的概率所确定。一个评估包括一个安全控制评价,这个安全控制能减少每个威胁和实施相关安全控制的成本。安全评估也必须比较安全成本和事件相关成本。

实现可接受风险级别是一个减小事件发生概率的过程,可通过减轻或消除可利用漏洞和事件所造成后果的方法实现这个过程。安全漏洞的优先顺序必须基于成本,并且提供一个业务案例,至少实施一个最小的控制系统安全性需求,降低风险到可接受级别,从而使目标受益。在试图选择和实施安全控制之前,必须进行漏洞和风险评估。

属于 NIST SP 800-53 风险评估成员的安全控制提供政策和操作步骤,开发、分发和维护一个成文的风险评估政策,描述安全控制的目的、范围、作用、责任和政策的实施步骤。基于安全目标和风险级别范围对信息系统和相关数据进行分类。执行风险评估来识别风险和一个信息系统及其数据未经授权的访问、使用、泄露、破坏和修改或所可能导致危害的程度。这些安全控制还包括保持风险评估更新、执行周期性测试和漏洞评估机制。

SCADA 系统的具体建议和指导:机构必须考虑在 SCADA 中一个事件所导致的潜在后果。减轻风险技术由明确的政策和程序所确定,设计该技术用于阻挠事件发生和管理风险,消除或使后果最小化。对于 SCADA 来说,风险评估的一个非常重要的方面是确定从控制网络流向办公网络的数据价值。在由这个数据确定价值决策的实例中,数据可能有非常高的价值。通过比较减轻风险的成本和后果的影响,得出减轻风险的财政理由。但是,定义适合所有安全要求的政策是不可能的。也许能实现一个非常高级别的安全控制,然而,由于功能的丧失和其他相关成本,其在大多数情况下是不合适的。一个深思熟虑的安全控制实施必须平衡风险和成本。在多数情况下,风险可能是安全的、健康的或者与环境有关的,而不是纯粹与经济相关。这个风险可能导致不可恢复的后果,而不是临时的金融挫折。

（4）系统和服务获取

属于 NIST SP 800-53 系统和服务获取（SA）成员的安全控制，为满足保护信息系统准确服务获取需求而制定政策和程序提供了基础。这些服务的获取基于安全需求和安全规范。作为服务获取的一部分，使用系统开发生命周期的方法管理一个信息系统，包括信息安全方面的考虑，并在信息系统和构成组件上维持足够的文档。SA 成员也可以处理外包系统，所支持的组织指定的供应商提供足够的安全控制。供应商在这些外包信息系统的配置管理和安全测试方面负有责任。

SCADA 系统的具体建议和指导：一个组织外包管理的安全需求和它所有或者一部分信息系统、网络和桌面环境的控制问题必须在合同当事人之间的约定中得到解决。影响组织安全性的外部供应商必须保持相同的安全政策和程序，保证 SCADA 安全性的整体级别。SCADA 和控制系统获取项目开发了一个获取语言，用于当获取新系统或者维护现有系统时指定安全需求。

（5）项目群管理

属于 NIST SP 800-53 项目群管理（PM）的安全控制，关注的是企业范围内的信息安全要求，它与任何特定的信息系统是无关的，并且对于管理信息安全项目至关重要。

2. SCADA 系统安全管理的 21 个步骤

美国关键基础设施建设保护委员会和能源部已经为改善 SCADA 网络安全性提出了安全管理的 21 个步骤，在促进保护 SCADA 网络安全性上做出了重要贡献。

（1）确认 SCADA 网络的连接完好

要对 SCADA 网络的每一条连接的安全性和必要性进行评估分析。对 SCADA 网络的连接有一个比较综合的理解，并知道它们连接的保护状况。确认和评估以下类型的连接：

- 确认本地和广域网络，包括商业网络。
- 互联网。
- 无线网络设备，包括卫星上行链路。
- 调制解调器或是拨号连接。
- 与商业合作伙伴、供应商和客户之间的连接。

（2）断开没有必要的 SCADA 网络连接

为了保证 SCADA 网络安全度最高，要在最大程度上避免 SCADA 网络与其他网络的连接。任何与外网的连接都会带来风险，尤其是如果这条连接通向互联网。尽管与其他网络的直接连接可以允许重要的信息高效、便利地传输，而不安全的连接绝对是不值得的。为了提供必要的保护而把 SCADA 网络隔离是一个主要的目的。通过使用“隔离区”和数据

库可以使 SCADA 网络和商业网络之间的数据安全传输变得容易一些。然而，这些策略必须设计合理、实施正确，这样才能避免因为不恰当的设置所带来的附加困难。

（3）对 SCADA 网络所剩下的连接安全性进行评估并进一步加强

对 SCADA 网络所剩下的连接进行深入的测试和脆弱性分析，以评估这些路径所处的安全状态。使用这些信息和风险管理为 SCADA 网络的所有链路生成一个强健的保护策略。由于 SCADA 网络的安全取决于它的最薄弱的连接点，所以在每个进入点使用防火墙、入侵检测系统（IDS）和一些其他的安全策略十分重要。配置防火墙可以禁止信息在 SCADA 网络上传输，当然也可以只禁止某些特定的连接。例如，独立系统运行机构不要应用于整个网络，因为 SCADA 系统的某些部分需要连接起来。原则上，把 IDS 置于每个点的入口，向安全人员提醒每个分支的网络安全问题。公司的管理层必须理解和接受由于连接到 SCADA 网络所带来的风险。

（4）通过取消或是减少一些没有必要的服务来巩固 SCADA 网络

建立在商业或是开放源码基础上的操作系统可以通过很多默认的网络服务遭到攻击。要在最大程度上减少、忽略、取消不用的网络服务或是后台，以减少直接的网络攻击。除非经过风险评估显示，这项服务的好处远远大于其潜在的风险所带来的危害，否则绝对不能允许 SCADA 网络使用某项服务或是性能。可以从 SCADA 系统上取消的服务包括邮件服务、互联网访问等。一个可以取消的特性包括远程维护。许多针对商业和开放源码操作系统的安全配置方针都已经公开，如国家安全局的一系列安全方针。另外，要 SCADA 系统供应商紧密合作确认安全配置，协调操作系统的某些或是所有的改变来保证当取消、忽视、减少一些服务后不会导致停工、服务运行障碍或是丧失支持。

（5）不要依靠专有的协议来保护系统

一些 SCADA 系统为了支持在现场设备和服务器之间的通信而使用独立、专有的协议。通常这些 SCADA 系统的安全性只是基于对这些协议的保密性上。然而不幸的是，保密的协议所提供的真正安全少得可怜。所以，不要依靠专有的协议或是为了保护系统安全而进行工厂默认配置。另外，应该要求供应商关闭 SCADA 系统上所有的后门或是供应商接口，并要求他们提供可以得到保护的系统。

（6）执行设备或是系统供应商提供的安全性能

大多数老的 SCADA 系统（正在使用的）没有任何安全性能可言。SCADA 系统的使用者必须要坚持让他们的系统供应商以补丁或是升级的形式提供安全性能。一些新的 SCADA 设备配有基本的安全设备，但是为了保证安装简易，这些功能往往会无效。

分析 SCADA 设备，判断是不是有安全性能，另外，一些出厂默认设置（如计算机网络

防火墙)经常会设置成最大的可用性,结果会导致安全性最小化。要设置所有的安全性能,最大限度地提供安全。只有在通过对减少安全等级所带来的后果进行全面评估之后,才可以降低安全等级。

(7) 严格控制作为 SCADA 网络后门的所有途径

如果 SCADA 网络上真的存在后门或是供应商连接时,要严格执行验证以保证安全通信。调制解调器、通信和维护用的无线及有线的网络是 SCADA 网络和远程站点的最脆弱部分。“战争拨号器”和“接入点映射”等攻击可以使攻击者穿越所有的控制,直接访问 SCADA 网络或是资源。为了把这种袭击的危险最小化,取消入站访问使用类似自动回呼系统。

(8) 执行内部和外部的入侵检测系统,保证每天 24 小时监控

为了对网络袭击具有有效的响应,要使用一种入侵检测策略,当包括来自互联网或是外部资源的恶意行为时,对网络管理员提出警示。入侵检测系统是 24 小时连续工作的,这项功能可以很容易地被设置。另外,事故响应程序必须要恰当,在攻击发生时可以有效地做出动作。为了执行网络的监控功能,要在所有系统上增强日志功能,并且每天审核日志,即时地检测到可疑行为。

(9) 对 SCADA 设备和网络以及其他相连的网络进行技术上的审核

要保证持续的安全性,就要对 SCADA 设备和网络的技术进行审核。许多商用的或是开放源码的安全工具都可以使用,系统管理员可使用这些工具对系统或网络进行审核,确认活跃的服务、补丁级别、普遍的漏洞。使用这些工具虽然不可以解决系统上的问题,但是可以消除攻击者在进行攻击时可以找到的“捷径”。分析已经确认的漏洞,判断它们的意义,采取适当的策略。跟踪正确的行为并分析这些信息,以确认它的发展趋势。然后,在执行正确的行为之后要重新测试系统,以进一步确认漏洞确实被消除。

(10) 进行物理安全调查并对远程站点进行评估

任何连接到 SCADA 网络上的部分都是被检查和评估的目标,尤其是无人操作或是没有任何防范措施的远程站点。在每个设备上都要进行物理上的安全检查,确认并评估所有的信息资源,包括可能被窃听的电话和计算机网络、光缆;可能被利用的无线电和微波线路;可能被访问的计算机终端、无线网络的访问点。消除单纯的点失败,这些点的安全性可以足够阻止未授权访问。不允许只为了方便,在远程或是没有任何保护的站点设置活动访问点。

(11) 成立“特别部队”来明确和找出潜在的攻击

要成立一个“特别部队”来确认潜在的攻击可能,评估系统的脆弱性。要调动尽可能

多的人来全面剖析整个网络、SCADA 系统、物理系统和安全控制的漏洞。每天与系统打交道的工作人员深谙 SCADA 网络的弱点在哪里，所以当要确认可能出现的攻击事件和产生的结果时，一定要向他们讨教。而且内部人员的恶意行为也要充分考虑，要将其作为企业或组织的最大威胁之一。

（12）明确管理人员、系统管理员、用户的角色、责任和权利

组织人员需要了解在保护信息技术资源的时候所明确定义的相关人员的角色和职责的具体期望。另外，关键人物在执行他们所分配的职责时，需要给予充分的权利。通常情况下，良好的网络安全不是单个人的努力可以完成的，这经常会导致整体行动不一致，安全性差。建立一个网络安全组织结构，明确角色和职责，这样就可以明确网络安全问题的严重程度，在危急情况发生时明确应该通知谁来处理。

（13）建立网络架构档案，确认关键系统并进行特殊保护

要把建立一个强健的信息安全架构的档案作为确立一个有效保护策略过程的一部分。组织或是企业在设计他们的网络时应时刻把安全牢记在心，并且在整个生命周期之内对他们的网络架构有一个很好的理解。非常重要的一点是，要求对整个系统所执行的性能和所包含信息的敏感性有一个深刻的理解。如果没有充分理解到这些，就不可能恰当地评估风险，保护策略有可能不充分。把信息安全架构和它的组成部分归档，对于理解整个保护策略、确认单点失败十分重要。

（14）建立一个严格持续的风险管理进程

全面理解网络计算机资源风险，分析“拒绝服务”攻击、敏感信息泄露等对于安全分析是十分重要的。在技术的基础上对风险进行评估，对于生成有效的减少攻击的策略和保护计算机资源的完整性十分重要。最初，所执行的风险分析基于最近的风险评估，并生成一个网络保护策略。因为技术的迅速发展，每天都会有新的危险出现，所以需要进行持续的风险评估，这样可以把每天出现的风险都补充到保护策略中，这样的保护策略也就会持续有效。管理风险的基本工作还包括在保护策略中确认没有消除的风险，通过管理接受此风险。

（15）基于深度安全策略建立一个网络保护策略

深度安全策略是重要的安全保护策略。在进程开始的设计阶段就要考虑深度安全策略，而且所有与网络有关的技术决定也要考虑深度安全策略。无论是已经确认的风险还是在网络各个级别上存在的各种风险都可以使用技术和管理控制来减小。必须避免单点失败，网络安全防御必须分层，限制和包含任何安全事故的影响。另外，每一层必须防止相同层的其他系统进入。例如，为了防止内部的威胁，必须限制用户访问，用户只能访问那些与他

们的工作有关的资源。

(16) 明确网络安全要求

组织或公司应该构建安全程序，为建立预期目的要有授权规定，使执行人员有据可依，正式的规章和进程通常被用来建立和规划一个网络安全程序。一个规范的程序对于建立一个持续的基于标准的网络安全解决方法非常重要，可以消除对个人的依赖。原则和进程还可以使员工明确他们各自的网络安全职责，一旦没有满足要求，后果将会如何。当网络安全事故发生时，员工就会在指导方针的指引下工作进行，在危机时刻采取有效并且高效的行动。用户协议、通知和警告也要作为网络安全要求的一部分。建立规章来使来自内部的恶意行为最小化，包括严格核查工作人员的工作背景，网络权限只授权给绝对必要人员。

(17) 建立有效的配置管理方法

保持网络安全的基本管理进程应包括配置管理，配置管理需涵盖硬件和软件配置。硬件或是软件上的改变极易引入漏洞，进而破坏网络安全。这就需要一些章程来评估和控制任何更改，确保网络保持安全。配置管理起始于我们的系统测试良好，且被证明是安全的。

(18) 进行日常的自我评估

需要强健的性能评估进程为组织提供网络安全策略和技术执行情况的有效性反馈。一个成熟组织的标志就是可以自己明确问题，进行问题根源分析，执行有效且正确的行动来解决独立或系统问题。作为一个网络安全程序一部分的自我评估进程包括日常的脆弱性扫描、自动审核网络、对组织和个体的性能进行评估。

(19) 建立系统备份和灾难恢复计划

建立一个可以从任何紧急情况中（包括网络攻击）快速恢复的灾难复原方案。系统备份是任何计划的重要部分，可以对网络进行快速重建。通常灾难恢复计划要保证他们工作的有效性，并且工作人员要对这些计划十分熟悉。要根据实际得到的经验对灾难恢复计划进行适当的修正。

(20) 高级组织领导者应该对网络安全的执行性能建立期望并负有责任

有效的网络安全性能要求组织的高级管理者承担义务且有领导责任。高级管理人员要对网络安全抱有很高的期望，并与全组织的所有下属经理保持联系。对于高级管理者建立一个网络安全程序架构也十分重要，这个架构可以使一个网络安全程序拥有持续的执行力。当然，每个个体也要对他们自己的工作负责，因为这关系到网络安全。这些个体包括经理、系统管理员、技师和用户 / 操作员。

(21) 建立安全管理原则并开展培训

公布关于 SCADA 网络的相关数据必须在严格且必须公布的基础之上，且保证只公布

给授权人员。“社会工程”陷阱通过提问收集单纯的用户关于计算机或计算机网络的信息，通常是计算机网络恶意攻击的第一步。某台计算机或计算机网络所泄露的信息越多，这台计算机或网络就越危险。记住，不要通过电话或对个人泄露关于 SCADA 网络的信息，包括系统操作员 / 管理员的名字或联系方式、计算机操作系统、计算机或网络的物理或逻辑地址，除非他们是明确授权可以得到这些信息的人。人是网络安全的薄弱环节，要进行培训和信息安全活动，保证工作人员在保护敏感网络信息尤其他们的密码方面时刻保持警觉。

4.3 SCADA 系统安全测试平台

SCADA 系统的高可靠性和高安全性等特殊需求，使得直接评估实际 SCADA 系统的脆弱性并部署 SCADA 系统安全措施变得不可行，因此迫切需要研制相应的 SCADA 安全测试平台仿真模拟实际 SCADA 系统，并以此为基础进行安全评估和防范研制。

4.3.1 SCADA 系统安全测试平台的重要性

尽管在实际的 SCADA 平台上进行安全性评估更有说服力，但是由于一些实际存在的问题限制了使用实际 SCADA 系统进行测试和评估工作。这些问题体现在以下几个方面。

（1）测试成本

为了测试一项安全方案或者进行一次漏洞攻击实验而搭建实际的 SCADA 系统是不现实的。实际的 SCADA 系统包含了大量的分布式数据收集设备以及相关的通信设备，使用这样的系统进行测试将消耗大量的资金，这在大部分情况下是不可承受的。

（2）测试对系统的影响

在实际 SCADA 系统上进行拒绝服务攻击（DoS）或者分布式拒绝服务攻击（DDoS）等测试实验将影响 SCADA 系统的响应速度，严重时可能会关闭整个系统。这样的攻击测试对于需要实时运转的 SCADA 系统来说是不可接受的，如电力、石油和水利等工控系统。

（3）面临失败的风险

在实际的 SCADA 系统上运行未经过充分测试的安全方案将存在潜在的风险。存在漏洞的安全方案不适合在实际 SCADA 平台上部署，除非这些方案经过了严格的测试。

（4）与互联网隔绝

测试用的 SCADA 平台处在一个独立的模拟网络环境中，在这样的环境中可以避免外部网络对在测试平台上进行的安全实验造成负面影响。另外，在测试平台上进行的攻击实验可以在可控的条件下进行，避免这些实验由于失控造成没有必要的损失。

基于 SCADA 测试平台的科研工作可以分为实时监控、异常及入侵检测、安全分析与评估、减灾策略的提出及测试 4 个阶段，如图 4-19 所示。

在实时监控阶段，研究人员需要针对特定的应用场景组建相应的测试平台，如智能电网和油气输送。根据应用场景将测试平台搭建所需的软件和硬件设备进行连接，之后运行测试平台保证监控和采集过程能够顺利进行。接下来的异常及入侵检测阶段中，研

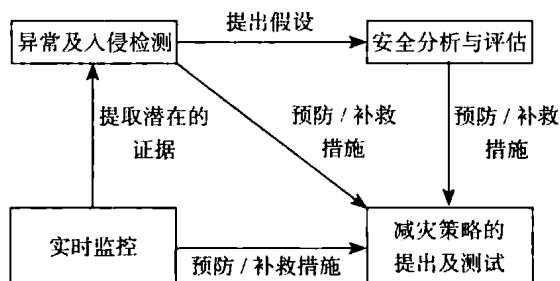


图 4-19 SCADA 测试平台实验的一般流程

究人员模拟恶意入侵者的一些行为对平台进行模拟攻击实验，如发动拒绝服务攻击或者篡改通信数据，当然也可以在测试平台的一些组件中注入恶意代码影响其正常的监控及采集过程。在安全分析与评估阶段，基于前一个阶段各类攻击对测试平台的影响评估系统的脆弱性并分析系统的漏洞。最后结合平台的实验结果提出相应的减灾方案，对系统进行安全加固。

4.3.2 SCADA 系统安全测试平台的分类

目前提出的 SCADA 测试平台搭建方案可以分为两类：纯软件模拟的测试平台和使用硬件搭建的测试平台。

1. 软件测试平台的优缺点

使用软件虚拟出 SCADA 系统中的各种设备，这种模拟测试平台的优点体现在以下 4 个方面。

(1) 较高的可重复性

使用软件模拟的测试平台避免了研究机构重新搭建平台的过程。当一个开放的软件模拟平台不能满足一个研究机构的需求时，研究人员仅需花费少量的时间改进现有平台而无须从头构建。

(2) 为科研工作提供共同的平台

尽管有些科研机构已经拥有自己的 SCADA 测试平台，研究人员仍然可以测试并发布这个开放性平台的其他版本。这样做的好处一方面是可以共享部分代码，另一方面是方便了不同机构间进行试验结果的比较。

(3) 可用来捕捉正常系统和异常系统的快照

入侵检测系统的研究者需要捕获系统在正常运行情况下的系统快照，以此为基准与系

统在受到攻击的情况下捕捉的快照进行对比,由此方便系统异常的监测。

(4) 方便大规模系统的组建

对于需要大规模组建的 SCADA 测试平台,软件模拟的方案很好地解决了这个问题。软件虚拟的设备不需要考虑成本问题,这对于大规模的 SCADA 系统来说是一个很好的选择。

软件模拟的 SCADA 测试平台也有它的缺点,体现在以下两个方面:

1) 不能测试特定的恶意攻击。SCADA 软件测试平台难以模拟针对实际硬件漏洞而发动的攻击,从而不能进行全面安全测试。

2) 测试结果偏差比较大。SCADA 软件测试平台由于将大部分 SCADA 组件进行了虚拟化处理,所以无法完整、准确地模拟硬件的实际运行状况。

2. 硬件测试平台的优缺点

在一些 SCADA 测试平台搭建方案中,研究人员使用了能够用于实际 SCADA 系统的硬件设备,如传感器和电动机,这些硬件也可能是实际设备的小型化版本。

使用实际硬件搭建测试平台的优点体现在以下 3 个方面:

1) 实验获取的数据更真实,具有较强的说服力。

2) 没有操作系统等软件因素的影响,使得系统的控制过程更为准确。

3) 由于硬件的个体独立性,攻击实验可以针对某一具体设备进行,并且不会干扰到其他系统组件。

硬件测试平台不可避免也有自身的缺点,主要体现在 3 个方面:

1) 当 SCADA 系统具有较大的规模时,使用硬件搭建测试平台的成本较高,大量的设备需要花费高额的资金。

2) 硬件测试平台的扩展性较差,不容易随意增加设备或者为 SCADA 系统添加新的特性。

3) 测试平台不可能像实际的 SCADA 平台一样在设备上完全一致,大部分情况下这些设备比实际小很多,功能上也可能会受到制约。

4.3.3 SCADA 系统安全测试平台的搭建

(1) 软件测试平台的搭建

文献 [52] 提出了一种电力系统模拟平台搭建方案。在该方案中,SCADA 系统由两部分组成:客户端和服务端。客户端运行在 SCADA 系统管理人员可以控制的计算机上,该客户端提供图形界面来显示整个系统的全局情况。客户端的数据来源于服务端,服务端通过 TCP/IP 协议传输数据。客户端同时提供控制和监视系统的接口,该客户端可以接入多

个服务器端进行数据检索，也可以改变虚拟设备或线路的状态。服务器端使用 PowerWorld 软件模拟 SCADA 系统的其他组件，如 MTS、RTS/IED 以及 Field Device。用户在搭建系统时，可以在服务器端的图形界面上对虚拟的设备和线路进行可视化布局。该测试平台搭建方案没有使用具体的智能电子设备（IED）或者可编程逻辑器件（PLC），整个实验过程在虚拟的平台上完成。该平台为了模拟现实中复杂的互联网拓扑结构，在客户端与服务器端之间使用 RINSE 网络模拟器构建一个虚拟网络。

文献 [53] 提出的软件模拟测试平台中所有的虚拟设备都使用 Python 语言编写，每个设备都有相应的通信接口及设备逻辑。除了虚拟的设备外，该平台还提供过程模拟器、配置文件以及日志记录组件。过程模拟器负责对整个 SCADA 系统进行建模，包括系统的层次结构及虚拟设备间的连接关系。配置文件描述了特定设备的参数，研究人员可以通过更改这些参数来改变虚拟设备的特性。日志记录组件的功能是记录系统运行状态的历史数据，包括设备的异常信息、状态信息及一些传感器产生的参数。该平台由于将整个 SCADA 系统模块化定制，所以在构建大规模系统时有较大的优势。

（2）硬件测试平台的搭建

文献 [54] 提出了一种结合实际传感器和智能电子设备的 SCADA 测试平台搭建方案。在该方案中的测试平台使用超声波测距传感器测量水箱的水位高度，并使用电动机向水箱给排水以保持水位在预定的高度。平台使用的超声波测距传感器、电动机基于 Lego Mindstorms NXT 微控制器。为了模拟实际 SCADA 系统复杂的网络结构，平台使用 OMNET++ 软件模拟 SCADA 核心网络部分。这样由硬件和软件结合搭建的平台能够更好地对实际 SCADA 系统进行模拟，在该平台上的实验具有更高的可信度。

文献 [55] 提出了一种用于教学和科研的 SCADA 测试平台。该平台的组件按照通信方式可以分为两类：串口通信控制系统和基于以太网通信的控制系统。平台使用了较多的物理设备模拟实际工业的控制系统。串口通信控制系统中包含油气输送管道、储水箱、水塔、工厂传送带以及工业电动机。基于以太网的控制系统主要包含钢铁轧制系统和智能电网传输系统。该平台的人机交互接口（HMI）允许 SCADA 系统操作人员使用 Modbus/ASCII、Modbus/RTU 和 DNP3 这 3 个协议控制所有的工业子系统，并将这些系统的实时状态显示在图形化界面上。该平台可以用于高校或研究机构的教学或科研工作。

4.3.4 基于 SCADA 系统安全测试平台的实验

（1）拒绝服务攻击

拒绝服务攻击通过限制网络中设备的服务能力使 SCADA 系统处于瘫痪状态。攻击者

也可以入侵系统中的特定设备使其不能对外服务,如智能电网。在这类试验中,研究人员可以首先组织一个“僵尸”网络,通过发动大规模的拒绝服务攻击破坏整个 SCADA 系统的服务能力。或者找出系统中一些设备存在的漏洞并入侵,在完全控制这些设备后修改设备的运行状态使其不能正常响应客户端的数据查询或状态变更请求。为了应对这类攻击,SCADA 系统可以部署包过滤防火墙和入侵检测系统,阻挡无效的请求并检测设备的异常行为,将这些情况及时报告给 SCADA 系统管理员并采取相应的措施。

(2) 蠕虫感染

计算机蠕虫具有自我复制并通过网络传播感染其他主机或设备的能力。当蠕虫被激活后,其行为可以像计算机病毒一样安装木马程序或者在感染设备上执行相应的操作。在这样的实验中,研究人员可以利用 SCADA 服务器上的软件漏洞传播蠕虫。这些蠕虫可以关闭设备的网络连接,使设备从 SCADA 网络中独立出去。Fovino 等人在文献 [56] 中使用 MalSim 恶意软件模拟器进行这样的攻击实验并取得了较好的效果。为了抵御蠕虫对系统的感染,对服务器和设备进行定期升级并查杀蠕虫是一个必要的手段。

处理网络涵盖了整个 SCADA 系统,如在监控区域控制电力网络的 RTU 设备。这些 RTU 设备通过 Modbus 或 DNP3 这样的协议通信。在这样的情形下,如果一个感染了恶意软件的节点与其他节点通信,那么其他节点也将被注入恶意软件。恶意病毒主要有两种类型,一种是关闭自身与其他设备连接的 DoS 恶意软件,另一种是可以执行恶意操作的病毒。预防恶意软件感染同样需要系统管理人员具有足够的安全意识,经常检查系统的软件异常行为能够较有效地将恶意软件及时排除。

(3) 消息欺骗及钓鱼攻击

这类攻击的主要目的是进行信息的收集,攻击者通过让目标主机或设备连接到恶意站点后骗取相关信息。攻击的实施可以通过修改 DNS 服务器的域名解析规则,使 SCADA 系统中用到的域名解析到恶意服务器,完成正常设备对恶意设备的连接。SCADA 系统需要具备对异常主机或设备检测的能力,防止异常组件对系统的其他部分造成破坏。

4.3.5 SCADA 系统安全测试平台实例——HoneyNet

SCADA HoneyNet 测试平台由两台虚拟机共同组成,如图 4-20 所示。一台虚拟机模拟实际 SCADA 系统的复杂网络情况,另一台虚拟机模拟实际部署的区域监控设备的运行情况,如传感器节点采集的数据模拟。

该虚拟平台设备上运行了一系列服务,这些服务可以很好地模拟实际 SCADA 系统的一些必需功能和服务。

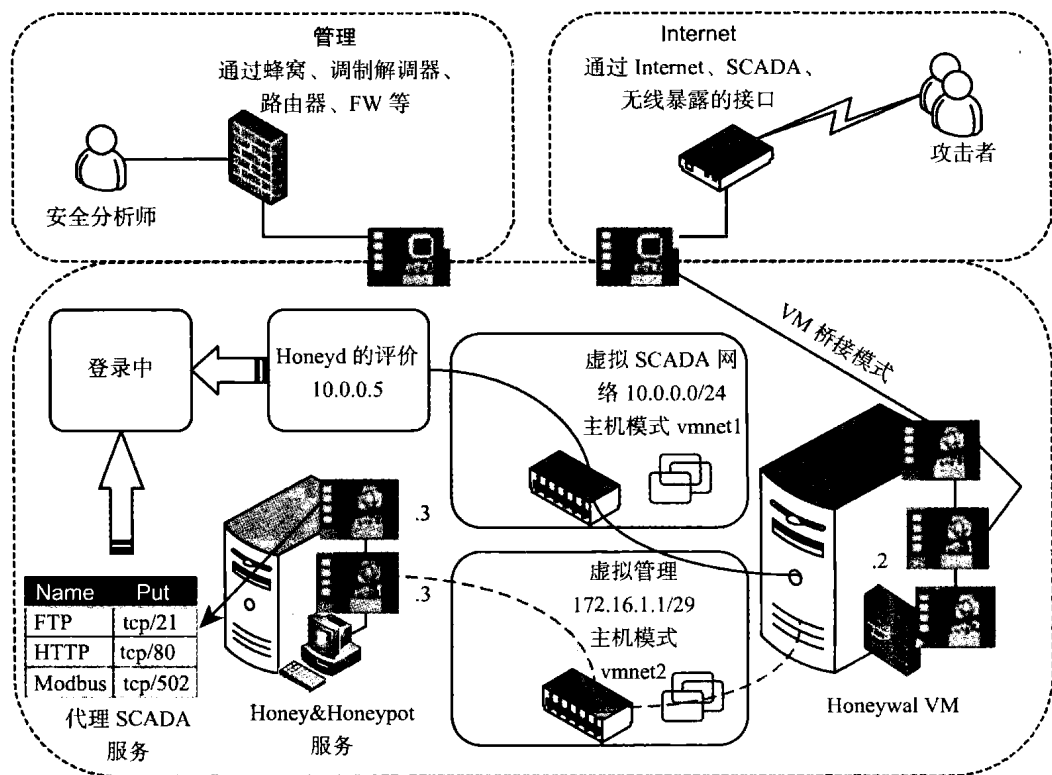


图 4-20 SCADA HoneyNet 测试平台

(1) Modbus TCP 服务

平台提供了开放性的 Modbus TCP 接入服务，攻击者可以通过 Modbus 客户端接入这个 SCADA 网络中，并且可以读取到一些模拟的变电系统参数，如电压、电流以及断路器等等继电保护设备的工作状态。攻击者也可以修改可编程逻辑控制器属性，以此来破坏变电系统数据的完整性。

(2) FTP 服务

平台提供了 VxWorks FTP 服务，SCADA 系统管理员可以通过该服务对可编程逻辑控制器的固件进行升级或配置。

(3) Telnet 服务

测试平台内置了远程连接服务，攻击者可以利用此服务对 SCADA 模拟设备进行参数设置和修改。

(4) HTTP 服务

SCADA 系统中的区域设备所采集的数据以及设备状态信息可以通过 HTTP 服务传递给系统管理员，方便管理员随时掌握系统运行状态信息，同时该服务给攻击者提供了系统接入的机会。

(5) SNMP 服务

简单网络管理协议 (SNMP) 可以向系统管理员或攻击者提供监控和控制 SCADA 网络的接口。

4.4 SCADA 系统安全典型案例

电力 SCADA 系统是最为典型的 SCADA 系统, 面临着各种安全威胁, 受到安全攻击。目前已经报道的 SCADA 系统受攻击的实际案例, 很多也是针对电力 SCADA 系统的。

1. 电力 SCADA 系统运行机制

SCADA 系统在电力工业控制系统中占据着举足轻重的地位, 主要包括数据采集和监视控制两大功能。电力 SCADA 系统持续从终端设备收集数据, 并返回控制命令, 确保终端设备持续正常运行, 为电力系统的运行维持一个稳定的工作环境。

电力系统日常的工作离不开 SCADA 系统的支撑, SCADA 系统具有多种功能, 确保电力系统正常地运行。电力 SCADA 系统的功能包括识别故障、隔离故障设备和恢复服务, 断路器和重合器控制, 馈线开关和侦察网络配置, 线路开关、电压控制、负荷管理、自动抄表、自动发电控制、经济调度、模拟和仿真、电容器组合开关、电压调节器监测、变压器温度和计量。为了确保电力的可靠供应, 电力系统依据 IEEE 标准 C37.1 的规定, 具有内置的自动保护和控制功能。自动继电器、自动开关和断路器通过改变功率流路线确保电源不间断的供应, 以避免可能会破坏功率流的故障。如果 SCADA 系统出现故障或者发送控制信号关闭不必要的功率流, 那么自动控制装置将自我纠正, 并发送正确的控制信号确保持续的电力供应。然而, SCADA 系统的控制功能只能在电力系统特定参数范围内有效。例如, 当变电站没有加热器时, SCADA 系统并不能够提高变电站的温度。

2. 电力 SCADA 系统存在的安全问题

在电力 SCADA 系统应用之初, 其工作环境是相对隔离的, 属于独立的系统和网络, 这在一定程度上保证了它的安全性, 并且 SCADA 最初应用的目的旨在功能的最大化, 只着眼于系统有效地运行而忽视了它的安全性。如今, 在电力系统中计算机网络技术被广泛应用, 而由此所带来的安全问题也日益凸显。

(1) 不安全的网络体系结构

为了提高电力 SCADA 系统网络以及企业网络的安全性, 适时适当地与公用网络断开是网络体系结构设计需要着重考虑的问题。网络体系结构设计的不足可增加 SCADA 系统的风险, 从互联网上引发的攻击可能会导致 SCADA 系统受到威胁。常见的网络体系结构

弱点如下：文件传输协议（FTP）、网络和电子邮件服务器有时不经意间提供企业内部的网络访问；企业合作伙伴之间通过防火墙、入侵检测系统或与其他网络相连的虚拟专用网络（VPN）连接并不安全；拨号调制解调器接入企业网络，往往不能实行企业拨号访问策略；防火墙和其他网络访问控制机制没有在内部实现，使得不同的网段之间并没有完全隔离。

（2）通信协议的漏洞

我国电力 SCADA 系统采用的通信协议为 IEC 60870-5、IEC 60870-6、IEC 61850 等。由于 SCADA 系统的很多协议不支持加密技术，攻击者可以成功侵入网络嗅探通信网络，攻击者可以检测到数据和控制命令，并使用这些控制命令发送错误信息。网络攻击者还可以在传输网络上篡改数据，导致设备不能正常工作。更严重的情况是，攻击者可能会篡改操作员的显示值，导致当警报响起时人们并不能察觉，延迟人们对紧急情况反应的时间，甚至危及工作人员的生命。

3. 电力 SCADA 系统安全通信

电力 SCADA 通信传输网，即控制中心与变电站间的远程通信，存在严重的安全问题。SCADA 通信传输网与一般计算机网络在实现技术上具有相似性，均属于数据通信网，但是，电力 SCADA 传输网又具有诸多方面的特殊性。

（1）实时性

电力 SCADA 传输网要求通信站点必须在规定的时间内予以响应，其对于延迟时间要求严格，一般在 1 s 以内。若通信站点对信息未能在规定时间内完成响应，将会对 SCADA 系统正常运行造成危害。

（2）安全性

电力 SCADA 传输网主要进行“四遥”信息的通信，而“四遥”信息是实现控制调度自动化的基础，一旦信息被破坏会造成电力系统的重大事故，因此 SCADA 通信传输网具有很高的安全性。

（3）可靠性

电力 SCADA 传输网是 24 小时不间断运行的，当遭到攻击、破坏时，能够在几十毫秒以内实现自动保护和恢复。因此其具有很高的可靠性，SCADA 传输网一般都会具有冗余设计。

4.5 SCADA 系统安全发展趋势

1. 自动化系统逐渐 IT 化是发展趋势，网关隔离是第一道防护

德国工业 4.0 已经将工业向互联网方向发展，随着工业自动化技术的发展，各行业呈现

生产设备的智能化、生产业务的可视化、过程监控的实时化、全部过程的安全化、决策需求的全景化需求等特点。信息技术（包括硬件技术、操作系统技术、网络技术）逐步渗入电力、化工、冶金、交通等各种行业的日常运行中，这些系统的正常运行保证了国民经济的正常健康运行，同时保证了人民享受安全舒适的生活环境；而工业自动化系统的安全事件频发则为自动系统正常稳定运行蒙上了阴影，此类事件往往会影响到国民经济和人民生活密切相关的设施，带来巨大的破坏性，为了抵御此类事件的发生，必须进行工业自动化系统安全控制技术。

2. 传统边界网关防护设备不能满足工业控制环境

传统的边界防护产品不能满足工业控制环境，主要体现在以下几方面：①传统的边界防护网关可能对工业控制系统的性能及网络环境产生影响；②控制层一般使用特殊的工业协议或介质，传统的边界网关设备不能对此协议进行解析和控制；③自动化系统设备接入点诸多，成本太高，需要使用的安全设备配置与为一个 IT 系统进行安全配置的方案相比具有较大差异；④传统的边界防护对恶劣的工业环境的适应性。

3. 整合自动化与信息安全公司优势，带动产业发展

由于目前国内的工控安全网关分两个方向，一是自动化厂商，二是传统信息安全厂商，两类厂家产品设计理念、架构及功能均不同，国家也未出台相关工业安全防护网关产品的相关标准，目前行业内未形成统一气候，需要整合实际用户的需求对产品进行完善和适用性应用。

工控安全不但是国际和国内 IT 市场的关注热点，更是中国政府、军队、大型企业未来的安全核心。在过去很长的一段时间内，各大安全厂商群雄逐鹿，都将重心放在了传统安全产品的更新换代上，市场中“下一代”产品层出不穷，真正的工控安全却鲜有关注。

4.6 本章小结

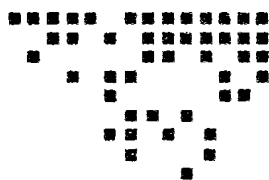
本章我们讨论了 SCADA 系统的安全需求和安全目标，SCADA 系统与传统信息系统一样，其核心安全目标都是机密性、完整性和可用性，但是 SCADA 系统在性能要求、实时性要求、风险管理要求、物理相互作用等方面与传统信息系统存在巨大的区别；讨论了 SCADA 系统安全关键技术——安全域划分、密钥管理和风险评估等；对 SCADA 系统的测试平台进行了介绍，并阐述了 SCADA 系统安全的发展趋势。

通过本章的学习，我们对 SCADA 系统的安全概况有了较为全面的理解，后面的章节

将对 SCADA 中使用的协议和设备存在的安全问题进行讨论。

4.7 本章习题

1. SCADA 系统由哪些部分组成？请简要介绍各个部分。
2. SCADA 系统和传统信息系统的安全目标有什么相同和不同之处？
3. SCADA 系统存在哪些脆弱性？请对这些脆弱性进行简要概述。
4. 根据入侵检测分析方法的不同可将入侵检测系统分为哪些种类？请简要概述这些不同的种类。
5. SCADA 系统的网络通信容易受到哪些攻击？
6. 为什么要在 SCADA 系统安全测试平台中进行安全评估，而不是在实际系统中？
7. 请简要概述电力 SCADA 系统存在的安全问题。
8. 根据 CVE-2011-4876 的信息，部署组态环境进行漏洞的测试和验证。



工业控制网络通信协议的安全性分析

工业控制系统的现场网络与控制网络之间的通信、现场网络各工控设备之间的通信、控制网络各组件的通信往往采用工业控制系统特有的通信协议，工业控制系统通信协议往往是专用、私有控制性协议，目的是满足大规模分布式系统的实时性运作需求。这就表现为这一大类通信协议设计之初主要考虑效率问题，而忽略其他功能需求。在两化融合、工控系统安全面临风险越来越大的背景下，没有考虑安全问题的工业控制系统通信协议逐渐成为工控系统安全的关注点。例如，Modbus 协议、Profinet 协议、DNP3 协议、OPC 协议、IEC 系列协议等常见工业网络协议，为了保障通信的实时性和可靠性而放弃认证、授权和加密等需要附加开销的安全特征和功能，存在严重的安全问题。本章将重点分析 Modbus 协议、DNP3 协议、OPC 协议、IEC 系列协议存在的安全问题，以及采用的安全防护技术。

5.1 工业控制网络常用通信协议概述

工业控制协议是随着现代工业自动化的飞速发展而诞生的。工业控制协议的应用覆盖面很广，从应用行业的角度来说，其发展轨迹从工业现场总线、局域网络至当今互联互通的无线物联网行业，设计标准与 OSI 七层设计并不具有一一对应的关系。从行业角度来看，目前存在的工业控制网络协议分类见图 5-1。

工业控制网络是在现场总线技术的基础上发展而来的，它是用具有数字通信能力并能大量分散在生产现场的测量控制仪表作为网络节点而构成的。工控网络具有较高的公开性，

对于通信协议的可靠性、实时性要求很高。标准化工业控制网络协议的出现,方便地实现了各种异构现场设备之间的无障碍通信,使工业生产更自动化,在大型工业控制网络里现场总线就不能很好地完成相关的任务。

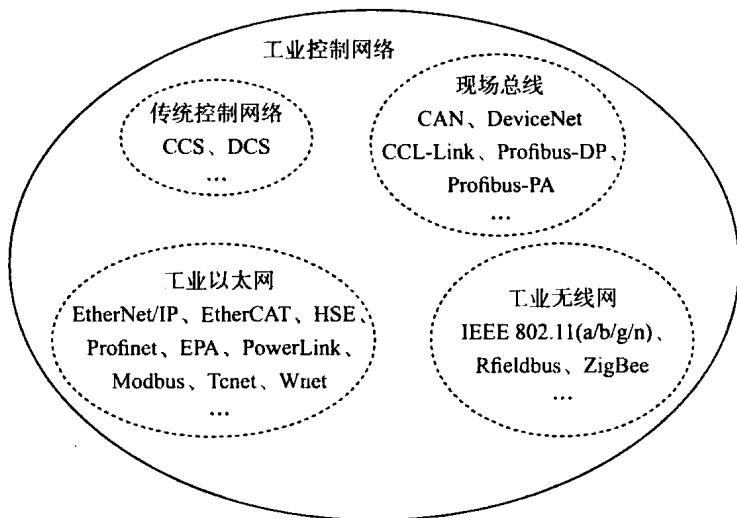


图 5-1 工业控制网络的协议分类

工业控制网络按不同的行业对于控制精度可划分为实时的网络协议和非实时的网络协议。工业以太网以优良的性价比、可靠的媒介传输容量、良好的传输质量、成熟的体系结构,具有其他网络传输介质不可比拟的优势,广泛地应用于各工业控制系统网络环境中。

另外,以 TCP/IP 为基础的工业控制应用协议,也因其开放性,广泛地应用于各类工业系统中。一般来说,协议安全性问题可以分为两种:一种是协议自身的设计对安全性考虑的先天不足,即从设计方面引入的安全问题;另一种是协议的不正确实现引起的安全问题,黑客入侵时将对这些不安全的设计或者实现进行相关的渗透和利用。本章列举了当前工业控制系统中常见的几种基于以太网或 TCP/IP 的工业控制协议,并对其脆弱性和安全防护原理与相关的技术进行阐述。

5.2 Modbus 协议

Modbus 是一种应用层消息传输协议,位于 OSI 模型的第 7 层,通过此协议,控制器之间、控制器经由网络(如以太网)和其他设备之间可以通信。本节将对 Modbus 进行详细介绍,包括协议描述、数据编码等,还将对 Modbus 存在的安全问题和防护技术进行讨论。

5.2.1 Modbus 协议概述

1979 年, 莫迪康 (Modicon) 发明了 Modbus 协议 (因此 Modbus 是 Modicon's BUS 的简称), 成为业界第一个真正用于工业现场的总线协议。因其简单易于实现, 得以迅速推广, Modbus 使得成千上万的自动化设备能够通信。莫迪康公司作为协议发明者, 并没有因为 Modbus 的推广而受益, 反而是公司几经动荡, 最终被施耐德控股公司收购, 成为施耐德子公司。

基于 Modbus 的长远发展考虑, 施耐德公司将 Modbus 协议的所有权移交给 IDA (Interface for Distributed Automation, 分布式自动化接口) 组织, 使得 Modbus 成为一个标准、开放, 用户可以免费、放心地使用的协议, 并成为通用工业控制系统通信标准, 使不同厂商生产的控制设备可以连成工业网络, 进行集中监控。此协议定义了一个控制器能认识使用的消息结构, 而不管它们是经过何种网络进行通信的。它描述了一个控制器请求访问其他设备的过程, 如何回应来自其他设备的请求, 以及怎样侦测错误并记录。它制定了消息域格局和内容的公共格式。我国也对 Modbus 进行了国家标准转换, 形成 GB/T 19582—2008。

互联网组织能够使用 TCP/IP 栈上的保留系统端口 502 访问 Modbus。这也是 TCP/IP 协议唯一为工控系统协议保留的端口号。目前, 使用下列方式实现 Modbus: 以太网上的 TCP/IP、各种物理介质 (有线如 EIA/TIA-232-E、EIA-422、EIA/TIA-485-A; 光纤、无线等) 上的异步串行传输^[57], 如图 5-2 所示。

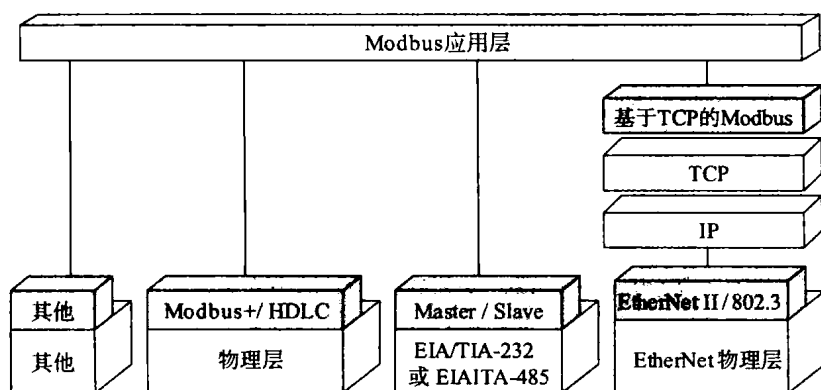


图 5-2 Modbus 通信栈

Modbus 协议允许在各种网络体系结构内进行简单通信。每种设备 (PLC、HMI、控制面板、驱动程序、动作控制、输入输出设备) 都能使用 Modbus 协议来启动远程操作。在基于串行链路和以太 TCP/IP 网络的 Modbus 上可以进行相同通信。一些网关允许在几种使用

Modbus 协议的总线或网络之间进行通信。图 5-3 为 Modbus 网络体系结构的一个案例^[58]。

Modbus 协议定义了一个与基础通信层无关的简单协议数据单元 (PDU)，特定总线或网络上的 Modbus 协议映射能够在应用数据单元 (ADU) 上引入一些附加域。图 5-4 是一个标准的 Modbus 帧结构。

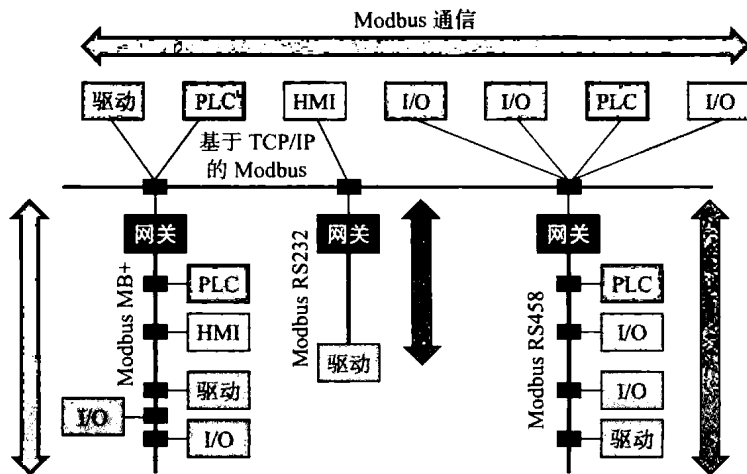


图 5-3 Modbus 网络架构

Modbus 是采用请求 / 应答方式的应用层消息协议，非常方便实现在低级设备和高级设备间通信，它包含三个独特的协议数据单元 (Protocol Data Unit, PDU)：Modbus 请求 (Modbus Request)、Modbus 应答 (Modbus Response) 以及 Modbus 异常应答 (Modbus Exception Response)。通信过程如图 5-5 所示。

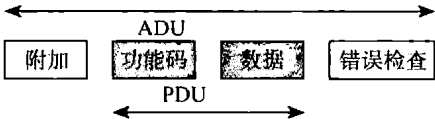


图 5-4 Modbus 帧

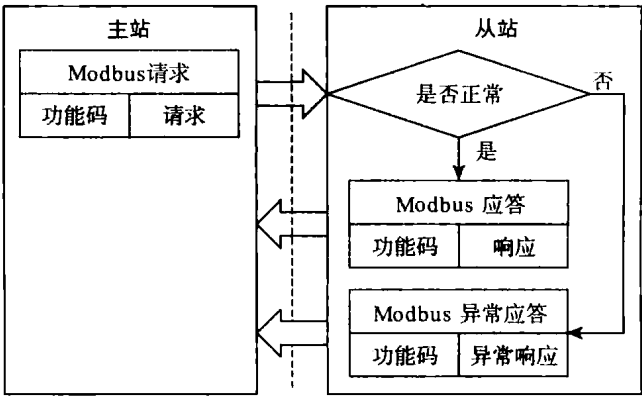


图 5-5 Modbus 协议工作机制

使用 Modbus 协议通信的每个设备都必须指定一个地址。在通信工作中，每个命令都会指定目的地址，虽然非通信设备也可能收到命令消息，但只有地址匹配的才会响应。客户端发起一个包含初始功能码和数据请求的请求 PDU，启动会话，服务器端有两种应答方式，正常情况下，服务器端回复一个包含功能代码和数据应答的应答 PDU。如果发生错误，设备会回复一个包含异常功能代码与异常代码的 Modbus 异常响应。

功能码和数据请求可用于指定多种命令，常见的命令包如控制 I/O 接口、读取 I/O 接口数据、读寄存器值、写寄存器值等，详细功能码介绍如下：

Modbus 功能码有以下三种类型：

- 公共功能码：是较好地被定义的功能码，保证是唯一的；Modbus 组织可改变的、公开证明的、具有可用的一致性测试；MBIETF RFC 中证明的、包含已被定义的公共指配功能码和未来使用的未指配保留功能码。
 - 用户定义功能码：有两个用户定义功能码的定义范围，即 65 至 72 和 100 至 110；用户没有 Modbus 组织的任何批准就可以选择和实现一个功能码，不能保证被选功能码的使用是唯一的；如果用户要重新设置功能作为一个公共功能码，那么用户必须启动 RFC，以便将改变引入公共分类中，并且指配一个新的公共功能码。
 - 保留功能码：一些公司对传统产品通常使用的功能码，并且对公共使用无效的功能码。
- 具体功能码定义如表 5-1 所示。

表 5-1 Modbus 功能码

功能码	名称	作用
01	读取线圈状态	取得一组逻辑线圈的当前状态 (ON/OFF)
02	读取输入状态	取得一组开关输入的当前状态 (ON/OFF)
03	读取保持寄存器	在一个或多个保持寄存器中取得当前的二进制值
04	读取输入寄存器	在一个或多个输入寄存器中取得当前的二进制值
05	写单线圈	强置一个逻辑线圈的通断状态
06	写单寄存器	把具体二进制值装入一个保持寄存器
07	读取异常状态	取得 8 个内部线圈的通断状态，这 8 个线圈的地址由控制器决定，用户逻辑可以将这些线圈定义，以说明从机状态，短报文适宜于迅速读取状态
08	回送诊断校验	把诊断校验报文送从机，以对通信处理进行评鉴
09	编程（只用于 484）	使主机模拟编程器作用，修改 PC 从机逻辑
10	控询（只用于 484）	可使主机与一台正在执行长程序任务的从机通信，探询该从机是否已完成其操作任务，仅在含有功能码 9 的报文发送后，本功能码才发送
11	读取事件计数	可使主机发出单询问，并随即判定操作是否成功，尤其是该命令或其他应答产生通信错误时
12	读取通信事件记录	可使主机检索每台从机的 Modbus 事务处理通信事件记录。如果某项事务处理完成，记录会给出有关错误
13	编程（184/384 484 584）	可使主机模拟编程器功能修改 PC 从机逻辑

(续)

功能码	名称	作用
14	探测 (184/384 484 584)	可使主机与正在执行任务的从机通信, 定期控询该从机是否已完成其程序操作, 仅在含有功能 13 的报文发送后, 本功能码才得发送
15	强置多线圈	强置一串连续逻辑线圈的通断
16	预置多寄存器	把具体的二进制值装入一串连续的保持寄存器
17	报告从机标识	可使主机判断编址从机的类型及该从机运行指示灯的状态
18	(884 和 MICRO 84)	可使主机模拟编程功能, 修改 PC 状态逻辑
19	重置通信链路	发生非可修改错误后, 使从机复位于已知状态, 可重置顺序字节
20	读取通用参数 (584L)	显示扩展存储器文件中的数据信息
21	写入通用参数 (584L)	把通用参数写入扩展存储文件或修改之
22 ~ 64	保留作扩展功能备用	
65 ~ 72	保留以备用户功能所用	留作用户功能的扩展编码
73 ~ 119	非法功能	
120 ~ 127	保留	留作内部作用
128 ~ 255	保留	用于异常应答

在图 5-2 中, 可以看到 Modbus 可以采用多种通信方式, 也侧面体现了 Modbus 普及应用过程中发展的几个方向。其中包括 Modbus RTU、Modbus ASCII、Modbus TCP、Modbus Plus, 下面将简要介绍。

(1) Modbus RTU 与 Modbus ASCII

在 Modbus 诞生之初, 标准的 Modicon 控制器使用 RS232C 实现串行的 Modbus, Modbus RTU 与 Modbus ASCII 是最简单的两种 Modbus 发展变种, 适用于通信串行总线 (接口一般采用 RS232C 或 RS485/422 等), 数据通信采用 Master/Slave 方式。Modbus 协议需要对数据进行校验, 串行协议中除有奇偶校验外, ASCII 模式采用 LRC 校验, RTU 模式采用 16 位 CRC 校验。

Modbus RTU 数据帧结构如图 5-6 所示。

起始	地址码	功能码	数据	CRC	结束
传输间隔 T1 ~ T4	8 位	8 位	$n \times 8$ 位连续数据流	16 位	传输间隔 T1 ~ T4

图 5-6 Modbus RTU 数据帧结构

Modbus ASCII 数据帧结构如图 5-7 所示。

起始	地址码	功能码	数据	CRC	结束
1 字符	1 字符	2 字符	n 字节连续数据流	2 字符	2 字符 CR/LF

图 5-7 Modbus ASCII 数据帧结构

在 RTU 模式下, 一字节的数据传输的就是一字节。在 ASCII 模式下, 同样一字节的数据用了二字节来传输。例如, 要传输数字 0x5B, RTU 传输的是 0101 1011 (二进制), 而 ASCII 传输的是 00110101 和 01000010。可见, ASCII 传输的速率是 RTU 的一半。

(2) Modbus TCP

Modbus TCP 和 Modbus RTU 协议非常类似, 只要把 RTU 协议二字节的校验码去掉, 然后在 RTU 协议的开始加上 5 个 0 和一个 6, 并通过 TCP/IP 网络协议发送出去即可。Modbus TCP 适用于以太网, 默认分配 502 端口。对于 Modbus TCP 而言, 主站通常称为 Client, 从站称为 Server。

相比较于 RTU 模式, Modbus TCP 有如下变化:

- 早期取消了校验位。数据链路层上就进行了 CRC-32 的校验, TCP/IP 是面向连接的可靠性的协议, 因此没必要再加上校验位; 不过当前绝大部分的 Modbus TCP 在 TCP/IP 载荷内部包含了 Modbus 原有的校验数据, 参见图 5-8 Modbus TCP 帧结构。
- Slave 地址换成了 Unit Identifier。当网络里的设备全使用了 TCP/IP 时, 这个地址是没有意义的, 因为根据 IP 就能进行路由寻址。如果网络里还有串行通信设备, 则需要网关来实现 Modbus TCP 到 Modbus RTU 或 ASCII 之间的协议转换, 这时用 Unit Identifier 来标识网关后面的每个串行通信设备。
- 表头增加的 Length 是为了应对有些情况下 TCP/IP 协议会将应用层的数据拆包传输。
- 由 Client 生成 Transaction Identifier 和 Protocol Identifier, Server 的响应将复制这些参数。

Modbus TCP 帧结构如图 5-8 所示。

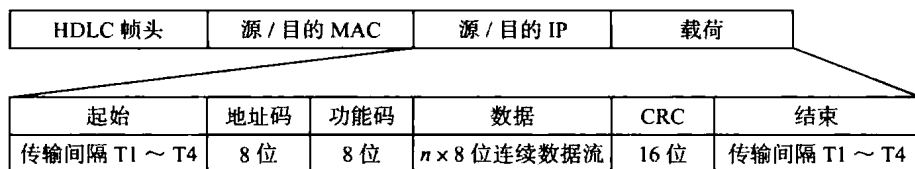


图 5-8 Modbus TCP 帧结构

(3) Modbus Plus (简称 MB+)

MB+ 是一种高速现场总线网络, 允许计算机、可编程控制器 PLC 和其他数据源以对等式令牌循环方式进行通信, 其电气特性为 RS-485, 适用于工业控制领域。MB+ 网络具有高速、对等通信、结构简单、安装费用低等特点; 其通信速度为 1MB/s, 通信介质为双绞线或同轴电缆或光纤。MB+ 网络上的节点均为对等逻辑关系, 通过获得令牌来传递网络信息。

网络中的每一个节点均分配一个唯一的地址，一个节点拥有令牌就可以与所选的目标进行信息传递，或与网络上所有节点交换信息。

MB+ 网络的典型应用主要包括网络控制、数据采集、信号监测、程序上载 / 下传、编程、远程测试等。

MB+ 网络可有三种配置方式，即本地 I/O（也叫主站）、远程 I/O（RIO，称为分站）、分布式 I/O（DIO）。CPU 配置在主站，主站最多可以配置 14 个 I/O 模块或其他模块；每个 CPU 可配置的 RIO 最多为 31 个远程 I/O 对等节点，不带中继器的通信距离为 457 米，每个 RIO 可配置成单或双电缆方式。当采用 DIO 时，每个 CPU 可配置最多 3 个分布式网络，每个网上（采用一个中继器）最多可有 64 个分站，使网络最大扩展到 1828 米通信距离，每个 DIO 可配置成单或双电缆方式。

5.2.2 Modbus 协议存在的安全问题

绝大多数工控协议在设计之初，仅仅考虑了功能实现、提高效率、提高可靠性等方面，而没考虑过安全性问题，Modbus 协议也不例外。从前面的原理分析可知，协议的规约设计本身缺乏安全性，如缺乏认证、授权、加密等安全设计，另外，厂商在协议的具体实现时，常常出现功能码滥用、代码缓冲区溢出而导致的安全性问题^[59]。

1. Modbus 协议设计的固有问题

（1）缺乏认证

认证的目的是保证收到的信息来自合法的用户，未认证用户向设备发送控制命令不会被执行。在 Modbus 协议的通信过程中，没有任何认证方面的相关定义，攻击者只需要找到一个合法的地址就可以使用功能码并建立一个 Modbus 通信会话，从而扰乱整个或者部分控制过程。

（2）缺乏授权

授权是保证不同的特权操作由拥有不同权限的认证用户来完成，这样可大大降低误操作与内部攻击的概率。目前，Modbus 协议没有基于角色的访问控制机制，也没有对用户进行分类，没有对用户的权限进行划分，这会导致任意用户可以执行任意功能。

（3）缺乏加密

加密可以保证通信过程中双方的信息不被第三方非法获取。在 Modbus 协议的通信过程中，地址和命令全部采用明文传输，因此数据可以很容易地被攻击者捕获和解析，为攻击者提供便利。

2. Modbus 协议实现产生的问题

虽然 Modbus 协议获得了广泛的应用,但是在实现具体的工业控制系统时,开发者并不具备安全知识或者没有意识到安全问题。这样就导致了使用 Modbus 协议的系统中可能存在各种各样的安全漏洞。

(1) 设计安全问题

Modbus 系统开发者重点关注的是其功能实现问题,安全问题在设计时很少被注意到。设计安全是指设计时充分考虑安全性,解决 Modbus 系统可能出现的各种异常和非法操作等问题。例如,在通信过程中,某个节点被恶意控制后发出非法数据,就需要考虑这些数据的判别和处理问题。

(2) 缓冲区溢出漏洞

缓冲区溢出是指在向缓冲区内填充数据时超过了缓冲区本身的容量导致溢出的数据覆盖在合法数据上,这是在软件开发中最常见也是非常危险的漏洞,可以导致系统崩溃,或者被攻击者用来控制系统。Modbus 系统开发者大多不具备安全开发知识,这样就会产生很多的缓冲区溢出漏洞,一旦被恶意者利用会导致严重的后果。

(3) 功能码滥用

功能码是 Modbus 协议中的一项重要内容,几乎所有的通信都包含功能码。目前,功能码滥用是导致 Modbus 网络异常的一个主要因素。例如,不合法报文长度、短周期的无用命令、不正确的报文长度、确认异常代码延迟等都有可能拒绝服务攻击。

(4) Modbus TCP 安全问题

目前,Modbus 协议已经可以在通用计算机和通用操作系统上实现,运行于 TCP/IP 之上以满足发展需要。这样,TCP/IP 协议自身存在的安全问题不可避免地会影响工控网络安全。非法网络数据获取、中间人、拒绝服务、IP 欺骗、病毒等在 IP 互联网中的常用攻击手段都会影响 Modbus 系统安全。

5.2.3 Modbus 协议安全防护技术

从前面的分析可以看出,目前 Modbus 系统采取的安全防护措施普遍不足,这里参考信息安全业内研究并结合工控系统自身的安全问题,提出了一些安全建议,能够有效地降低工业控制系统面临的威胁。

(1) 从源头开始

工控网络漏洞很大一部分是其实现过程出现的漏洞。如果从源头开始控制,从 Modbus 系统的需求设计、开发实现、内部测试和部署等阶段,全生命周期地介入安全手段,融入安全设计、安全编码以及安全测试等技术,可以极大地消除安全漏洞,降低整个 Modbus 系

统的安全风险。

(2) 异常行为检测

异常行为代表着可能发生威胁,不管有没有攻击者,因此开发针对 Modbus 系统的专用异常行为检测设备可以极大提高工控网络的安全性。针对 Modbus 系统,首先要分析其存在的各种操作行为,依据“主体、地点、时间、访问方式、操作、客体”等行为描述成一个六元组模型;进而分析其行为是否属于异常;最终决定采取记录或者报警等措施,如图 5-9 所示。

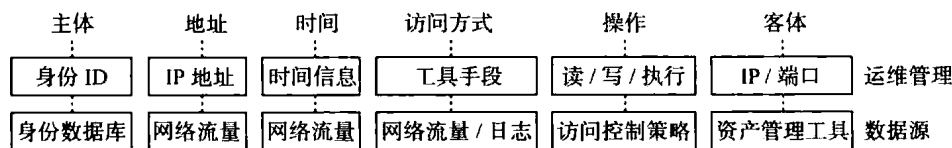


图 5-9 异常行为检测六元组

(3) 安全审计

Modbus 的安全审计就是对协议数据进行深度解码分析,记录操作的时间、地点、操作者源和目标对象、操作行为等关键信息,实现对 Modbus 系统的安全审计日志记录和审计功能,从而提供安全事件爆发后的事后追查能力^[60]。

(4) 使用网络安全设备

使用工业入侵防御和工业防火墙等网络安全设备。防火墙是一个串行设备,通过设置只允许特定的地址访问服务端,禁止外部地址访问 Modbus 服务器,可以有效地防止外部入侵;入侵防御设备可以分析 Modbus 协议的具体操作内容,有效地检测并阻止来自内部/外部的异常操作和各种渗透攻击行为,对内网提供保护功能。

另外,使用支持 Modbus TCP 深度解析和防护的防火墙设备,采用功能码的白名单机制,避免设计期间不合理功能码的随意使用,可将风险限制在最小范围。

5.3 DNP3 协议

DNP (Distributed Network Protocol, 分布式网络规约) 最初由哈里斯公司为北美电力行业开发设计,用于与遥控变电站和其他智能电子设备 (IED) 的通信,如今已发展至 DNP3.0。现在由 DNP 用户组 (DNP User Group) 进行升级和维护。DNP 是一种应用于自动化组件之间的通信协议,由 IEEE 提出,参考了 IEC 870-5 以及其他一些 IEC 协议。DNP 提供了对数据的分片、重组、数据校验、链路控制、优先级等一系列服务,在协议中大量使用了 CRC 校验来保证数据的准确性。

本节将对工控网络中使用的 DNP3 进行介绍,包括协议的传输格式和字段含义等,还将对 DNP3 存在的安全问题及防护技术进行讨论。

5.3.1 DNP3 协议概述

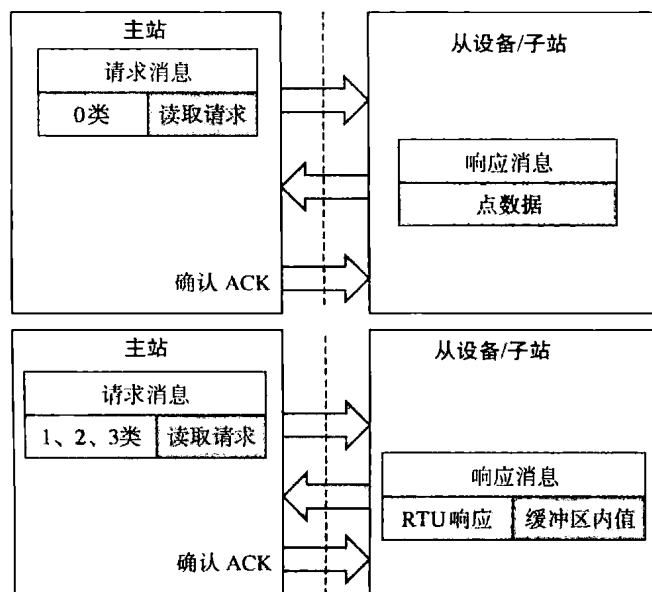
DNP3 最初是一种用于主控站和从设备“子站”之间以及控制站内 RTU 与 IED 之间的串行协议,与其他控制系统协议一样,可通过 TCP/UDP 进行封装,以便在以太网上运行,支持 DNP3 的从设备默认会开放 TCP 的 20000 端口用于通信。相对于 IEC 60870-5-104 对 IEC 60870-5-101 的修改, TCP/IP 上的 DNP3 并没有对串行链路上的 DNP3 作任何实质上的修改,而是将整个链路协议数据单元 (LPDU) 作为 TCP/IP 之上的应用层数据进行传输 (也可能是基于 UDP)。DNP3 的文本共分 4 部分:数据链路层规约、传输功能、应用层规约和数据对象库^[61]。

DNP3 的规约决定了其优点:在保持效率且适合实时数据传输的同时,具有高度的可靠性。它还使用了几种标准数据格式,支持数据时间戳 (以及时间同步),使得实时传输更加高效、可靠。此外, DNP3 对 CRC 校验频繁使用,单个 DNP3 帧可包含高达 17 个 CRC (帧头一个,帧内载荷的每个数据块内有一个)。DNP3 还有可选的数据链路层确认以便进一步保证可靠性,并且还有多种支持数据链路层授权的变种版本。由于校验操作都是在数据链路层帧内完成,因此 DNP3 在以太网上被封装起来传输时,还可以使用额外的网络层校验。

相比较于 Modbus 协议, DNP3 是双向且支持基于异常报告的协议, DNP3 子站可能在非正常轮询周期时发送自发响应,将事件通知给主节点。

DNP3 提供一种方法来识别远程设备参数,然后使用对应 1 到 3 类事件数据的消息缓冲区来识别输入消息并同已知的点数据进行比较。采用这种方式,主设备只需要读取由点变化或变化事件产生的新消息。

DNP3 通信流程分为由主站发起到子站、自发响应时由子站向主站发送两种模式。如图 5-10 和图 5-11 所示。



1) 主站发起到子站:最初通信

图 5-10 DNP3 协议交互机制

从主站到子站的 0 类请求，用于将所有点数值读入主数据库。接下来的通信通常可能的类型是：主站发送的某数据类型直接轮询请求；从主站到 RTU 的控制或配置请求及后续周期性的 0 类轮询。

2) 子站到主站的自发响应：由于 DNP3 是一种支持自发响应的双向协议，子站可以对某数据类型自发响应。这就对 DNP3 数据帧结构提出了一些要求。例如，每帧都必须包含源地址和目的地址，以便接收设备确定处理哪些消息，并向哪个设备返回响应。下面就简要介绍一下 DNP3 帧结构。

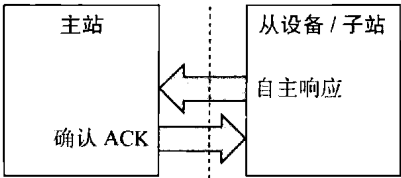


图 5-11 自发响应允许生产远程警报

DNP3 的第 2 层帧中包括源地址、目的地址、控制及载荷等，可以由包括 TCP/IP（通常使用 TCP 端口 20000 或 UDP 端口 20000）在内的多种协议作为应用层协议承载。功能代码于 DNP3 帧头的 CNTRL 字节中，如图 5-12 所示。

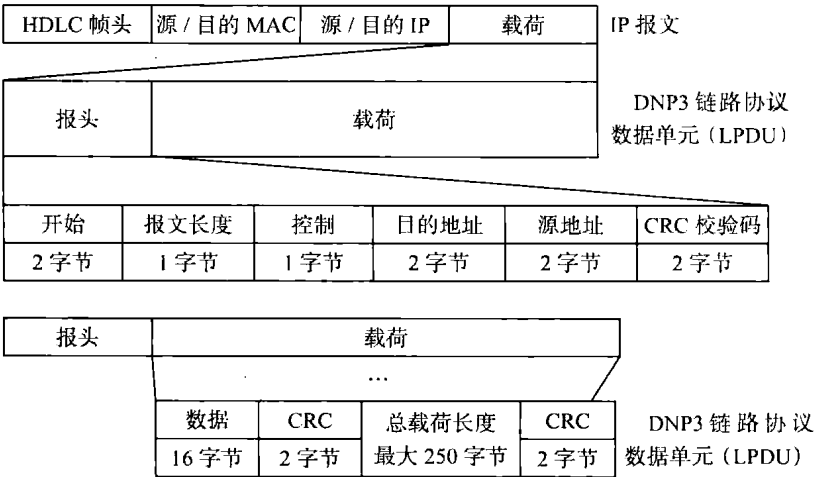


图 5-12 DNP3 帧结构

5.3.2 DNP3 协议存在的安全问题

DNP3 是典型的工控网协议，研究其安全性对于加强工业控制网络安全有重要意义。相比于 Modbus 协议，DNP3 在安全性方面已经有了提高，甚至已经引入了安全的 DNP3，如图 5-13 所示。

安全 DNP3 是一种在响应 / 请求处理中加入了授权机制的 DNP3 变体。授权是以质疑形式由接收设备发起的。在会话初始化、经过预设超时时间后，或在发生关键请求时将发生授权质疑。但是在 DNP3 协议中引入安全机制的同时带来了复杂度的增加，也使协议本身健壮性降低，出现新的漏洞。再者加入安全的 DNP3 协议实现成本增加，各厂商产品参差

不齐, 因此本书从传统 DNP3 协议 (没有加入安全机制) 自身的设计和描述及其不正确实现引起的安全问题来讨论 DNP3 协议存在的安全问题^[62]。

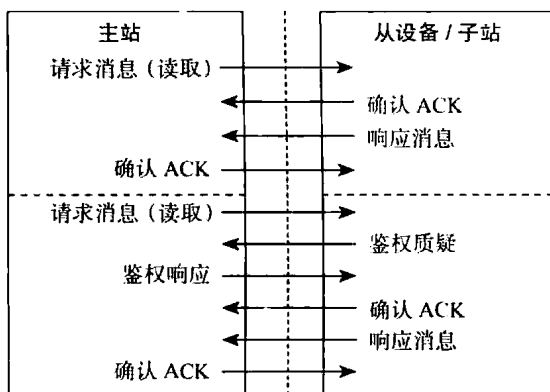


图 5-13 消息确认和安全 DNP3 授权机制

1. DNP3 的固有问题

(1) 缺少认证

认证的目的是保证收到的信息来自于合法的用户, 未认证的用户向设备发送命令不会被执行。在 DNP3 的通信过程中, 没有任何认证方面的相关定义, 攻击者只要找到一个合法地址即可使用功能码建立 DNP3 通信会话, 从而扰乱控制过程。

(2) 缺少授权

授权是保证不同的特权操作由拥有不同权限的认证用户来完成, 这样可以降低误操作与内部攻击的概率。目前 DNP3 没有基于角色的访问控制机制, 也没有对用户进行分类, 没有对用户的权限进行划分, 这样任意用户可以执行任意功能。

(3) 缺少加密

加密可以保证通信过程中双方的信息不被第三方非法获取。在 DNP3 通信过程中, 地址和命令全部采用明文传输, 因为可以很容易被攻击者捕获和解析, 然后篡改报文, 发送出去, 从而影响控制过程。

(4) 协议复杂性

除缺乏认证、授权和加密等安全防护机制之外, 协议的相对复杂性也是 DNP3 中存在安全问题的主要根源。

2. DNP3 实现产生的问题

(1) 设计安全问题

应用开发者在使用 DNP3 设计应用的功能的同时应该考虑其功能实现之后导致的安全

问题。保证 DNP3 应用的设计安全性,能够处理应用中会出现的各种异常响应以及非法操作等问题,充分保障应用程序的健壮性。

(2) 功能码滥用

功能码是 DNP3 中一项重要的内容,几乎所有通信都涉及功能码。功能码滥用也是导致网络异常的一个主要因素。例如,需要引起 IDS/IPS 开发人员高度关注的 DNP3 消息:关闭主动上送;在 DNP3 端口上运行非 DNP3 通信;长时间多重主动上送(响应风暴);授权客户冷重启;未授权客户冷重启;停止应用;热重启;重新初始化数据对象;重新初始化应用;冰冻并清除可能重要的状态信息。

(3) TCP/IP 层安全问题

目前 DNP3 可以在通用计算机和通用操作系统上实现、运行于 TCP/IP 协议之上。这样 TCP/IP 协议自身的安全问题就会不可避免地影响工控网络安全。非法网络数据获取、中间人、拒绝服务、IP 欺骗等互联网中常用的攻击方法都会威胁 DNP3 系统的安全。

5.3.3 DNP3 协议安全防护技术

在前面已经提到,DNP3 设计之初没有安全机制,但由于承载协议的智能单元总是跨网络传输,协议的设计后期做了一些与安全相关的功能性增强,开发了 DNP3 的安全版本,实现协议承载相关安全方面的认证等问题。

因此,DNP3 的安全防护总体建议是:使用安全版本的 DNP3。但是,由于工业设备供应商支持等原因,一时很难做到。当前整个行业内上线产品也以传统版本为主,因此建议采取传输层协议安全措施,如使用传输层安全协议(TLS)等,即将 DNP3 数据流视为机密信息,尽量使用各种 TCP/IP 安全手段保护它。在实际工程部署中,DNP3 主控站与子站往往被隔离到只包含授权设备的唯一分区中,因此可以通过防火墙、IDS 等设备部署,对 DNP3 链路上的数据类型、数据源及其目的地址进行严格控制,实现分区进行全面的安全加固^[63]。

5.4 IEC 系列协议

IEC 系列协议首先由欧洲发起,经过欧美多个标准组织联合研究后陆续发布,最终被 IEC 确认并形成系列协议,在欧美得到广泛应用。在我国,自 1997 年颁布 DL/T 634DL634—1997 以来,得到了行业内众多用户的关注。但我国最初颁布的 DL/T 634DL634—1997 标准不是等同引用的 IEC60870-5-101:1995,在实际使用过程中上出现了一些问题。因此,全国电

力系统管理及其信息交换标准化技术委员会决定研制等同引用 IEC 协议的方案。鉴于 IEC 在 2002 年的北京年会上通过了 IEC60870-5-101:2002, 我国依照此标准研制并颁布了 DL/T 634DL634.5101—2002, 该标准完全等同引用了 IEC60870-5-101:2002 (2.0 版) 并作为我国电力行业的标准

无论是在调度自动化系统、集控自动化系统还是配网自动化系统中, IEC 系列协议都被普遍采用。以江苏电网为例, 江苏电网的规划是厂站之间的主通道采用以太网通信的 IEC60870-5-104 网络的协议, 备用通道采用串口通信的 IEC60870-5-101 的协议。IEC 系列协议的广泛使用使得各种电力自动化系统中的通信标准化程度越来越高。

5.4.1 IEC 系列协议概述

IEC 系列协议如 IEC60870-5-101、IEC60870-5-104 是电力行业的主要工控协议, 在电厂、变电站等领域有广泛应用, 研究其安全性对加强工业控制网络安全有重要意义。目前我国电厂、变电站远动系统普遍采用基于电路的独立 64Kbit/s 专线通道进行串口通信, 所使用的串口通信协议多数为 IEC60870-5-101 和 DNP3 等, 这些协议遵循基于 ISO 参考模型的增强性能结构 (Enhanced Performance Architecture, EPA), 仅用了 OSI 7 层模型中的 3 层 (物理层、数据链路层、应用层) 来实现数据传输。随着网络技术的迅猛发展和 IEC61850 标准在电力行业的逐步推广, 为满足网络技术在电力系统中的应用, 通过网络传输远动信息, IEC 在 IEC60870-5-101 基本远动任务配套标准的基础上制定了 IEC60870-5-104 远动传输协议。其采用平衡传输模式, 通过 TCP/IP 协议实现网络传输远动信息, 适用于调度主站 (中心站) 的 EMS 系统和子站 (远方站) 的 RTU 或计算机监控系统之间, 采用专用 Intranet 网络进行通信, 本节将以电力系统远动和 IEC60870-5-104 标准为例, 介绍 IEC 系列协议的规范与使用^[64]。

1. 一般体系结构

IEC 标准定义了开放的 TCP/IP 接口在工控电力系统网络中的使用, 这个网络包含如传输 IEC 60870-5-101 ASDU 的远动设备的局域网。包含不同广域网类型 (如 X.25、帧中继、ISDN 等) 的路由器可通过公共的 TCP/IP 局域网接口互联 (见图 5-14)。图 5-14 所示为一个冗余的主站配置与一个非冗余的主站配置。

使用单独的路由器有以下好处:

- 终端系统无须特殊的网络软件。
- 终端系统无须路由功能。

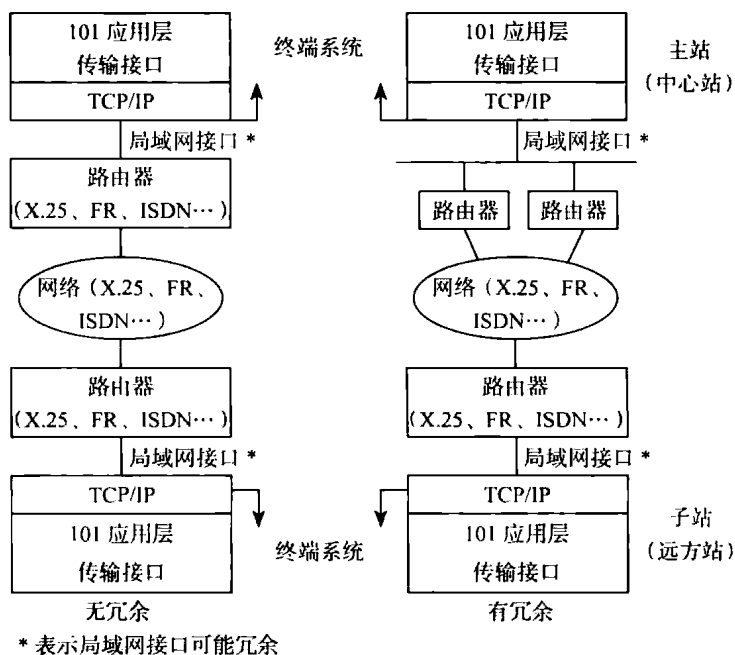


图 5-14 一般体系结构 (示例)

- 终端系统无须网络管理。
- 使从专门从事远动设备的制造商处得到终端系统更为便利。
- 使从非专业远动设备的制造商处得到适用于各种网络的路由器更为便利。
- 只需更换路由器即可改变网络类型，而对终端系统没有影响。
- 特别适合转换原已存在的支持 IEC 60870-5-101 的终端系统。
- 现在和将来都易于实现。

协议的主要特点：

- TCP/IP 网络通信。
- 端口号 2404。
- IEC 60870-5-101 协议采用平衡式传输。
- 时标 7 字节。
- 时钟同步召唤 1 级、2 级不能用。
- 工作量小，效果很好，易实现。

2. 应用协议数据单元 (APDU) 和应用协议控制接口 (APCI)

标准的 APDU 的定义如图 5-15 所示，它可以传送一个完整的 APDU（或者出于控制目的，仅仅传送 APC 域）。APDU 包含 APCI 和 ASDU。

传输接口（TCP 到用户）是一个面向流的接口，它没有为 IEC60870-5-101 中的 ASDU 定义任何启动或者停止机制。为了检测 ASDU 的启动和停止，每个 APCI 应该包括下列定界元素：一个启动字符（固定为 0x68），APDU 的规定长度，以及控制域。标准的 APCI 的定义如图 5-16 所示。

启动字符 68H
APDU 长度 (最大 253)
控制域 8 位位组 1
控制域 8 位位组 2
控制域 8 位位组 3
控制域 8 位位组 4
ASDU

图 5-15 标准的 APDU 定义

启动字符 68H
APDU 长度
控制域 8 位位组 1
控制域 8 位位组 2
控制域 8 位位组 3
控制域 8 位位组 4

图 5-16 标准的 APCI 定义

启动字符 68H 定义了数据流中的起点。
APDU 的长度域定义了 APDU 报文体的长度，它包括 APCI 的 4 个控制域 8 位位组和 ASDU。
第一个被计数的 8 位位组是控制域的第一个 8 位位组，最后一个被计数的 8 位位组是 ASDU 的最后一个 8 位位组。

ASDU 的长度限制在 249 以内，因为 APDU 域的最大长度是 253（APDU 最大值 = 255 - 启动和长度八位位组），控制域的长度是 4 个 8 位位组。

控制域定义了保护报文不至丢失和重复传送的控制信息、传输连接的监视信息、报文传输的启动 / 停止等控制信息。

3 种类型的控制域格式用于编号的信息传输（I 格式）、编号的监视功能（S 格式）和未编号的控制功能（U 格式），分别如图 5-17 ~ 图 5-19 所示。

8	7	6	5	4	3	2	1
发送序列号 N(S) LSB							0
MSB 发送序列号 N(S)							
接收序列号 N(R) LSB							0
MSB 接收序列号 N(R)							

图 5-17 信息传输功能 I 格式

控制域第一个 8 位位组第一个比特等于 0，定义了 I 格式，I 格式的 APDU 通常包含一个 ASDU。I 格式用于编号的信息传输。

8	7	6	5	4	3	2	1
0						0	1
0							
接收序列号 N(R) LSB							0
MSB 接收序列号 N(R)							

图 5-18 计数确认功能 S 格式

控制域第一个 8 位位组第一个比特等于 1，第二个比特等于 0，定义了 S 格式。S 格式用于编号的监视功能，可以对 I 格式的数据帧加以确认。

8	7	6	5	4	3	2	1
TESTFR		STOPDT		STARTDT		1	1
确认	生效	确认	生效	确认	生效		
0							0
0							

图 5-19 启动、停止、测试 U 格式

控制域第一个 8 位位组第一个比特等于 1，第二个比特等于 1，定义了 U 格式。U 格式用于未编号的控制功能，如启动数据传输、停止数据传输、测试链路等。

3. 应用层报文格式 (ASDU)

(1) 协议 ASDU 部分描述

IEC 60870-5-3 描述了远动系统传输帧中的基本应用数据单元，此子条款是从基本标准中所选择的特定域元素，并定义了用于配套标准中的应用服务数据单元 (ASDU)。配套标准规定每一个链路协议数据单元 (一个报文) 只有一个应用服务数据单元 (ASDU)。

应用服务数据单元由数据单元标识符和一个或多个信息对象所组成。数据单元标识符在所有应用服务数据单元中常有相同的结构，一个应用服务数据单元中的信息对象常有相同的结构和类型，它们由类型标识域所定义。

数据单元标识符的结构如下：

- 一个 8 位位组：类型标识，如表 5-2 所示。
- 一个 8 位位组：可变结构限定词。
- 两个 8 位位组：传送原因，如表 5-3 所示。
- 两个 8 位位组：应用服务数据单元公共地址。

应用服务数据单元公共地址的 8 位位组数目是由系统参数所决定的，公共地址是站地址，它可以去寻址整个站或者站的特定部分。

(2) 类型标识

单元标识符的类型标识如表 5-2 所示。

表 5-2 数据单元标识符的类型标识

类型	数值 (十六进制)	意义
遥测	09	带品质描述的测量值, 每个遥测值占 3 字节
	0A	带 3 字节时标的且具有品质描述的测量值, 每个遥测值占 6 字节
	0B	不带时标的标度化值, 每个遥测值占 3 字节
	0C	带 3 个时标的标度化值, 每个遥测值占 6 字节
	0D	带品质描述的浮点值, 每个遥测值占 5 字节
	0E	带 3 字节时标且具有品质描述的浮点值, 每个遥测值占 8 字节
	15	不带品质描述的遥测值, 每个遥测值占 2 字节
通信	01	不带时标的单点遥信, 每个通信占 1 字节
	03	不带时标的双点遥信, 每个通信占 1 字节
	14	具有状态变位检出的成组单点遥信, 每个字节 8 个通信
SOE	02	带 3 字节短时标的单点遥信
	04	带 3 字节短时标的双点遥信
	1E	带 7 字节时标的单点遥信
	1F	带 7 字节时标的双点遥信
KWH	0F	不带时标的电能量, 每个电能量占 5 字节
	10	带 3 字节短时标的电能量, 每个电能量占 8 字节
	25	带 7 字节短时标的电能量, 每个电能量占 12 字节
其他	2E	双点遥控
	2F	双点遥调
	64	召唤全数据
	65	召唤全电度
	67	时钟同步

(3) 常用传送原因

数据单元标识符的常用传送原因如表 5-3 所示。

表 5-3 数据单元标识符的常用传送原因

数值	意义	数值	意义	数值	意义	数值	意义
01	周期、循环	04	初始化	07	激活确认	0a	激活结束
02	背景扫描	05	请求或被请求	08	停止激活	14	响应总召唤
03	突发	06	激活	09	停止激活确认		

4. 协议通信过程

1) TCP 连接的建立过程。调度主站作为客户端不断向子站 RTU 发出连接请求, 一旦连接请求被接收, 则应监测 TCP 连接的状态, 以便 TCP 连接被关闭后重新发出连接请求。

每次连接被建立后,主站与子站 RTU 应将发送和接收序号清零,并且子站只有在接收到主站发送的开始数据传输信号后,才能响应数据请求并循环上送数据,但在接收主站发送的开始数据传输信号前,子站对遥控、遥调等命令仍然进行响应。

2) 变化遥测数据上传过程。按照南网细则要求,总调可以对接入的 500 kV 厂站遥测量统一使用类型标识(如 36,即采用带 7 位长时标的浮点数)。

3) 总召唤过程。主站向子站发送总召唤命令(类型标识 100,传送原因 6),子站回应确认(类型标识 100,传送原因 7),然后子站向主站发送单点遥信(类型标识 1),全遥测数据(类型标识 13,不带时标的浮点数),最后向主站发送总召唤结束命令(类型标识 100,传送原因 10,表示执行结束)。

4) 子站事件主动上送过程。当子站发生突发事件时,将根据现场具体情况向主站发送以下报文:单点遥信(类型标识 1,传送原因 3),事件顺序记录(类型标识 30,传送原因 3)。

5) 遥控、遥调过程。单点设置,主站发送遥调命令(类型标识 48,归一化值,传送原因 6),子站执行确认(类型标识 48,传送原因 7)。多点设置,主站发送遥调命令(类型标识 136,传送原因 6),子站执行确认(类型标识 136,传送原因 7)。单点遥控,分为预置和执行两步操作,首先主站发送遥控预置命令(类型标识 45,传送原因 6),子站收到遥控预置命令后确认(类型标识 45,传送原因 7),然后主站发送遥控执行命令(类型标识 45,传送原因 6),子站收到遥控执行命令后确认(类型标识 45,传送原因 7)。

6) 计划曲线下发过程。南网细则对 IEC60870-5-104 协议中的类型标识进行了扩充,规定用类型标识 137 来实现对子站的曲线下发,采用带长时标的多点设点命令下发计划值,给每个计划值分配一个固定地址,从 0 时 0 分开始到 23 时 55 分,一共 288 个量。主站发送计划曲线(类型标识 137,传送原因 6),子站接收到计划曲线后以镜像报文确认(类型标识 137,传送原因 7)。

7) 时钟同步、时差召唤过程。主站发出时钟同步命令(类型标识 103,传送原因 6),子站收到同步命令后确认(类型标识 103,传送原因 7),然后将时差以变化遥测数据上传(类型标识 36,传送原因 3)。

8) 分组召唤过程。南网细则定义 1~8 组是遥信数据,9~12 组是遥测数据。分组召唤结束后子站以确认报文(类型标识 100,传送原因 10)上传主站。

9) 远方复位进程。主站发出复位进程命令(类型标识 105,传送原因 6),子站收到复位命令后确认(类型标识 105,传送原因 7)。

5. 报文举例

总召唤上传遥测报文举例如下：

```

68  40  18  00  04  00  09  91  14  00  01  0B  70  40  00  00
00  00  00  00  00  00  00  00  00  00  00  00  00  00  00  00
00  00  00  00  00  00  F4  01  00  00  00  00  00  00  00  00
00  00  00  00  00  00  00  00  00  00  00  00  00  00  00  00

```

说明：

- 0x68：固定的启动字符。
- 0x40：APDU 长度。
- 0x18 00 04 00：控制域八位组 1-4。
- 0x09：ASDU 类型（遥测数据）。
- 0x91：第七位定义该帧应用数据的数目，低位在前高位在后。最高位为 1 表示应用数据是信息体地址连续的一串数据，报文中只提供一个起始信息体地址，即第一个遥测的信息体地址，后面的遥测在此地址的基础上递增。如上报文上送的是起始信息体地址为 0x4070 的 17 个遥测。
- 0x0014：定义数据上送的原因，低位在前高位在后。20 为召唤上送，一般为响应总召唤。
- 0x004070：该帧第一个遥测信息体地址，其后信息体地址在此地址后依次递增。
- 0x0b01：主站给予站设定的地址，低位在前高位在后。由主站方确定，子站严格按照此地址定。
- 00 00 00：以下每 3 字节一个遥测数据，信息体地址在起始地址上依次递增。

5.4.2 IEC 系列协议存在的安全问题

本小节从 IEC 系列协议自身的设计和描述引起的安全问题以及其不正确实现引起的问题来讨论 IEC 协议存在的安全问题。

1. IEC 协议的固有问题

(1) 缺少认证机制

认证的目的是保证收到的信息来自于合法的用户，并保证未认证的用户向设备发送的命令不会被执行。如在 IEC60870-5-104 协议通信过程中，没有任何认证方面的相关定义，攻击者只要找到一个合法地址即可使用功能码建立 IEC60870-5-104 协议通信会话，从而扰乱或破坏控制过程。

(2) 缺少授权机制

授权是保证不同的操作需要拥有不同权限的认证用户来完成,这样可以降低误操作与内部攻击的概率。目前 IEC60870-5-104 和 IEC60870-5-101 都没有基于角色的访问控制机制,也没有对用户进行分类,没有对用户的权限进行划分,这样任意用户可以执行任意操作,导致误操作和内部攻击事件的发生。

(3) 缺少加密机制

加密可以保证通信过程中双方的信息不被第三方非法获取。在 IEC60870-5-104 协议通信的过程中,ASDU 部分全部采用明文传输,很容易被攻击者捕获和解析,然后篡改报文后发送出去,从而影响控制过程。

(4) 缓冲区溢出漏洞

缓冲区溢出是指向缓冲区中填充数据时超过缓冲区本省容量导致溢出的数据覆盖在合法数据上,该漏洞在软件开发过程中比较常见,可以导致系统崩溃,甚至被攻击者利用来控制系统。

2. IEC60870-5-104 协议实现产生的问题

(1) TCP/IP 层安全问题

目前 IEC60870-5-104 协议可以在通用计算机和通用操作系统上实现,并运行于 TCP/IP 协议之上。这样 TCP/IP 协议自身的安全问题就会不可避免地影响工控网络安全。非法网络数据获取、中间人攻击、拒绝服务、IP 欺骗等互联网中常用的攻击方法都会威胁着工控系统的安全。

(2) 功能码滥用

几乎所有通信都涉及功能码。IEC 系列协议也存在功能码滥用的问题,功能码滥用也是导致网络异常的一个主要因素。

5.4.3 IEC 系列协议安全防护技术

从以上协议安全问题分析可知:保证远动数据的完整性、安全性及保密性,关键在于数据包加密及身份认证,认证方法的关键也在于加密,加密技术是信息安全技术的基础。但远动系统是实时控制系统,其实时性要求较高(秒级),且远动系统可用计算机资源相对较少,从而决定了远动信息传输的加密及身份认证的算法和方式有其自身的特点和要求,必须将对实时性的影响降到最小^[65]。

1. 基本防护

1) 保证通信驱动软件的高可靠性和正确性。编写通信驱动软件时要对写数据请求的合理性进行严格检查,避免写数据越界,破坏系统数据,造成缓冲区溢出,留下隐患;同时软件的正确性要经过严格认证,不能影响系统的正常运行。

2) 合理配置信息转发表。对于不同的主站,远动系统往往配置不同的信息转发表,进行初步的信息访问控制,包括遥测、遥信、遥控信息转发表等。对于无遥控信息要求的,必须取消遥控信息转发表,以免留下安全隐患。

3) 关闭不必要的服务和协议。仅提供 IEC 协议及开放相应端口(一般为 2404),关闭其他所有协议的服务及端口。

4) 进行基本身份验证。厂站远动要验证主站及路由器 IP 地址,主站也要验证厂站及路由器 IP 地址。可使用防火墙进行访问控制,考虑到远动信息的实时性要求,可开发厂站专用防火墙,以降低通用防火墙软件延时较大所造成的影响。

2. 合理的网络隔离

1) 厂站内部网络与远传网络隔离。远传网络不能路由到内部网络,反之亦然。

2) 远传网络中控制网络与非控制网络隔离。由于目前尚不具备遥控操作的身份验证,遥控操作的安全性得不到充分保证,有必要将控制网独立出来,且让其他任何网络无法路由到控制网。

3. 加密技术

1) 直接对远动信息进行加密。即在应用层进行加密,这也是 IEC TC57 WG15 标准工作组正在研究的工作,其关键是如何快速地加密和进行身份认证,以保证远动信息的实时性、安全性、可靠性、完整性。

2) IP 层的加密。目前最有影响的是 IPSec,IPSec 既可工作在传输模式,也可工作在隧道模式(提供 VPN)。同样,如何保证远动信息的实时性,如何选择加密及认证方式,密钥如何管理也是其面临的主要问题。IP 层加密最主要的优点是它的透明性,也就是说,安全服务的提供不需要应用程序、其他通信层次或对网络部件作任何改动,可通过具有加密功能的路由器或防火墙实现。

5.5 OPC 协议

事实上,OPC (OLE for Process Control,用于过程控制的 OLE) 协议不是严格的工业类协议。它由自动化行业软硬件巨头公司与微软合作开发,起源于 20 世纪 90 年代。微软操

作系统统治了整个自动化领域，自动化厂商开始在工业产品中使用微软的 COM 和 DCOM，定义了应用 Windows 操作系统在基于 PC 的客户机之间交换自动化实时数据的方法。OPC 的宗旨是在微软 COM、DCOM 和 ActiveX 技术的功能规程基础上开发一个开放和互操作接口标准，最终目标是促使自动化、控制系统、现场系统、设备、办公应用之间具有更强大的互操作能力。OPC 国际基金会正基于此目的而成立。

OPC 国际基金会前身是 Fisher-Rosemount、Opto 22、Rockwell Software、Siemens、Intellution 和 Intuitive Technology 等著名自动化大公司组成的专门工作组。基金会仅仅用短短的一年时间便开发出一个基本可用的 OPC 技术规范，在 1996 年 8 月发布了简单的、一步到位的解决方案。发展至今，OPC 是世界上最广为应用的信息交换的互操作标准，它具有安全性、可靠性以及平台独立性。OPC 国际基金会现拥有 450 家会员和上千种合规产品（详细 OPC 国际基金会历史与发展情况参见其中文官网：<http://www.chinaopc.org/>）。本节将对 OPC 协议的作用和细节进行介绍，并讨论其存在的安全问题和防护技术。

5.5.1 OPC 协议概述

在自动化工业中的 3 个不同软件应用和 3 个不同过程控制设备之间的常规通信架构的示例在图 5-20 中给出。

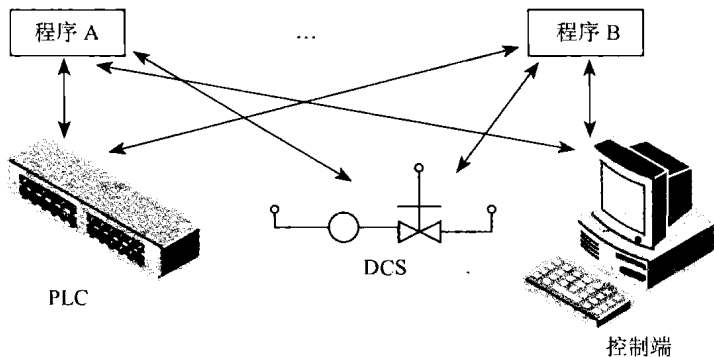


图 5-20 软件应用通信架构示例

系统中的每个软件必须具有用于每个设备的驱动器，以便能够彼此通信。这样的做法通常会导致应用的复杂性、高成本、低效率等工程性缺点。由于不同系统的数据有着不同的格式和不同的通信协议，创建过程监控、控制和数据管理系统的软件供应商必须为每个协议开发单独的 I/O 驱动程序。为每种类型的设备开发独特的驱动程序不仅耗时且效率低下，而且还会对项目的成功和及时完成增加额外的风险^[66]。

OPC 技术是自动化组件与控制硬件和现场设备之间方便、高效连接的技术基础。它

还用于各种数据源（工业设备或数据库）之间的通信。使用 OPC 标准的通信体系结构如图 5-21 所示。

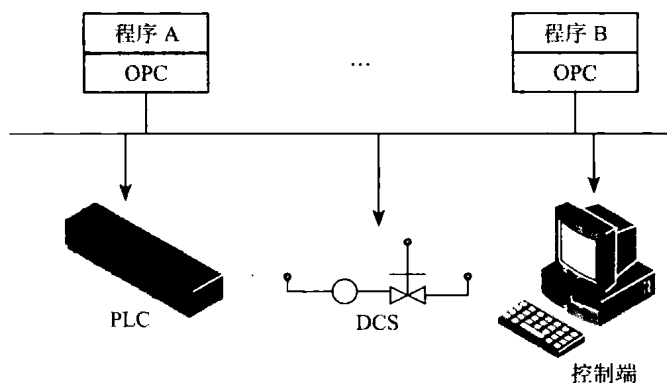


图 5-21 OPC 通信体系结构

OPC 协议采用客户端/服务器模式，在客户端和服务端都各自定义了统一的符合 OPC 标准的接口，此接口具有不变特性。接口明确定义了客户端同服务器间的 COM 方式的通信机制，它是连接客户端同服务器的桥梁和纽带。由设备厂家或第三方开发出现场设备的访问接口（驱动及总线协议），并将其封装到 OPC 服务器中（硬件驱动模块）；客户端通过 OPC 标准接口实现与服务器的数据交换。

当 OPC 客户端与服务器在同一台计算机上时，客户端通过 COM 进行本地过程调用（LRC）服务；当客户端与服务器不在同一台计算机上时，客户端通过 DCOM 进行远程过程调用（RRC）服务与服务器进行通信。

当 OPC 客户端访问服务器时，服务器程序就会为其打开一个进程实例，此时需要考虑三种情形：

- 若 OPC 服务器只允许一个用户访问，如果已有一个实例，则其他用户无法访问。
- 若 OPC 服务器允许多个用户访问，随着用户增多，实例也会增加，会占用更多计算机资源。
- 此外，还存在硬件抢占问题，比如串口，当一个用户使用了，其他用户就无法使用。

应用程序开发人员在设计客户端 OPC 接口程序时必须包含释放接口的函数，否则即使 OPC 客户端退出与服务器的连接，服务器上对应的进程实例也不会关闭，它会继续占用服务器系统资源。

OLE 对控制系统开发的效用是显而易见的。在概念上，人机界面是一个包含可编程逻辑控制器（PLC）、远程终端单元（RTU）等各个终端设备信息同时可以控制各个终端设备的人

机交互界面。不用理解终端设备通信的细节,通过这些设备的标准应用编程接口(API)可以获得其设备参数信息,同时也可以使控制命令从HMI传递到终端设备,开发人员不需要向系统上的每种类型的设备(和协议)写入特定的接口。因此,SCADA系统HMI可以容易地与来自不同制造商的各种各样的设备通信。此外,OLE接口的使用在Microsoft应用程序开发中是一种常用而且十分成熟的技术,使用标准化工具(如Visual Basic和Visual C++)很容易实现OLE自动化。

使用COM/DCOM技术的优点是将规范工作减少到针对不同需求的相应API的定义,而不需要定义用于进程间通信的网络协议或机制。然而,其主要的缺点是使用远程通信时的Windows平台依赖和DCOM问题。

OPC UA标准使用XML和Web服务作为基础技术,通过互联网将数据从现场设备传输到企业应用程序。它仅定义过程数据、报警、历史数据和程序的一个地址空间^[67]。

OPC UA规范包括重要的工业问题,如数据访问(DA)、报警和事件(AE)、历史数据访问(HDA)、批处理、安全、XML、复杂数据和数据交换。这些规格现已被接受为自动化行业的工业标准。定义供应商和协议独立的服务器/客户端模型的OPC UA规范已经发布,并形成了IEC 62541标准。通常,每个规范用于工业应用的特定领域,并且基于对应于这样的应用领域的模型。自引入统一架构(UA)的新OPC产生以来,OPC规范被分为基于MS-RPC开发框架的“经典”OPC和OPC UA。

OPC协议的介绍如下所示。

(1) “经典” OPC

“经典”OPC最初被称为过程控制的OLE,因为第一个OPC标准基于Microsoft的OLE技术。这种技术的历史从组件对象模型(COM)开始。这是微软的分布式对象技术的方法——跨不同进程或不同计算机实现面向对象的接口。COM是一种客户端/服务器技术,提供一组接口,允许客户端和服务端在同一台计算机内进行通信。

DCOM是分布在不同计算机上的COM。也就是说,客户端程序对象可以从网络中其他计算机上的服务器程序对象请求服务。COM和DCOM最初是Microsoft特定的技术。Unix世界中的类似或竞争技术是CORBA(公共对象请求代理体系结构)。DCOM实现也可用于主要的UNIX平台。

(2) OPC DA

OPC DA即OPC数据访问规范,它是由OPC基金会定义的一种通信规范,定义了实时数据如何在数据源和数据接收体(如PLC、HMI)之间,在不知道彼此特定通信协议的情况下仍然可以进行交换、传输。如表5-4所示是OPC DA规范的主要版本历史。

表 5-4 OPC DA 规范的主要版本历史

年份	版本	备注
1996	1.0	初始规范
1997	1.0a	数据访问，该名称用于区分与其并行开发的其他规范
1998	2.0 到 2.05a	多处规范澄清和修改
2003	3.0	进一步补充和修改

OPC DA 定义了 OPC 服务器中一组 COM 对象及其接口，并规定了客户程序对服务器程序进行数据存取时需要遵循的标准、OPC DA 以 OPC 对象模型逻辑为基础，该模型包含 3 类对象：OPC 服务器（Server）对象、OPC 组（Group）对象和 OPC 项（Item）对象，如图 5-22 所示。OPC 服务器对象作为 OPC 组对象的包容器维护有关服务器的信息，OPC 服务器对象主要实现 IUnknown 和 IOPCServer 接口，OPC 客户程序通过 OPC 服务器的接口与 OPC 对象进行通信，存取数据源。数据源可以是现场设备，也可以是应用程序。服务器内部封装了与 I/O 控制设备进行通信及操作的具体实现过程；OPC 组对象维护有关其自身的信息，提供包容 OPC 项的机制并管理 OPC 项，它提供了一种客户程序组织数据的手段，例如，一个组中可以包括一个设备中所有的数据项，客户程序和数据项之间可以建立基于“订阅”的连接。其有两种类型的组：公共组和局域组，公共组可以被多个客户共享，而局域组只能被一个客户使用，每个组中都可以定义一个或多个 OPC 项。

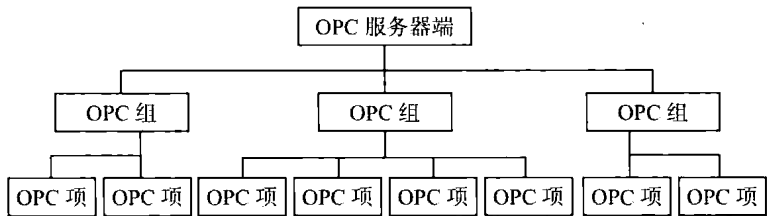


图 5-22 OPC DA 中的对象

(3) OPC HDA

OPC HDA 即 OPC 历史数据存取规范，提供了一种统一的在各种不同的应用层面之间传递数据的方式，但与 OPC DA 完全不同的是，OPC HDA 在不同角色之间传递的是非实时数据，即不是当下的时刻，而是过去某点或某段时间内的过程数据。任何支持 OPC HDA 规范的数据可视化、数据分析或者趋势汇报的软件，都可以从任何一个支持 OPC HDA 的过程历史数据库中读取数据。因为 OPC HDA 已经是一种非常成熟的 OPC 访问规范，所以现在市场上的主要过程历史数据库都支持 OPC HDA，即使用户所用的历史数据库没有提供 OPC 通信，现在各大 OPC 供应商也都有为不同历史数据库提供 OPC 接口的软件。可以看

出其应用主要不同的地方在于它是与过程数据库进行数据交换，其余的应用与之前的 OPC DA 规范基本相同，是为了适应新需求而升级的规范。

OPC 历史数据服务器对象实现了与历史服务器进行读取或写入数据的功能，数据类型取决于服务器。通过接口可以获取所有的 COM 对象，客户端只能看到这些 COM 对象。

(4) OPC A&E

OPC A&E 即 OPC 报警事件规范，提供了基于事件信息的接口。OPC 支持两种类型的报警事件服务器，即简单服务器和复杂服务器。简单服务器监测报警或事件，并提供给报警事件客户；复杂服务器从多个数据源处（包括简单服务器）监测报警或事件信息，并向报警事件客户提供信息。报警事件客户也分为 3 类：操作站、报警事件管理子系统和报警事件 logging 组件。

OPC 报警事件服务器包含一系列的对象和接口，这些对象和接口向客户提供报警事件信息。OPC 报警事件服务器中涉及以下几个概念。

1) 报警 (Alarm): 报警是一种非正常的状态。

2) 状态 (Condition): 状态是 OPC 报警事件服务器定义的，每个状态还可以包含若干个子状态，状态最终是与现场数据项联系的。每一个状态都包含一个或多个子状态、属性和质量等属性。OPC 报警事件服务器中定义状态机处理相应的状态或子状态之间的变化。

3) 事件: OPC 规范中定义了 3 种事件，即条件事件（定义描述了状态的变化）、跟踪事件（指当客户与 OPC 事件服务器中定义的数据项之间发生交互时引发的事件）、简单事件（指除以上两种事件以外的任何事件，如服务器中定义的物理系统和设备的错误等）。

OPC A&E 服务器主要包括 OPC 事件服务器对象、OPC 事件订阅对象和 OPC 事件区域浏览对象。

(5) OPC XML-DA

OPC XML-DA 是 OPC 基金会提出的一个基于 XML 规范和 SOAP 技术的接口规范，OPC XML-DA 将要交换的结构化数据信息组织为 SOAP 消息来传送。

基于 XML 技术和 SOAP 技术的特征使得它可以更好地促进工业现场数据跨越 Internet 的传输，简化不同应用间的互操作性，并将现场数据统一到企业层的运用中，实现诸如 MES 和 ERP 等系统的一体化连接。XML 在 OPC 规范中的引入为控制系统到信息系统之间的数据交换搭建了一个桥梁。控制系统现场采用 XML 描述的数据可以被管理信息系统中的标准 XML 解析器解析，而不需要根据不同的控制系统数据描述开发多种解析器，这使得统一和标准化的数据传输成为可能。

OPC XML-DA 支持 8 种服务，每种服务都包括 1 个请求和 1 个响应。对这些服务的定

义提供了访问工业现场数据的标准接口，请求和响应按照 SOAP 协议标准被包装成 SOAP 信封，信封标题说明消息如何被处理，信封正文则包含工业过程信息。

OPC XML-DA 支持的服务类型具体包括如下几种。

- **GetStatus**: 返回服务器、版本、当前模式、运行状态等信息。
- **Browse**: 在服务器的命名空间里搜索所有可获取项的名字。
- **GetProperties**: 返回 1 个或多个项的属性相关信息。
- **Write**: 向 1 个或多个项中写入新值。
- **Read**: 返回 1 个或多个项的值、品质和时间戳。
- **Subscribe**: 指定 1 个客户希望持续更新的项列表。
- **SubscriptionCancel**: 删除在前一个 Subscribe 调用中指定的项列表。
- **SubscriptionPolledRefresh**: 返回上次调用以来在项列表中数值发生变化的所有项。

(6) OPC UA

OPC UA 标准是用于将原始数据和预处理信息从车间或车间传输到生产计划或 ERP 系统的下一代技术。它扩展了现有的 OPC 标准，具有平台独立性、可扩展性、高可用性、Internet 功能等基本特性。它定义应由服务器为客户端提供的服务，并定义服务器如何指示它们提供哪些服务。新标准的关键问题之一是实施它可能是相当具有挑战性的。为了做到这一点，OPC 基金会采取了许多方法。为了促进采用这一新标准并减少进入壁垒，OPC 基金会开发了一个 OPC UA 软件开发工具包 (SDK)。SDK 是跳过现有应用程序并使其启用 OPC UA 的入口点。SDK 包括一系列应用程序编程接口和示例代码。为此，OPC UA 规范被编写为平台无关的，因此，SDK 支持不同的编程语言，以便于在不同平台上进行移植。这一统一标准旨在实现企业的互操作性。

一个 OPC UA 系统可以包含多个客户端和服务端。每个客户端可以与一个或多个服务器并发地交互，并且每个服务器可以与一个或多个客户端并发地交互。应用程序可以组合服务器和客户端组件，以允许与其他服务器和客户端进行交互。图 5-23 包括组合的服务器和客户端的体系结构。

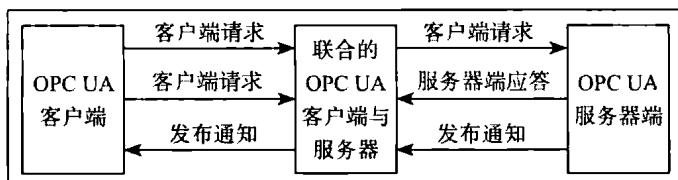


图 5-23 OPC UA 系统架构

OPC UA 客户端架构为客户端 / 服务器交互的客户端端点建模。图 5-24 说明了典型的 OPC UA 客户端的主要元素以及它们之间的相互关系。

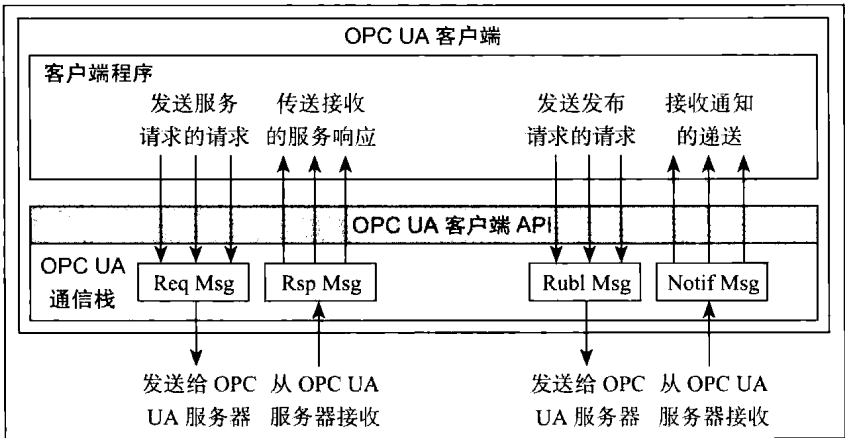


图 5-24 OPC UA 客户端架构

OPC UA 客户端使用 API 向 OPC UA 服务器发送和接收 OPC UA 服务请求和响应。OPC UA 客户端 API 是将客户端应用程序代码与 OPC UA 通信栈隔离的内部接口。OPC UA 通信栈将 OPC UA 客户端 API 调用转换为消息，并根据客户端应用程序的请求通过底层通信实体将它们发送到服务器。OPC UA 通信栈还从底层通信实体接收响应和通知消息，并通过 OPC UA 客户端 API 将它们传递给客户端应用程序。

OPC UA 服务器架构为客户端 / 服务器交互的服务器节点建模。图 5-25 说明了 OPC UA 服务器的主要元素以及它们之间的相互关系。

OPC UA 服务器应用程序使用 OPC UA 服务器 API 从 OPC UA 客户端发送和接收 OPC UA 消息。OPC UA 服务器 API 是将服务器应用程序代码与 OPC UA 通信栈隔离的内部接口。

OPC UA 地址空间包括地址空间节点、地址空间视图、地址空间组织。

地址空间节点可被理解为客户端使用 OPC UA 服务（接口和方法）可访问的一组节点。地址空间中的节点用于表示真实对象（实际对象可以是 OPC UA 服务器应用程序可访问或在内部维护的物理对象或软件对象）及其定义、它们相互之间的引用。

地址空间组织包含用于以一致的方式从互连的节点中创建地址空间的元模型“构件块”的细节。服务器可以根据自己的选择在地址空间中自由组织它们的节点。在节点之间使用引用允许服务器将地址空间组织成层次结构、节点的全网状网络或任何可能的组合。

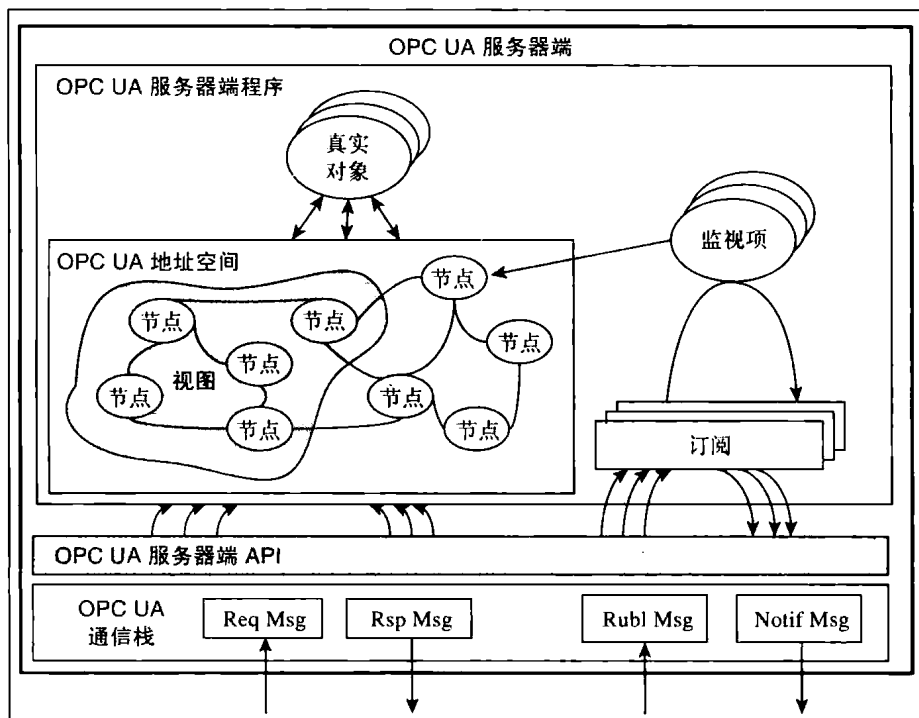


图 5-25 OPC UA 服务器端架构

地址空间视图是地址空间的一个子集。视图用于限制服务器对客户端可见的节点，从而限制客户端提交的服务请求的地址空间的大小。默认视图是整个地址空间。服务器可以可选地定义其他视图。视图隐藏了地址空间中的一些节点或引用。视图通过地址空间可见，客户端可以浏览视图以确定其结构。视图通常是层次结构，这对于客户端来说更容易以树的形式进行展现。

5.5.2 OPC 协议存在的安全问题

OPC 是过程控制行业中使用的软件编程标准和接口的集合。它旨在提供开放连接和供应商设备互操作性。OPC 技术的使用简化了集成来自多个供应商的组件并支持多个控制协议的控制系统的开发，广泛应用于过程控制行业。兼容 OPC 的产品可从大多数控制系统供应商获得。

OPC 协议的安全性问题主要体现在如下几个方面。

1) 已知操作系统的漏洞问题。由于 OPC 基于 Windows 系统，通常的主机安全问题也会影响 OPC 系统。OPC 最初称为过程控制的 OLE，因为 OPC 的第一个标准是基于 Microsoft Windows 操作系统的底层 DCOM 服务。微软的 DCOM 技术以高复杂性和高漏洞数量而著称，这些操作系统层面的漏洞也成为经典 OPC 协议漏洞的来源和攻击入口。虽然

OPC 及相关控制系统漏洞只有基金会的授权会员才能获得，但大量现存 OLE 与 RPC 漏洞早已广为人知。因为在工业网络中为产品系统打补丁存在困难，所以目前正在使用的工控系统依然存在许多这样的漏洞，哪怕微软公司已经提供了相应的补丁，但这种安全状态一直没有得到改变。

2) Windows 操作系统的弱口令。经典 OPC 协议使用的最基本的通信握手过程需要建立在 DCOM 技术上，通过 Windows 内置账户的方式进行认证。但是大量 OPC 主机使用弱安全认证机制，即使启用了认证机制也常使用弱口令。

3) 部署的操作系统承载了多余、不必要的服务。许多系统启用了与 SCADA 系统无关的额外 Windows 服务，导致非必需的运行进程和开放端口，如 HTTP、NEBBIOS 等系统入口，这些问题将 OPC 系统广泛暴露于攻击之下。

4) 审计记录不完备。由于 Windows 2000/XP 审计设置默认不会记录 DCOM 连接请求，因此攻击发生时，日志记录往往不充分甚至缺失，无法提供足够的详细证据。

也就是说，与前述的简单且目的单一的协议（如 Modbus、DNP3）不同，OPC 必须使用最新操作系统与网络安全手段。

表 5-5 列出了涉及 RPC 和 DCOM 服务的一些比较典型的漏洞。

表 5-5 涉及 RPC 和 DCOM 服务的典型漏洞

漏洞编号	漏洞描述
CVE-2002-2077	Windows 2000 SP3 之前版本的 DCOM 客户端不能正确地在发送“alter context”请求之前清除内存，远程攻击者可能通过发会话话获得敏感信息
CVE-2003-0352	Microsoft 的 RPC 部分在通过 TCP/IP 处理信息交换时存在问题，远程攻击者可以利用这个漏洞以本地系统权限在系统上执行任意指令 此漏洞是由于不正确处理畸形消息所致的，漏洞影响使用 RPC 的 DCOM 接口。此接口处理由客户端机器发送给服务器的 DCOM 对象激活请求（如 UNC 路径）。攻击者成功利用此漏洞可以以本地系统权限执行任意指令。攻击者可以在系统上执行任意操作，如安装程序、查看或更改 / 删除数据或者建立系统管理员权限的账户。要利用这个漏洞，攻击者需要发送特殊形式的请求到远程机器上的 135 端口
CVE-2003-0813	RPCSS 模块中的激活类函数在处理部分激活消息请求时存在问题，远程攻击者可以利用这个漏洞以 SYSTEM 进程权限在系统上执行任意指令 RPCSS 模块包含的激活类函数设计用于处理进入的 DCOM 激活请求，因此实例可提交给请求代理端。通过初始化两个同步的激活请求，然后快速关闭连接，Window RPC 实时库处理这个特殊的消息时可触发竞争条件问题，这样 svchost RPC 服务进程堆中会引起小部分破坏而导致崩溃，精心构建提交请求可能以进程权限在系统上执行任意指令
CVE-2004-0116	RPCSS 模块在处理部分畸形消息时存在问题，远程攻击者可以利用这个漏洞对 RPC 服务进行拒绝服务攻击 在 DCOM 激活请求传递给 RPCSS.DLL 函数后，类中处理会分配请求包长度字段指定的大小，由于 DWORD 长度字段在分配前没有任何验证，客户端发送激活请求包含任意长度大小，可造成系统异常而使服务崩溃，产生拒绝服务

(续)

漏洞编号	漏洞描述
CVE-2004-0124	Windows NT 4.0、Windows Server 2000、Windows XP 和 Windows Server 2003 系统的 DCOM RPC 接口上允许远程攻击者经由“改变上下文”引起网络通信,调用包含附加数据,这也称为“对象标识漏洞”。严重程度高,远程可利用
CVE-2005-2996	VERITAS Storage Exec 的多个 DCOM 服务程序中存在栈和堆溢出,成功利用这个漏洞的攻击者可能让系统崩溃,或以通过认证的用户的权限访问本地系统。起因是没有正确地验证和解析外部输入,可以通过调用相关的 ActiveX 控件来初始化 DCOM 服务程序中的溢出

上述这些 RPC 和 DCOM 漏洞不是特定于工业控制系统网络的。然而,使用 OPC 的控制系统网络容易受到这些威胁。控制系统网络管理员必须通过保持最新补丁和服务包或应用其他安全措施来缓解这些威胁。从攻击者的角度来看,知道经典 OPC 协议正在被使用意味着系统中可能具有相关的漏洞,进一步地,攻击者可以尝试针对这些服务的已知攻击方法来获得系统访问。

其他 OPC 安全问题包括:

(1) 过时的授权服务

受限于维护窗口、解释性问题等诸多因素,工业网络系统升级困难,导致不安全的授权机制仍在使⽤。例如,在许多系统中,仍在使⽤默认的 Windows 2000 LanMan (LM) 和 Windows NT LanMan (NTLM) 机制,这些机制与其他过时的授权机制相比过于脆弱而易受攻击。

(2) RPC 漏洞

由于 OPC 使用 RPC,因而易受所有 RPC 相关漏洞影响,包括几个在授权前就暴露的漏洞。攻击底层 RPC 漏洞可以导致非法执行代码或 DoS 攻击。

(3) OPC 服务器完整性

攻击者可以创建一个假冒 OPC 服务器,并使⽤这个服务器进行服务干扰、DoS 攻击,通过总线监听窃取信息或注入恶意代码。

5.5.3 OPC 协议安全防护技术

使用 OPC 技术的控制系统继承了与 Microsoft Windows 环境中的基础 RPC 和 DCOM 服务相关的漏洞。这些服务一直是许多严重漏洞的来源,对未打补丁系统的攻击是广泛存在的。OPC 使用所需的系统配置排除了操作系统的安全补丁和服务包的自动应用。资产所有者应该了解使用这些服务的未修补系统所呈现的漏洞,并确保在不能应用传统修补程序时,其他适当的安全控制已就位。

OPC 安全性涉及客户端和服务器的认证、用户认证、其通信的完整性和机密性以及功能声明的可验证性。对于 OPC 协议的安全防护方面，我们应该着手从以下几方面予以考虑。

1. 会话认证

应用层安全性依赖于在应用会话期间活动的安全通信信道，并确保所交换的所有消息的完整性。这意味着当应用程序会话建立时，用户需要进行一次身份验证。当会话建立时，客户端和服务器应用程序协商安全通信信道并交换标识客户端和服务器的软件证书及其提供的功能。服务器进一步认证用户并授权后续请求访问服务器中的对象。

2. 审计

OPC 应用应对客户端和服务器审计日志之间具有可跟踪性的安全审计跟踪的支持。如果在服务器上检测到与安全相关的问题，则可以查找和检查关联的客户端审核日志条目。OPC 还应提供服务器生成事件通知的能力，该事件通知向能够处理和记录它们的客户端报告可审计的事件。

通过监控 OPC 网络或 OPC 服务器（服务器活动可以通过采集与分析 Windows 日志监控）的可疑行为，可以检测多种威胁，包括：

- 从 OPC 服务器发起的使用非 OPC 的端口与服务。
- 出现已知 OPC（包括底层 OLE RPC 与 DCOM）攻击。
- 来自未知 OPC 服务器的 OPC 服务（意味着存在假冒服务器）。
- OPC 服务器上的失败授权尝试或其他授权异常。
- OPC 服务器上由未知或未授权用户发起的成功授权尝试。

3. 传输安全

传输层的安全性可基于加密和签名消息。加密和签名防止信息泄露和保护消息的完整性。

4. 冗余

OPC 的设计应确保供应商能够以一致的方式创建冗余的客户端和服务器。冗余可用于高可用性、容错和负载平衡。OPC 的开发应含有高度可靠性和冗余性的设计。可调试的逾时设置控制工程网版权所有、错误发现和自动纠正等新特征，都使得符合 OPC 规范的软件产品可以很自如地处理通信错误和失败。

当前的 OPC 基金会正在努力推广基于 Web 协议、独立于微软操作系统的下一代 OPC UA 技术，新的协议从操作系统宿主、认证授权、加密等各方面，在设计上给予了非常充分的安全性考虑，新协议的推广和实施还有待从业人员的持续努力^[68]。

5.6 本章小结

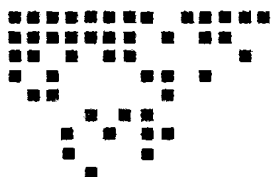
工业网络协议总体上可以归类为内部私有网络协议，其协议规约是由厂商根据自己的设备自行规定的，没有统一的协议标准，因此也造成了目前工业网络各种协议“百家争鸣”的情况。

本章重点介绍了4种典型的工业网络协议（Modbus、DNP3、IEC、OPC），分别从协议的规约、发展、应用、安全以及防护5方面来重点阐述。通过对本章协议的学习，我们不难得出这么一个结论：工业网络协议较互联网协议要简单，且大多数工业网络协议本身没有安全防护方案，在保证可用性的基础上难以保证协议的保密性、完整性。

在未来的发展中，特别是在国家“两网合一”政策的促进下，工业网络协议安全将会是未来工控领域面临的一个重大挑战。

5.7 本章习题

1. 简述以 TCP/IP 为基础的工业控制应用协议存在的安全性问题。
2. 描述 Modbus 帧结构。
3. 简要阐述 DNP3 协议存在的安全问题。
4. 简述 IEC 60870-5-104 协议。
5. 简要阐述 OPC 协议存在的安全问题。
6. 从行业角度描述工业控制网络协议的分类。
7. 尝试使用两台 PC 分别模拟 Modbus 的客户端和服务端，然后通过 ARP 欺骗的方式嗅探客户端与服务端之间的交互数据。



工业控制网络漏洞分析

传统的工控网络是一种专用网络，处于一个相对封闭的网络环境，因此工业控制系统在设计之初都认为不会有安全威胁而忽视了安全性考虑。工控网络中的数据传输都是没有加密的明文，也没有进行任何身份认证，在系统正式运行前几乎不会进行安全漏洞检测，在投入生产后为了保障稳定运行，也很少会对系统和软件进行升级或打补丁。这样脆弱的工控网络直接接入互联网就如同将温室中培养出来的花朵暴露在烈日、狂风和暴雨下，是非常危险的。

在本章，我们将会介绍工控网络中存在的几种典型安全漏洞，并介绍漏洞形成的原因，以及如何对工控网络中的这些漏洞进行检测。

6.1 工业控制网络漏洞概述

要对工控网络中的漏洞进行检测和分析，首先要对工控安全漏洞有一个总体的认识，本节将对工控安全漏洞的挖掘技术、分类、主要的漏洞发布平台和工控安全漏洞的态势进行介绍，通过本节的学习读者会对工控网络安全漏洞有一个初步的了解，有助于后续章节的深入学习。

6.1.1 工业控制网络安全漏洞挖掘技术分析

1. 工控设备漏洞挖掘的可行性

(1) 工控设备和系统

工控系统通常由以下系统组件构成：工业业务子系统（也称为实际业务子系统，在不同

的工业行业中具有不同的命名,如电力中的 SIS、DCS、PSCADA 等,有时也称为上下位机)、网络子系统、现场仪器仪表和现场设备。以网络为中心的工业控制系统常具有安全边界的隔离设备、授权远程访问的网络设备、网络基础连接设备(如路由器、交换机、工业专用网关等)、网络安全防护设备(网络流量分析、防火墙,主机加固设施)、工业控制设备(PLC、RTU、DCS 或 FCS 控制器、智能传送器)等。

其中,工业业务子系统中控制程序状态的控制设备或者嵌入式系统是工控系统的核心。这些终端设备中定制了预先配置的指令集,用来控制设施在控制过程中的变化,它们都被连接到工厂的固定设备上,用来测量温度、压力、水位或流量的改变,然后发送信号给其他工厂设备,像阀门、泵、发电机等,控制其开关或者维持其在稳定状态。

工控设备和系统有如下一些典型特点:

1) 系统的封闭性:设计之初的 SCADA、DCS、ICS 处于封闭网络,因此没有将安全机制考虑在内。

2) 数据接口的多样性:多种数据接口(如 RJ45、RS485、RS232 等),协议规约实现多样。

3) 通信的复杂性:专用的通信协议或规约(如 OPC、Modbus、DNP3、Profibus 等)。

4) 不可改变性:工控系统程序和固件难以升级。

以上特点导致传统信息系统漏洞检测技术无法直接应用于工业控制系统,因此需要对工业控制系统的特点,研究对应的漏洞检测技术,分析工控系统中的安全威胁,从而对安全威胁进行有效的防御^[71]。

(2) 漏洞挖掘的可行性

过去工业控制设备通过串行电缆和专有协议连接到计算机网络,随着业务的发展以及传统 IT 基础设施的开放和技术渗透,目前通过以太网电缆和标准化的 TCP/IP 通信协议连接到计算机网络的工业控制系统越来越多。供应商提供的大量工控设备提供了嵌入式 Web、开放的 FTP、远程 Telnet 等传统服务。这些开放的端口和服务为工控终端设备漏洞被挖掘和利用打开了通道,给工控系统造成了巨大的安全隐患。

(3) 漏洞挖掘的困难性

目前,公开的工业控制设备的漏洞数目不多,但漏洞直接关系到控制生产等实际业务流程的现场设备,并分布在大量的基础设施中。因此如果控制设备受到攻击,将会造成直接而严重的损失,如设备损坏、停机甚至人员伤亡。

需要注意的是,对这些工控设备的网络渗透测试不能在实际运行的系统中进行,因为渗透测试的某些测试样本会使设备达到极限性能或者出现异常,所以渗透攻击测试都应该

运行在模拟平台上，或者正在开发、测试的系统中。

另外，工业控制设备通常不公开其内部结构，且设备品牌众多，体系也各不相同，漏洞挖掘人员对此普遍接触较少，导致目前对其内部结构相关的研究也比较少，这是目前直接针对工业控制设备的漏洞挖掘方法非常少的重要原因^[69]。

2. 传统信息系统漏洞挖掘方法适用性分析

传统信息系统的漏洞挖掘方法主要分为白盒方法、灰盒方法和黑盒方法 3 种。白盒方法是指在有源代码、对目标完全了解的情况下进行漏洞挖掘，主要方式有源代码审计和走读、源代码静态分析等；灰盒方法是指在有目标文件、对于目标有部分了解的情况下进行的漏洞挖掘，包括二进制插桩、动态污点分析等；黑盒方法是指在对目标完全不了解的情况下进行的漏洞挖掘，典型的代表是模糊测试（Fuzzing）。

传统信息系统漏洞挖掘技术对于工控终端设备的适用性如表 6-1 所示。

表 6-1 传统信息系统漏洞挖掘方法适用性分析表

指标 方法	必备条件	优点	缺点	可使用性
白盒方法	源代码	高效、快速	误报率高	无源代码，不可用
灰盒方法	目标文件、调试工具	准确度高	效率低、技术要求高	无目标文件，不可用
黑盒方法	无	准确度高	覆盖率低	可用

现阶段，安全研究人员对于工业控制设备的内部结构了解不足，逆向工控设备的技术处于起步阶段，又因为无法获取工控系统的源代码和目标文件，无法采用白盒方法和灰盒方法挖掘漏洞，所以现阶段采用模糊测试来挖掘工控设备漏洞的方法较为常见^[70]。

6.1.2 工业控制网络安全漏洞分析

与传统信息系统相比，工业控制系统采用了很多专用的工控设备、工控网络协议、操作系统和应用软件，工业控制系统的安全漏洞也具有工控系统独有的特性。根据漏洞出现于工控系统组件的不同，工控安全漏洞可划分为工控设备漏洞、工控网络协议漏洞、工控软件系统漏洞、工控安全防护设备漏洞等。如表 6-2 所示。

表 6-2 工业控制系统漏洞分类举例

漏洞分类	典型设备 / 协议
工控设备漏洞	PLC、RTU、DCS、交换机、工业协议网关等
工控网络协议漏洞	OPC、Modbus、Profibus、CAN 等
工控软件系统漏洞	WinCC、Intouch、KingView、WebAccess 等
工控安全防护设备漏洞	工业防火墙、网闸等

Schneider Electric Telvent 信息泄露漏洞 (CVE-2015-6485) 是施耐德的 Telvent Sage 2300/2400 RTU 存在 IEEE 802 合规性问题, 对少于 56 字节的数据包, 常驻内存及其他数据在填充字段时会造成信息泄露, 所以属于典型的工控 RTU 设备漏洞。而 Advantech WebAccess 缓冲区溢出漏洞 (CVE-2016-4528) 是研华科技基于 Web 的 SCADA 产品的安全问题, 属于软件系统漏洞范畴, 特定型号的 SCADA 构造的 DLL 文件可触发缓冲区溢出漏洞。

图 6-1 显示了目前已知的公开工控相关安全漏洞在不同的工控产品上的分布情况, 可以明显地发现上位机环境和各类系统的漏洞占据了多数, 下位机的漏洞主要集中在 PLC 上, 另外, 服务器、固件和网络设备也占据了一定的比例。对工控系统而言, 可能带来直接隐患的安全漏洞也可以分为 SCADA 系统软件漏洞、操作系统安全漏洞、网络通信协议安全漏洞、安全策略和管理流程漏洞。

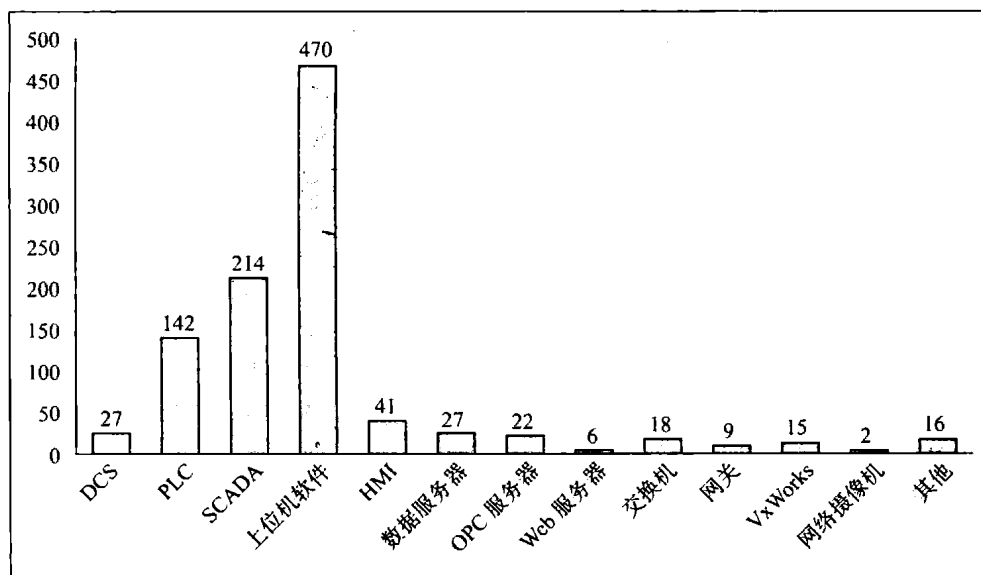


图 6-1 2000 ~ 2016 年公开工控漏洞影响产品统计数据

6.1.3 工业控制网络安全漏洞标准化工作

漏洞标准化工作在传统信息系统中已经非常成熟, 需要对发现的漏洞进行标准化管理的主要原因:

- 1) 规范漏洞的描述体系, 为漏洞的多种属性提供规则。
- 2) 利于信息安全产品的研发和自动化。
- 3) 为信息安全测评和风险评估打下基础。

4) 是对漏洞进行合理、有效管控的重要手段,为漏洞的预防、收集、削减和发布等活动提供指导。

漏洞编号便是一种漏洞标准化的表述方式,美国的安全研究机构与组织先后推出了一系列有影响力的标准,其中 CVE、CVSS 等 6 个标准已被国际电信联盟 (ITU) 的电信标准化部门 (ITU-T) 纳入了其 X 系列 (数据网、开放系统通信和安全性) 建议书中,成为 ITU-T 推荐的国际漏洞标准。另外,国际标准化组织 (ISO) 和国际电工委员会 (IEC) 的联合技术委员会也先后发布了《信息技术—安全技术—漏洞披露》(ISO/IEC 29147) 和《信息技术—安全技术—漏洞处理流程》(ISO/IEC 30111) 两个有关漏洞管理的国际标准。国内的安全漏洞标准化工作也在建设中,在中国信息安全测评中心与其他政府及学术机构的共同努力下,相继制定了《信息安全技术—安全漏洞标识与描述规范》(GB/T 28458—2012)、《信息安全技术—信息安全漏洞管理规范》(GB/T 3027—2013)、《信息安全技术—安全漏洞等级划分指南》(GB/T 30279—2013) 和《信息安全技术—安全漏洞分类规范》(正在制定中) 四项国家标准。下面我们对在工业控制领域同样比较有代表性的三个标准进行简要介绍。

1. 公共漏洞和暴露

公共漏洞和暴露 (Common Vulnerabilities & Exposures, CVE) 就好像是一个漏洞字典库,它为广泛认同的信息安全漏洞或者已经暴露出来的脆弱性提供一个约定俗成的编号和漏洞名。使用这个漏洞编号,用户可以在各自独立的各种漏洞数据库和漏洞评估工具中共享数据。这样就使得 CVE 成为安全数据信息共享的基础索引。如果在一个漏洞报告中指明的某个漏洞具备 CVE 编号,你就可以快速地在任何其他 CVE 兼容的评估工具中索引到相应漏洞修补措施,以解决对应的安全问题。

2. 美国工控系统网络应急响应小组

美国工控系统网络应急响应小组 (The Industrial Control Systems Cyber Emergency Response Team, ICS-CERT) 作为美国国家国土安全部的一部分,保证工业控制系统的安全性和风险可控,协调相关安全事件和信息共享。国内的很多机构、组织、社区平台都引用该平台发布的漏洞信息报告。

3. 国家信息安全漏洞共享平台

国家信息安全漏洞共享平台 (China National Vulnerability Database, CNVD) 是由国家计算机网络应急技术处理协调中心 (即国家互联网应急中心, CNCERT) 联合国内重要信息系统单位、基础电信运营商、网络安全厂商、软件厂商和互联网企业建立的信息安全漏洞信息共享知识库。

6.1.4 工业控制网络安全漏洞态势分析

本小节将从工控系统公开的安全漏洞统计、近期典型的工控安全事件及新型攻击技术等多个方面,讨论工控系统安全漏洞态势。

1. 工控漏洞的价值被高度重视

工控网络已经成为信息安全人员关注的新焦点,一些恶意的攻击者不断扫描工控系统的漏洞,并使用针对工控系统的专用黑客工具发动网络攻击。

近几年漏洞的数量呈爆发式增长的趋势,主流的工业控制系统也普遍存在安全漏洞,且多为能够造成远程攻击、越权执行的严重威胁类漏洞。此外,工业控制网络通信协议种类繁多、系统软件难以及时升级、设备使用周期长,以及系统补丁兼容性差、发布周期长等现实问题,造成了工业控制系统的补丁管理困难,难以及时处理威胁严重的漏洞。因此,及早发现工控系统中的漏洞是保护工业控制系统的关键。

2015年,随着“互联网+”、“中国制造2025”等国家战略方针的出台,随着“两化融合”政策的深入推进,国内工业控制系统的网络化、智能化水平快速提高,但国内工控系统安全问题突出,系统网络普遍脆弱,整体安全形势面临严峻挑战。

截至2015年年底,根据国家信息安全漏洞共享平台所发布的2015年新增漏洞信息,共整理出2015年新增的工业控制网络相关的漏洞108个。

从图6-2可以看出,除了2011年的爆发式增长外,每年公开发布的新增漏洞数量都呈下降的趋势。

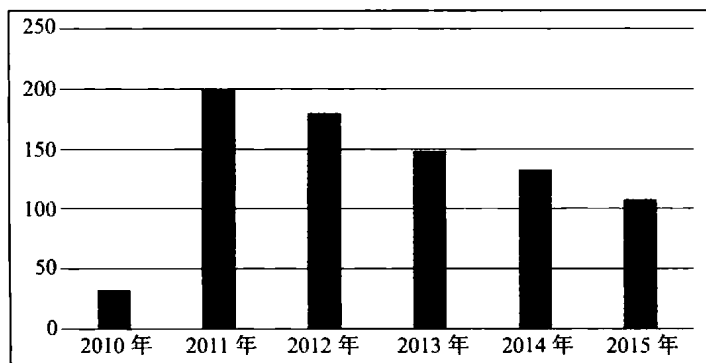


图 6-2 工控行业每年新增漏洞统计

造成这一趋势的原因如下:

一方面,工控系统的主要厂商意识到其产品在安全方面的脆弱性并加强自身产品的安

全性设计和开发，使漏洞挖掘的难度增加。

另一方面，由于政治、军事等因素的影响，作为国家基础设施建设的工控系统已经成为信息战场的必争之地，导致部分漏洞信息可能被限制公开或转为地下交易。从美国 ICS-CERT 每年发布的安全事件数量可以佐证这一推论，如图 6-3 所示。虽然每年公开的新增漏洞数量在下降，但工控安全事件数量却呈明显的上升趋势。

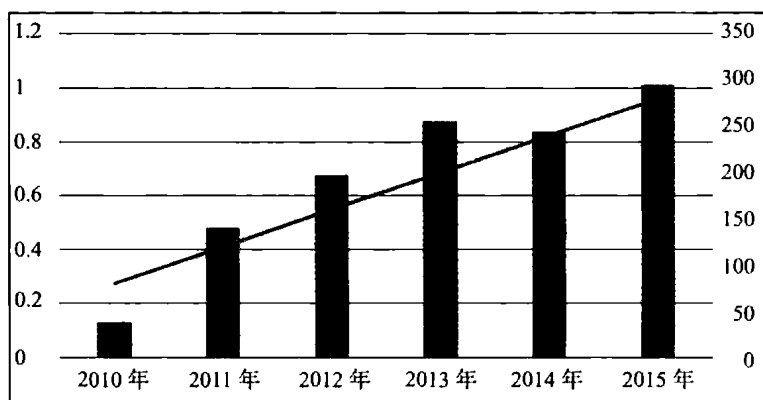


图 6-3 工控行业每年安全事件数量统计

2016 年，工控安全厂商和国家安全组织仍在不遗余力地收集、挖掘工控安全漏洞信息，并寻求解决方案，以帮助工控企业提高系统安全防护能力，抬高攻击者的攻击门槛和攻击成本。

2. 中高危漏洞比例居高不下

根据 CNVD 公布的 2015 年工控系统漏洞数据，其中高危漏洞和中危漏洞所占比例居高不下，如图 6-4 所示。

由此可以看出，工控相关应用系统和应用软件的安全健壮性不足。无论是应用软件漏洞还是设备固件漏洞，均是目标系统在开发过程中遗留的安全设计和实现缺陷所导致的，1 个高危漏洞就意味着目标系统中存在 1 个甚至多个致命安全性缺陷。

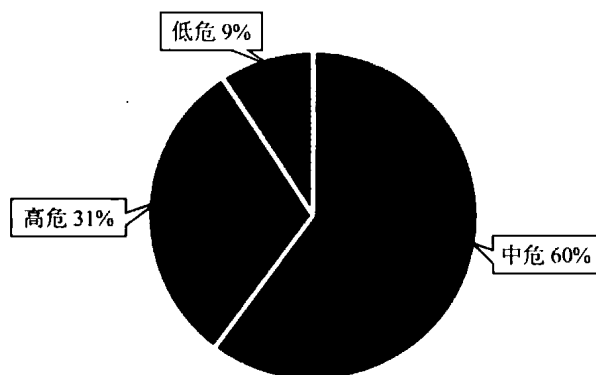


图 6-4 工控行业漏洞危险级别统计

软件缺陷通常在软件发布初期出现得较多，随着软件版本不断更新而减少。工控应用

系统中的高危漏洞占比如此之高，说明这些目标系统的安全性设计和验证还处于初期阶段，亟待自动化厂商在开发测试阶段加入安全设计基因，以降低产品发布后潜在的中高危漏洞的数量。

3. 漏洞类型复杂，危害严重

从图 6-5 可以看出，信息泄露相关的漏洞高居榜首，对工控系统的影响主要体现在两个方面：一方面，企业内部的工艺流程、图纸、排产计划等关键数据容易成为攻击者窃取的对象；另一方面，攻击者利用间谍工具收集的各种涉密信息，为后续具有破坏性的网络攻击提供安全情报。

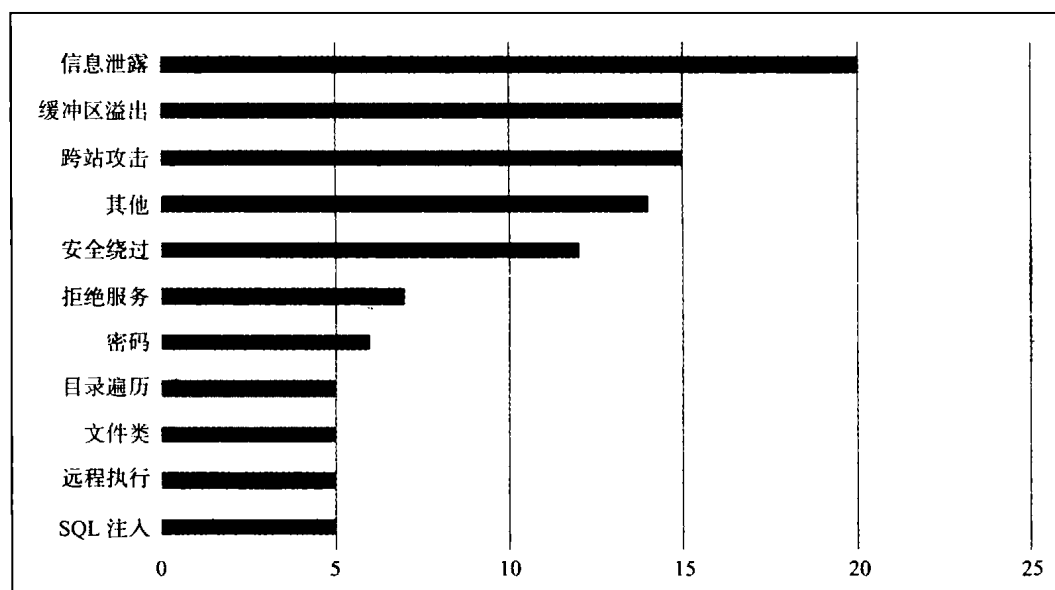


图 6-5 2015 年工控漏洞数量分布统计

紧随其后的是缓冲区溢出漏洞和跨站攻击漏洞，缓冲区溢出在各种操作系统、应用软件中广泛存在。利用缓冲区溢出漏洞，恶意攻击代码可以导致应用程序运行失败、系统宕机、重新启动，甚至用于执行非授权代码，对工业现场的智能设备下达非法指令（如修改运行参数、关闭阀门开关等）。

工控系统中的跨站攻击漏洞主要出现在现场设备提供的 Web 服务上，利用该漏洞攻击者可以盗取现场工程师或操作员的账号等信息，并利用盗取的信息进行非法操作，进一步使处于工作区域的工作站成为恶意代码和程序攻击目标设备的跳板。

另外值得一提的是，密码类漏洞明显增多（该漏洞在传统信息网络的漏洞中已经不多

见), 主要包括密码存储和传输过程中未进行加密和编码变换的处理, 或者设备的默认口令在实施过程后并未更改, 让攻击者很容易就能获取管理密码。

4. 漏洞的补丁发布严重滞后

发现漏洞并打补丁在信息安全领域是安全防护工作的常态, 但在工控安全领域却经常面临着发现了漏洞却无补丁可补的尴尬状态。从图 6-6 的数据看, 2015 年发布的新增漏洞中有 30% 的漏洞在发布的时候相关厂家并未提供漏洞补丁。

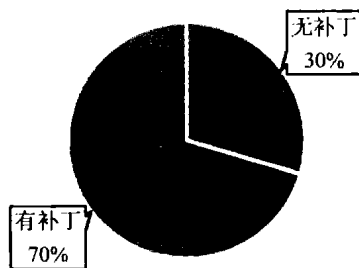


图 6-6 2015 年新增工业控制系统漏洞补丁情况统计

6.2 工业控制网络安全漏洞分析技术

工控系统这个“温室花朵”都有些什么样的漏洞呢? 有些工控系统的漏洞已经被发现, 并且公布在专门的漏洞发布平台上, 这种漏洞我们称为“已知漏洞”。对于已知漏洞, 检测起来相对简单一点。还有一些工控系统的漏洞我们称为“未知漏洞”, 在它们被发现以前, 我们对它们一无所知, 甚至在发现后的一段时间内也束手无策, 这种未知漏洞(也可以叫作零日漏洞)的危险性极大, 需要专门进行深度挖掘才能发现。

6.2.1 已知漏洞的检测技术

1. 现状

(1) 美国能源部 SCADA 测试平台计划 (2008 ~ 2013)

美国能源部通过联合其下属 Idaho 等 6 个国家实验室的技术力量, 提供各种工控系统的真实测试环境, 实现对石油、电力等行业控制系统的安全测评。其中典型测试平台包括 SCADA 控制系统测试平台(如图 6-7 所示)、信息安全测试平台、电网测试平台、无线技术测试平台。

(2) 欧洲 SCADA 漏洞检测平台

此平台采用现场系统进行渗透测试, 建立风险分析方法, 测试、评估 SCADA 系统的安全性。具有高度重构能力, 与其他 SCADA 系统安全、远距离通信连接, 构建先进的分布式测试环境。对于 CERT 发布的 SCADA 安全信息能够快速处理, 以保护世界各地的运行系统。

(3) 学术界工控系统漏洞检测技术研究

国外安全学者致力于搭建 SCADA 系统的真实测试环境, 模拟攻击行为, 通过仿真和建模分析 SCADA 系统的安全性。

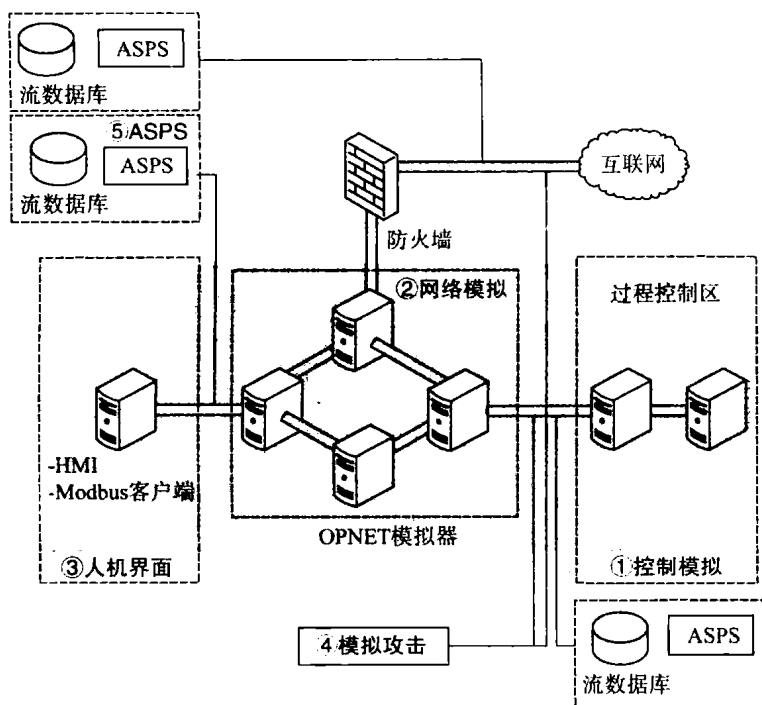


图 6-7 SCADA 控制系统测试平台实例

（4）国际知名工业安全测试公司相关产品和解决方案

加拿大 Wurldtech 的 Achilles 测试工具采用漏洞扫描和模糊测试的方法，测试工控系统中设备和软件的安全问题。

加拿大的 ICS Sandbox 测试平台采用渗透测试的方法，通过模拟真实的网络攻击，测试 SCADA 系统中关键基础设施的脆弱性。

芬兰科诺康 Codenomicon Defensics 工控健壮性 / 安全性测试平台采用基于主动性安全漏洞挖掘的健壮性评估与管理方案，与 ISASecure 合作，并遵循 IEC 62443 标准。

2. 工控系统漏洞检测的关键技术

（1）构建工控系统漏洞库

由于通信协议的特殊性，传统漏洞库并不适用于工业控制系统漏洞测试领域，需要构建工控系统专有漏洞库，其构建过程如图 6-8 所示。

一个漏洞扫描系统的“灵魂”就是它所使用的系统漏洞库，漏洞库信息的完整性和有效性决定了扫描系统的功能，漏洞库的编制方式决定了匹配原则以及漏洞库的修订、更新的性能，同时影响扫描系统的运行时间。

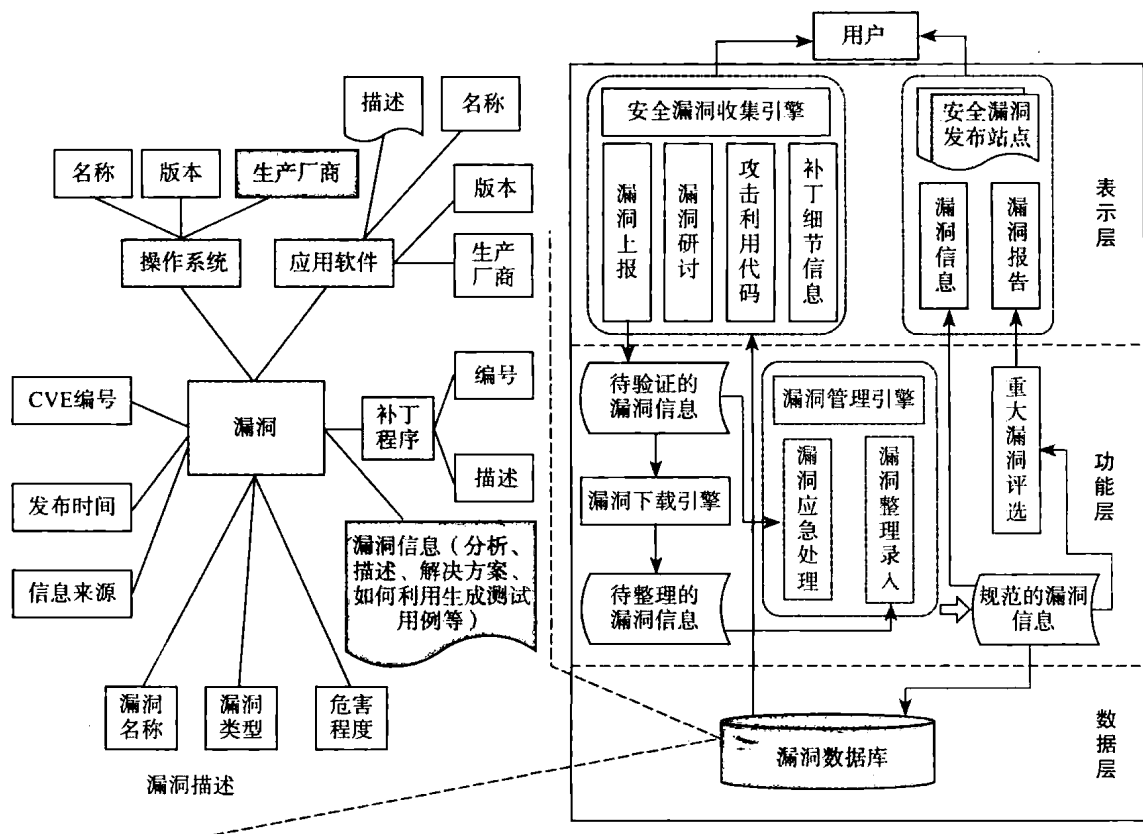


图 6-8 工控系统专有漏洞库构建过程

通过比较分析和实验分析，在漏洞库的设计中需要遵循以下几条原则：

1) 从漏洞库的简易性、有效性出发，选择以文本方式记录漏洞。这样易于用户自己对漏洞库进行添加配置。因此在提供漏洞库升级的基础上，又多出了一条途径更新漏洞库，以保持漏洞库的实时更新，也使得漏洞库根据不同的实际环境而具有相应的特色。

2) 对每个存在安全隐患的网络服务建立对应的漏洞库文件。一般情况下一个网络服务对应两个漏洞库，一个是针对类 UNIX 系统平台的漏洞库，另一个则是针对 Windows 平台的漏洞库。

3) 对漏洞危险性进行分级。这有助于系统管理员了解漏洞的危险性，从而决定所要采取的措施。

4) 提供漏洞危害性描述和建议的解决方案。有些扫描器虽然扫描漏洞的功能强大，但不提供详细描述和解决方案（如著名的扫描器 ISS Internet Scanner）。这往往导致系统管理员对检测出的漏洞没有足够的重视，或不了解它的危害不知如何修补漏洞而暂置一旁。因此，漏洞扫描器要真正发挥它的预警及预防的作用，真正成为系统管理员的有效助手，就

应当提供对漏洞的具体描述和有效的解决方案。

漏洞库的实现主要通过大量的公开漏洞资源收集，即主要是对 www.ics-cert.org、www.cert.org、www.exploit-db.com、www.aucert.com、www.securefocus.com 及中国绿色联盟等权威网站漏洞信息进行分类整理，对存在漏洞的主要网络服务逐一建立三级漏洞描述文件，作为各个漏洞扫描子模块的访问库体。

（2）基于工业漏洞库的漏洞检测技术

基于工业漏洞库的漏洞检测技术通过漏洞扫描引擎选用合适的检测规则，结合工控系统漏洞库，扫描系统中的关键目标系统和设备的脆弱性。另外，需要完整支持 Modbus、DNP3、Profinet 等工业通信协议，以及支持 ICMP Ping 扫描、端口扫描等传统扫描技术，其工作过程如图 6-9 所示^[72]。

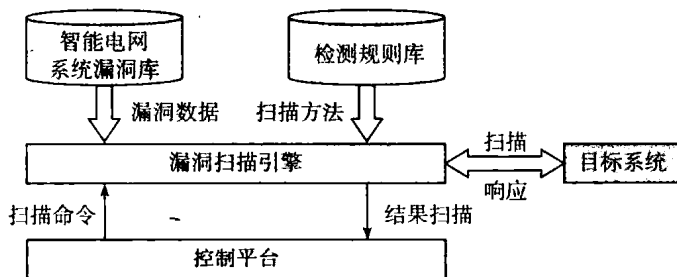


图 6-9 漏洞扫描过程

漏洞扫描的策略主要分为主机漏洞扫描和网络漏洞扫描，在工业控制系统场景下，主机漏洞扫描一般特指在上位机环境，包括操作员站、工程师站和服务器安装漏洞扫描的代理工具或者直接部署服务实现，从而方便实现对文件、进程、内存等对象的访问。而网络漏洞扫描则更多是针对目标系统、服务或者资源较低的工业设备本身进行的，通过构造特殊的数据包发送给目标，收集反馈信息来判断是否有特定的漏洞存在。

漏洞检测的主要方法包括直接测试、推理测试和凭证测试三种。

1) 直接测试：特指利用漏洞特点发现目标系统漏洞的方法，根据扫描检测或者渗透方式的不同，有些是直接有明确反馈而被观测到的，还有一些是需要稍作分析或者间接观测到的，由于其粗暴的攻击特性有的时候可能会造成检测的目标对象被破坏，但也正因为如此准确性比较高。典型的测试应用是 Web 服务漏洞测试和拒绝服务漏洞测试。

2) 推理测试：指根据相关系统、应用的版本、时序结果判断是否具有某个漏洞，并结合目标所表现出来的行为情况分析是否具有感染漏洞的行为特征的检测方法。这种方法对目标系统影响非常小，但是可能有较高的误检测情况。

3) 凭证测试: 是在已有访问服务的授权情况下, 进行对应检测的方式。

6.2.2 未知漏洞的挖掘技术

6.1 节中介绍过传统信息系统的漏洞挖掘方法对工控系统的适用性, 因为很难获取工控应用软件的源代码或目标文件, 因此目前对于工控系统未知漏洞的挖掘主要采用的是模糊测试 (Fuzzing) 的方法。

1. 传统 Fuzzing 技术简介

Fuzzing 技术是一种通过构造能够使软件崩溃的畸形输入来发现系统中存在漏洞的安全测试方法, 通常被用来挖掘网络协议、文件、ActiveX 控件中存在于输入验证和应用逻辑中的漏洞, 其自动化程度高、适应性广的特点使其成为漏洞挖掘领域最为有效的方法之一。

一般来说, Fuzzing 测试包括协议解析、测试用例生成、异常捕获和定位三个阶段。协议解析是通过公开资料或者对网络数据流量的分析, 理解待测协议的层次、包字段结构、会话过程等信息, 为后续生成测试用例打下基础; 测试用例生成依据上一阶段分析出来的包字段结构, 给待测对象发送采用变异方式生成的畸形测试用例; 异常捕获和定位的目的是通过多种探测手段发现由测试用例触发的异常, 保存异常相关数据信息, 为后续异常的定位和重现提供依据。整个流程如图 6-10 所示。

Fuzzing 技术一般可以分为两类:

1) 基于生成的 Fuzzing 算法。这种方法基于与有效输入结构和协议状态相关的生成规则进行建模, 构造模糊输入。最简单的基于生成的模糊测试器 (Fuzzer) 使用随机的方式构造任意长度字符串 (包含随机字节) 的模糊输入, 有些基于生成的模糊测试工具, 如 Sulley 和 Peach 也集成了基于块的特性。最新的基于生成的 Fuzzer, 如 EXE, 通过编码的方式来产生成功概率高的测试用例。基于生成的 Fuzzing 需要使用者对协议格式有非常透彻的了解, 并需要大量的人工参与。

2) 基于突变的 Fuzzing 算法。这种方法通过在已有数据样本中插入畸形字节以及 (或者) 变换字节来修改正常输入, 制造模糊输入。一些现代的突变 Fuzzer, 基于输入层的描述构造其模糊决策 (如 Peach 的突变)。其他突变 Fuzzer 如通用目标模糊测试器 (GPF) 并不需要知道输入协议的任何先验知识, 仅仅使用简单的启发式来猜测域的边界, 并对输入进行突变。CFG 模糊测试器对两者进行了折中, 通过使用推论算法从足够规模的网络流

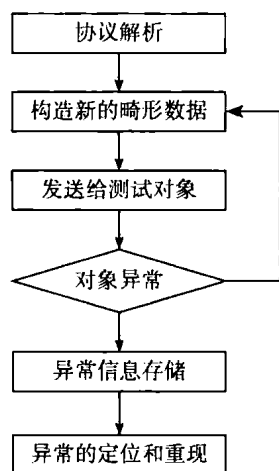


图 6-10 传统 Fuzzing 测试流程

量中推导协议的近似生成模型,然后使用变异算法来生成突变的输入。该方法对变异的初始值有着很强的依赖性,不同的初始值会造成代码覆盖率差异很大,从而产生截然不同的 Fuzzing 测试效果,大多数突变 Fuzzer 使用预先捕获的网络流量作为突变的基础,少数也会部署一些内联 Fuzzer 来读取实时流量。

相比基于生成的 Fuzzing 算法,基于突变的 Fuzzing 算法更适合对私有协议进行模糊测试。

2. 传统的 Fuzzing 工具难以测试工控网络协议

由于工控系统以及工控网络协议的特殊性,传统网络协议 Fuzzing 测试技术无法直接应用,具体体现在协议解析、异常捕获和定位以及部署方式上存在的困难。

(1) 工控网络协议解析方面

根据信息公开的程度,工控网络协议大致可以分为两种:私有协议,如 Harris-5000 以及 Conitel-2020 设备的协议,这些协议资料不公开或者只在有限范围内半公开,数据包和字段的含义未知,协议会话过程功能不清晰;非私有协议,如 Modbus TCP、DNP3、IEC61850 以及 CIP、EtherNet/IP 等,具有协议资料公开、会话功能明确的特点。

对于公开的控制协议,虽然可以使用基于生成的 Fuzzing 技术进行测试,但由于工控协议面向控制、高度结构化、控制字段数量较多,使得需要构造大量的变异器,测试效率不高。

对于私有的控制协议,需要先弄清楚协议的结构才能进行模糊测试。一般来说,有两种思路:对协议栈的代码进行逆向分析,分析出重要的数据结构和 workflows;抓取协议会话数据包,根据历史流量来推测协议语义。

对于大量使用私有协议的基于嵌入式的工控系统来说,其运行环境较为封闭,很难使用加载调试器的方法对协议栈的二进制代码进行逆向分析。相比之下,采用基于数据流量的协议解析方法更实际。然而,工控设备具有时间敏感、面向会话的特点,使得部署需要大规模网络流量输入的基于突变的传统 Fuzzing 测试工具并不现实。

(2) 工控网络协议异常捕获和定位方面

目前在网络协议 Fuzzing 测试中常用的异常检测手段主要有返回信息分析、调试器跟踪及日志跟踪 3 种方法。

对于返回信息分析,主要通过分析请求发送后得到的返回信息判断目标是否出错,其优点是处理简单,但由于工控设备具有较快的自修复能力,在发生异常后网络进程会自动重启,如果请求收发频率不够高,将无法捕获发生的异常。

对于调试器跟踪,主要通过监视服务器进程,在进程出错时抓取进程异常信息并重启

来实现，但由于工控设备运行环境封闭，且使用嵌入式系统，难以安装第三方调试工具，因而该方法只适用于工控设备机对协议栈的分析，无法应用在 PLC 等工控设备上。

对于日志跟踪，主要通过解析服务器日志判断进程是否发生异常，但由于工控设备属嵌入式系统，计算、存储和网络访问均受到严格的制约，在 PLC 等工控设备上难以实现对异常事件的日志记录和访问。

(3) Fuzzing 测试工具的部署方式方面

目前，由于在传统信息系统中 C/S 模式的 Client 端漏洞利用较困难，价值相对不高，因而传统网络协议 Fuzzing 测试技术主要针对 Server 端软件，较少涉及 Client 端，但有些工控系统 Client 端负责数据采集与监视控制，其网络协议栈存在的漏洞可能导致重要数据传输实时性的丧失，影响生产控制过程的正常运行，因此只测试 Server 端的 Fuzzing 测试工具不能满足工控协议测试的需求。

3. 工控 Fuzzing 测试框架的设计准则

根据工控网络协议的特点，结合已有工控网络协议 Fuzzing 测试的研究成果，从模糊测试的步骤和部署方式来看，工控网络协议 Fuzzing 测试框架应该遵循以下几点准则。

(1) 支持对私有工控网络协议的测试

由于大量工控网络协议结构不公开，对私有协议的支持成为工控网络协议 Fuzzing 测试框架的首要需求。一般来说，对于私有协议的模糊测试思路主要有离线分析和在线分析两种。

1) 基于离线分析：梳理协议的结构和内容，生成协议模型，然后在此基础上进行 Fuzzing 测试，即先将私有协议变成公有协议，再使用基于生成的方法产生测试数据，如图 6-11 所示。

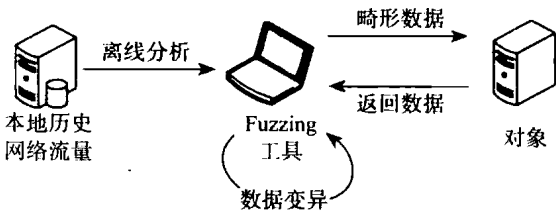


图 6-11 基于离线分析的模糊测试

2) 基于在线分析：只是使用在线的方式，通过人工智能的方法对工控网络协议的实时网络流量进行学习，生成并完善协议的语义结构，如图 6-12 所示。

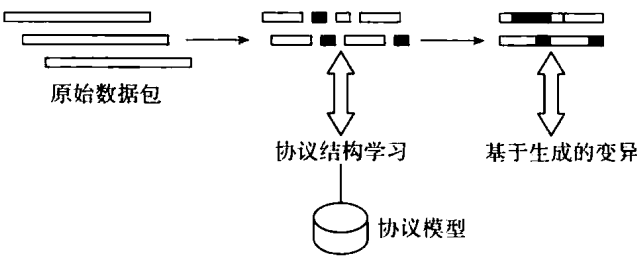


图 6-12 基于在线分析的模糊测试

离线分析方法虽然生成的测试用例质量较高，但需要积累相当数量的历史网络数据流量作为原始样本，且

初始阶段需要耗费大量的人力，对协议分析经验要求较高且实时性差。相比之下，在线分析方法虽然在测试初期生成的模型较为粗糙，需要耗费大量计算资源，但随着学习过程的不断深入，模型会逐步成熟，测试用例的质量也会不断提升。

（2）不依赖本地调试进行异常捕获和定位

作为工控系统的核心组件，PLC 等物理设备运行环境封闭且存储计算资源受限，无法通过附加调试组件的方式记录异常事件并保存日志，只能依赖网络探测的方式。较为可行的方法之一是使用心跳机制，以间歇性“请求-响应”的形式探测目标是否出错，同时结合异常隔离机制，在每传输一组测试用例后通过发送心跳包的方式检测对象是否发生异常，如果超过一定的时间阈值未收到回复包，则认为测试对象发生了异常，需采取逐步隔离的方式，如图 6-13 所示，从该组用例中找出触发异常的单个测试用例，并保存异常产生的流量数据，以便进一步分析。



图 6-13 基于心跳检测的故障隔离技术

此外，对于构建于 TCP 之上的工控网络协议，TCP RST 标识也可以用来检测测试对象的网络异常。

（3）具有对网络协议进行双向测试的能力

工控协议要支持对 Server 端和 Client 端的双向测试，且对数据流量较小、类型单一的工控私有网络协议 Client 端而言，由于其会话时间较短、时间敏感性强，对要求大量历史数据流量的传统 Fuzzing 测试工具基本免疫，可行的方法之一是采取内联的方式，通过 ARP 欺骗，将 Fuzzing 测试工具插入服务器和客户端之间，捕获发往 Server 端或者 Client

端的实时通信流量数据，使用重放或中间人攻击对数据进行区域突变，产生用于测试的畸形数据，发送给测试对象，如图 6-14 所示^[73]。

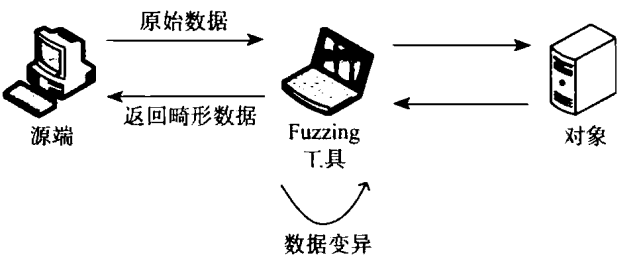


图 6-14 工控网络协议的双向模糊测试

6.3 上位机漏洞分析

工业控制系统从结构上分类，主要包括数据采集与监控系统、分布式控制系统、可编程逻辑控制器、远程终端单元等，从安全研究的角度来看简要分类为上位机和下位机环境。而现在已知的大量工控安全事件，多数是从上位机发起的，本节主要介绍上位机的概念及其安全问题，下节将对下位机的内容进行介绍。

6.3.1 上位机概念和简史

上位机是指人可以直接发出操控命令的计算机设备，一般是 PC、人机界面等，常见的上位机包括 HMI、操作员站、工作站等。它的作用是监控现场设备的运行状态以及下达控制指令，当现场设备出现问题时，上位机屏幕上就能显示出各设备之间的状态（如正常、报警、故障等），上位机屏幕上也会显示各种信号变化（如液压、水位、温度等）。

以图 6-15 所示的变频调速系统为例，上位机需要连接可编程控制器（PLC）、变频器、直流调速器、仪表等工业控制设备，利用显示屏显示，通过输入单元（如触摸屏、键盘、鼠标等）写入工作参数或输入操作命令，实现人与机器信息交互的数字设备，其由硬件和软件两部分组成。

上位机除了与通用 PC 基本一致的操作员站之外，最有代表性的就是 HMI，HMI 的硬件部

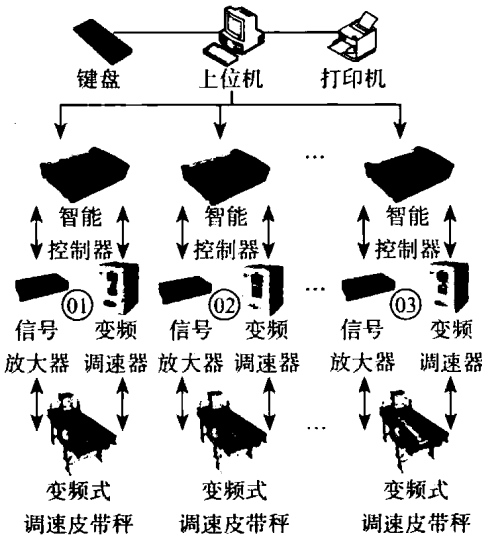


图 6-15 变频调速系统原理图

分包括处理器、显示单元、输入单元、通信接口、数据存储单元等，其中处理器的性能决定了 HMI 产品的性能高低，是 HMI 的核心单元，如图 6-16 所示。根据 HMI 的产品等级不同，处理器可分别选用 8 位、16 位、32 位的处理器。

HMI 软件一般分为两部分，即运行于 HMI 硬件中的系统软件和运行于 PC Windows 操作系统下的画面组态软件（如 JB-HMI 画面组态软件），如图 6-17 所示。使用者都必须先使用 HMI 的画面组态软件制作“工程文件”，再通过 PC 和 HMI 产品的串行通信口，把编制好的“工程文件”下载到 HMI 的处理器中运行。

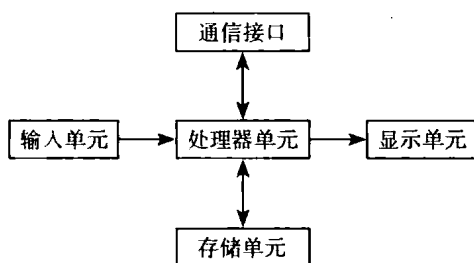


图 6-16 人机界面硬件构成

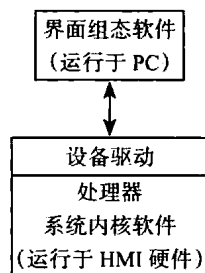


图 6-17 人机界面软件构成

要挖掘上位机的漏洞就需要熟悉市面上常见的上位机系统环境，下面对常见的上位机系统环境及简史进行介绍。

（1）Wonderware

Wonderware 是上位机软件市场最早期的开拓者。其 HMI 的市场份额很大，SCADA 软件的技术更是领先同期的很多厂商，起家于美国，旗下的 Intouch HMI 软件极为出名，Intouch 后来被 Invensys 集团收购。2013 年，Invensys 集团又向施耐德电气集团（Schneider Electric）出售了自动化产品线的业务，Wonderware 现在属于施耐德。

（2）Intellution

Intellution 的核心代表产品是 iFix，它是世界排名第二的 HMI 软件，后被 WinCC 超越。爱默生（Emerson）后来并购了 Intellution 公司，GE 自动化后来又从爱默生公司并购了 Intellution 产品线。Intellution 现在归属于 GE 自动化。

（3）西门子

WinCC 隶属于西门子，是欧洲业绩第一的上位机软件，在中国区市场中 WinCC 市场份额也极高，破解版的 WinCC 软件更是被大量应用。

（4）Citect

Citect 是澳大利亚本土软件厂商。后被施耐德收购。借助施耐德强力的销售渠道，Citect 的销售业绩后来居上，Citect 现归属于施耐德。

(5) Cimplicity

Cimplicity 是 GE 旗下原生的 HMI 软件产品,收购了 Intellution 之后 GE 旗下便拥有了 Cimplicity HMI 和 iFix 两条上位机软件产品线。

(6) FactoryLink

FactoryLink 属于 UGS 旗下的 Tecnomatix 子公司。后来被西门子收购后不再更新。

(7) PVSS

PVSS 是奥地利 ETM 公司的产品。后来 ETM 被西门子收购, PVSS 并入西门子,更名为 WinCC OA。PVSS 专门面向大的自动化控制系统,具有跨平台特性,支持 UNIX 和 Linux 平台。

6.3.2 上位机常见安全问题

上位机漏洞包括通用平台的系统漏洞、采用的中间件漏洞、工控系统驱动漏洞、组态开发软件漏洞、Activex 控件和文件格式等,这些漏洞形成的原因有多种。目前,针对上位机环境开发语言多为 C/C++,下面我们对使用 C/C++ 开发的上位机系统环境的常见漏洞从源头进行分析。

(1) 缓冲区溢出漏洞

缓冲区溢出漏洞一般是在程序编写的时候不进行边界检查,超长数据可以导致程序的缓冲区边界被覆盖,通过精心布置恶意代码在某一个瞬间获得 EIP 的控制权并让恶意代码获得可执行的时机和权限。在 C/C++ 开发的上位机系统里比较常见的就是缓冲区数组。

(2) 字符串溢出漏洞

字符串存在于各种命令行参数,在上位机系统和系统使用者的交互使用过程中会存在输入的行为。XML 在上位机系统中的广泛应用也使得字符串形式的输入交互变得更为广泛。字符串管理和字符串操作的失误已经在实际应用过程中产生过大量的漏洞,差异错误、空结尾错误、字符串截断和无边界检查字符串复制是字符串常见的 4 种错误。

(3) 指针相关漏洞

来自外部的数据输入都要存储在内存当中,如果存放的时候产生写入越界正好覆盖掉函数指针,此时程序的函数执行流程就会发生改变,如果被覆盖的地址是一段精心构造的恶意代码,此恶意代码就会有被执行的机会。不仅是函数指针,由于上位机系统开发流程的日益复杂,很多时候面临的是对象指针。如果一个对象指针用作后继赋值操作的目的地,那么攻击者就可以通过控制该地址从而修改内存其他位置中的内容。

(4) 内存管理错误引发漏洞

C/C++ 开发的上位机系统有时候需要对可变长度和数量的数据元素进行操作,这种操作对应的是动态内存管理。动态内存管理非常复杂。初始化缺陷、不返回检查值、空指针

或者无效指针解引用、引用已释放内存、多次释放内存、内存泄漏和零长度内存分配都是常见的内存管理错误。

(5) 整数类溢出漏洞

这几年整数安全问题有增长趋势，在上位机系统的开发者眼里，整数的边界溢出问题通常大部分时候并没有得到重视，很多上位机系统开发人员明白整数是有定长限制的，但是很多时候他们会以为自己用到的整数表示的范围已经够用。整数类漏洞的情景通常是这样的，当程序对一个整数求出了一个非期望中的值，并进而将其用于数组索引或者大于后者循环计数器的时候，就可能导致意外的程序行为，进而导致可能的漏洞利用。

6.3.3 上位机典型漏洞分析

上位机系统漏洞挖掘分析一直是一个重要的研究课题。对于上位机典型漏洞，我们分别以 dll 劫持漏洞、ActiveX 控件漏洞、组件服务类漏洞为例进行说明。

1. 上位机系统 dll 劫持漏洞分析

由于上位机系统软件更新频次较低，dll 劫持漏洞较为普遍，我们从 ICS-CERT 统计了历年的该类漏洞信息，如表 6-3 所示。

表 6-3 上位机系统 dll 劫持漏洞

上位机系统 dll 劫持漏洞	CVE 编号
RealFlex RealWinDemo DLL Hijack	CVE-2012-3004
Open Automation Software OPC Systems NET DLL Hijacking	CVE-2015-7917
Measuresoft ScadaPro DLL Hijack	CVE-2012-1824
Cimon CmnView DLL Hijacking Vulnerability	CVE-2014-9207
WellinTech KingView DLL Hijack Vulnerability	CVE-2012-1819
Rockwell Automation FactoryTalk DLL Hijacking Vulnerabilities	CVE-2014-9209
ABB Panel Builder 800 DLL Hijacking Vulnerability	CVE-2016-2281
ABB RobotStudio and Test Signal Viewer DLL Hijack Vulnerability	CVE-2014-5430
Ecava IntegraXor DLL Hijacking	CVE-2015-0990
Invensys Wonderware InTouch 10 DLL Hijack	CVE-2012-3005
Siemens SIMATIC STEP 7 DLL Vulnerability	CVE-2012-3015
7-Technologies Termis DLL Hijacking	CVE-2012-0223
Schneider Electric OFS Server Vulnerability	CVE-2015-1014
7-Technologies Interactive Graphical SCADA	CVE-2011-4053

dll 劫持漏洞在上位机系统中每年都会被发掘并上报，上位机现存系统中该类漏洞数量很高。常见挖掘方法一般来说都是用 dll Hijack Auditor（dll 劫持检查工具）或者类似工具生成一个测试 dll，测试 dll 里面包含一段特定的标记代码，通过将该测试 dll 置于不同的路径，重启目标进程后检测特定的标记代码是否执行来检测目标软件是否存在 dll 劫持漏洞。该类

工具局限性较大，只能基于路径进行 dll 劫持的检测。对于 dll 的特定时刻会被调用的特定函数无法作劫持检测。我们还可以通过手工的方式对 dll 劫持漏洞进行挖掘。dll 劫持漏洞手工检测流程如图 6-18 所示。

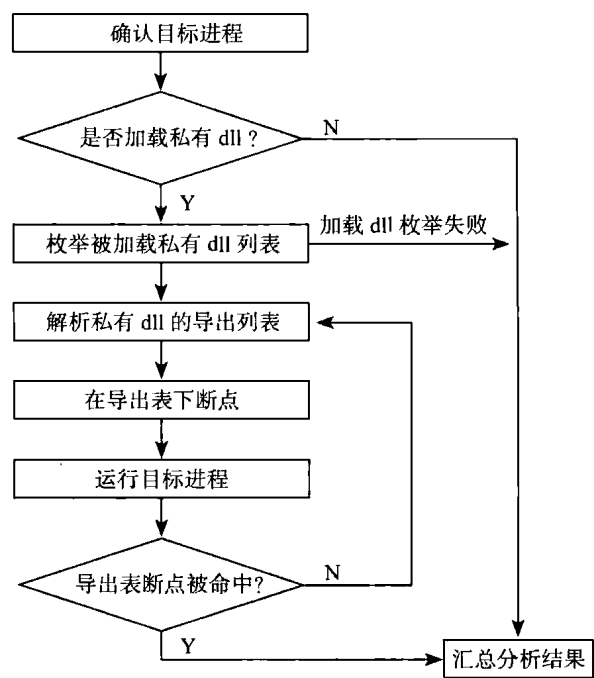


图 6-18 上位机系统的 dll 劫持漏洞挖掘流程

对上位机软件 WebAccess 的 3 个版本 7.2/8.0/8.1 分别进行 dll 劫持漏洞挖掘测试，结果如表 6-4 所示。

表 6-4 手工方式 dll 劫持漏洞挖掘的结果

dll 劫持挖掘工具	上位机名称	dll 组件名称	可被劫持函数
流程图手工检测	WebAccess 7.2/8.0/8.1	bwopctool.dll	BwSetCurrentRPCJobID
流程图手工检测	WebAccess 7.2/8.0/8.1	bwabout.dll	BwGetPrivateProfileIntMutex
流程图手工检测	WebAccess 7.2/8.0/8.1	bwpalarm.dll	BwProjInitKey
流程图手工检测	WebAccess 7.2/8.0/8.1	webvsid.dll	WsPingLocalServer
DllHijackAuditKit	WebAccess 7.2/8.0/8.1	无法检出可被劫持 dll	无法检出可被劫持 dll 函数
DllHijackAuditor	WebAccess 7.2/8.0/8.1	无法检出可被劫持 dll	无法检出可被劫持 dll 函数

使用流程图展示的手工挖掘流程一共挖掘了该上位机系统的 4 个漏洞，而机械地使用 dll 劫持测试工具并无法挖掘出可被劫持 dll 函数的 dll 劫持漏洞。

2. 上位机组件 ActiveX 控件漏洞分析

ActiveX 于 1996 年推向市场。由于支持将原生的 Windows 技术嵌入至网页浏览器，

ActiveX 的发展很快得到了很多企业的响应。在 2015 年 7 月 29 日发行的 Windows 10 自带的 Edge 浏览器中不再支持 ActiveX。但为兼容性需要，Windows 10 自带 IE11 依然支持 ActiveX。上位机系统的开发人员往往并不很关注安全。一般开发好 ActiveX 控件之后都会全部打包到上位机系统安装包内，在 ActiveX 控件当中上位机系统开发人员往往封装了很多功能强大的接口，例如，直接可以调用 ActiveX 控件操作新增或者修改文件内容，操作 WMI 访问登录信息，直接运行其他的可执行文件。这些属于封装的 ActiveX 控件的正常功能，问题出在安装的时候不对控件加以区分，全都加入 SFS（Safe For Scripting，脚本安全）标志。一个 ActiveX 控件被标注为 SFS 之后 IE 可以通过脚本语言（如 JavaScript 或 VBScript）调用控件，并修改或读取它的属性，这也意味着攻击者可以写一段网页代码去调用别的软件的 ActiveX 控件达到远程操作注册表文件的效果。上位机系统中有很多大量的远程交互操作，这些大都是通过 ActiveX 控件实现的。

笔者从 ICS-CERT 统计了近些年上位机系统的 ActiveX 控件漏洞，如表 6-5 所示。

表 6-5 ICS-CERT 历年上位机 ActiveX 模块漏洞统计

上位机系统 ActiveX 控件漏洞	CVE 编号
WellinTech KingView ActiveX Vulnerabilities（亚控组态王）	CVE-2013-6127 CVE-2013-6128
InduSoft ISSymbol ActiveX Control Buffer Overflow	暂无
Schneider Electric SoMachine HVAC Unsafe ActiveX Control Vulnerability	CVE-2016-4529
InduSoft ISSymbol ActiveX Control Buffer Overflow	CVE-2011-0342
Honeywell ScanServer ActiveX Control	暂无
Wonderware InBatch ActiveX Vulnerabilities	CVE-2011-4870
Wonderware InBatch Client ActiveX Buffer Overflow	暂无
ICONICS GENESIS32 Insecure ActiveX Control	CVE-2014-0758
Advantech Broadwin WebAccess ActiveX Vulnerability	暂无
Advantech Studio ISSymbol ActiveX Buffer Overflow	CVE-2011-0340
Moxa VPort ActiveX SDK Plus Stack-Based Buffer Overflow Vulnerability	CVE-2015-0986
Siemens SIMATIC RF Manager ActiveX Buffer Overflow	CVE-2013-0656
WellinTech KingView ActiveX Vulnerabilities	暂无
ARC Informatique PcVue 上位机 ActiveX Vulnerabilities	CVE-2011-4042
WellinTech KingView 6.53 KVWebSvr ActiveX	暂无
ICONICS Login ActiveX Vulnerability	暂无
Ecava IntegraXor ActiveX Buffer Overflow	CVE-2012-4700

(1) ActiveX 模块漏洞挖掘前置知识

1) SFS。一旦 ActiveX 被标记了 SFS，浏览器就可以通过脚本语言（如 JavaScript 或 VBScript）调用控件，并设置或获得它的属性，这意味着攻击者可以直接构造一组恶意的内

嵌脚本语言的 HTML 网页，直接调用该属性实现堆栈溢出攻击或者远程调用该 ActiveX 模块的注册表文件进程操作接口，进行远程未授权的恶意操作。

2) KillBit。注册表中有一个项目叫 KillBit，当被标记了 KillBit 后，浏览器便不再加载该 ActiveX 控件。当控件被发现有漏洞的时候，可优先设置 KillBit 以使浏览器在使用默认设置时不调用存在漏洞的 ActiveX 控件。

(2) ActiveX 漏洞挖掘分析

ActiveX 漏洞从形成上区分为如下两类。

1) 逻辑类漏洞：不应该标记 SFS 的模块错误地标记了 SFS，并且该模块提供了注册表、进程和文件的接口，结果导致可以进行远程未授权的操作。

2) 溢出类漏洞：由于功能需要模块被标记了 SFS，但是该模块提供的接口存在堆栈溢出的风险。

现有的 ActiveX 漏洞挖掘分为工具挖掘和手工测试。工具类漏洞挖掘如 Axfuzz、Axman、Comraider、Dranger 普遍对逻辑类漏洞的挖掘能力比较弱，而纯手工测试对于溢出类漏洞的挖掘效率比工具低很多。这时我们可以使用下列 ActiveX 漏洞挖掘流程对上位机 ActiveX 模块进行漏洞挖掘测试。

步骤 1：获取 ActiveX 控件信息

使用注册表操作函数枚举 HKEY_CLASSES_ROOT\CLSID 中记录的 classid 下面的 typelib。使用 OLEView 工具再一次枚举 typelib，综合两次枚举获取完整的 ActiveX 的 typelib 信息。

步骤 2：判定 ActiveX 控件是否设置 KillBit

使用注册表操作函数在下列注册表位置枚举 KillBit 标志 DWORD 值 0x00000400，并作记录。记录如下：

32 位 IE/32 位 Windows：HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\InternetExplorer\ActiveX Compatibility/。

64 位 IE/64 位 Windows：HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\InternetExplorer\ActiveX Compatibility/。

32 位 IE/64 位 Windows：HKEY_LOCAL_MACHINE\SOFTWARE\Wow6432Node\Microsoft\Internet Explorer\ActiveX Compatibility/。

步骤 3：判定 ActiveX 控件是否标记脚本安全

使用注册表操作函数枚举“HKEY_CLASSES_ROOT\CLSID /<control clsid>/Implemented Categories”的注册表键并确认该项下具有子键 7DD95801-9882-11CF-9FA9-00AA06C42C4。

具有该注册表键者为脚本安全，记录进入步骤 4。

步骤 4：挖掘 ActiveX 模块的漏洞

1) 通过步骤 2 和步骤 3 筛选出没有被设置 KillBit 并且是 SFS 的 ActiveX 控件，通过步骤 1 解析出接口的名称、方法、属性。根据名称手工排查表 6-5 和类似表 6-5 命名的文件 / 注册表类操作函数，如表 6-6 所示。

表 6-6 常见 ActiveX 文件注册表可能函数名称

函数类型	函数可能名称	函数类型	函数可能名称
文件操作	saveto/writeto/save/write/deletefile	信息泄露	read/show/getinfo/getfile/get
注册表操作	getregvalue/setregvalue/setregedit	网页下载	urldownload/hostnameget/remotefile

2) 在网页中用脚本调用具有类似表 6-6 的威胁函数进行测试，使用含有畸形超长数据的网页对其他 ActiveX 接口进行测试。

3) 汇总分析结果。

图 6-19 给出了 ActiveX 模块漏洞挖掘的流程简图。

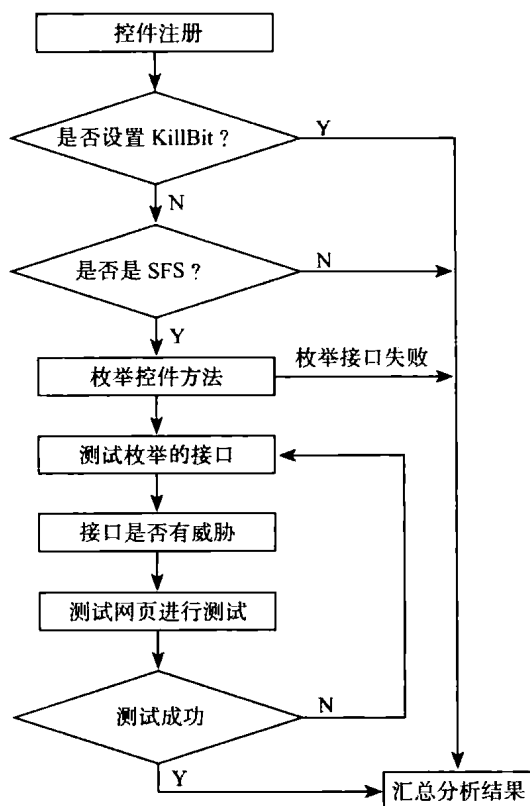


图 6-19 上位机系统的 ActiveX 模块的漏洞挖掘流程

按照上述的 ActiveX 模块的漏洞挖掘流程，在上位机系统的 ActiveX 控件挖掘中成功挖掘了两个漏洞，如表 6-7 所示。

表 6-7 WebAccess ActiveX 漏洞挖掘结果

ActiveX 漏洞挖掘方式	上位机名称	挖掘到的漏洞
新方法挖掘	WebAccess 7.2/8.0/8.1	ActiveX ChkTable 缓冲区溢出
新方法挖掘	WebAccess 7.2/8.0/8.1	ActiveX VBWinExec 函数逻辑远程执行
传统方式挖掘	WebAccess 7.2/8.0/8.1	暂未挖掘到 WebAccess 的 ActiveX 漏洞

3. 上位机组件服务类漏洞分析

由于上位机系统的功能比较复杂，大都需要在系统上安装很多服务，因此服务提权类漏洞比较普遍。表 6-8 是从 ICS-CERT 网站统计的历年服务类权限问题导致的漏洞。

表 6-8 ICS-CERT 历年上位机本地权限提升类漏洞统计

漏洞名称	CVE 编号
Siemens SINEMA Server Privilege Escalation Vulnerability	CVE-2016-6486
Resource Data Management Privilege Escalation Vulnerability	CVE-2015-6470
Siemens COMOS Privilege Escalation Vulnerability	CVE-2013-4943
Innominate mGuard Privilege Escalation Vulnerability	CVE-2014-9193
Siemens COMOS Privilege Escalation	CVE-2013-6840
Siemens SCALANCE Privilege Escalation Vulnerabilities	CVE-2013-3633
Siemens COMOS Database Privilege Escalation Vulnerability	CVE-2012-3009
GE Proficy HMI SCADA CIMPLICITY Privilege Management Vulnerability	CVE-2016-5787

服务的权限类漏洞可以认为是访问控制缺陷，这种漏洞一般无法使用 Fuzzing 工具来进行挖掘，因为常规的 Fuzzing 工具无法理解应用程序的逻辑，不容易判定访问控制越权。

(1) 上位机组件服务提权类漏洞挖掘前置知识

1) AccessChk 工具。AccessChk 工具被包含在 Sysinternals 套件工具包里面，主要用于检查一个程序可以被何种权限的用户访问，使用命令“accesschk.exe-q-v-c 服务名”即可检查一个服务可以被何种权限的用户访问。

2) sc 命令。sc 命令是 Windows 命令行工具中自带的，可以用来查询、枚举、更改服务的状态。使用“sc qc 服务名称”即可查询一个服务的状态。

(2) 上位机组件服务提权类漏洞挖掘流程

针对 Fuzzing 工具无法挖掘组件服务类权限访问控制漏洞，我们使用以下流程来对组件服务类权限访问控制类漏洞进行更高效的挖掘。

1) 安装目标上位机系统，使用 Windows 自带的服务管理工具来侦测目标上位机系统新创建的服务。

2) 使用 `sc` 命令来枚举目标上位机系统的服务，并且使用 `AccessChk` 来侦测该服务对于各个用户组的权限。

3) 筛选用户组为 `RW EVERYONE` 并且服务权限为 `SERVICE_ALL_ACCESS` 的服务。

4) 循环枚举目标上位机系统创建的服务直到枚举完毕。

5) 汇总分析结果。

完整的组件服务提权类漏洞挖掘流程如图 6-20 所示。

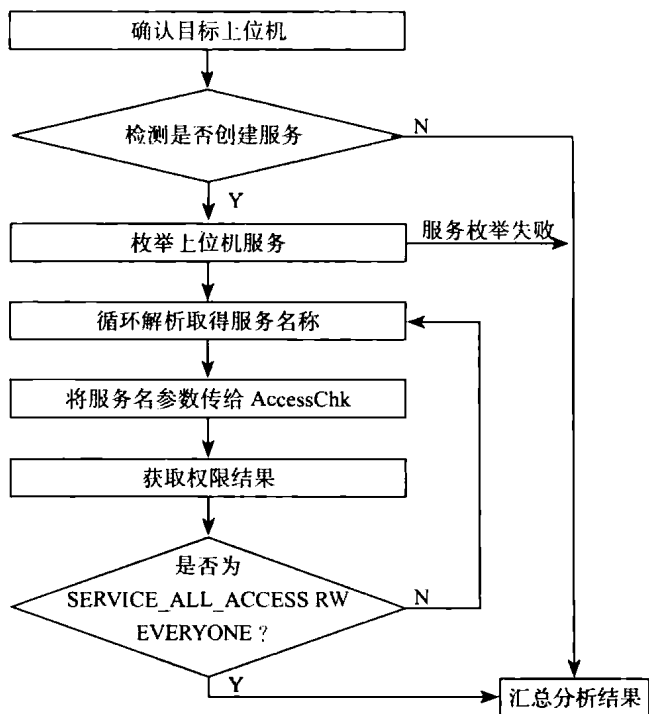


图 6-20 上位机系统的服务提权漏洞挖掘流程

我们使用图 6-20 所提出的挖掘服务类访问权限控制漏洞方法，挖掘了 GE Proficy HMI SCADA CIMPLICITY 的服务权限提升漏洞，而传统的 Fuzzing 工具对于组件服务类权限访问控制漏洞暂时没有很好的挖掘方法^[76]。

6.4 下位机漏洞分析

虽然就目前绕开上位机直接针对下位机攻击的情况还不多，但是随着社会工程和无线在工业控制系统环境下的应用越来越多，以及很多直接暴露在互联网环境下的下位机服务，下位机上的漏洞将呈现飞速增长。下面我们就一起来看看关于下位机的一些概念和安全问题。

6.4.1 下位机概念和简史

下位机是直接控制设备和获取设备状况的计算机，一般是 PLC、单片机、智能仪表、智能模块等。上位机发出的命令首先下达下位机，下位机再根据此命令转换成相应的时序信号直接控制相应设备。下位机间歇性地读取设备状态信息，转换成数字信号反馈给上位机，上下位机也都需要进行功能编程，基本都有专门的开发系统。概念上，被控制者和被服务者是下位机。本身上位机和下位机可以理解为主从关系，在一些特定的应用或者场景下两者也可以互换。

常见的下位机一般指放置在现场的数据采集设备，如 AD4500 等设备，用来采集相关智能设备运行的数据，并把数据通过串口或者其他通信方式传送给服务器端。下位机一般具有自我检查和自我启动的功能，是一种小型的计算机，功能比较单一，大多使用 VxWorks、 μ CLinux 或 WinCE 等专用的嵌入式操作系统。在一般情况下，一个上位机对应几个下位机，上位机把服务器的控制信息下达给下位机或者把下位机的数据转发给服务器。有时候上位机本身就充当服务器。

两机之间的通信方式通常由下位机决定。一般情况下，TCP/IP 都是支持的，但是下位机通常会有更可靠的专有通信协议。购买下位机时会附有大量的参考手册和使用光盘，指导用户怎样使用它的专有协议通信，里面会有大量实际应用的例子，这对于编程人员而言并没有多么复杂，只是使用一些新的 API。

通常下位机和上位机的通信可以采用不同的通信协议，可以使用 RS232 串口通信，或者使用 RS485 串行通信，当用下位机和上位机通信的时候，不仅可以使传统形式的串行通信，还可以使用更适合工业控制的双线的 Profibus-DP 通信，采用生产厂商封装好的程序开发工具进行开发，就可以实现下位机和上位机的通信。当然也可以自己编写驱动类的接口协议控制下位机和上位机的通信。

因为 PLC 在下位机中的普遍意义，以及超过 95% 的下位机漏洞占比，我们对下位机的分析就以 PLC 为样本。

下位机 PLC 有许多种定义。IEC 对 PLC 的定义是：可编程控制器是一种数字运算操作的电子系统，专为在工业环境下应用而设计。它采用可以编制程序的存储器，用来在其内部存储执行逻辑运算、顺序运算、计时、计数和算术运算等操作的指令，并能通过数字式或模拟式的输入和输出，控制各种类型的机械或生产过程。PLC 及其有关的外围设备都应该按易于与工业控制系统形成一个整体、易于扩展其功能的原则而设计。

1968 年美国 GM（通用汽车）公司提出取代继电器控制装置的要求，次年，美国数字公司研制出了基于集成电路和电子技术的控制装置，首次采用程序化的手段应用于电气控制，

这就是第一代可编程控制器，称为 Programmable Controller (PC)。直到个人计算机（简称 PC）发展起来后，为了方便，也为了反映可编程控制器的功能特点，可编程控制器定名为 Programmable Logic Controller (PLC)。

20 世纪 80 年代至 90 年代中期是 PLC 发展最快的时期，年增长率一直保持在 30% ~ 40%。在这段时期，PLC 在处理模拟量能力、数字运算能力、人机接口能力和网络能力方面得到大幅度提高，并逐渐进入过程控制领域，在某些应用上取代了在过程控制领域处于统治地位的 DCS。目前，PLC 在国内外已广泛应用于钢铁、石油、化工、电力、建材、机械制造、汽车、轻纺、交通运输等行业。

6.4.2 下位机常见安全问题

下位机暴露在互联网中会带来许多安全隐患。

1. 未授权访问

未授权访问指未经授权使用网络资源或以未授权的方式使用网络资源，主要包括非法用户进入网络或系统进行违法操作以及合法用户以未授权的方式进行操作。

防止未经授权使用资源或以未授权的方式使用资源的主要手段就是访问控制。访问控制技术主要包括入网访问控制、网络的权限控制、目录级安全控制、属性安全控制、网络服务器安全控制、网络监测和锁定控制、网络端口和节点的安全控制。根据网络安全的等级、网络空间的环境不同，可灵活地设置访问控制的种类和数量。

2. 通信协议的脆弱性

不仅仅是 Modbus 协议，像 IEC 60870-5-104、Profinet 这类主流工控协议都存在一些常见的安全问题，这些协议的设计为了追求实用性和时效性，牺牲了很多安全性。这类脆弱性导致了很多人下位机漏洞的产生。这类通信协议类的主要漏洞包括明文密码传输漏洞、通信会话无复杂验证机制导致的伪造数据攻击漏洞、通信协议处理进程设计错误导致的溢出漏洞等^[77]。

3. Web 用户接口漏洞

为了便于用户管理，目前越来越多下位机配置了 Web 人机用户接口，但方便的同时也带来了众多的 Web 安全漏洞。这些漏洞包括命令注入、代码注入、任意文件上传、越权访问、跨站脚本等。

4. 后门账号

有些下位机设备硬编码系统中存在隐蔽账号的特殊访问命令，工控后门就是特指开发

者在系统开发时有意在工控系统代码中设计的隐蔽账户或特殊指令。通过隐蔽的后门，设计者可以以高权限的角色进行设备访问或操作。工控后门对工控网络造成巨大的威胁。攻击者可以利用它来进行病毒攻击、恶意操控设备等。

6.4.3 下位机典型漏洞分析

下位机的漏洞很多在控制设备的固件或者硬件芯片之上，这里我们以下位机最常见的固件操作系统 VxWorks 为例进行漏洞分析。

VxWorks 是世界上使用最广泛的一种在嵌入式系统中部署的实时操作系统，是由美国 WindRiver 公司（风河公司，即 WRS 公司）于 1983 年设计开发的。其市场范围跨越所有的安全关键领域，包括火星好奇流浪者号、波音 787 梦幻客机、网络路由器等。这些应用程序的安全高危性质使得 VxWorks 的安全被高度关注。

2015 年加拿大安全研究人员 Yannick Formaggio 发现 VxWorks 中存在严重的通信协议处理不当导致的漏洞，可能会允许攻击者远程执行代码。Formaggio 对 VxWorks 进行了深入的安全分析，包括它所支持的网络协议和操作系统安全机制。他采用了模糊测试框架 Sulley 对 VxWorks 系统的多个协议进行了 Fuzzing，挖掘到一些漏洞，并结合 VxWorks 的 WDB RPC 实现了一个远程调试器，进行了相关调试分析。下面我们通过 Sulley 模糊测试框架为例，参照 Formaggio 的方法，对 VxWorks 进行安全分析^[78]。

1.WDB RPC 介绍

在对 VxWorks 进行模糊测试前，需要明白 WDB RPC 是一个基于 SUN-RPC 协议的调试接口，它的服务运行在 UDP 协议的 17185 端口上，可以直接访问系统的内存。

WDB 协议图解如图 6-21 所示。

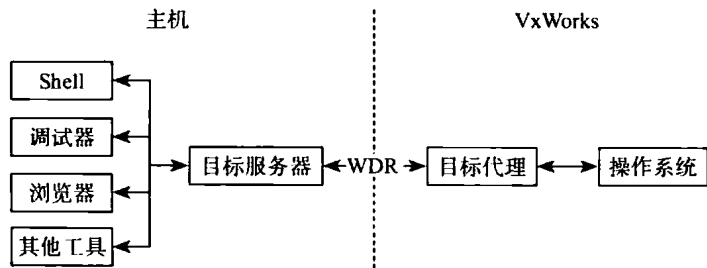


图 6-21 WDB 协议图解

- 调用：由目标服务器发出，如图 6-22 所示。

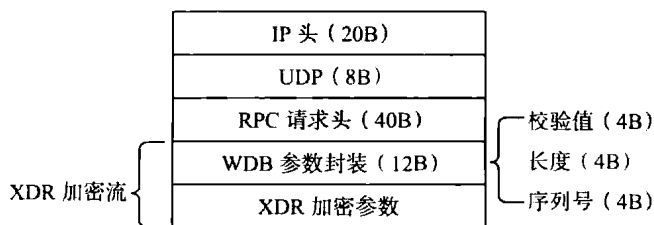


图 6-22 调用过程

- 应答：由目标代理发出，如图 6-23 所示。

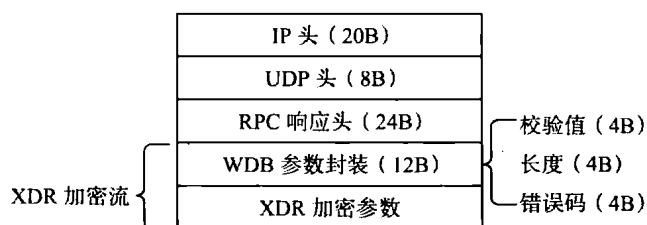


图 6-23 应答过程

针对 VxWorks 5.x 使用 WDB 对过程进行测试，如图 6-24 所示。

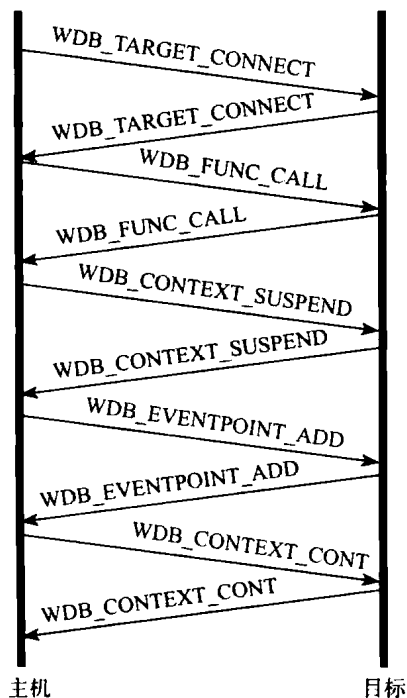


图 6-24 测试过程

WDB_TARGET_CONNECT

- 调用过程：主机连接至目标。
- 应答过程：目标连接至主机。

WDB_FUNC_CALL

- 调用过程：主机对目标发起 WDB 功能调用操作。
- 应答过程：目标对主机发起 WDB 功能调用操作。

WDB_CONTEXT_SUSPEND

- 调用过程：主机对目标发起 WDB 内容挂起操作。
- 应答过程：目标对主机发起 WDB 内容挂起操作。

WDB_EVENTPOINT_ADD

- 调用过程：主机对目标发起 WDB 事件点添加操作。
- 应答过程：目标对主机发起 WDB 事件点添加操作。

WDB_CONTEXT_CONT

- 调用过程：主机对目标发起 WDB 内容控制操作。
- 应答过程：目标对主机发起 WDB 内容控制操作。

对崩溃检测机制的介绍如图 6-25 所示。

- EVENT_NOTIFICATION：目标向主机发送事件通知。
- WDB_EVENT_GET：主机确认。
- WDB_REGS_GET 和 WDB_MEM_READ：主机请求更多的信息（寄存器内容、内存区域等）。

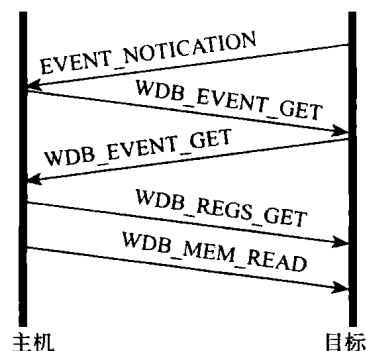


图 6-25 崩溃检测

2. 从模糊测试到漏洞利用

对 VxWorks 的一些网络协议（RPC、FTP、TFTP、NTP 等）可以通过 Sulley 进行模糊测试，对于没有可用的精确崩溃检测的问题可以使用 WDB RPC 作为解决方案。

Fuzzing 过程图解如图 6-26 所示。

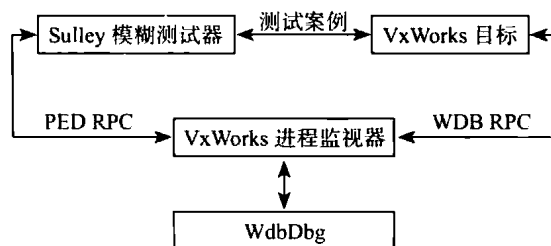


图 6-26 基于 Sulley 的 Fuzzing 过程图解

VxMon 使用 WDB RPC 对 VxWorks 目标进行监测, Sulley 模糊测试框架对 VxWorks 目标进行模糊测试, 当 VxMon 收到崩溃发生事件时, 使用 Sulley 的 ped-rpc 例程与 Sulley 模糊测试框架进行通信, 告知其崩溃发生。

图 6-27 便是模糊测试的一个示例。

Sulley Fuzz Control			RUNNING
Total:	6,852 of 11,576		59.191%
PMAPPROC_GETPORT:	1,532 of 1,960		78.163%
Pause		Resume	
Test Case #	Crash Synopsis	Captured Bytes	
000864	crash detected on tc 864	454	
000866	crash detected on tc 866	454	
002264	crash detected on tc 2264	470	
002266	crash detected on tc 2266	470	
004224	crash detected on tc 4224	470	
006184	crash detected on tc 6184	470	
006186	crash detected on tc 6186	470	

图 6-27 模糊测试示例

接下来是对 Fuzzing 过程中的崩溃进行分析, 分析结果如图 6-28 所示。

```

Eflags Register : 0x00010202
Error Code      : 0x00000000
Page Fault Addr : 0x00000000
Task: 0x149acf8 "tPortmapd"
0x149acf8 (tPortmapd): task 0x149acf8 has had a failure and has been stopped.
0x149acf8 (tPortmapd): fatal kernel task-level exception!

Page Fault
Page Dir Base   : 0x01477000
Esp0 0x016014fc : 0x0040f3c6, 0x01601564, 0x01601528, 0x00000200
Esp0 0x0160150c : 0x0160169c, 0x0040b2d0, 0x01601564, 0x00000200
Program Counter : 0x00000000
Code Selector   : 0x00000000
Eflags Register : 0x00010202
Error Code      : 0x00000000

```

图 6-28 Fuzzing 过程崩溃分析

- 1) Portmap task 在 RPC 的 credential flavor 字段崩溃了多次。
- 2) 当设置一个负值时, PC 将被设置为任意的内存值。
- 3) 对系统的 authenticate 函数进行反汇编, 如图 6-29 所示。

从 0x004173aa 开始, 先对 eax 和 ebx 寄存器进行赋值操作, 再使用 cmp 指令对比 ebx 寄存器和 2 的大小, 注意 ebx 寄存器的值为 0, jg 是一个大于转移的汇编指令, 由于 “0<2” 不满足条件, 所以不会跳到 0x004173c7 地址去执行。由于并未跳转而是继续向下执行, call 指令调用了 svcauthsw 函数, 如图 6-30 所示。

```

[0x00308000]> pdf @ sym._authenticate
; arg int arg_2      @ ebp+0x8
; arg int arg_3      @ ebp+0xc
-- sym._authenticate:
0x0041736f 55          mov     ebp, esp
0x0041736f 89e5       mov     ebx, ebp
0x0041736f 53          push   ebx
0x00417370 8b550c     mov     edx, dword [ebp + 0xc]
0x00417373 8b5218     mov     edx, dword [edx + 0x16]
0x00417376 8b4508     mov     eax, dword [ebp + 8]
0x00417379 89500c     mov     dword [eax + 0xc], edx
0x0041737c 8b550c     mov     edx, dword [ebp + 0xc]
0x0041737f 8b521c     mov     edx, dword [edx + 0x17]
0x00417382 8b4508     mov     eax, dword [ebp + 8]
0x00417385 895010     mov     dword [eax + 0x10], edx
0x00417388 8b550c     mov     edx, dword [ebp + 0xc]
0x0041738b 8b5220     mov     edx, dword [edx + 0x20]
0x0041738e 8b4508     mov     eax, dword [ebp + 8]
0x00417391 895014     mov     dword [eax + 0x14], edx
0x00417394 8b4508     mov     eax, dword [ebp + 8]
0x00417397 8b581c     mov     ebx, dword [eax + 0x1c]
0x0041739a 8b05fcf34c00 mov     eax, dword [sym._null_auth]
0x0041739d 894320     mov     dword [ebx + 0x20], eax
0x004173a0 c74328000000 mov     dword [ebx + 0x28], 0
0x004173a3 8b4508     mov     eax, dword [ebp + 8]
0x004173a6 8b580c     mov     ebx, dword [eax + 0xc]
0x004173a9 83fb02     cmp     ebx, 2
0x004173ac 7f12       jg     0x4173b3
0x004173af 750c       jmp     [ebp + 0xc]
0x004173b0 7508       jmp     [ebp + 8]
0x004173b3 149dbce648 mov     dword [eax + sym._authsw], unk(unk, unk, unk)
0x004173b6 83c408     add     esp, 8
0x004173b9 eb05       jmp     0x4173c5
; JMP XREF from 0x004173b3 (sym._authenticate)
; JMP XREF from 0x004173c5 (sym._authenticate)
0x004173ba 5b          mov     ebx, esp
0x004173bd 89ec       mov     esp, ebp
0x004173c0 5d          pop     ebp

```

图 6-29 authenticate 函数的反汇编

```

[0x00308000]> pxw 16 @ sym.svcauthsw
948e5nc 0x00000000 .SA .SA .UA
[0x00308000]> pd @ 0x4173d4
;-- sym._svcauth_null:
0x004173d4 55          mov     ebp, esp
0x004173d7 31c0       xor     eax, eax
0x004173d7 5d          pop     ebp
0x004173d8 c3          ret
[0x00308000]> pd @ 0x4173dc
;-- sym._svcauth_unix:
0x004173dc 55          mov     ebp, esp
0x004173dd 89e5       mov     ebp, esp
0x004173df 83ec30     sub     esp, 0x30
0x004173e2 53          push   ebx
[0x00308000]> pd @ 0x4175a4
;-- sym._svcauth_short:
0x004175a4 55          mov     ebp, esp
0x004175a5 b802000000 mov     eax, 2
0x004175aa 5d          pop     ebp
0x004175ab c3          ret
[0x00308000]>

```

图 6-30 call 指令调用 svcauthsw 函数

进入 svcauthsw 函数内存空间，发现已经发生了溢出。

进行漏洞利用的方法如下：

- 整数溢出导致了 RCE（远程代码执行）。
- 堆喷射 shellcode。
- 计算 credential flavor 的值。

- 直接跳进 shellcode。
- 绕过所有的内存保护。
- 设置后门账户。

这是一个典型的整数溢出漏洞，这个漏洞会影响到应用非常广的 VxWorks 5.5，也就是需要补丁的设备可能数以百万计。

6.5 工控网络设备漏洞分析

本节将对工控网络设备的基本概念及其存在的典型漏洞进行介绍，并针对这些漏洞的原理和检测方法进行讨论。

6.5.1 工控网络设备概念

工控网络设备及组件是连接到工控网络中的物理实体，工控网络设备的种类繁多，且与日俱增。基本的工控网络设备包括工控计算机（FTP 服务器、Web 服务器等，简称工控机）、集线器、工控交换机、工控路由器、工控防火墙等。

6.5.2 工控网络设备常见安全问题

已知的工控网络设备的很多安全问题大多数都发生在这些设备的 Shell 及对外提供的 Web、SNMP、Telnet 等服务上，其中，常见 Web 服务安全问题如下所示。

（1）SQL 注入漏洞

SQL 注入漏洞是由于 Web 应用程序没有对用户输入数据的合法性进行判断，攻击者通过 Web 页面的输入区域（如 URL、表单等），用精心构造的 SQL 语句插入特殊字符和指令，通过与数据库交互获得私密信息或者篡改数据库信息。SQL 注入攻击在 Web 攻击中非常流行，攻击者可以利用 SQL 注入漏洞获得管理员权限，在网页上加挂木马和各种恶意程序，盗取企业和用户敏感信息。

（2）跨站脚本漏洞

跨站脚本漏洞是因为 Web 应用程序没有对用户提交的语句和变量进行过滤或限制，攻击者通过 Web 页面的输入区域向数据库或 HTML 页面中提交恶意代码，当用户打开有恶意代码的链接或页面时，恶意代码通过浏览器自动执行，从而达到攻击的目的。跨站脚本漏洞危害很大，尤其是目前被广泛使用的网络银行，通过跨站脚本漏洞攻击者可以冒充受害者访问用户重要账户，盗窃企业重要信息。

(3) 文件包含漏洞

文件包含漏洞是指攻击者向 Web 服务器发送请求时, 在 URL 添加非法参数, Web 服务器端程序变量过滤不严, 把非法的文件名作为参数处理。这些非法的文件名可以是服务器本地的某个文件, 也可以是远端的某个恶意文件。由于这种漏洞是由 PHP 变量过滤不严导致的, 所以只有基于 PHP 开发的 Web 应用程序才有可能存在文件包含漏洞。

(4) 命令执行漏洞

命令执行漏洞是指通过 URL 发起请求, 在 Web 服务器端执行未授权的命令, 获取系统信息, 篡改系统配置, 控制整个系统, 使系统瘫痪等。

命令执行漏洞主要有两种情况:

- 通过目录遍历漏洞, 访问系统文件夹, 执行指定的系统命令。
- 攻击者提交特殊的字符或者命令, Web 程序没有进行检测或者绕过 Web 应用程序过滤, 把用户提交的请求作为指令进行解析, 导致执行任意命令。

(5) 信息泄露漏洞

信息泄露漏洞是由于 Web 服务器或应用程序没有正确处理一些特殊请求, 泄露 Web 服务器的一些敏感信息, 如用户名、密码、源代码、服务器信息、配置信息等。

造成信息泄露主要有以下 3 种原因:

- Web 服务器配置存在问题, 导致一些系统文件或者配置文件暴露在互联网中。
- Web 服务器本身存在漏洞, 在浏览器中输入一些特殊的字符, 可以访问未授权的文件或者动态脚本文件源码。
- Web 网站的程序编写存在问题, 对用户提交请求没有进行适当的过滤, 直接使用用户提交上来的数据。

6.5.3 工控网络设备典型漏洞分析

我们以西门子 SCALANCE X-300 系列交换机中存在的一个存储型跨站脚本漏洞为例进行工控网络设备漏洞分析。

1.XSS 漏洞原理

XSS 又叫 CSS (Cross Site Script, 跨站脚本攻击), 它指的是恶意攻击者往 Web 页面里插入恶意脚本代码, 而程序对于用户输入内容未过滤, 当用户浏览该页时, 嵌入 Web 里面的脚本代码会被执行, 从而达到恶意攻击用户的特殊目的。

跨站脚本攻击的危害包括窃取 Cookie、放蠕虫、网站钓鱼等。

跨站脚本攻击的分类主要有存储型 XSS、反射型 XSS、DOM 型 XSS 等。

2.XSS 的检测

检测 XSS 一般分两种方法：一种是手工检测，另一种是软件自动检测。手工检测的检测结果准确，但对于大型 Web 来说费时费力。软件自动检测则方便省力，但存在一定误报，且部分较隐蔽的 XSS 无法被检测出。检测 XSS 最重要的就是考虑输入点的位置，以及输入数据后在哪里输出。

(1) 手工检测

1) 可得知输出位置。

输入敏感字符，如“<”、“>”、“”、“'”、“()”等，提交后查看 HTML 源代码，看这些字符是否被转义。

在输出这些字符时，程序可能已经进行了过滤，输入“AAAAAA<>"&'()”字符串，然后查找“AAAAAA”会更加方便。

2) 无法得知输出位置。

很多 Web 应用程序源码不公开，在测试时无法得知输出位置，如有些留言本在留言后必须经过管理员审核才能显示，无法得知数据在后台管理页面处于何种状态，例如：

- 在标签中：<div>XSS Test</div>。
- 在属性内：<input type="text" name="content" value="XSS Test"/>。

这种情况通常采用输入“"/>XSS Test”来测试。

(2) 软件自动检测

如 APPSCAN、AWVS、Burp Suite 等软件都可以有效地检测 XSS，它们还会检测其他漏洞，但是效率不如专业的 XSS 检测工具高。专业的 XSS 扫描工具有 XSSER、XSSF 等，还有专门扫描 DOM 类型 XSS 的 Web 服务。

一般要手工和软件一起使用，因为有些 XSS 软件不能检测，如有些留言需要输入验证码等，软件工具还无法做到。

这里我们通过手工检测发现该处漏洞。首先通过设备 IP 地址访问设备，进入西门子交换机 Web 管理页面，设备使用了默认账号和密码：admin/admin。

在 Agent → SNMP → Groups 页中，可以看到 Group Name 处没有对 XSS 代码进行过滤，导致了 XSS 漏洞。

在图 6-31 中的 SNMPv3 组配置管理界面输入，保存后即可触发 alert(1) 脚本执行，如图 6-32 所示。表明该工控网络交换机存在存储型 XSS 漏洞，如图 6-33 所示。

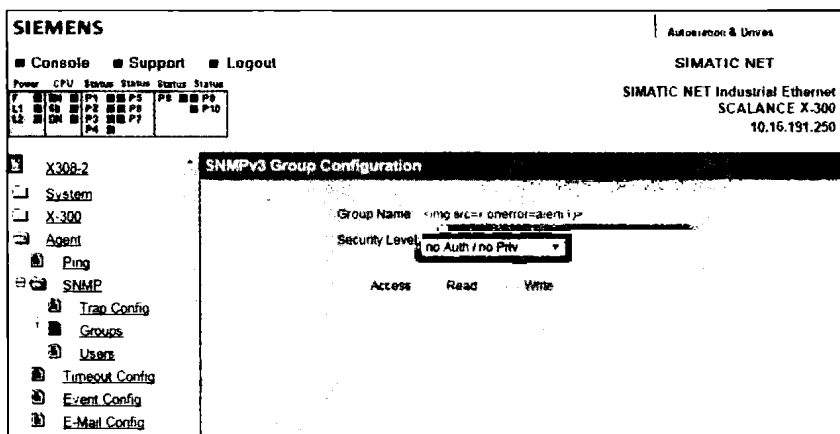


图 6-31 SNMPv3 组配置管理界面 1

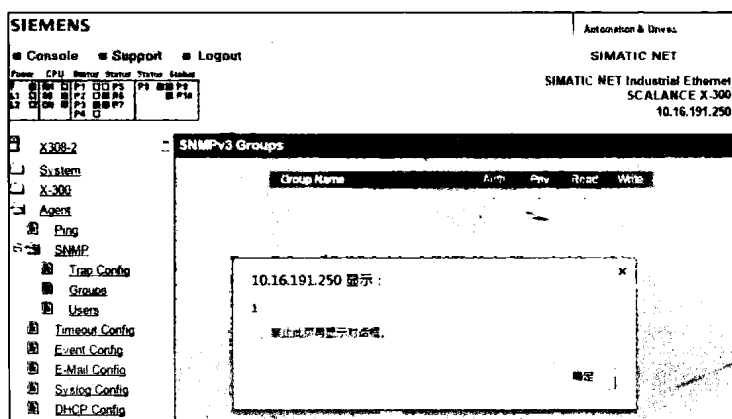


图 6-32 触发脚本执行

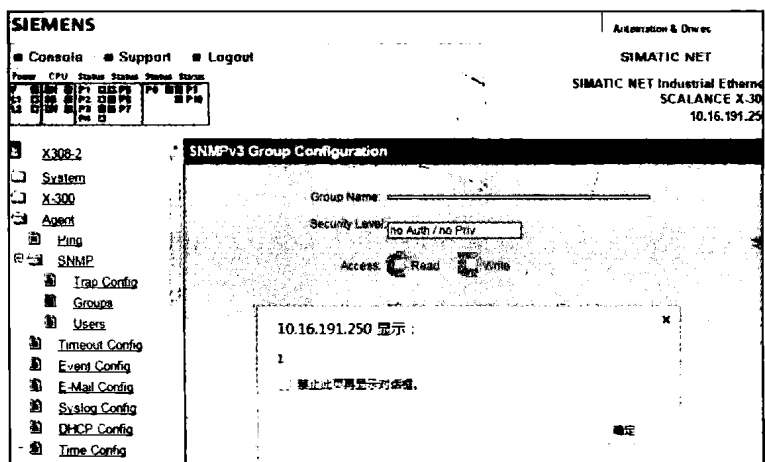


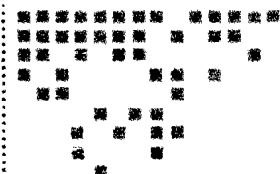
图 6-33 存在存储型 XSS 漏洞

6.6 本章小结

在本章中，我们讨论了工控安全漏洞的基本特征，并对工控漏洞分析的技术（构建漏洞库、漏洞扫描、Fuzzing 技术）进行了介绍；将整个工控系统按上位机、下位机、工控网络设备进行划分，分别介绍了它们的基本概念和相关常见安全问题，并就典型漏洞进行了分析。通过本章的学习，我们已经掌握了工控系统中漏洞相关的主要知识，为以后深入学习工控系统安全做好了铺垫。

6.7 本章习题

1. 目前工控网络中漏洞挖掘的主要困难是什么？
2. 工控安全漏洞发布的主要平台有哪些？请简要概述这些平台。
3. 为什么传统信息系统的漏洞检测技术不适用于工业控制系统？
4. Fuzzing 技术有哪些分类？哪一种更适合工控系统？
5. 上位机有哪些常见的漏洞？请简要概述它们。
6. 基本的工控网络设备有哪些？
7. Web 服务器有哪些常见的漏洞？请简要概述它们。
8. 尝试对固件 NOE771 进行逆向，进一步分析出其后门。



Chapter 7 第7章

工业控制网络安全防护技术

工控网络安全防护的核心是建立以安全管理为中心，辅以符合工控网络特性的安全技术，进行有目的、有针对性的防御。

保障工控网络安全首先要从工控网络的自主、可控和可信来考虑，也就是基础软硬件的安全性，对于设备本体存在的安全漏洞我们需要考虑对漏洞进行打补丁操作，但是由于工控网络与互联网络隔离的特性，这种打补丁操作很多时候成为不可能，那我们需要考虑使用其他补偿性的措施来保障设备的自身安全性，同时我们也需要保障工控网络环境下的行为安全性和工控网络本身的结构安全性。下面我们就分别从工控网络安全设备的引入和使用方法、对已知工控网络安全威胁的处理方法和对未知工控网络安全威胁的处理方法来分别阐述如何实现工控网络的基础软硬件安全、设备与主机安全、行为安全和结构安全。

7.1 工业控制网络安全设备的引入和使用方法

现代工业控制网络安全防护工作要求我们在加强企业安全策略和规程建设、增强员工法制和网络安全意识、全面提高企业安全管理水平的同时，必须规划网络基础设施的安全配置，积极引入先进的网络安全防护设备，从不同的网络层面分区域、分功能、分重点地加强控制网络的安全防护。

7.1.1 从信息安全到工业控制网络安全

尽管工控网络安全防护与标准企业信息安全在许多方面类似，但也存在其独有的挑战。

由于工控系统对可靠性和生存期的要求较高，所以其使用的系统与网络技术很容易被攻击者所超越。工业控制系统可能需要不间断地运行数月甚至数年，其全部生命周期也可能长达数十年，而攻击者却可以在任何时候使用新的工具进行攻击。由于类似原因，工控网络的安全设计与实践方面也相对落后：所使用的系统落后于现代网络基础设施，总是只能保证物理安全而非数字安全。

由于工控网络的重要性与受到攻击后潜在的毁灭性后果，需要采用新的方法来保护它的安全。工控网络破坏的真实案例随处可见，工控网络已被锁定为攻击对象，而且逐渐成为更精细、更具针对性的攻击威胁的目标。

7.1.2 工业控制网络安全设备的引入

加强工控网络安全防护的需求再怎么高估也不为过，下面我们从几个方面来看一下工控网络安全设备的引入和使用方法。

1. 工控网络边界安全防护

在工业控制网络边界即与办公网络交界位置，需要进行严格的隔离防护，可以分为以下几种情况：

1) 理想状态下，物理隔离依然保留，使工业控制网络和办公网络形成两套独立的网络结构，两套网络之间没有任何访问。

2) 随着工控网络业务运作的发展，实时信息共享的需求也日渐凸显，由于所需的信息往往位于隔离系统的异侧，因而需要设计通过隔离系统的方法，可以使用单向网闸对两种网络进行单向隔离，数据流动方向为由工业控制网络流向办公网络。

3) 如果办公网络与工业控制网络间有双向访问需求，典型的防护方式为双向隔离网闸或防火墙，除了提高业务运行效率所必需的信息外，所有其他流量都需要被屏蔽。

2. 区域边界安全防护

在已定义的区域周围建立电子安全边界（ESP）可以提供直接的保护，并防止对封闭系统的未经授权的访问，也可以防止从内部访问外部系统。为了建立 ESP 并有效保护入站和出站的流量，必须完成以下两点：

1) 所有入站和出站流量必须强制通过一个或多个已知的、可被监视和控制的网络连接。

2) 每个连接中都应该部署一个或多个安全设备。

每个区域都应该选择并部署适当的安全设备。

安全保护类平台如工业防火墙、单项隔离网关、工业协议过滤器、数据采集隔离平台

等是最低限度的安全设备要求。安全管理类平台如安全监控平台、安全审计平台、IDS 等，在通常情况下，区域的重要级别决定了所需的安全防护强度。

根据 NERC CIP 和 NRC CFR 73.54 的安全评价标准和建议，本书对区域的安全级别和所需的安全防护强度进行了对应建议，建议如表 7-1 所示。

表 7-1 边界安全性设备选择对照表

临界点	所需安全性	建议的措施
4（最高）	NRC CFR 83.54：非直接边界 NERC CIP 005：安全保护平台设备	安全管理平台设备、安全保护平台设备
3	NRC CFR 83.54：非直接边界 NERC CIP 005：安全保护平台设备	安全管理平台设备、安全保护平台设备
2	NERC CIP 005：安全保护平台设备	安全保护平台设备
1	NERC CIP 005：安全保护平台设备	安全保护平台设备
0（最低）	NERC CIP 005：安全保护平台设备	安全保护平台设备

建议为每个安全区域边界使用智能保护平台设备和监测报警平台，这是因为这些设备具有不同的功能：

1) 工业防火墙：工业防火墙建立在深度数据包解析和开放式特征匹配之上，支持工控网络协议，可适用于 DCS、SCADA 等控制系统，不仅具备多种工控网络协议数据的检查、过滤、报警、阻断功能，同时拥有基于工业漏洞库的黑名单入侵防御功能、基于机器智能学习引擎的白名单主动防御功能以及大规模分布式实时网络部署和更新等功能。

2) 安全监测平台：安全监测平台是一种实时监控和告警系统，通过监控关键设备和安全产品的日志和监控信息，快速进行安全事件的反馈和报警。

3) 安全审计平台：安全审计平台是一种将工业控制系统环境中相关软硬件系统和其他安全设备的信息进行长时间记录存储，以供后续审计、分析、取证时使用的系统，一般都会有独立的数据库存储系统配套使用。

最严格的区域边界安全设备可能是数据二极管，也称为单向网关。单向网关可以被简单描述为一个单向的连接——往往是受限的物理连接，其发送或接收只使用一条光纤链路，仅使用光通信进行发送，在包含控制系统设备的高度敏感网络区域内部不能进行任何数字通信，而监控数据则可以从这个戒备森严的区域传递至外部的 SCADA DMZ 或更远的区域。在某些情况下，如高度敏感文档的存储，单向网关可以反转，从而使信息只可以发送到安全区域中，而从物理上阻止发往区域外的通信。

3. 区域内部安全防护

与具有明确分界且可被监控的区域边界不同，区域内部由特定的设备以及这些设备之

间各种各样的网络通信组成。区域内部的安全主要是通过基于主机的安全来完成的，它可以控制最终用户对设备的身份认证、该设备如何在网络上通信、该设备能访问哪些文件，以及可以通过它执行什么应用程序。

我们可以按照不同的安全等级选择不同的安全量度，如表 7-2 所示。

表 7-2 不同设备等级安全量度选择对应表

设备	合适的安全量度
运行现代操作系统的 HMI 或者是类似的设备。应用程序对时间不是敏感的	①主机防火墙 ②主机 IDS ③工控安全卫士或类似反病毒系统或者应用程序白名单 ④禁用所有未使用的端口和服务
运行现代操作系统的 HMI 或者是类似的设备。应用程序对时间是敏感的	①主机防火墙 ②禁用所有未使用的端口和服务
PLC、RTU 或者类似的设备运行一个内嵌的商业 OS	①主机防火墙或主机 IDS ②外部的安全控制
PLC、RTU、IED 或者是类似的设备运行一个内嵌的运行环境	外部的安全控制

（1）主机防火墙

主机防火墙的主要工作原理与网络防火墙类似，需要进行主机和连接的网络之间的初步过滤。主机防火墙将基于防火墙具体配置允许或拒绝入站流量。通常情况下，主机防火墙是会话感知防火墙，允许控制不同的入站和出站应用程序会话。

（2）主机 IDS

主机 IDS 与网络 IDS 的工作方式类似，它们只工作在一个特定的资产以及监管该资产内部的系统上。通常情况下，主机 IDS 的设备可以监控系统设置和配置文件、应用程序及敏感文件。区别于终端杀毒系统和其他的主机安全选项，由于这些设备工作时可以执行网络数据包检查，因此可以通过监控主机系统的网络接口来检测或防止入站威胁，从而可以直接模仿网络 IDS 的行为。

（3）终端杀毒系统

终端杀毒系统被设计用来检测恶意软件，它们使用基于标志的检测以验证系统文件。当标志匹配已知病毒、木马或其他恶意软件时，可疑文件通常被隔离以待进一步清除或删除。

（4）应用程序白名单

应用程序白名单提供了与传统主机 IDS、终端杀毒系统、终端安全管理、黑名单技术不同的方法来保护主机安全。“黑名单”解决方案把监控对象与已知的非法对象清单作比较。

这引出了两个问题：

1) 由于不断发现新的威胁，必须不断更新黑名单。

2) 存在无法检测或阻止的攻击，如 0day 漏洞和已知的没有可用标志的攻击。相比之下，“白名单”的解决方案是创建一个列表，列表中的所有项都是合法的，并利用了很简单的逻辑，即如果不在名单上就阻止它。

应用程序白名单的解决方案把这个逻辑用在主机的应用程序上。这样，即使病毒或木马穿透了控制系统的边界防御，并找到了目标系统的路径，主机本身也会停止执行恶意软件，致使它不能继续生效。

因为在控制系统中资产应该都有明确定义的端口和服务，所以应用程序白名单在控制系统中使用尤其合适。此外，没有必要不断下载、测试、评价并安装标志更新。相反，应用程序白名单只需要在主机系统的应用程序更新时进行更新和测试。

然而，由于应用程序白名单运行在操作系统的底层，因此它为该主机上的所有应用程序和服务的执行路径引入了新的代码。这就在主机的所有功能中添加了一些延迟，可能会对那些对时间敏感的操作造成难以接受的时间延迟，因而需要进行充分的回归测试。

(5) 外部控制

当没有必要使用基于主机的安全工具时，可能需要使用到外部工具。例如网络 IDS、工业网络防火墙和其他专门用于控制系统操作的网络安全设备，可用于监视和保护这些资产。许多此类设备都支持串口及以太网接口，可以直接部署在特定的设备或设备组之前，如部署在一个特定的过程或回路中。

其他外部控制，如安全信息和事件管理系统，可以更全面地监测控制系统，它是通过使用从其他资产（如 MTU 或 HMI）、其他信息存储（如历史数据系统）或网络本身得到的信息来达到目的的。这些信息可用于检测存在于多个系统中的风险和威胁活动。

外部控制，特别是被动地监测和记录，也可以用于弥补已经受到主机防火墙、主机 IDS、终端杀毒系统和应用程序白名单保护的资产。

4. 统一管理平台的选择

众多设备的堆砌确实可以提高工业网络的整体安全，但是也要考虑这些安全设备的统一部署、统一管理或分布式部署的问题，这样可以最大限度地增强设备间的协作能力，实现统一部署、统一策略、统一调度、统一管理、及时监测报警、及时处理日志等，让企业的工业网络控制系统坚固地像铁板一样。

网络安全监管类的设备是对网络安全保护设备进行统一监控和管理的设备，大多是一套集硬件、软件于一体，用于统一配置、管理、监测工控网络安全的产品。网络安全监管

平台能对工控网络内的安全威胁进行分析,提供包括行为审计、事件追踪、威胁分析、日志管理、设备管理、安全性分区等多项功能。

7.1.3 工业控制网络安全设备的使用方法

1. 工控网络边界防护设备配置

- 1) 除了提高业务运行效率所必需的信息外,所有其他流量都进行屏蔽。
- 2) 可访问性可以由网络访问控制进行约束,并且在网络设施中强制执行。
- 3) 谨慎配置防火墙,指明对一个方向“拒绝所有”的规则,或者专用的无向网络网关或网闸。
- 4) 完成监控、分析与防御之间的反馈环路,提供一种动态控制,通过适当的配置边界防御,使用更先进的安全信息和事件管理或者日志管理工具进行自动化处理。
- 5) 防御拒绝服务(DoS)或者信息洪流,限制面向外部服务的直接可见性与可访问性,在边界防御 DoS 行为,并阻止可能引发 DoS 行为的连接访问尝试。
- 6) 在边界防火墙策略中需要明确定义源地址与目的 IP 以及端口号,这样潜在易受攻击的通信就只能在可信任的资产之间进行。
- 7) 要求管理员分级,包括超级管理员、安全管理员、配置管理员、审计管理员等,并定义相应的职责,维护相应的文档和记录。
- 8) 重要的系统边界建议采用冗余架构,包括业务系统、网络、电源、安全等系统的冗余机制。
- 9) 对安全设备管理的限制,包括关闭 Telnet、HTTP、ping、SNMP 等,以及使用 SSH 而不是 Telnet 远程管理防火墙。
- 10) 账号管理安全,设置口令和账户策略,避免出现弱口令和长时间不修改等问题。

2. 区域边界防护设备配置

- 1) 通过网络地址,将系统或设备划归到特定安全域。
- 2) 通过用户名或其他标志,获得修改区域权限的用户。
- 3) 在区域中使用的协议、端口及服务要进行严格定义。
- 4) 所有入站和出站流量必须强制通过一个或多个已知、可被监视和控制的网络连接。
- 5) 每个通信连接中都应该部署一个或多个安全设备。
- 6) 以双向通信 DENY ALL (拒绝所有) 规则开始,确保所有的 Allow (允许) 规则都被明确地定义。

3. 入侵检测与防御设备配置

入侵检测与防御设备配置规则如表 7-3 所示。

表 7-3 入侵检测与防御设备配置规则表

允许端口或服务	源	目的	服务的重要性	事件的威胁度	建议的动作	注意
无	所有	所有	所有	所有	拒绝	区域内没有明确允许的所有通信应拒绝，以中断未经授权的会话并阻止攻击
有	区域内部	区域内部	高	所有	警报	主动阻塞或拒绝区域内起始和终止的流量会影响运行。例如，误报可能导致在合法的控制系统内流量被阻塞或拒绝
有	区域内部	区域内部	低	所有	警报或者跳过	对于非关键服务，日志是建议的，但不是必要的（警报措施将提供有价值的事件和数据包信息，可以协助以后的事故操作）
有	区域外部	区域内部	高	低（事件来自混淆的检测标志或信息事件）	警报	许多检测标志在检测大范围的潜在威胁活动的时候比较广泛。这些标志应该警告以防止无意的中断控制系统的操作
有	区域外部	区域内部	高	高（明确的恶意软件或者利用精确协调的标志）	阻塞、警报	如果关键系统或者资产的人站流量包含已知的恶意载荷，流量应该被阻塞，以防止外部网络事件
有	区域内部	区域外部（明确允许目的地址）	所有	所有	警报	这个流量最有可能是合法的。然而，对事件发出警报或者是记录会提供很有价值的事件和数据包信息，这些信息会协助以后的事故调查
有	区域内部	区域外部（未知的目的地址）	高	高	阻塞或者重新设置	这个流量最有可能是非法的。应迅速寻址产生的警报：如果出现误报，必要的流量可能会被无意地阻止；如果该事件是一个威胁，它表明区域已经被破坏

使用包括 Block（阻塞）规则在内的入侵检测与防御设备配置的基本建议，可以达到如下目标：

- 1) 防止任何未定义流量经过区域边界（通信中断不会影响合法服务的可靠性）。
- 2) 防止所有含有恶意软件或代码的已定义流量通过区域边界。
- 3) 检测并记录可用或异常活动。
- 4) 在区域内记录正常或者合法的活动，可用于合规性报告。

已定义区域的功能隔离和分割程度越高，IDS、IPS 的策略就越简洁、越有效，下面这些 IDS 和 IPS 规则适用于区域边界：

- 1) Block 所有大小或程度有错误的工业网络协议包。
- 2) Block 所有区域中不允许的入站或出站网络流量。

3) Block 所有在协议不被允许的区域中检测出的工业网络协议包。

4) Alert 所有登录验证尝试,以记录成功和失败的登录。

5) Alert 所有工业网络端口扫描。

6) Alert 所有工业网络协议码。

4. 区域内部安全防护设备配置

(1) 主机防火墙

与网络防火墙一样,主机防火墙应按照“防火墙配置指南”提出的准则进行配置:以 DENY ALL 策略开始,Allow 规则只用于特定的端口和特定资产上的服务。

(2) HIDS (主机 IDS)

HIDS 可以使用表 7-3 中提出的准则进行配置。因为 HIDS 也能够检查本地文件,所以这个名称有时也能够用于其他基于主机的安全设备,如工控安全卫士、反病毒系统,或者提供重叠安全功能的主机安全实践。

与网络 IDS 一样,HIDS 的设备会为所有违反策略的行为产生警报。

(3) 终端杀毒系统

像其他基于标志的检测系统一样,终端杀毒系统需要定期进行病毒库更新。

(4) 应用程序白名单

应用程序白名单技术指的是确保只有安全获得审核的应用才能运行,这里包括了最早获得批准的以及那些随着时间推移被允许执行的程序。应用程序白名单技术的解决方案,也会避免通过白名单内的合法应用程序发起的内存攻击。

白名单是一种在计算机上按照实际情况对文件进行控制的模式:不是担心现有和将要创建的文件,白名单关注的是已经存在并获得认证的文件。

应用程序白名单技术的主要目的是保障计算机和应用程序的正常运行,这包括了操作系统和应用程序中的所有可执行文件。如果应用程序不在列表上,它将无法运行。

7.2 对工业控制网络已知安全威胁的防护方法

随着我国工业智能化和智慧城市的建设,关键基础设施的互联互通带来新的安全威胁。近年来,国内外频繁发生针对关键基础设施的破坏和信息窃取事件。经过对我国大量关键基础设施建设的调研,深入了解其采用的网络结构、安全技术与防护体系,并结合对一系列安全事件的研究,本书介绍典型的针对关键基础设施安全基准来解决安全架构的设计和针对已知威胁的防御技术。

安全基准结合工业控制系统的特性,包括了4个技术和管理层面,即结构安全、设备与主机安全、行为安全、基础软硬件安全,以及安全的时间持续性,实现从网络安全到业务安全到基础设施安全的综合防护能力。与IT系统的安全架构进行类比,结构安全可以对应物理安全和网络安全,设备与主机安全主要对应的就是主机和设备终端的安全,行为安全更多地对应的是安全分析和安全管理,基础软硬件安全对应数据安全和应用安全,时间持续性与安全咨询和安全运营相对应。本节不涉及物理安全和管理部分内容。

7.2.1 结构安全

结构安全性即基础设施建设过程中网络拓扑结构,以及区域、层次的划分是否满足安全需求。通过隔离、过滤、认证、加密等技术,实现合理的安全区域划分、安全层级划分,实现纵深防御能力。对于新装系统,应实现结构安全同步建设;对于再装系统,应进行结构安全改造;对于因条件限制无法进行改造的系统,应建立安全性补偿机制。所以结构安全最为重要,结构安全解决了大部分安全问题。

而针对结构安全又可以分为两部分考虑,分别是网络结构的优化与防护技术和设备的部署。

1. 结构优化

结构主要指的是网络的结构,但是也包括生产的布局结构。它与入侵容忍度是紧密相关的。当某件事发生的时候,必须有相应的结构,这样才能保证其他大面积系统不受影响。这是结构安全的核心。实际上这就是一个分区隔离的概念,它会把危害限制在一个尽量小的可控范围之内,如国家电网的“横向隔离、纵向认证”。

结构安全性中所谓的隔离不一定是物理隔离,因为我们很多系统需要互联,甚至是互联网的接入,所以这里引入了访问控制的技术。新装系统的结构安全性问题和在装系统的结构安全性改造问题大多时候就是将部分行为安全中安全管理的内容条理化,转变为结构安全问题。

例如图7-1所示的星形网络,它是呈现星形的一种拓扑结构,其实如果它的结构良好,就能够把这8套系统都进行隔离,中间加上一个隔离设备,如果1号系统有可疑行为,可以把其他7套先隔离。评估一个系统或做安全方案,都应该从结构安全性做起。

再如后门,后门经常被用于远程调测。调测方是否设置了安全措施是未知的,或者是不受控的。我们可以在入口处部署隔离措施,就可以控制入口的一切行为。

但是结构安全在最新的应用场景下也暴露出了新的问题,这就是无线网络的应用。例如,传输线路采用光纤和无线互为备份,因为无线是开放的,所以就带来了结构安全性

问题。这个时候还想保证结构安全性，既可以进行网络的调整，也可以增加设备的技术措施。

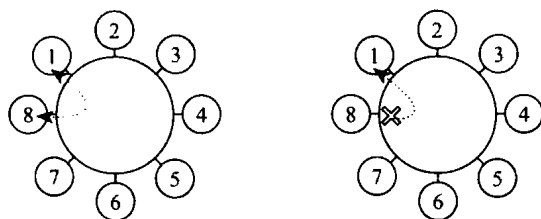


图 7-1 星形网络的结构问题

2. 访问控制

结构安全的根本所在就是通过控制如何访问目标资源来防范资源泄露或未经授权的修改。访问控制的实现手段在本质上都处于技术性、物理性或行政管理性层面。基于政策的文档、软件和技术、网络设计和物理安全组件都需要实施这些控制方法。接口处是最应该实施安全控制的一个地方，毕竟这是通向关键资产的入口，需要层层纵深防御来实施访问控制。因此，了解如何部署这些控制方法极其重要。

访问控制本身是一种安全手段，它控制用户和系统如何与其他系统和资源进行通信和交互。访问控制能够保护系统和资源免受未经授权的访问，并且在身份验证过程成功结束之后确定授权访问的等级。尽管我们经常认为用户是需要访问网络资源或信息的实体，但是还有许多其他类型的实体需要访问作为访问控制目标的其他网络实体和资源。如图 7-2 所示模型，在访问控制环境中，正确理解主体和客体的概念是非常重要的。

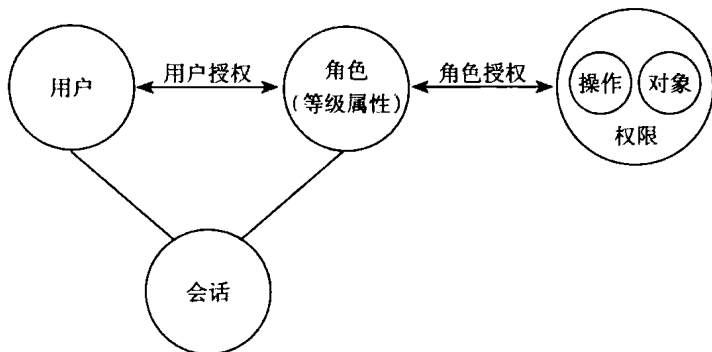


图 7-2 主体 - 客体角色互斥约束模型

访问是在主体和客体之间进行的信息流动。主体是一个主动的实体，它请求对客体或

客体内的数据进行访问。主体可以是通过访问客体以完成某种任务的用户、程序或进程。当程序访问文件时，程序是主体，而文件是客体。客体是包含被访问信息或者所需功能的被动实体。客体可以是某个系统、PLC、传感器、计算机、数据库、文件、计算机程序、目录或数据库中某个表内包含的字段。当用户在数据库中查询信息的时候，用户就是一个主动实体，而数据库则是一个被动客体。

访问控制包含的范围很广，它涵盖了几种对计算机系统、网络和信息资源进行访问控制的不同机制。因为访问控制是防范计算机系统和资源被未授权访问的第一道防线，所以其地位非常重要。提示用户输入正确的账号密码才能使用该系统的某个资源就是一种访问控制。一旦用户登录并尝试访问文件，文件就应该有一个包含能够访问它的用户和组的列表，如果用户不在这个列表中，那么他的访问要求会被拒绝。用户的访问权限主要基于其身份、许可等级和组成员资格。访问控制给予组织机构控制、限制、监控以及保护资源可用性、完整性和机密性的能力。本节会介绍包括防火墙和入侵检测为主的一些访问控制技术与体制，但是针对访问控制还有物理性、行政管理等层面的技术和措施，本书不进行单独介绍。

3. 防火墙技术

防火墙用于限制从另一个网络对特定网络的访问。大多数企业都使用防火墙来限制从 Internet 对企业网络的访问。他们还可能使用防火墙限制一个内联网段对另一个内联网段的访问。例如，如果网络管理员需要让雇员无法访问生产网络，那么他会在这个网络和其他所有网络之间设立一个防火墙，并且配置防火墙为只允许放行它认为可以接受的流量类型。

防火墙设备支持和实施企业的网络安全访问策略。有组织的安全策略可以提供高层次、可接受和不可接受操作的指示，从而维持整体的边界安全性，所以防火墙技术本身也是结构安全层面最为重要的安全技术手段，是实现结构安全的基础。防火墙具有定义更详细和更细粒度的安全策略的能力，从而规范哪些地址、哪些端口、哪些服务或者协议允许或者被禁止访问哪些区域，就像我们生活中的门禁和保安系统。下面是一般防火墙提供的 4 种主要服务。

- 1) 服务控制：确定可以访问的网络服务。
- 2) 方向控制：决定在哪个方向上的服务请求可以被发起并通过防火墙。
- 3) 用户控制：内部用户、外部用户所需的某种形式的认证机制。
- 4) 行为控制：控制一个具体的服务怎样被实现。

防火墙的实现形式包括搭载防火墙软件产品的服务器或者其他特殊硬件设备，防火墙会将经过它的数据包进行分析过滤，可能丢弃、重新打包、重定向或者直接放行。通常在

结构优化设计阶段,会使用防火墙在企业内部不同安全级别和业务需求的区域之间部署防火墙产品和策略,实现彼此之间互相访问资源的时候可以有严格的安全策略进行过滤和控制,比较典型的例子为“隔离区”(DMZ),这是一个位于受保护网络和未受保护网络之间的网段,如图 7-3 所示。DMZ 提供了一个在相对危险的区域和企业努力保护的内部网络区域内的信息之间的缓冲地带。

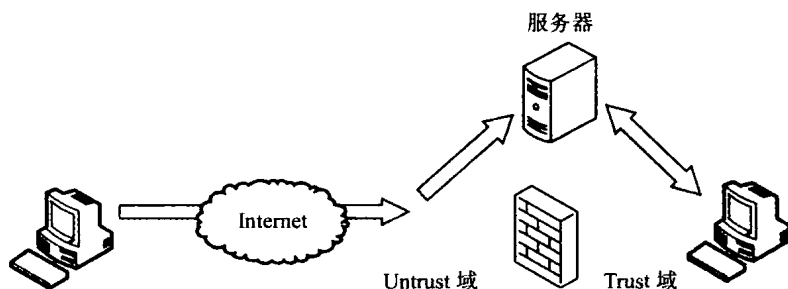


图 7-3 DMZ

DMZ 中的业务或者资源处于受攻击的最前沿,所以是最需要保护的区域。许多 DMZ 还具有能够监听恶意和可疑行为的入侵检测系统或者蜜罐系统。

7.2.2 设备与主机安全

设备与主机安全即工控环境中各种设备自身的安全性。例如,智能设备在基础设施建设中广泛使用,包括感知设备、网络设备、监控设备等,这些设备普遍存在漏洞、后门等安全隐患。保障基础设施设备与主机的安全性应首先具备标准化的检测工具,这些智能设备在出厂时需要做充分检测从而保障设备的离线安全、在项目建设过程中进行入网安全检测、在项目运行过程中进行实时在线检测,从而全方位保证设备的自身安全性。

设备与主机安全很重要的一点就是设备本身的安全系统。以乌克兰电网事件为例,这个工业控制系统的自身安全性就存在极大缺陷。绝大多数厂商的工控设备和产品一般都不进行兼容性和互联互通性测试(不含西门子和 GE),出厂测试非常单纯。不夸张地说,现在的工业控制系统的稳定性可能还达不到 20 多年前 Win32 的水平。

现在大量工控厂商会混淆稳定性与安全性的概念,如双系统备份,一定程度上增强的是稳定性,但如果两个具有同样的安全缺陷,那也并不会更安全。对于实际使用这些系统的企业来说,其实也没有办法解决这些安全缺陷。因为这些工控厂商在开始做这个事的时候就普遍缺乏安全意识,这从目前已知的千余种工控漏洞,仍有大量漏洞没有发布补丁和漏洞解决方案就可以看出这个问题的严重性。

1. 漏洞发现与打补丁

企业自身及时发现漏洞并打好补丁的可能性比较小，而且还要考虑一个时间窗口的问题。对于这个问题世界上处理最快的公司就是美孚，它是工控领域世界上打补丁最快的公司，但是也要 18 个月的时间。从这个补丁出来，到内部验证和论证大概需要 9 个月，然后再进行处理和解决，换句话说，在这 18 个月里，这个漏洞就暴露在攻击之下。所以打补丁的成本高，不是最好的解决方案。

工控设备厂商的版本发布周期长达 1 年到 1 年半，发现问题后一般来不及修改代码。所以 IT 领域使用普遍的打补丁方法，在天生没有安全基因的工控领域就显得非常不适用了。但是漏洞发现技术的使用还是有必要的。

发现漏洞的最高效、最普遍使用的技术就是漏洞扫描和漏洞挖掘，它是系统管理员保障系统安全的有效工具，当然如果使用不当也会成为网络入侵者收集信息的重要手段，所以漏洞发现技术本身也是一把双刃剑。

漏洞扫描技术根据扫描对象的不同，包括工业网络控制设备、工业网络控制系统、工业网络安全设备、工业网络传输设备等。进行漏洞扫描工作时，首先探测目标系统的存活设备，对存活设备进行协议和端口扫描，确定系统开放的端口协议，同时根据协议指纹技术识别出主机的系统类型和版本。然后根据目标系统的操作系统和提供的网络服务，调用漏洞资料库中已知的各种漏洞进行逐一检测，通过对探测响应数据包的分析判断是否存在漏洞。漏洞扫描挖掘如图 7-4 所示。

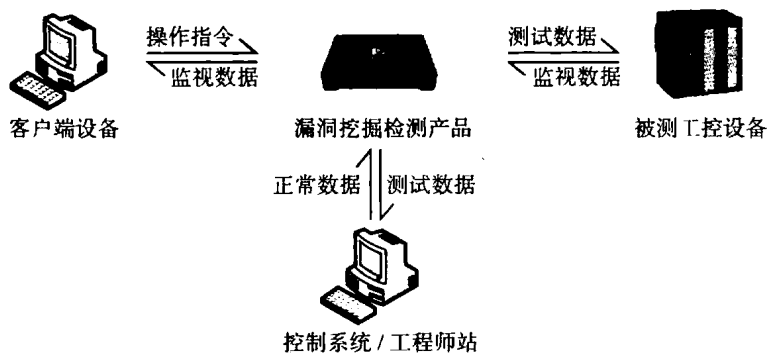


图 7-4 漏洞扫描挖掘

当前的漏洞扫描主要是基于特征匹配原理，一些漏洞扫描工具通过检测目标主机不同端口开放的服务，记录其应答，然后与漏洞库进行比较，如果满足匹配条件，则认为存在安全漏洞。所以，在漏洞扫描中，漏洞库的定义精确与否会直接影响最后的扫描结果。

2. 补偿性措施

当某个特定数据包会让工控系统崩溃或者引发进一步的安全问题时，保护设备可以拦截这个包，这样就不用修改工控系统代码或者打补丁了。那么这类保护设备实现的功能我们就称之为补偿性措施。

保护设备放在需要保护的设备或者系统前端。如果用户自身已经知道，这个漏洞风险很大，一定会导致死机，一定会窃取信息，而且也发生过，那么多数用户都会非常希望有这个补偿性措施，这个补偿性措施比升级工控系统软件或者打补丁的风险要低很多。设备存在自身的安全性漏洞，可进行准入检查，可加保护措施。如果一个针对工控系统的攻击，不能达到自身安全性的层次，其实它所能造成的威胁是非常有限的。

我们还有一个安全处置的思路就是，优先审计后再加保护。为什么我们要先进行审计，再添加保护措施呢？因为审计会发现问题，感知到了再判断和进行进一步的处理。进行安全防护类似于在家里装个保险箱，需要解决两个问题。

第一，证明现在这个锁是不安全的，贼可以比较容易地进来。第二，还得证明有贼“惦记”着。那么审计设备或者演示系统做的就是这件事，就是证明有贼惦记着并且也可以进来，当然其最重要的作用还是为我们第二步如何部署防护设备和策略作为参考。

当然，设备与主机安全性问题也可能被意外触发（非恶意攻击）。例如，ABB 与施耐德的设备部署在同一个系统中时，ABB 收到广播信息后可能就会死机；俄罗斯输油管道系统新配发的对讲机的频率干扰了摩托罗拉的控制器，导致管道切断从而系统关闭等。这些都是非恶意但是造成了恶意结果的事例。对于企业，有效地管理设备与主机安全性带来的这部分威胁也是非常重要的。

7.2.3 行为安全

行为安全包括两部分，即系统内部发起的行为是否具有安全隐患，系统外部发起的行为是否具有安全威胁？行为安全性防护首先应该具备感知能力，在云端通过大数据分析感知威胁和安全态势，在本地端通过靶场、蜜罐、审计、溯源等技术，对网络流量、文件传输、访问记录等进行综合分析 with 数据挖掘，实现对已知威胁和未知威胁的感知（通过分析进行未知威胁感知会在 7.3.2 节介绍），以及对全局安全态势和局部安全态势的感知，并与其他安全防护技术联动，对不安全行为进行及时处理。

除了后面章节我们会重点介绍的行为分析技术之外，我们还需要重点了解的就是行为安全的管理技术（不同于安全管理）。对于传统办公网的信息安全，在发现问题的节点后，通常会立即采取行动。TCP/IP 网络建立的原则就是不相信对方是可靠的。而工业控制网络

是在闭环理论下建立的，所以默认都是相信对方是可靠的。

工业控制网络很少敢在发现问题的那个节点马上采取行动，除非是最后一点。它通常将问题报给控制点，而控制点也未必会采取行动。例如，国内某石化企业新装了 18 套中控系统，每个系统都能被 100% 隔离，并希望每个系统内有探针（只读的感应器），发现问题后报到总控，由总控做出决策。自动化做出的决策往往就是切断系统业务，将有问题的系统进行隔离，确保问题不再蔓延。之后，根据具体情况，判断是应该重新恢复还是继续关闭。但是，停机就意味着停产，这个时间要尽可能短。能给我们用来分析的时间非常少，也基本不可能会有复现的机会，所以我们还应该有更完善的记录措施，随后将系统复位到基线水平（类似于沙箱），目前这种做法在 IT 系统也已经有大量应用，如谷歌的浏览器。

工控安全威胁的最大特征是全网的行为安全性，对于工业控制系统的攻击、渗透、病毒，复杂性很高，传统信息安全很大一部分攻击是 DDos 攻击，而对工控系统，边界上的 DDos 不影响生产，更具威胁的攻击手段是渗透。渗透需要跳转，整个过程会把自己伪装成合法行为。利用单点单逻辑去判断，特定操作都是合法的，需要从多个合法行为的组合中找到非法行为的特征。这是在工控安全或基础设施安全中经常遇到的，我们的规则要在全网范围内实施，Havex 病毒就是一个典型例子。

行为安全性有的还不是恶意的，是人为的失误或者巧合。例如，操作员发错了一个指令，一个系统最高权限的控制命令被触发了，这一触发就有可能使整个系统全部停机，人力物力损失都不会低。

行为安全还包括很多日常管理的部分，包括 USB 管理、定期的一些操作审查等。下面我们就介绍一种比较成熟且有代表性的针对安全威胁的行为检测和分析技术——入侵检测技术。

传统的信息安全方法采用严格的访问控制和数据加密策略来防护，但在复杂系统中，这些策略是不充分的，它们是系统安全不可或缺的部分，但不能完全保证系统的安全。入侵检测（Intrusion Detection）是对入侵行为的发觉。它通过从网络或特定系统的关键点收集信息并进行分析，从中发现网络或系统中是否有违反安全策略的行为和被攻击的迹象。

进行入侵检测的软件与硬件的组合便是入侵检测系统（Intrusion Detection System IDS），其对系统的运行状态进行监视，发现各种攻击企图、攻击行为或者攻击结果，以保证系统资源的机密性、完整性和可用性。

入侵检测系统一般包括 3 个功能模块：信息收集模块、信息分析模块、结果处理模块。

1. 信息收集模块

入侵检测的第一步是信息收集，收集内容包括系统、网络、数据及用户活动的状态和

行为,信息收集的位置需要在计算机网络系统中的若干不同关键点(不同网段和不同设备),尽可能扩大检测范围,因为来自一个源的信息有可能看不出疑点。

入侵检测在很大程度上依赖于收集信息的可靠性和正确性,所以要保证用来检测网络系统的软件的完整性,特别是入侵检测系统软件本身应具有相当强的坚固性,防止被篡改而收集到错误的信息。

2. 信息分析模块

这是实现入侵检测技术的核心模块,也就是一般认为的检测模块。信息分析的方式主要有3种。

(1) 模式匹配

模式匹配就是将收集到的信息与已知的网络入侵和系统误用模式数据库进行比较,从而发现违背安全策略的行为。

一般来讲,一种攻击模式可以用一个过程(如执行一条指令)或一个输出(如获得权限)来表示。该过程可以很简单(如通过字符串匹配以寻找一个简单的条目或指令),也可以很复杂(如利用正规的数学表达式来表示安全状态的变化)。

(2) 统计分析

统计分析方法首先给系统对象(如用户、文件、目录和设备等)创建一个统计描述,统计正常使用时的一些测量属性(如访问次数、操作失败次数和响应频率等)。

测量属性的平均值和偏差将被用来与网络、系统的行为进行比较,任何观察值在正常值范围之外时就认为有人入侵行为发生。

(3) 完整性分析

完整性分析主要关注某个文件或对象是否被更改,这经常包括文件和目录的内容及属性,在发现被更改的、被安装木马的应用程序方面特别有效。

3. 结果处理模块

入侵检测的处理方式一般就是发现威胁进行干预,或者认为不是威胁进行安全放行,但是由于多方面的原因,经常会产生误报和漏报的情况,例如,有一些应用场景下一个业务流程设计的特殊性刚好匹配了一类典型的攻击行为。

- 误报(False Positive):系统错误地将异常活动定义为入侵。
- 漏报(False Negative):系统未能检测出真正的入侵行为。

7.2.4 基础软硬件安全

基础软硬件安全性即CPU、存储、操作系统内核、基本安全算法与协议、数据库和软

件开发中使用到的中间件、库、框架等基础软硬件的完整可信、自主可控。在有条件的情况下，应实现对自有系统与设备的基础软硬件安全性改造，以及对进口系统与设备的基础软硬件安全性加固。在条件不具备的情况下，应具备安全补偿机制。

基础软硬件安全性的概念比较多，它的核心概念在于免疫性安全，也就是说这个设备自身具有排除破坏、攻击、篡改的能力。例如可信计算的应用，某个程序想在硬盘上启动，但是因为没有被授权此行为，所以认为这是不可靠的，究其本身是一种免疫机制，即排除恶意代码执行、植入的可能性，这就是基础软硬件安全的一个典型实例。由于想要做到这一点需要对设备进行底层改造并升级，这个周期比较长，难度也非常大，所以运维安全在做到这一点之前就显得尤为重要。7.2.5 节针对运维安全的时间持续性进行了基本介绍，这里我们仅选择基础软硬件安全中最具有代表性的可信网络、可信计算和开发安全进行介绍。

1. 可信网络

可信网络架构不是一个具体的安全产品或一套针对性的安全解决体系，而是一个有机的网络安全全方位的架构体系化解决方案，强调实现各厂商的安全产品横向关联和纵向管理。因此在实施可信网络过程中，必将涉及多个安全厂商的不同安全产品与体系，这需要得到国家政府和各安全厂商的支持与协作。

鉴于可信计算技术的重要性，国际上一些著名的大学和公司，如卡内基梅隆大学、AT&T、微软公司等也在积极开展这方面的研究，并取得了一系列成果。随着研究的日渐深入，可信网络开始走上台前。

当前，可信计算方兴未艾，可信网络呼之欲出。各企事业单位在信息化的过程中，根据各自面临的安全问题与应用需求，并根据针对性的安全性问题，逐步构建了基于信任管理、身份管理、脆弱性管理以及威胁管理等相应的安全管理子系统。但是这些针对性的安全产品和安全解决方案缺乏相互之间的协作和沟通，无法实现网络安全的整体防御。

因此，网络安全领域的发展已进入了综合安全系统建设的阶段。安全企业将面临用户从以往的安全系统建设转化为安全运行维护的新需求：如何发挥已有安全产品的整体效能；如何保护已有的投资，避免重复投入与建设以节省资源；如何建立各安全子系统、各安全产品之间的关联，提高网络整体的安全防御能力成为网络安全发展的必然趋势。这些问题正受到企业的密切关注。

可信网络的推出旨在实现用户网络安全资源的有效整合、管理与监管，实现用户网络的可信扩展以及完善的信息安全保护；解决用户的现实需求，达到有效提升用户网络安全防御能力的目的。

(1) 可信网络特征

- 网络中的行为和行为中的结果总是可以预知与可控的。
- 网内的系统符合指定的安全策略，相对于安全策略是可信的、安全的。
- 随着端点系统的动态接入，具备动态扩展性。

(2) 架构网络安全模型

可信网络架构的推出可以有效地解决用户所面临的如下问题：设备接入过程是否可信；设备安全策略的执行过程是否可信；安全制度的执行过程是否可信；系统使用过程中操作人员的行为是否可信等。

可信网络的一般性架构主要包括可信安全管理系统、网关可信代理、网络可信代理和端点可信代理四部分，从而确保安全管理系统、安全产品、网络设备和端点用户 4 个安全环节的安全性及可信性，最终通过对用户网络已有的安全资源的有效整合和管理，实现可信网络安全接入机制和可信网络的动态扩展，加强网内信息及信息系统的等级保护，防止用户敏感信息的泄露。

2. 可信计算

可信计算 / 可信用计算 (Trusted Computing, TC) 是一项由可信计算组织 (Trusted Computing Group) 推动和开发的技术。这个术语来源于可信系统 (Trusted System)，并且有其特定含义。从技术角度来讲，“可信的” (Trusted) 未必意味着对用户而言是“值得信赖的” (Trustworthy)。确切而言，它意味着可以充分相信其行为会更全面地遵循设计，而执行设计者和软件编写者所禁止行为的概率很低。

这项技术的拥护者称它将会使计算机更加安全，更加不易被病毒和恶意软件侵害，因此从最终用户角度来看也更加可靠。此外，他们还宣称可信计算将会为计算机和服务提供更强的计算机安全性。而反对者认为可信计算背后的那些公司并不那么值得信任，这项技术给系统和软件设计者过多的权利和控制。他们还认为可信计算会潜在地迫使用户的在线交互过程失去匿名性，并强制推行一些不必要的技术。最后，它还被看作版权和版权保护的未版本，这对于公司和其他市场的用户非常重要，同时这也引发了批评，引发了对不当审查 (Censorship) 的关注。

可信计算包括 5 个关键技术概念，它们是完整可信系统所必需的，这个系统将遵从 TCG 规范。

(1) 签注密钥

签注密钥是一个 2048 位的 RSA 公共和私有密钥对，它在芯片出厂时随机生成并且不能改变。这个私有密钥永远在芯片里，而公共密钥用来认证及加密发送到该芯片的敏感数据。

（2）安全输入输出

安全输入输出是指计算机用户和他们认为与之交互的软件间受保护的路径。当前，计算机系统上的恶意软件可通过许多方式来拦截用户和软件进程间传送的数据，如键盘监听和截屏。

（3）存储器屏蔽

存储器屏蔽拓展了一般的存储保护技术，提供了完全独立的存储区域，如密钥的存放。即使操作系统自身也没有密钥存储的完全访问权限，所以入侵者即便控制了操作系统，信息也是相对安全的。

（4）密封存储

密封存储通过把私有信息和使用的软硬件平台配置信息捆绑在一起来保护私有信息，意味着该数据只能在相同的软硬件组合环境下读取。例如，某个用户在他们的计算机上保存一首歌曲，而他们的计算机没有播放这首歌的许可证，他们就不能播放这首歌。

（5）远程认证

远程认证准许用户计算机上的修改被授权方感知。例如，软件公司可以避免用户干扰他们的软件以规避技术保护措施。通过硬件生成当前软件的证书，随后计算机将这个唯一证书传送给远程被授权方来显示该软件公司的软件的状态信息，如尚未被干扰（尝试破解）。

从广义的角度，可信计算平台为网络用户提供了一个更为宽广的安全环境，它从安全体系的角度来描述安全问题，确保用户的安全执行环境，突破被动防御打补丁方式。

3. 认证体制

一位用户为了能够访问资源，首先必须证明他是自己所声明的人，拥有必需的凭证，并且具有执行所请求动作的必要权限或特权。一旦这些步骤成功完成，这位用户就能够访问和使用网络资源。然而，我们还需要跟踪该用户的活动以及对其活动实施可问责性。身份标识描述了一种能够确保主体（用户、程序或进程）就是其所声称实体的方法。通过使用用户名或账号就能够提供身份标识。为了能够进行正确的身份验证，主体往往需要提供进一步的凭证，这些凭证可以是密码、密码短语、密钥、个人身份号码、生物特征或者令牌。这些凭证项将会与先前为该主体存储的信息进行比较。如果这些凭证与存储的信息相匹配，那么主体就通过了身份验证，但是验证工作本身并未结束。

一旦主体提供了其凭证并且被正确标识了身份，主体试图访问的系统就需要确定该主体是否具有执行请求的动作所需的权限和特权。系统会查看某种访问控制矩阵或比较安全标签，以便验证该主体是否确实能够访问请求的资源和执行试图完成的动作。如果系统确

定主体可以访问特定的资源，那么就会为该主体授权。

尽管身份标识、身份验证、授权与可问责性都具有完整和互补的定义，然而它们在访问控制过程中都有着自己明确的作用。一个用户能够顺利地通过网络上的身份标识和身份验证，但是可能不被授权访问文件服务器上的文件。此外，用户能够被授权访问文件服务器上的文件，但是在未顺利通过身份标识和身份验证之前，他们也将无法获得这些资源，只有这 4 个步骤全部完成后，主体才能够成功访问客体，如图 7-5 所示。

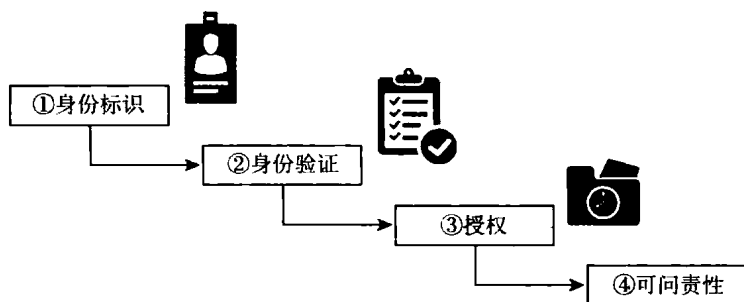


图 7-5 主体访问的认证机制

主体在一个系统或区域内的动作应该可问责，确保可问责性的唯一方法是主体能够被唯一标识，并且主体的工作被记录在案。

逻辑性访问控制是用于身份标识、身份验证、授权与可问责性的技术工具，它是实施针对系统、程序、进程和信息的访问控制措施的软件组件。逻辑性访问控制能够嵌入操作系统、应用程序、附加安全包或数据库以及通信管理系统内，使所有访问控制同步，并且确保在未影响原有功能的情况下覆盖所有脆弱性，这些工作非常具有挑战性。

一个人的身份必须在身份验证过程中被验证，身份验证通常涉及一个包含两个步骤的过程：输入公共信息（用户名、雇员号、账号或部门 ID），然后输入私有信息（静态密码、智能令牌、感知密码、一次性密码、PIN 码或数字签名）。输入公共信息是身份标识步骤，而输入私有信息则是身份验证步骤，身份标识和身份验证所使用的每一项技术都有其优缺点，因此需要在特殊的环境中正确地对其进行评估，以便采用正确的策略。

4. 密码体制

加密传输的数据只能被指定方读取和处理，它被视为通过将信息加密成不可读格式以对其进行保护的一门学科。在介质上存储或通过不可信网络通信路径传输敏感信息时，密码体制是一种有效的保护方式。

密码学的一个重要目标是对未授权的个人隐藏信息。然而，如果黑客有足够的时间、

强烈的愿望和充足的资源，那么大部分密码算法都能够被攻破，从而破译加密的信息。因此，密码学的一个更现实的目标是：对于攻击者来说，要破译密码以获取信息所需的工作强度和耗费的时间是令人难以接受的。

最早的加密方法可以追溯到 4000 多年前，当时人们更多地认为它是一种艺术形式。后来，人们将加密作为一种工具，用在战争、商业、政府以及其他需要保护秘密的场合中。纵观历史，个人和政府都努力通过加密来保护通信安全。因此，加密算法及使用它们的设备的复杂度越来越高，新的方法和算法不断增加，加密也已成为计算领域一个不可分割的部分。

密码学的历史非常有趣，在其数个世纪的发展过程中经历了许多变化。事实证明，保密对于文明的发展非常重要。它使得个人和团体能够隐藏他们的真实意图，获得竞争优势，减少损失等。密码学所经历的变化与技术的进步息息相关。最初，人们将消息刻录在木头或石块中，然后将它们送交给指定的个人，再由后者通过相应的方法对消息进行解密。从此以后，密码学有了很大发展。如今，人们将消息插入二进制代码，再通过网线通信路径和电波进行传送。

密码学的研究主要有两个方向：密码编码学（Cryptography）和密码分析学（Cryptanalysis）。密码编码学主要研究对信息进行变换，以保护信息在信道中安全传送。而密码分析学则是研究如何分析和破译密码。我们需要理解的基本概念主要有明文、密文、加密、解密和密钥，密码体制如图 7-6 所示。

- 明文：需要交换的原信息。
- 密文：明文经过变换成为另一种隐蔽的形式。
- 加密：完成变换的过程。
- 解密：从密文中恢复出明文的过程。
- 密钥：加解密过程中的秘密钥匙，在明文转换为密文或将密文转换为明文的算法中输入的特殊参数。

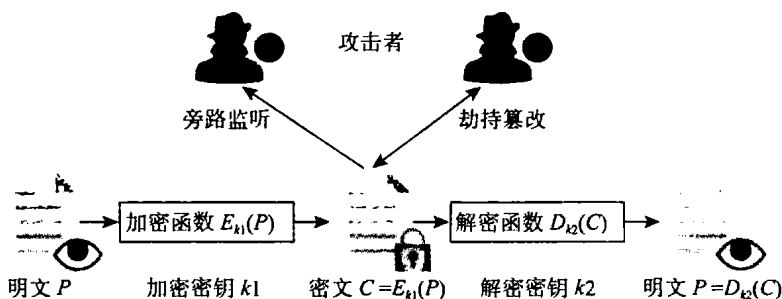


图 7-6 密码体制

一种完整的密码技术包括密钥管理和加密处理两个方面, 密钥管理包括密钥的产生、分配、保管和销毁等, 加密处理包括加密和解密。根据密钥的特点又可以分为私钥(单钥、对称)密码体制和公钥(双钥、非对称)密码体制。

(1) 私钥密码体制

私钥密码体制也叫作单钥或对称密码技术, 其最大的特点就是加密和解密时所用的密钥是相同的或者类似的, 即由加密密钥可以很容易推导出解密密钥。

(2) 公钥密码体制

在私钥密码体制中, 消息的发送方和接收方必须在密文传输之前通过安全信道进行密钥传输。而实际的传输信道安全性并不理想, 所以密钥在传输过程中被暴露的风险很大。公钥密码的最大优点在于针对密钥管理方法的改进。在公钥密码系统中, 加密密钥是公开的, 任何人都可以采用这些公开的加密密钥对消息进行加密。同时只有正确的接收方才能够用自己所保管的解密密钥对密文进行解密, 这些解密密钥需要妥善保存。

目前, 大部分加密算法都已经公开了, 像 DES 和 RSA 等加密算法甚至作为国际标准来推行。因此明文的保密在相当大的程度上依赖于密钥的保密。

在现实世界里, 密钥的分配与管理一直是密码学领域较为困难的部分。设计安全的密钥算法和协议是不容易的, 但可以依靠大量的学术研究。相对来说, 对密钥进行保密更加困难。因而, 如何安全可靠、迅速高效地分配密钥, 如何管理密钥一直是密码学领域的重要问题。

5. 开发安全

从世界各国的经验来看, 软件缺陷是组织面临的主要威胁。虽然大家都知道想要解决此问题需要从源头出发, 但是从目前客观或主观的情况来看很难做到这点。在安全领域有一个普遍的说法, 即网络由一个“硬脆的外壳和柔软厚实的中间部分组成”。安全行业在结构安全设备和技术上取得了惊人的进步(如防火墙、入侵检测、入侵防御系统等), 它提供了硬脆的外壳, 但是我们每天执行关键流程的软件依旧有很多可以被利用的漏洞。

应用程序和系统开发的首要目的往往是满足功能需求, 而并非安全。为了满足这两方面的需求, 在设计和开发时必须同时考虑安全性和功能性。安全交织在产品的核心之中, 并在各个层面提供保护。相对于在产品与其他应用程序集成时再开发可能影响总体功能和留下安全漏洞的前端或者包装程序, 在设计之初就考虑安全因素的方法要好得多。表 7-4 列出了软件生命周期模型的各个阶段与安全注意事项的一些重要关系。

尽管在开发软件时首先考虑的是功能性, 然而如果在项目启动之前就引入安全性并集成到并发过程的每个步骤中, 那么无疑是非常有益的。虽然很多企业不将此视为最有益的

软件开发方法，但是随着不得不开发和发布越来越多的安全补丁和修补程序，其客户不断要求更安全的产品，他们会开始承认这一事实。

软件开发是一项复杂的任务，这种复杂性也使得实现有效的安全越来越困难。多年以来，编程人员和开发人员在编码时并不需要考虑安全方面的因素，不过这种趋势正在改变。教育、经验、意识、实施以及客户需求等因素都迫使我们在使用的所有程序代码中实施更安全的实践和技术。

表 7-4 SDLC 模型中的安全注意事项

	启动	开发测试管理	实现部署	运行维护	处理
SDLC	• 决定需求 • 认识需求 • 任务与目标性能实践的联系 • 评估备用资本资产 • 准备资本审查和预算	• 功能需求声明 • 市场调查 • 可靠性研究 • 需求分析 • 备用方案分析 • 成本 / 收益分析 • 软件转换研究 • 成本分析 • 风险管理计划 • 购置规划	• 安装 • 检查 • 验收测试 • 初步培训 • 文档资料	• 性能评估 • 合约修改 • 运行 • 维护	• 处理的适当性 • 交流与销售 • 内部组织机构筛选 • 转让与捐献 • 终止合约
安全注意 事项	• 安全分类 • 初始风险评估	• 风险评估 • 安全功能需求分析 • 安全保证需求分析 • 成本注意事项与报告 • 安全规划 • 安全控制开发 • 开发安全测试与评估 • 其他规划组件	• 检查验收 • 系统集成 • 安全认证 • 安全认可	• 配置管理与控制 • 持续监控	• 信息保存 • 介质净化 • 硬件和软件处理

7.2.5 安全时间持续性

安全时间持续性即建立长效的安全机制，在持续对抗中保障安全。从技术、设备、人员、管理等多个维度，实现综合安全服务能力，保障关键基础设施全生命周期的安全性。

大多数攻击者对工业控制系统的攻击是非常有耐心的。攻击者选定攻击目标后，会一直持续攻击，这与工控系统的稳定性有关。另外其单点故障成本高，所以时间持续性要求很高。

运营安全是关于为保持网络、工控系统、计算机系统、应用程序和环境运转并以安全和受保护的方式运行所发生的一切事情。它包括确保人员、应用程序和服务器仅拥有访问他们所需要资源的权限，并通过监控、审计和报告控制来实现监督。操作是在网络已开发并得到实现后才产生的，这包括一个运行环境的持续维护和那些每天或每周应该发生的活

动。这些活动实际上是日常事务，并且确保工控网络和个人计算机系统正确、安全地持续运行。

工控网络和计算机环境都是正在演变的实体，仅仅因为它们在这周是安全的，并不能说明它们在3周后仍然是安全的。很多企业都已经聘请了那些建议他们如何改善其基础设施、策略和措施的安全顾问。随后，企业可以花费巨额资金实现顾问的建议，安全正确地配置防火墙、入侵检测系统、防病毒系统以及给管理系统打补丁。然而，假设入侵检测系统和防病毒系统没有持续得到升级或更新，系统没有持续地打补丁，没有测试防火墙和设备的脆弱性，或者新软件加入到网络 and 操作的计划当中，那么公司可能会很快倒退至一个不安全和危险的境地。如果公司没有持续更新它的运营安全任务，那么就会发生这种情况。表7-5为安全部门测试时间表示例。

表 7-5 安全部门测试时间表举例

测试类型	频率	好处
网络扫描	持续或每季度进行	列举网络结构并决定活动主机和相关软件 标识连接到网络的未授权主机 标识开放端口 标识未授权的服务
战争拨号	每年进行	检测未授权的调制解调器，并组织对被保护网络的未授权访问
驾驶攻击	持续或每周进行	检测未授权的无线访问点，并组织对被保护网络的未授权访问
病毒检测	每周或按需进行	在病毒安装到系统之前检测并删除
日志检查	每天对关键系统进行	确保系统根据策略运行
口令破解	持续或按终止策略以相同的频率进行	验证策略能够有效生成或多或少难以破解的口令 验证用户选择了符合组织机构安全策略的口令
脆弱性扫描	每季度进行或每两月进行（通常针对的是高风险的系统），或者在更新脆弱性数据库时进行	列举网络结构并决定活动主机和相关软件 标识一组目标计算机专门进行脆弱性分析 标识目标计算机上的潜在脆弱性，确保操作系统和主要的应用程序安装了最新的安全补丁和软件版本
渗透测试	每年进行	确定组织机构网络被渗透的脆弱性以及可能导致的损失程度 测试IT人员如何响应已知安全事故，以及组织机构安全策略和系统安全要求的实现情况
完整性检查	每月及在发生可疑事件时进行	检测未授权的文件修改

时间持续性安全运维应该维持已部署的解决方案、保持对变更的跟踪、正确地维护系统、不断地加强必要的标准以及坚持安全实践和任务。如果在几个月之后执行变得松懈，用户可以使用他们想要的任何口令，那么对一个企业来说开发一套强壮的口令策略就没有任何好处。这类似于锻炼和保持身材，某人已经变胖，一周的慢跑并不意味着他在其他时间内一直吃甜品也可以保持身材。

7.3 对工业控制网络未知安全威胁的防护方法

针对安全威胁的技术防御方法，我们最容易想到的措施可能就是防火墙、IPS 和防病毒等技术措施。从已知威胁和典型安全防护技术方案的介绍中我们可以知道，通过以上安全技术结合合理的结构安全设计，我们可以解决威胁的传播、扩散等问题，并且能避免一些高危的系统漏洞被利用。但是，这些防御思路和技术措施想要达到预期的效果，都有一个前提条件需要满足，这就是所能防御的威胁都是我们已经发现的威胁。如果不法分子发现了还没有被公之于众的漏洞，则通过依赖于传统特征库检测技术的思路可能就很难再对其进行成功的检测，此时依赖于特征库检测技术的安全技术和解决方案就基本没有任何作用了。

那么如果作为一个新型漏洞，它的所有特征和信息都是未知的，又怎么能使用已有的技术手段去检测和防御它呢？这就是本节我们探讨的内容——如何发现和防御 ICS 中新型的、未知的安全威胁。

7.3.1 纵深防御技术

按照传统的纵深防御技术针对 ICS 的结构安全进行全面部署之后，理论上我们至少应该已经具备了类似于传统 IT 网络中防火墙、入侵检测系统、入侵防御系统、防病毒和应用程序监控等安全设备的能力。其实纵深防御技术的解决方案除了可以解决结构安全和已知攻击的防御能力之外，如果应用巧妙同样可以发现和防御很多未知威胁的攻击。

防火墙和 IPS 设备的特定策略都可以用于评估各种行为，匹配策略的不同条件对应的不同行为可以区分所有数据的情况，虽然防护的结果是“非黑即白”的结论，但是通过大量看似没有问题的行为和事件同样可以拿来检测可疑的活动。也就是说通过该层面处理数据生成的结论和日志信息进行评估，就能够覆盖所有区域的通信状态、用户访问、运行、控制管理等，如 ICS 内部进行通信的时候源地址不可能出现无法识别的非内网网段地址。

从表 7-6 中我们可以看到除了一般的安全隔离和检测类措施之外，还借助到了像 SIEM 和日志分析管理类的工具，这些工具被设计用来收集和查看来自多个数据源的信息，一般为日志数据，并将这些信息进行基本的关联。但是，在没有人工充分地理解和分析判断的情况下，这些信息也没有办法直接拿来确定可能的异常行为和未知威胁。

表 7-6 违规行为举例

异常	执行的策略	由什么检测	建议的动作
网络流量来自不同的区域，而不是来自目的地址	功能组或者区域的网络隔离	防火墙、网络监管、网络 IDS/IPS 等，使用异常 IP 变量	只警告，会对所有区域间通信生成报告

(续)

异常	执行的策略	由什么检测	建议的动作
网络流量来自外部地址,但是这个地址在受保护的区域中	互联网上的关键区域的隔离	日志管理/分析、SIEM等,关联异常IP和用户授权活动	重要警告,表示受保护的区域可能遭到入侵
访问网络的一个授权用户,其来自新的或者是不同的地址	用户访问控制策略	日志管理/分析、SIEM等,关联异常IP和用户授权活动	仅警告,用于创建非正常管理员的报告
未授权的用户实现了管理员功能	用户访问控制策略	日志管理/分析、SIEM等,关联授权用户变量和应用程序活动	严重警告,预示潜在的未授权特权升级
工业网络协议在非工作区域中使用	通过协议进行功能组的网络隔离	网络监管、网络IDS/IPS、应用程序监控器、工业协议监管等,使用异常协议变量	只警告,用于对非正常的协议使用生成报告
“写”功能代码在正常的业务时间之外被使用	管理控制策略	应用程序监控器检测管理函数识别或者认证系统认为正常的管理交接 SIEM或者其他日志分析工具关联预期业务变更时间与管理功能	只警告,用于在非预期的管理行为上生成报告
工业网络协议使用“写”功能代码,而这个代码来自于授权设备的非管理员用户	用户访问控制策略	应用程序监控器检测管理函数识别或者认证系统认为正常的管理交接 SIEM或者其他日志分析工具将认证日志和控制策略、工业协议功能相关联	严重警告,用于揭示可能的内部威胁或者破坏

7.3.2 异常行为检测

有时候即便是一个非威胁行为也可能会违背预设的安全策略,通过与已知的正常参数进行比较和分析我们可以了解到这些异常事件的具体原因。这种比较可以采用人工也可以使用自动化分析处理的方式,其最大的意义在于实际的业务运转过程中必然会有大量的“非黑非白”数据或者事件产生,这里面有一部分可能就是没有意义的“脏”数据,还有一部分就有可能是一个我们还未得知的新型攻击方式,或者为了一个攻击目的所做的铺垫行为。

发现这些异常的情况并进行分析可能的潜在结果就是异常行为检测的最终目的,为了实现这个目的我们就需要定义一些固定的衡量标准和算法,这里我们将这种衡量标准称为衡量参量。参量就包括正常参量和异常参量,这是我们进一步进行异常行为分析的基础,因为一个异常行为可以通过一个或者多个异常参量完全确定下来。

1. 异常参量

异常参量作为异常行为检测的最小分析单元,需要通过一个特定的衡量标准进行制定,在不同的行业ICS中可能有较大差别。因为所有的正常和异常行为特性都会在同一时空轴中进行,所以不同行业中众多的异常参量会有一个共有的固定参量,这个参量就是时间。

每一个参量单元都是基于固定时间的运行平均值，这个特性使得它提供了可以用现有业务行为与之比较的基础。异常参量不仅在比较过去和现在的行为方面行之有效，在衡量 ICS 中的程序能力、业务指标等方面也非常有效。通过参量的过去已知数据可以分析未来行为的延续性趋势。

参照表 7-7 的样例，每一个异常参量的定义都应尽量简化，这样在量化和异常算法的使用中就可以留出足够灵活的空间，逻辑上也会更加清晰。

表 7-7 异常参量举例

类型	异常参量	测量方式	分析方式
网络流量	①所有独立的源 IP ②所有独立的目的 IP ③所有独立的 TCP/UDP 端口 ④所有流量的容量 ⑤所有字节数流量的容量 ⑥流量持续时间	①网络交换机或路由器的流量日志（即网络流量、jFlow、sFlow 等） ②网络侦查（如 IDS/IPS、网络监管等）	①网络行为异常检测系统（NBAD） ②日志管理系统 ③SIEM 系统
用户活动	①所有独立的活跃用户 ②所有登录数 ③所有登出数 ④认证成功用户登录数 ⑤认证失败用户登录数 ⑥用户的活动（如配置变化、备份）	①应用程序日志、数据库日志和事务分析 ②应用程序日志和会话分析 ③集中认证（LSAP、Active directory、IAM）	①日志管理系统 ②SIEM 系统 注意：用户活动需要额外的关联层次，用于将多个用户名或账户与单个用户实体绑定
过程和控制行为	①所有独立的功能代码 ②每个独立功能代码的总量 ③所有设置点或其他配置变化	①工业协议监控器 ②应用程序监控器 ③数据历史化标签	①历史数据库 ②SIEM 系统
事件和事故活动	①所有事件数 ②所有关键的和严重的事件数 ③安全设备的事件数	安全设备（即防火墙、IPS）的日志	①应用程序监视器 ②工业协议过滤器

2. 异常行为

通过使用异常参量的比对我们可以发现偏离正常范围的一些异常情况，但是单一的异常参量并不一定可以确定一个异常事件或者威胁。例如，图 7-7 列出了一年 12 个月中锅炉平均温度的变化情况。我们如果发现一个锅炉中的温度传感器的温度低于 1000 度并不能直接判断其是否为正常情况，这个时候如果我们还需要确认其是否为异常情况，可能还需要了解更多的参量，如传感器状态、业务时间表等。

那么，对于有些有时间规律的业务就可以加入时间参量去解决这个问题，生成一个非线性基线图作为参量。例如，我们的管理员在一周时间中登录 PMI 的次数中，可能每周的周一会比较多，而周末会偏少。如图 7-8 所示。

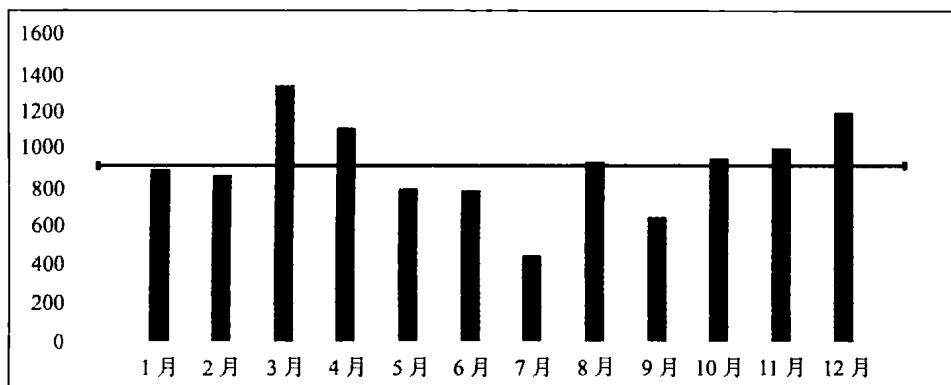


图 7-7 12 个月传感器事件平均值

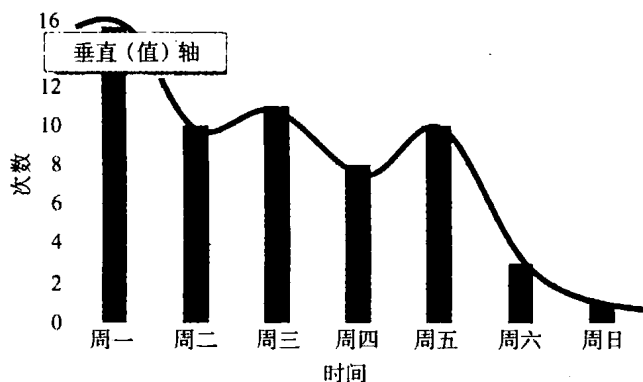


图 7-8 一周时间为基准的非线性基线

时间相关的基准是非常有用的，因为大量的业务规律都随着时间变化呈现一定的规律性。针对不同的业务场景和系统情况，可能是1个小时一个周期、1天一个周期、1周一个周期、1个季度一个周期，每个ICS可能会有数百个这种基于不同时间规律的基线，通过这种基于时间的规律综合分析这数百个异常参量，我们就可以很好地发现一些可疑的异常行为。

为了达到这个效果我们就需要在一开始的数据采集和建模阶段就按照时间发展规律去做，然后再对其进一步进行统计分析。

表 7-8 是一些典型工控系统环境下的异常行为实例。

由于无须依赖检测标志，异常行为检测是一种非常实用的未知威胁检测技术。相比于一般的IT系统，工业控制系统中业务的规律性和稳定性更强，再通过时间参量进行建模之后，随着时间推移能够统计分析应用于绝大多数场景的异常检测。

表 7-8 异常行为举例

正常行为	异常行为	通过什么测量	表现
到一组 PLC 的 Modbus 所有通信都是来自于相同的 3 个 HMI 工作站	出现第 4 个系统与 PLC 进行通信	从以下分析中可得出，独立源 IP 的数量出现了超过 20% 的增加： ①网络流量 ②从防火墙、IPS 等设备得到的安全事件日志 ③应用程序日志 ④其他	①一个新的、未授权的设备被插入网络中（如一个管理员的笔记本电脑） ②一个使用欺诈 IP 地址的恶意 HMI 正在运行 ③新的系统安装上线
每个设备都有唯一的 MAC 地址和唯一的 IP 地址	一个 IP 地址来源于两个或者多个 MAC 地址	从以下分析中可以得出，每个 IP 地址的 MAC 地址数大于 1： ①网络流量 ②从防火墙、IPS 等设备得到的安全事件日志 ③应用程序日志 ④其他	①攻击者伪装一个地址 ②设备失效并被新的硬件所取代
控制系统区域中的某个过程持续运行某个控制回路	流量增长至超过预期	从网络流量的分析中可知，总的网络流量有超过 20% 的增长（以字节计）	①一个未授权的服务在运行 ②扫描或者测试正在进行 ③转移变化正在进行 ④开始了一批新的作业或者过程
	流量减少至预期之下	从网络流量的分析中可知，总的网络流量有超过 20% 的减少（以字节计）	①服务停止运行 ②网络设备失效或离线 ③一批作业或过程的完成
可编程逻辑的变化	工业网络监控器，如 SCADAIDS 梯形逻辑发生突变	通过以下渠道分析获得的个体功能代码的所有改变和功能代码的频率： ①工业协议监控器 ②应用程序监控器 ③ SCADA IDS/IPS 日志	①过程的修改 ②新的过程被执行 ③老的过程被移除 ④过程被破坏
在转移开始阶段，授权用户登录到常用系统中	①未授权的用户登录到系统，该系统一般只由管理员访问 ②授权用户在正常值班时间之外登录到系统 ③授权用户登录未知或预期之外的系统	通过对以下认证日志进行分析得出所有的变化： ①活动目录操作系统日志 ②应用程序日志	①用户个人改变 ②由于管理员不在或缺席，故责任被移交给了其他用户 ③系统授权了一个恶意用户 ④管理员账户被破解并为攻击者所使用

7.3.3 白名单技术

其实结构安全中使用的访问控制功能就是一个最具有代表性的白名单技术应用，人工配置的每一条访问控制安全策略就是每一个访问路径的白名单规则。针对未知威胁的发现

通过简单的白名单技术肯定没有办法实现,但是从保障 ICS 的安全角度来看,它几乎可以做到最准确地防御所有未知威胁。也就是说白名单的未知威胁防御技术是一种与黑名单思路截然相反的安全防御方式,它本身不需要分析和检测谁是威胁,只需要关心谁不是威胁就能做到安全防护的效果。

1. 应用程序白名单

应用程序白名单 (Application Whitelisting, AWL) 是用来防止未认证的应用程序运行的一种措施,传统的病毒查杀往往是以“黑名单模式”工作,把恶意软件隔离或清除,这种方式很明显永远都只能防御已知的威胁和病毒,而 AWL 的理念是“白名单”模式,只有允许的应用程序才能被运行。

在特定的应用场景下,需要针对场景中为了实现业务系统的正常运转所需要使用到的所有软件 and 应用程序进行统计,然后对其进行充分的代码审计、安全测试和分析,结合完整性检查方法的应用,一般为散列法,确保该应用程序是已认证安全通过的。

2. 用户白名单

对于发现一些潜在的威胁,针对一般的用户活动和管理员行为的分析其实是非常有必要的,大量的渗透攻击都是通过拿到一定权限的用户或者管理员账号之后进行下一步恶意行为的。例如,管理员账户直接进行恶意用途,或者用于为其他恶意账户提升权限,使其得到与管理员一样的权限等。

如果通过针对用户身份以及用户权限的白名单管理,我们就可以在系统之外多一个权限管理措施,其自身的规则强度与系统自身的用户权限是同级或者更高的。用户白名单的技术措施独立于系统自身的用户管理措施,但不同于结构安全中的基本访问控制功能,其自身还针对用户所拥有的权限进行白名单管理,实现了部分审计控制功能的自动化。

当年知名的 Stuxnet 就是使用一个默认的用户身份认证凭据去访问 PLC 的,假设当时如果在网络中部署了用户白名单的技术,那么就可以马上发现非法的接入和访问行为,提醒相关的管理人员注意或者直接进行干预。

3. 资产白名单

有很大一部分针对 ICS 的攻击或者误伤行为,都是由于在 ICS 的网络中非法接入了其他设备造成的。在这里借助于已经比较成熟的自动化网络扫描工具,可以快速得到 ICS 中的已知资产清单,当然这个过程也完全可以手工实现。而这份清单在得到确认之后,就可以用于记录合法设备的白名单。

在结构安全中我们比较强调基于边界的各种安全策略，而通过资产白名单的技术则将此边界直接做到了每一个设备上。此时，如果有一个恶意的设备或者地址被接入到 ICS 中，我们基于资产白名单技术，通过以前的结构安全方法仍然可以快速地发现这个威胁源，将可能的未知新型威胁检测出来，并进一步采取对应的措施。

针对这种不在资产白名单中的未知资产接入，典型的案例就是目前越来越普及的移动设备，它可以实现在一个区域内跨越所有物理的逻辑的边界以及防御措施，直接连接到受保护网络。这种情况可能是无害的，也可能是蓄意破坏的，无论哪种情况都应该在资产白名单技术的使用下，被 ICS 中部署的安全产品检测出来，然后再通过日志或者其他管理手段通知到责任人或者直接进行行为干预。

值得注意的是，针对资产白名单中出现的所有移动设备，如果其本身具备类似于 3G 和 4G 蜂窝网的接入能力，会绕过所有 ESP 的防御措施将系统彻底暴露在网络中，所以对于此类资产的配置需要格外谨慎。

4. 行为白名单

如同资产白名单一样，应用程序的每一个行为都可以被记录为白名单；同资产白名单一样，行为白名单也需要先进行明确的定义，从而将应用程序的正常业务行为和其他恶意或者无关行为区分开。

根据工业控制网络协议的自身性质，大多数的应用行为可以直接通过监控这些协议和解码来确定，其中解码还能确定应用程序的潜在功能代码和被执行指令。也正是因为这个特性，针对使用工控协议的工控业务存在一些内嵌的行为白名单特性。所以在进行行为白名单定义的时候，针对没有使用工业协议的企业应用程序和 SCADA 应用程序需要区分对待。

从表 7-9 行为的定义举例中我们看到，相比基于应用程序或者设备的资产白名单，这是一种更加细粒度、更加贴合业务的定义方式。例如，我们的 AWL 系统允许执行 HMI 应用程序和必要的操作系统进程服务，如果这个时候网络服务需要打开 Modbus 套接字，从而使得 HMI 可以与部分 PLC 和 RTU 进行通信。这个时候 AWL 并不会区分 HMI 应用具体的行为，所以 HMI 可以顺利地与 PLC 和 RTU 进行任意通信。如果此时系统内部有人恶意操作，如关闭关键系统或者随意修改设定点，即便部署了 AWL 系统仍然可以很容易地通过 HMI 实现。但是，针对可以基于网络行为进行区分的行为白名单系统，根据预定义好的授权命令行为白名单与之比较，就可以很容易地发现这些恶意操作和行为，从而将其通知给管理人员或者直接阻断。

表 7-9 不同网络系统中的行为举例

工业网络	企业网络	混合网络
①仅允许只读的功能代码 ②仅允许从预定义资产来的主 PDU 或者数据包 ③仅允许明确定义的功能代码	①只有编码的 HTTP 网页流量被允许，并且只能通过 443 端口 ②只允许利用 POST 命令进行网页表单提交 ③HMI 应用程序只有在预定义的主机上被允许使用	①只在本地现场总线协议中允许写入命令，并不基于 TCP/IP ②在监控网络中的 HMI 应用程序只允许在 TCP/IP 协议上使用读功能

表 7-10 列出了一些比较常见的行为白名单，以及对应的处理方式。

表 7-10 行为白名单举例

白名单	构建元素	执行元素	违规提示
通过 IP 授权的设备	①网络监控器或者探针（如一个网络 IDS） ②网络扫描	①防火墙 ②网络监控器 ③网络 IDS/IPS	恶意设备正在运行
通过端口授权的应用程序	①漏洞评估结果 ②端口扫描	①防火墙 ②网络 IDS/IPS ③应用程序流量监控器	恶意应用程序正在运行
通过内容授权的应用程序		应用程序监控器	应用程序正在使用违规策略
授权的功能代码 / 命令	①工业网络监控器，如 SCADA、IDS ②梯形逻辑、代码审查	①应用程序监控器 ②工业协议监控器	流程操作超出策略
授权的用户	①目录服务 ② IAM	①访问控制 ②应用程序日志分析 ③应用程序监管	恶意账户正被使用

7.3.4 关联分析技术

1. 智能列表

智能列表的概念在“2010 欧洲 SCADA 与过程控制峰会”中首次提出，其将智能分析的思考引入行为白名单的概念中，从而相结合催生出现在的智能列表概念。我们熟知的黑名单技术阻断恶意行为，白名单技术只允许合法的行为，而智能列表则基于白名单和时间轴线，动态地定义了黑名单的内容。

从某种意义上来说，智能列表技术将 AWL 和行为白名单技术进行了延伸。例如，一个关键系统的重要资产使用 AWL 技术阻止恶意程序的非法执行，一旦有未得到授权的应用要在系统中运行访问关键资产，就会被 AWL、资产白名单模块发现并告警。以往我们只能确定这是一个不被允许的应用行为，但是此应用有可能是被误用在不该应用的地方，这个时候如果直接将其加入黑名单或者拒绝，可能会给其他系统的使用造成影响。对此，有必要使用一种更加智能合理的方法解决此问题。智能列表会对其他白名单使用关联分析，可以

很快地确定该应用程序是否对其他应用是合法的。如果合法,智能列表功能的处理可能仅是一个信息提醒。如果此应用没有被定义为合法,智能列表就会分析其可能为恶意性质行为,在系统中将其定义为恶意应用,然后生成对应的处理脚本,并向安全设备发出控制命令完善黑名单策略。

因此,智能列表是一种基于多种白名单技术和关联比对能力,可以动态调整黑名单安全机制的新型控制方式。这种方式可以在新出现的威胁爆发的时候,第一时间对其进行发现和识别。

2. 事件关联

事件关联是通过大量离散的事件数据并把其作为一个整体,结合时间和实际的场景等客观因素进行综合分析,找到需要立即引起注意的重要模式和事故,从而提高威胁检测方法的手段和能力,发现一些隐藏在正常事件数据背后的异常事件。早年提出此方法进行关联分析的时候,由于数据量庞大,算法模型不成熟,大量的精力和研究都用到了如何减少多余或者重复的数据上。目前,比较新的技术是使用状态逻辑来分析发生的事件流,结合模式识别技术以找到可能的安全问题、故障、入侵和攻击事件^[79]。从某种意义上说,事件关联的灵感其实多来自于人工分析安全问题的方式,目前事件关联技术的发展程度虽然还没有达到可以完全替代人工的程度,但是也已经给人工的安全评估工作提供了很多便利,解决了很多人工做不到的问题。

为了使得状态逻辑变得清晰明确,首先,需要对事件进行标准化处理^[80],这是最重要的一步。其次,将发生的且符合标准化后的事件与一组已知的威胁模型或者关联规则进行比对,一旦发现匹配项,则在对应的状态项下进行标记,一直到所有的规则序列比对结束。每一个事件经过这么一轮比对之后,对应状态项都做好标记,并生成一个特有的状态树。任意多个威胁事件或者模型都能通过一个状态树定义出来。举例如下:

IF [连续输错5次口令] from [同一个源] to [同一个目的] within [5分钟]

这一条规则一共出现了4个条件项,每一个条件项就是一个标准化的事件,它们就能作为一次二叉树进行分裂。一个实际发生的业务在匹配所有标准化事件的时候,会逐一比对,当所有的标准化事件都比配成功之后,就会触发事件关联结果,做出对应的响应机制。

这里较为复杂的一个问题就是事件的类型和来源较多,可能来自于交换机、防火墙、HMI等,所有这些关联设备发出的事件要能拿来当作一个条件项,就要将它们所有的事件状态树放到同一个事件分类的框架中进行标准化。这样即便原始的日志信息或者数据格式不同,也可以将其相互关联起来进行分析,避免了因为标准不统一而需要添加的额外规则和复杂分析方式。表7-11为事件关联举例。

表 7-11 事件关联举例

威胁模式	描述	规则
暴力破解	快速进行大量随机或者有序密码的猜测尝试，以便成功得到一个已知用户密码	例：大量登录失败事件发生的同时还有一个或者多个同源登录成功或失败的事件
出站垃圾邮件	计算机发送大量垃圾邮件到外部地址	例：一个内部地址短时间内发出大量出站SMTP事件，或者向一个地址发送大量邮件的行为
HTTP 命令和控制	在 HTTP 中隐藏的信道，用来作为恶意软件的命令和控制通道	例：非 HTTP 服务器发出的 HTTP 流量
隐蔽的僵尸网络、命令和控制	恶意软件的分布式网络，在被防火墙和IPS策略允许的应用程序上建立隐蔽的信道	例：大量从 \$ControlSystem_Enclave01_Devices 到 !\$ControlSystem_Enclave01_Devices 的流量，其内容包含 Base64 编码

为了达到更好的未知威胁分析效果，我们需要增加关系设备的数据项，增加标准化事件的类型，增加已知威胁的二叉状态树模型。另外，我们结合事件关联的思路，也可以将每一个标准化的事件项作为关键词再进行一次关联事件的补充，这种方式我们可以称其为标准化数据补充。例如，同一个源 IP 地址连续 5 次输入错误口令，这个时候我们的标准化事件只有两项，即“同一个源 IP 地址”和“连续 5 次输错口令”，在一定程度上可能可以说明这个源 IP 存在一定风险，有可能是一个潜在的未知威胁，但是因为信息太少没有办法作进一步的分析和增加这个分析结果的可信度。其实只要再做一个动作，即便没有任何新的事件的增加，仍然能够让我们做更深入的分析，我们可以使用已知的这个源 IP 作为关键词，在现有的所有事件日志中进行一次查找，筛选出这个源 IP 的其他标准化事件信息作为补充。不过这种标准化数据补充的方式有一些局限性，需要提前分析并过滤掉，例如，还是这个源 IP，如果内网是一个 DHCP 的环境，那么在超过本次 DHCP 地址分发时间前后的事件可能就没有价值了。

(1) 多源关联

跨数据源的多源关联是指将关联扩展到多个数据源，从而使多个不同系统中的事件信息可以进行标准化处理并关联到一起，从而使得在单个系统中可能无法发现的问题，在汇集多个系统信息之后变得容易分析和处理。在关联方式和分析方法合理的前提下，能够关联起来的信息类型越多，威胁检测的有效性就越高，误报也会越少。

表 7-12 为单一数据源和多数数据源关联举例。

表 7-12 单一数据源和多数数据源关联举例

单一数据源关联举例	多数数据源关联举例
在多个登录失败之后伴随着一个或多个成功登录	关键资产的管理员用户账号发生多次登录失败的情况，且在不久的一段时间后又出现了一次或者多次成功的登录
所有到关键资产的成功登录	一般权限的终端用户或者在非工作时间内的管理员用户对关键资产系统的成功登录
HTTP 流量来自于一个不是 HTTP 服务的流量	HTTP 流量来自于境外的陌生地址，且为非 HTTP 服务器

随着现在 ICS 中系统数量的增多，理想状态就是所有系统的监测信息都可以进行标准化处理然后关联起来。

(2) 分层关联

分层关联指的是一个关联规则关系中嵌套另一个关联规则。例如，针对一个暴力破解尝试的事件就有可能有表 7-13 中列出的几种不同递进关系。

表 7-13 为分层关联举例。

表 7-13 分层关联举例

威胁模式	规则
暴力破解	从同一个源地址发起多次的失败登录尝试，后续又出现了一次或多次成功登录事件
暴力恶意软件注入	从一个源地址发起多次的失败登录尝试，后续又出现了一次或多次成功登录事件，接着又出现了一个恶意软件事件
内部传播后的暴力破解	从一个源地址发起多次的失败登录尝试，后续又出现了一次或多次成功登录事件，接着又出现了来自相同源地址的网络扫描事件
使用已知密码的内部暴力枚举	从同一个源地址发起多次的失败登录尝试，并且每一次都是同一个用户名不同的密码

分层关联的分析方式针对攻击溯源以及时间关联性。

3. 系统关联

对于关联分析技术之前的内容都是基于 IT 网络环境中的应用展开的，然而，对不同系统环境之间进行关联分析也是有必要的，因为大量的安全事故或者入侵事件并不会局限于在一个层面或者系统中进行，基本都会考虑多系统、跨层通信、渗透入侵的方式。这样我们就有了一种相比于一般事件关联上升了一个层次的关联分析方式，即系统关联。

这里主要介绍的是将 IT 系统中的事件与工业控制系统中的众多指标和业务进行相关联，因为 IT 与工业控制系统的不一致对于这类关联分析技术提出了很大的挑战，需要使用不同的工具针对不同系统中的信息构造特有的信息收集模型。针对 IT 系统的关注点主要是性能和安全性，而工业控制系统则更多侧重于过程的效率和性能，表 7-14 根据几类常见的事故进行了举例。

表 7-14 系统事件关联举例

事故	IT 事件	工业控制系统事件	条件
网络不稳定	延迟变大，ttl 值变化频繁，tcp 字段异常，坏包变多，接收窗口变化频繁等	效率变低	①运行过程中网络条件的表现 ②蓄意的网络破坏
操作变更	没有发现异常事件	运行设置点或者其他过程发生变化	①良性的过程调整 ②未检测到网络破坏

(续)

事故	IT 事件	工业控制系统事件	条件
网络破坏	事件关联检测威胁或者事故, 以确定是否对 IT 系统成功地进行了渗透	运行设置点的变化, 或者其他业务过程的变化	(1)良性的过程调整 (2)未检测到网络破坏
目标事故	检测威胁或者事故, 直接针对连接 IT 系统的工业 SCADA 或 DCS 系统	运行设置点的异常变化, 预期之外的 PLC 代码写操作等	潜在的 APT 事故或者破坏

需要引起重视的是在 IT 系统中的良性行为或者仅在工业控制系统中正常的业务过程也有可能影响系统运行, 在 IT 和工业控制系统中可能存在大量隐藏在正常业务行为模型下的潜在威胁, 我们通过关联 IT 与工业控制系统条件, 可以得到发现潜在网络事故的恰当方法^[81]。

系统关联技术需要解决的一个重要问题就是如何将需要的工业控制系统数据收集到已经比较成熟的 IT 系统中的 SIEM 中, 然后再将针对这部分特有的关联维度进行威胁分类和威胁参量的标准化。

7.3.5 蜜罐技术

蜜罐 (Honeypot) 首次出现在 Cliff Stoll 的小说《The Cuckoo's Egg》(1990) 里, “蜜网”项目组给出的定义是: 没有业务上的用途, 因此所有流入 / 流出蜜罐的流量都预示着扫描、攻击及攻陷, 主要用以监视、检测和分析攻击。它用真实的或虚拟的系统模拟一个或多个易受攻击的主机, 给入侵者提供一个容易攻击的目标, 从而发现攻击者采用的手段, 蜜罐系统一般位于屏蔽子网或者 DMZ 中的主机上, 本质是用于试图引诱攻击者, 而不是攻击实际的生产系统。

蜜罐的价值在于可以捕获、发现新的攻击手段及战术方法, 也就是针对未知的新型威胁最直接的发现武器。同时由于其目的性强, 捕获的数据价值高, 误报和漏报的情况极少, 对于大多数应用场景来说是一个非常有利的未知威胁发现工具。目前, 也有很多针对工控领域使用蜜罐实现沙箱功能的研究进展, 典型的工控沙盒是一个模拟各种 ICS/SCADA 的蜜罐设备, 可以与互联网连接或者只是在本地与真实的 ICS 连接, 蜜罐中包含了 ICS/SCADA 系统的典型安全漏洞, 蜜罐设备本身可以是锅炉的冷却控制系统, 也可以是一个水站的压力控制系统等。

蜜罐的核心技术主要包括三部分: 数据捕获技术、数据控制技术以及数据分析技术。其中数据捕获和分析技术与本书中提到的其他安全技术方案处理方式类似, 并无明显区别。

- 数据捕获技术: 数据捕获就是在入侵者无察觉的情况下, 完整地记录所有进入蜜罐系统的连接行为及其活动。捕获到的数据日志是数据分析的主要来源, 通过对捕获

到的日志进行分析,发现入侵者的攻击方法、攻击目的、攻击技术和所使用的攻击工具。一般来说,收集蜜罐系统日志有两种方式,即基于主机的信息收集方式和基于网络的信息收集方式。

- 数据分析技术:数据分析就是把蜜罐系统所捕获到的数据记录进行分析处理,提取入侵规则,从中分析是否有新的入侵特征。数据分析包括网络协议分析、网络行为分析和攻击特征分析等。对入侵数据的分析主要是为了找出所收集的数据哪些具有攻击行为特征,哪些是正常数据流。分析的主要目的有两个:一个是分析攻击者在蜜罐系统中的活动、关键行为、使用工具、攻击目的以及提取攻击特征;另一个是对攻击者的行为建立数据统计模型,看其是否具有攻击特征,若有则发出预警,保护其他正常网络避免受到相同攻击。

蜜罐根据系统功能的区别可以分为产品型蜜罐和研究型蜜罐,根据交互程度的区别可以分为低交互蜜罐和高交互蜜罐。虽然蜜罐技术具有能够有效发现未知的新型威胁,且误报率和漏报率低的优势。但是其使用维护成本高,需要较多的时间和精力投入,没有办法直接防护攻击,并且在伦理上也遭受到其为诱使攻击的批评。

蜜罐技术的发展是伴随着各种不同的观点而不断地成长的。蜜罐技术通过诱导让黑客们误入歧途,消耗他们的精力,为我们加强防范赢得时间。通过蜜网可以让我们在受攻击的同时知道谁在使坏,以及其目标是什么。同时也检验我们的安全策略是否正确,防线是否牢固,蜜罐的引入使我们与黑客之间同处于相互斗智的平台,而不是处处遭到“黑枪”的被动地位。我们的网络并不安全,入侵检测、防火墙、加密技术都有其缺陷性,我们期待它们与蜜罐紧密结合,那将是对未知威胁最有力武器的补充。

7.4 本章小结

本章我们介绍了结合纵深防御体系思想的结构安全防御方法,从整体结构的优化、访问控制技术的使用,防火墙、认证、密码和入侵检测技术的应用等方面作了较具体的介绍,虽然不全面,但是通常我们也将此称为纵深防御体系。针对软硬件系统自身可能存在的设计缺陷和漏洞,介绍了针对漏洞发现和处理的方方式,以及在软件开发阶段考虑安全问题的必要性。结合行为管理和可信计算的内容分别介绍了行为安全和基础软硬件安全的概念和主要内容,对如何从内到外、从里到表地去考虑安全问题提出了一些思路和看法。

本章强调了持续安全运维的重要性,时间因素的变化会带来更多新的安全问题,对此也需要从整体安全建设和运维思路完成对应的解决方案。以上4个技术领域和一个安全

理念的介绍是针对工业控制网络固有的一些特性，结合了信息网络安全建设的思路提出的已知威胁解决方案。

本章还介绍了针对未知的新型威胁被业界广泛采用或者研究的多个技术理论，大家需要重点理解的是异常行为、白名单和关联分析技术，它们同时也是态势感知的技术理论基础。

此外，通过已知威胁安全解决方案结合合理的运维分析就可以实现部分未知威胁问题发现的纵深防御技术，它与做好了陷阱等着别人来跳的蜜罐技术都是被大量实践证明行之有效的解决方案。

7.5 本章习题

1. 结构安全最核心的技术是什么？如何解释？
2. 典型的两种密码体制分别是什么？它们各自的优势和应用场景有哪些？
3. 防火墙和入侵检测技术分别有哪些优点和缺点？
4. 为什么传统网络不适于用行为安全的方式解决安全问题，而工业控制网络可以？
5. 定期进行日志审查的意义是什么？
6. 为什么说解决工控网络中已知威胁的解决方案在某些情况下也能发现未知威胁？这种方式的弊端又是什么？
7. 应该如何定义异常参量和异常行为？两者之间又有怎样的联系？
8. 智能列表是如何实现自动化安全运维的？它是否是一种理想的安全运维解决方案，为什么？
9. 异常行为检测、行为白名单检测和事件关联分析这几种未知威胁分析方法有哪些异同？
10. 蜜罐技术解决未知威胁问题的时候有哪些局限性？
11. 使用 Shodan 搜索所有暴露在互联网上的 PLC 设备。
12. 尝试自己编写 Python 脚本实现 Modbus 协议设备的发现功能。
13. 通过 IPtables 设计一套针对 PLC 访问的 ACL 防护规则，假设 PLC 的 IP 为 10.0.0.101，使用了 Modbus 的以太网协议。



综合案例分析

工业控制系统信息安全事关工业生产运行、国家经济安全和人民生命财产安全，其广泛运用于制造、能源、交通、市政等领域，用以控制生产设备的运行。一旦工业控制系统信息安全出现问题，将给工业生产运行和国家经济安全带来重大损失。目前，工控网络安全形势十分严峻，工业控制系统急需得到安全防护。限于篇幅，本章仅以先进制造、城市燃气、石油化工这三个典型行业为例，分别从工控安全分析及行业解决方案两大方面对各行业进行有效分析，并根据各行业的特点给出切实有效的工控安全防护解决方案整体思路。

8.1 先进制造行业案例

先进制造业是相对于传统制造业而言的，在传统制造业不断吸收电子信息、计算机、机械、材料以及现代管理技术等方面的高新技术成果的基础上，结合当前互联网技术、计算机信息技术、传感器及物联网技术等信息化技术手段，融合研发设计、生产制造、在线检测等产品全生命周期过程，从而实现了产品优质、高效、低耗、清洁、灵活的生产。先进制造业是实现信息化、自动化、智能化、柔性化、生态化生产，取得较好经济收益和市场效果的制造业总称。

8.1.1 先进制造行业工控网络安全分析

随着我国两化融合、“互联网+”、“中国制造 2025”发展战略的相继提出，先进制造

行业大力推进工业控制系统智能化应用,企业生产与管理效率逐渐提升。随着各种信息系统的互联互通逐步完善,工控网与设计网、办公网甚至互联网间信息交互的需求逐渐增强,但由于工业控制系统在建设初期更多的是考虑各自系统的可用性,并没有考虑系统之间互联互通的安全风险和防护建设,使目前的工业控制系统普遍存在安全隐患。

工业控制系统已广泛应用于国内的先进制造企业,主要由各种数控机床、精密测量仪器、PLC 控制器以及与生产相关的管理主机、服务器构成,这些先进的设备在企业生产制造中发挥着重要的作用,其中数控机床在制造业领域得到了非常广泛的应用,是先进制造业的典型代表。

1. 数控制造业的安全现状

数控机床是数字控制机床(Computer Numerical Control Machine Tool)的简称,是一种装有程序控制系统的自动化机床。该控制系统能够逻辑地处理具有控制编码或其他符号指令规定的程序,并将其译码,用代码化的数字表示,通过信息载体输入数控装置,经运算处理后再由数控装置发出各种控制信号,控制机床的动作,使其按图纸要求的形状和尺寸,自动地将零件加工出来。

在我国,高精度加工企业使用的数控机床主要依赖国外进口,核心技术受制于人,大大增加了不可控因素。另一方面,在生产过程中数控系统网络与设计网(或企业网)之间的信息传递越来越多,其中原始且低效的数据“摆渡”方式严重阻碍了智能制造的发展,致使制造业的数控网与设计网(或企业网)互联互通的需求越来越迫切,单台数控机床或独立的数控网络并不利于生产制造企业整体优势的发挥。

在此背景下,数控 DNC 网络得到了普遍的发展。数控 DNC 的发展是以计算机技术、通信技术、数控技术等为基础,把数控机床与上层控制计算机集成起来,从而实现数控机床的集中控制管理,以及实现数控机床与上层控制计算机间的信息交换。它将是现代化机械加工车间实现设备集成、信息集成、功能集成的一种新方法,是车间自动化的重要模式,也是实现智能制造的重要组成部分。但与此同时,数控网络也继承了来自上次传统信息网络的风险,未来迫切需要研究安全解决办法,促进先进制造业数控网络安全发展。

目前我国的先进制造业中,数控网络普遍存在以下几种形态,且各自存在不同程度的安全隐患。

(1) 数控机床未联网

在一些涉密军工生产企业,其信息化的发展进程要求设计网(高密网)和生产网(低密网)禁止互联互通,设计部门开发的数控加工代码只能通过刻光盘或用指定 U 盘拷贝的办法下发到生产车间,使得企业的生产效率大打折扣。有的企业设计部门与生产车间相隔数

十公里,这种原始的信息传递模式使得企业生产效率极其低下,而且“摆渡”介质的安全风险不好控制,存在丢失与泄密隐患。

(2) 数控机床与管理主机直连

管理主机与高端数控机床以直连的方式进行数控数据传输,其加工代码通常使用文件传输协议(File Transfer Protocol, FTP)、网上邻居共享或者私有通信协议传输至数控机床,数控机床通过人机交互(Human Machine Interface, HMI)进行加工操作,修改后的加工代码将以文件的形式返回管理主机。在此过程中,管理主机存在操作权限滥用、乱插 USB 外设等操作隐患,存在被病毒感染或误操作使加工数据被篡改的风险。另一方面,管理主机可通过 USB 口连接上网外设而导致其直接暴露在互联网上,存在数据泄密等诸多安全隐患。同时,也有设计部门与生产部门相距遥远,加工数据“摆渡”介质的安全问题,存在丢失与泄密隐患。

(3) DNC(分布式数控)数控机床联网

有些研究机构及企业为提高生产制造效率、实现协同制造已经进行尝试性研究与应用。各机构或企业结合自身实际业务需求,已开始制定数控机床组网保护方案,大部分已向主管部门提交数控机床组网方案申请,甚至开始了数控机床网络与设计网络互联测试。

数控机床联网运行会存在以下安全隐患:

- 管理主机未对 USB 口进行有效的管理,存在违规非法 USB 连接的情况。
- 管理主机缺乏病毒木马的查杀机制,存在管理主机感染木马病毒影响正常生产的安全问题。
- 部分现场工作人员缺乏基本的安全意识,存在使用管理主机安装盗版电脑游戏、炒股软件等行为,存在通过 USB 口连接上网设备进行互联网访问的行为。
- 未采取对工业控制网络区域间进行隔离、恶意代码监测、异常监测、访问控制等一系列的防护措施,很容易一点发生病毒或攻击,影响整个网络连接的主机系统。
- 数控编程局域网未采取有效的保护,任何接入该局域网的设备都可直接访问 DNC 服务器从而下载/上传加工代码,存在加工数据泄密与被恶意篡改的安全风险。
- 缺少完备的工业控制系统安全管理制度和流程,使得部分操作人员不按规定执行导致相关安全问题发生,影响生产质量。如 NC 程序版本混乱时可能导致一批加工部件质量不合格。
- 未对设备及日志进行统一管理,使得相关工控系统事件不能统一收集、分析,不易关联分析设备间的事件和日志,难以及时发现复杂的问题。
- 对外来人员(厂商维修人员)的安全管理不到位,如国外厂商很容易直接进入涉密区域。

2. 数控机床安全趋势分析

国家提出的两化融合、“互联网+”与“中国制造 2025”的发展战略，为企业科技发展指明了方向，制造企业将充分利用互联网、物联网以及信息化等先进技术，全面整合制造业资源，形成协同制造、智能制造的产业新格局，在此背景下，数控机床的安全发展主要体现在以下两方面：

1) 制造企业进一步推进加快数控机床联网建设与运行。

面对制造企业发展的需要，结合国家战略规划，行业主管部门将加快数控机床联网业务研究与数控网络安全标准制定，加快制造企业数控机床网络的建设，规范数控网与设计网的互联互通与边界防护，加强数控网络信息安全风险管控能力与应急处置能力的建设，为制造企业两化融合发展提供必要的信息安全保障。

2) 全面完善制造企业协同制造、智能制造的技术路线，推进制造企业变革与科技创新能力建设

随着行业主管部门与制造企业对协同制造、智能制造领域的理解与认知的不断深入，以及物流、材料供给等相关行业信息化水平的逐步提高，制造企业将逐步实现与上游生产订单商、下游物流商、材料供给商等建立网络互联互通、信息服务、数据交换与共享机制，形成更加广泛的协同制造与智能制造的产业新格局。制造企业的设计网、生产数控网将更加开放，内容更加多元化，与此同时，其信息安全防护要求将更高，信息安全防护的纵深化、体系化建设需求更加明显，制造企业将加强对全网安全风险的感知、预警、防控与协同处置的安全防护能力建设，实现新形势下的安全防护体系建设，为制造企业实现信息化、数字化应用提供信息安全保障。

8.1.2 先进制造行业工控网络安全解决方案

国内关键的数控机床及数控系统产品大量应用国外产品，安全受制于人，重要数控系统成为敌对势力渗透攻击的目标。我们必须要有针对性的防御措施，进行数控机床的安全防护是非常迫切和必要的。

1. 需求分析

随着国内经济的高速发展，“中国制造 2025”已经成为当前制造业的发展方向。制造企业通过更新换代数控加工技术与装备，引进新的生产模式来不断改进自己的生产工艺，提高生产效率和效能，虽然还没有达到智能制造的程度，但也在逐步部署 DNC 网络来提升数控机床的利用效率，快速发展的同时，也带来新的安全需求。

数控机床在设计之初是为了精确工艺，提升生产力，实现高效的业务生产功能，其自

身的安全防护能力普遍偏弱，再加上我国制造业的高端数控机床依赖进口，数控系统安全存在不可控因素。在此背景下，数控机床自身的安全隐患，以及数控网络的安全风险备受用户关注，如图 8-1 所示为数控安全风险示意图。

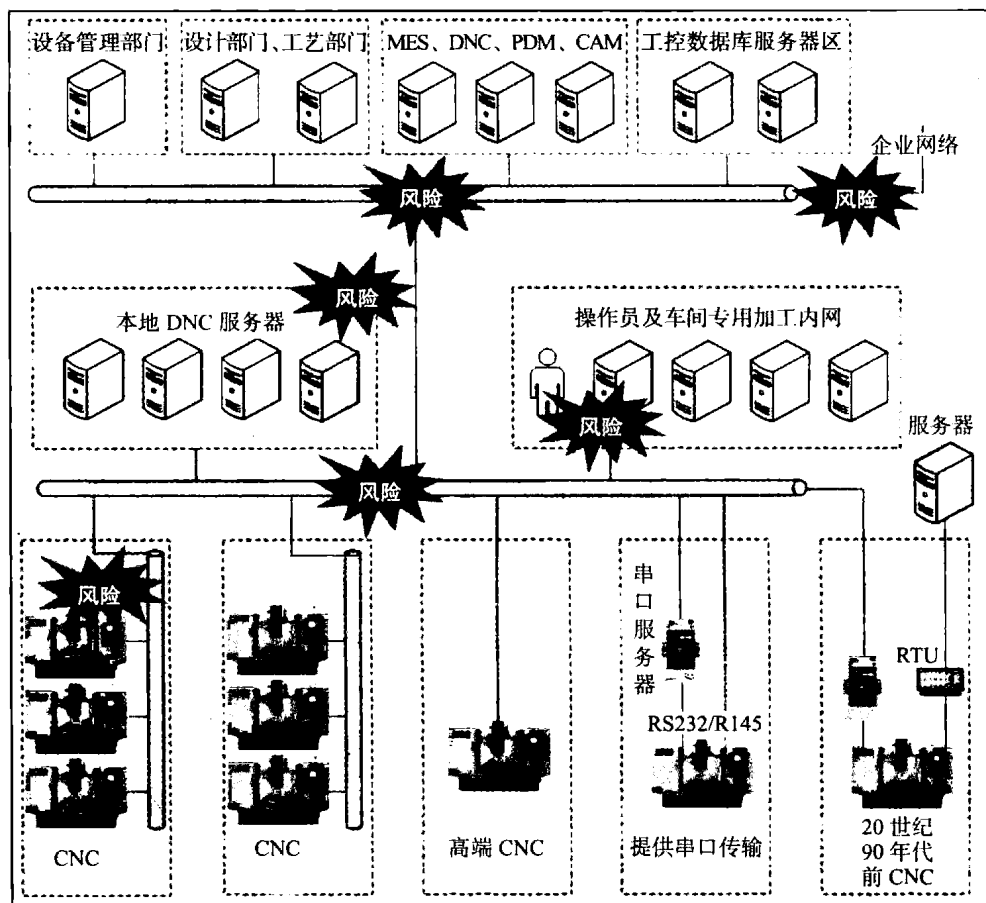


图 8-1 数控网络安全风险分析示意图

下面是常见的数控网络风险。

(1) 数控设备自身存在安全隐患

目前，在中国高端数控设备的应用市场中，以国外设备为主，设备自身存在的后门、漏洞等安全隐患是制造企业在生产和维护过程中无法自主可控的。

在中国高端数控机床 CNC 系统应用市场中，主要是国外品牌发那科 (FANUC, 日本)、西门子 (SIEMENS, 德国)、海德汉 (HEIDENHAIN, 德国)、马扎克 (MAZAK, 日本)、HAAS (美国) 占据主导地位。另外，大量国产数控机床品牌的 CNC 系统 OEM 了日本 FANUC 的 CNC 系统。

在中国精密测量仪器应用市场中，主要是国外品牌占据主导地位，海克斯康（Hexagon，瑞典）市场份额占55%，蔡司（ZEISS，德国）市场份额占20%，无法自主可控，系统设备存在预留后门的安全风险。

大型先进制造企业使用的是国外 DNC 系统，有美国的 Predator 或丹麦的 CIMCO，这两家公司的解决方案和软件占据了国内超过 90% 的 DNC 解决方案市场，DNC 系统存在的安全漏洞、后门也是无法自主可控的。

（2）滥用 USB 设备导致非法外联、病毒感染与数据泄露

众多企业在生产和维护过程中，对于数控机床和测量仪器以及管理主机均存在滥用 USB 设备的情况，其中包括各种类型的智能手机、非密 U 盘，部分主机甚至非法连接无线上网卡。智能手机可通过 3G/4G 移动网络连接外网，智能手机连接计算机后，只需进行对应的设置即可将智能手机的网络共享给管理主机使用。无线上网卡更是可以直接为计算机提供连接外网的途径。这些情况对于不应外联的现场数控生产环境而言，会导致对网络边界安全防护的失控，是巨大的安全风险及泄密隐患。滥用 USB 设备也存在“摆渡”病毒、“摆渡”数据，致使数控系统主机被病毒入侵而破坏、加工数据被非法复制而出现泄密事故等重大安全风险发生。

（3）数控网络缺乏必要的安全防护影响安全生产

DNC 网络缺乏必要的限制，DNC 服务器使用如 FTP 服务、Windows 网上邻居共享、私有协议等方式进行数控加工代码等数据的共享，缺乏必要的访问控制和身份验证，任何接入该网络的主机皆可访问 DNC 服务器，并进行加工代码下载/篡改等行为，可造成严重的数据泄密事件与安全生产事故。

（4）数控设备数据传输缺乏安全防护机制，容易导致数据泄露

大量的数控设备采用了 FTP 协议进行加工代码传输，而机床的账号口令均使用了不足 8 位长度的弱密码，存在被短时间内暴力破解 FTP 密码而发生数据泄露的隐患。当然也有些甚至部分数控机床的 FTP 服务器开放了匿名读写权限，无须任何用户名和口令即可登录并进行任何级别的文件操作（上传/下载/删除/修改），一旦被不法分子利用，也会造成重大的安全事故。

（5）数控管理主机缺乏对病毒的有效检测及防护机制

由于数控设备管理主机多数相对独立，不与外网直接连接，缺乏包括病毒防护、主机安全管理在内的安全机制，导致管理主机通过 USB 口或者内部网络而感染计算机病毒，如果感染了特定的病毒或木马，将可能在全厂范围内进行传播，从而导致严重的数据泄露事件，同时病毒或木马对主机的侵染也会直接影响正常生产业务。

(6) 人员的安全意识和技能不足

由于数控设备使用环境相对封闭，使用人员侧重关注生产工艺的提升，而缺少对网络安全知识的关注，使得相应的人员缺乏必要的网络安全防护意识和技能。

2. 解决方案设计

数控制造业整体安全防护方案是完全针对数控的特点、专业性、复杂性、稳定性进行设计的，以分区分域保护、安全加固、安全监测、审计保护、服务器和上位机防护为重点，为数控网络提供了全方位的综合安全防御能力，如图 8-2 所示。

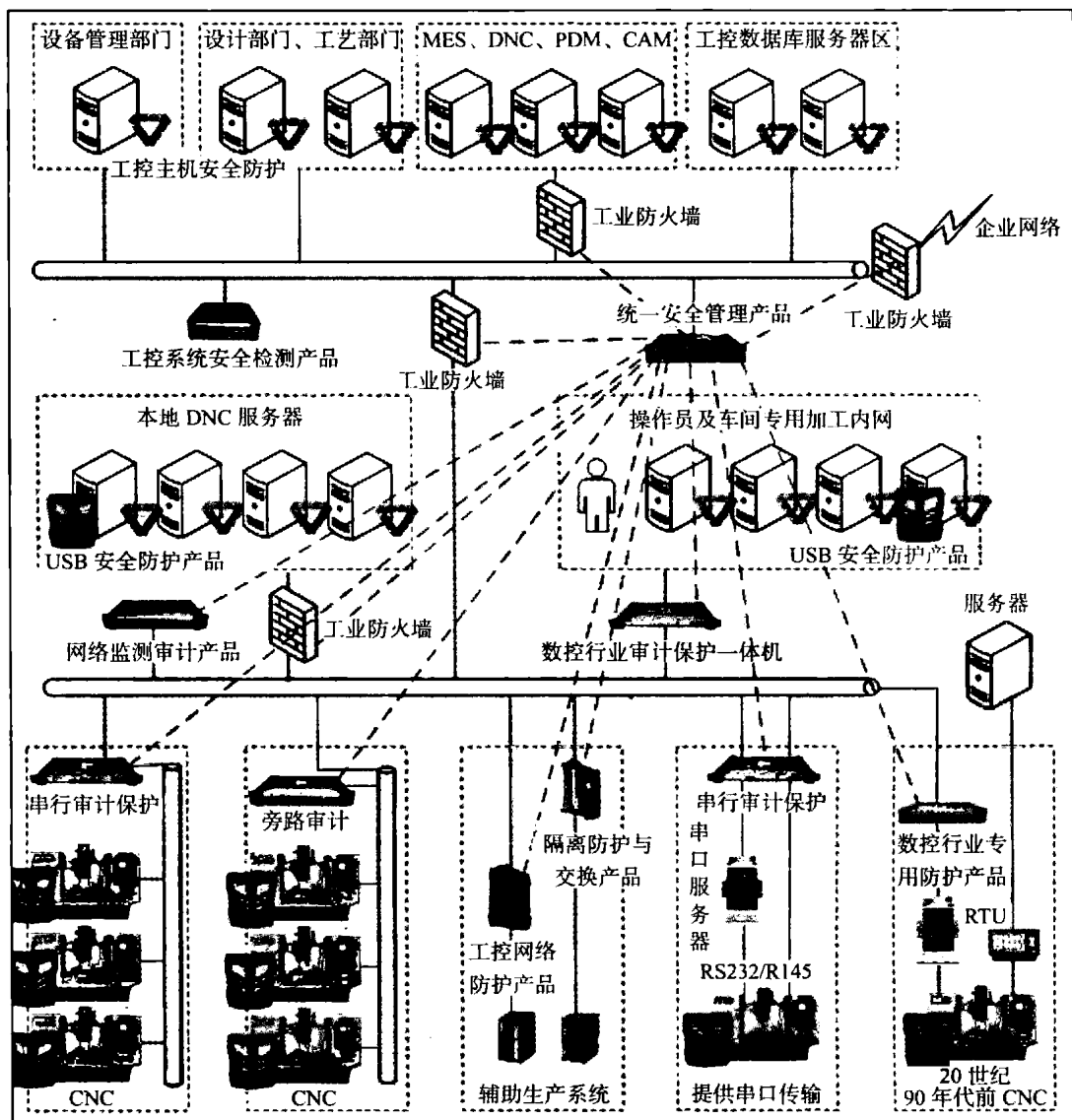


图 8-2 数控网络分层安全防护图

制造企业工业控制系统网络由于受各种因素影响,没有智能工厂集成度那么高,所以需要根据智能制造网络发展趋势结合制造企业现状进行安全设计。下面从数控网络结构安全、行为安全、本体安全、基因安全4个维度开展数控网络安全防护方案的实施,以满足数控网络安全防护的需要。

- 数控网络结构安全——梳理业务流程,优化数控网络结构,强化分区、分域防护,通过在安全域边界选择串行部署数控行业审计保护一体机、工控网络防护系统、隔离防护与交换产品,以保障数控网络结构的安全。
- 数控网络行为安全——加强数控网络访问行为、访问内容的监测,对异常行为、违规操作进行监测、审计与告警,借助与边界安全防护设备联动,支撑行为安全防控,提升数控网络安全。
- 数控网络本体安全——按照数控网络的应用特点,加强数控设备、上位机、服务器等主机安全管理,通过选择部署工控主机安全防护,USB主机防护设备专用安全产品实现主机的安全管理,包括主机防病毒、防第三方软件非授权安装,外界USB存储设备认证管理、操作行为审计,保护主机应用安全与防止数据泄密。
- 数控网络基因安全——以自主研发、可信计算为设计思路,在高端制造领域未来时机成熟时,可通过采购国产数控设备、网络设备和安全设备,规避国外厂商的后门风险。基于可信软件、可信芯片和可信网络技术,并结合数控网络业务模型,构建具有可信计算环境、可信存储环境和可信通信环境的基因安全数控网络系统。

3. 方案所解决的安全问题

数控网络安全方案涵盖了多种高端数控机床、精密测量仪器的组网场景,采用数控网到端点的逐级深度防御,适应国内高端数控机床、精密测量仪器的实际组网结构,具备了专业的适应性和拓展性。

安全防护方案采用智能主机白名单和网络黑白名单技术,具有实时识别移动USB设备的接入、非法的网络连接、移动设备笔记本电脑和移动智能终端的接入、恶意病毒木马、非工作范围软件入侵主机系统的特点,采取数据加密、内容识别、网络流文件还原和命令还原技术、基于数控行业主流设备通信协议深度数据包提取解析的智能学习技术、详细审计日志、网络操控行为识别与控制等多种技术手段,为用户提供了针对性的防入侵、防泄密手段以保障加工数据的安全。

此方案以高端数控机床的加工数据资产为焦点,以数据泄露风险为驱动,依据用户机床的加工数据,结合加工上位机应用程序的特点与具体应用场景,防止数据泄露并在复杂DNC网络中加入具备威胁智能识别和阻止能力的智能防护装置,实现了主动防御来自组网

结构外部的威胁源攻击的能力。同时实现了对 USB 口外界存储设备进行认证管理,对文件复制行为进行审计,预防了操作人员非法复制操作导致的加工数据泄密。

8.2 城市燃气行业案例

城市燃气因其使用的便利性,在现实中已得到了非常广泛的应用,目前绝大部分城市均已实现燃气的大规模使用。新建的住宅已基本实现燃气覆盖,除此之外,很多小区也通过管网铺设实现了管道燃气接入。

8.2.1 城市燃气行业工控网络安全分析

随着燃气行业的快速发展,尤其是天然气管道化的普及,燃气运行安全应当引起我们的高度重视。没有安全,燃气企业发展就无从谈起,燃气安全稳定运行才是燃气企业发展的前提。

1. 城市燃气行业的安全现状

城市燃气随着业务的飞速发展人力成本的上升、管网的不断变长以及复杂化,原有的燃气工控系统的“监而不控”方式已经无法适应,原有的手工巡检和抄表方式已经开始制约燃气系统的业务发展,城市燃气智能管网技术的发展成为未来发展的趋势,智能管网技术指利用传感器、嵌入式处理、数字化通信和 IT 技术,将管网信息集成到管道公司的流程和系统,使管网可观测(能够监测所有主要设备的状态)、可控制(能够控制所有主要设备的状态)和智能化(可自适应并实现智能分析策略),从而打造更加安全、环保、节能、经济、供需平衡的管网系统。城市燃气的工控系统技术发展已经呈现以下几种趋势。

(1) 城市燃气管网调控智能化

城市燃气管网调控的智能化、自动化随着城市燃气行业的发展不断提高。输气管网系统已由最初的独立干线向集群管网方向发展,其输送过程将越来越复杂。及时、全面、准确地掌握整个管网的动态情况将是保障燃气安全平稳输送的重要手段和措施,这些都为管线运行的调控提出了更高的要求。一方面,智能化管道建设发展对自动化程度提出了更高的要求,要求其控制系统在控制、安全等方面有更高的可靠性、开放性;另一方面,调度和控制向着智能化方向发展。

(2) 物联网技术广泛应用

智能管网技术离不开物联网技术,其中就包括网络无线射频识别(RFID)系统——把所有物品通过射频识别等信息传感设备与互联网连接起来,实现智能化识别和管理。目前

国内外企业就是使用 RFID 技术并将其应用在设备及备件采购、仓库管理、设备维修等方面。而无线定位技术在现有 GIS 的深层利用下,结合智能手机技术,开发便携式无线手持终端,所以它在无线巡检、厂区定位等方面会有更好的发展。另外可佩戴气体传感器的应用,可以进一步提高城市燃气管道现场检修人员的生命安全保护能力以及应急抢救能力。

将物联网技术应用于城市燃气管道设计、建设、运营、维护和管理的全过程,有利于促进管道的完整性管理和失效控制,提高管道运行的安全性和经济效益。

(3) 智能仪表将广泛应用于智能管网中

作为智能管网的数据采集和业务执行的端点,智能仪表的采用是确定城市燃气是否真正智能的标识之一,智能仪表内置微处理器,具有一定的运算处理能力和精确的测量能力,一般具有四大特点:输出信号精度高、运算能力强、通信功能强、安全性较强。

(4) 云计算将应用于城市燃气 SCADA 系统

在智能管网的计算平台中,云系统可以应用在 IT 基础设施、信息集成、分析应用等多个方面,它可以降低信息化的成本,提高 IT 的灵活性和支撑能力。随着云计算技术的发展,IT 资源的应用和共享方式发生了巨大的变化。企业私有云为智能管网数据集成与业务集成提供基础性服务,用来解决目前国内企业信息化中普遍存在的数据孤岛和业务隔离现象,包括可以建立共享数据中心或者云服务平台。

2. 城市燃气行业安全趋势分析

最初城市燃气工控网络安全技术在利用信息化升级改造的过程中,尝试使用用于传统 IT 环境的信息安全技术来解决工控网络的安全问题,然而问题并没有得到很好的解决,其中最主要的原因就是传统的信息安全技术不适用于城市燃气的工业控制环境,这包括以下几点:

- 城市燃气工控网络使用的并不是传统的 TCP/IP 技术,而是工业以太网技术,在安全性和可靠性方面都与传统的网络技术存在差异。
- 站控系统环节,尤其 PLC 和 RTU,甚至包括智能仪表,其多使用嵌入式操作系统,业务相对单一,无法采用传统的植入安全软件的方式保护工业控制网络。
- 城市燃气的工控系统多为国外厂商所垄断,由于协议约定的原因很难部署国外厂商非授权的安全产品。
- 多数城市燃气公司在部署工控系统时采用的是“监而不控”的技术,工控系统只采集数据,不直接对管网进行控制,而是通过派发工单,由人工方式进行现场操作,而且网络相对独立,所以轻易不会感染病毒,同时哪怕系统遭受攻击,可以很快使用手工方式来保障运行的安全。

- 城市燃气公司普遍信息安全意识薄弱，对网络安全的重要性认识不足也是原因之一。
- 随着智慧城市的建设以及智能管网技术的兴起，城市燃气公司的发展逐渐由封闭走向开放，原有的“监而不控”即将成为历史，但是处在开放的环境以及脆弱的防护体系下的工控系统，其工控网络安全呈现新的态势。
- 城市燃气的工控安全技术必须要适应企业的工业网络环境，包括能够解析工业网络协议、深度解析数据包和自我智能学习的能力。
- 城市燃气的工控系统本身的安全成为未来的主流，既要加强安全自主可控，使用国产工控系统，又要加强自身的安全防护。
- 智能管网最大的特点是实时监控，同时在网络上快速地实现，而且另外一个特点是与企业的信息网络连接，这使其暴露并被威胁的可能性变大，城市燃气公司的业主已经开始意识到必须强化其保护措施。

由于工控安全技术普遍比较复杂，所以对于工控安全产品的要求是：既要能够保护工控系统的安全，也要简单可操作，这对城市燃气的工控安全产品提出了更高的要求。燃气企业可基于上一章的工控网络安全防御技术，结合燃气行业工控网络特点，采取有针对性的防范措施。

8.2.2 城市燃气行业工控网络安全解决方案

工控网络安全防御的核心是以安全管理为中心，故燃气企业的工控网络安全防护单凭技术与部署安全产品是无法得到解决的，一定要从燃气自身业务发展的需要来进行设计，要符合整个企业的治理、风险和合规管理思路。

1. 需求分析

天然气主要工控网络为 SCADA 系统，SCADA 系统在燃气企业用于监测、控制整个现场内工艺设备的运行，保证输气生产安全、可靠、平稳、高效、经济地运行，对管道各站点进行实时工艺状态监视，发布调度指令及各站的气量统计、结算等。该系统可大大提高燃气企业的整体管理能力，加强燃气管网的安全系数，能起到降低企业运营成本的作用。SCADA 系统介绍详见第 2 章。

燃气行业典型网络结构如图 8-3 所示。

主要问题和风险如下所示。

1) 网络隔离不合理：从生产运营网络的角度出发，总部中心的网络除了与办公经营网络相连外，还与下级操作控制层进行联络，同时相应的数据还会直接连接到当地政府的系统中。在这些连接过程中，采用了传统的 IT 防火墙进行防护，但是无法对工控网络做到有

效的防护。另外就是许多控制网络都是“敞开的”，不同的接入网络之间都没有有效的隔离，尤其是基于 OPC、DPN3、Modbus 等通信的工业控制网络，从而造成安全故障通过网络迅速蔓延。

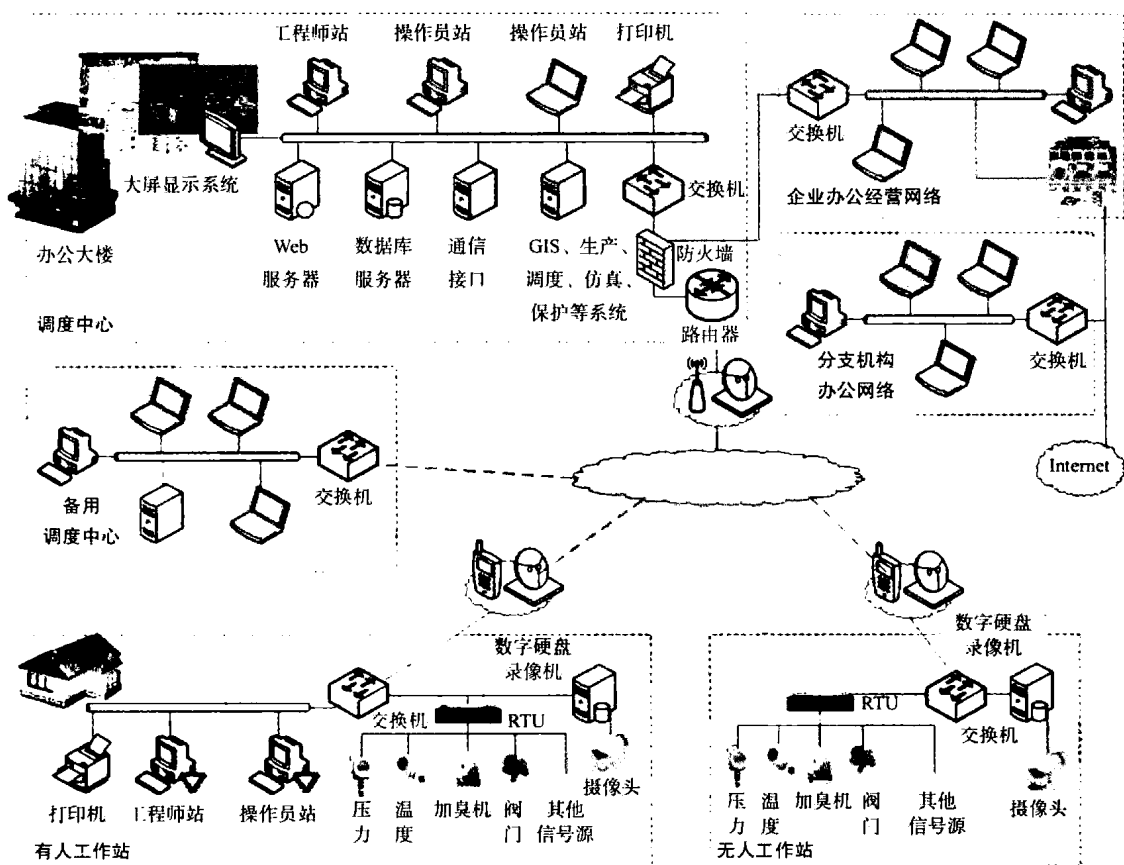


图 8-3 燃气行业典型网络结构图

2) 缺乏审计监测机制：控制中心没有部署安全监控设备，无法及时发现、告警控制网内的非法数据流量和异常操作行为。缺少控制系统安全审计机制。独立的安全审计人员应当定期检查和验证系统日志记录，并主动判断安全控制措施是否充分。未针对其工控系统建立信息安全审计机制，可能造成无法及时发现、追溯系统内部或源于网络的信息安全事件。

3) 工控系统普遍存在漏洞：由于工控系统大多以满足工业生产为前提，并没有太多考虑自身的系统安全问题。

4) 工控系统可能存在国外的“后门”：国内大多工控系统采用了国外的设备和系统，

为了维护方便，国外公司经常会留下维护端口以便于进行远程维护，但是也带来了安全隐患。

5) 缺乏针对工控系统的防护措施：传统的网络安全防护措施很难适应工业控制网络的安全要求，这也是工控系统自身的特点所决定的。

6) 操作人员缺乏信息安全意识：工控系统的操作人员往往不是 IT 人员，而是生产调度人员，这也使得工控终端缺乏传统 IT 的管控，使其成为外部威胁的可能接入点，如 USB 接口、维修连接、笔记本电脑等。

7) 缺乏专业的安全人才：燃气企业的信息化人员不足已经成为公认的事实，而专业的信息安全人员更是缺乏，既懂工控业务又懂信息安全的专业人员可谓是少之又少，这也使得专业的网络安全设备缺乏维护。

燃气企业在分析工控系统带来的风险的同时，也需要考虑工控网络自身的特点，需要识别以下工控网络可能带来的风险：

- 1) 识别影响生命安全的风险，并评价其影响。
- 2) 识别工控事件中可能影响物理设施的风险（爆炸、火灾）。
- 3) 识别可能影响工控流程的物理破坏（管网调度）。
- 4) 评价工控非数字化方面（温度、压力、电压和流量等）的影响。
- 5) 识别影响到保护系统（阴极保护系统）的影响。
- 6) 识别工控系统的级联风险。

从以上分析的这些风险可以看到，工控网络的一部分风险属于传统 IT 网络安全风险，而另外一部分属于工业生产的风险，所以在进行工控网络风险管控的过程中需要一个联合团队来对工控网络风险进行识别和管理，这在国内多数燃气企业是缺乏的。

2. 解决方案设计

燃气行业工控网络安全防护措施的设计遵循“以治理为保障、以风险为导向、以合规为基线”的指导方针来建设工控安全，在具体实施过程中要以“整体规划、分步实施”作为指导原则来建设工控安全体系，具体如下：

1) 组织治理：企业在建设工控安全体系时结合企业的战略目标，明确组织职责、运作机制和流程，建立有效的管理循环，保证企业目标得以实现。

2) 风险管理：从风险背景的建立开始，到开展风险评估工作、进行风险响应和风险监测，建立自上而下的风险管理架构能够帮助企业各个层级明确自身的风险管理职责和风险管理流程，有利于企业认知的信息安全风险。

3) 合规管理：企业通过建立自身控制基线，满足当前对风险控制的要求，同时符合国

家相关法律法规要求以及等级保护要求等,基线的建立除了要满足相关的监管要求外,还需要满足自身企业的业务目标,而这些离不开合规的管理。

燃气企业在两化融合的推进过程中,已经开始从最初的数据采集向“智能管网”方向发展,燃气企业的安全防护既需要考虑当前燃气企业的工控网络安全现状,也需要考虑未来燃气发展的需要。所以在设计安全防护方案时一定要以动态的眼光来对待工控网络安全问题。

根据燃气行业工控网络安全的现状与特点,结合工业控制系统信息安全防护思路,我们对燃气 SCADA 系统进行安全防护体系设计时,应考虑建立全生命周期的解决方案,包含网络隔离、监控审计、主机安全、安全服务 4 个部分,详见图 8-4。

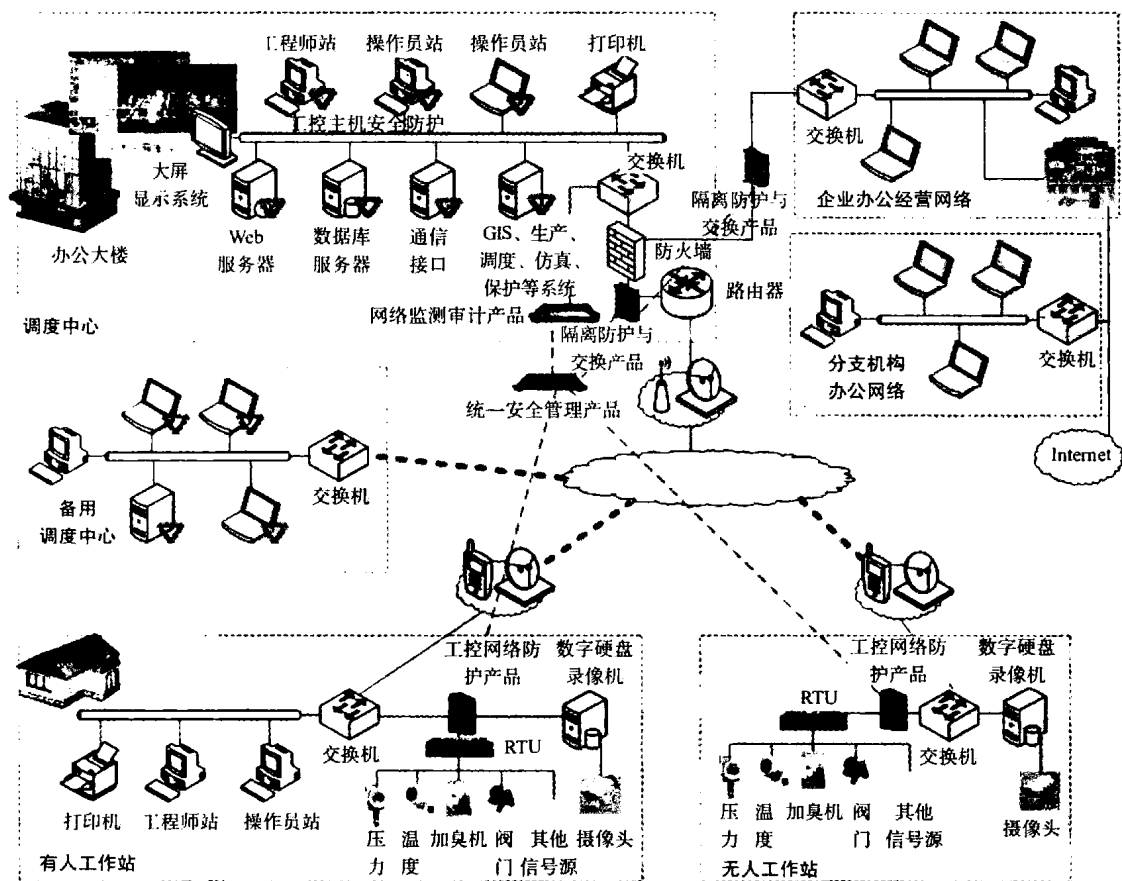


图 8-4 燃气 SCADA 系统安全防护整体示意图

3. 方案所解决的安全问题

对燃气行业工控网络进行安全防护时,为客户提供覆盖工控系统全生命周期的网络安

全解决方案,结合工控网络安全防御技术帮助企业进行整体的安全防御。

通过部署工控网络防护系统对终端 RTU、PLC 进行有效防护,能够通过各种方法快速识别出系统中的非法操作、异常行为以及外部攻击,在第一时间执行告警和阻断。

通过部署网络监测审计产品对网络数据、事件进行实时监视、实时告警,帮助企业实时掌握工业控制网络运行情况;对工控网络中存在的所有活动提供行为审计、内容审计,生成完整记录便于时间追溯;提供直观清晰的网络拓扑图并集成网络告警信息,使企业在了解网络拓扑结构的同时获知网络告警分布,轻松掌控网络状况;根据监视结果,提供防御策略建议,帮助企业构建适用的专属工控网络安全防御体系。

主机安全通过在所有工作站和服务服务器上安装工控主机安全防护软件,禁止非法进程的运行,禁止非法网络端口的打开与服务,禁止非法 USB 设备的接入,从而切断病毒和木马的传播与破坏路径,减少工作站和服务服务器面临的威胁。

由于工控网络的特殊性和燃气行业的特性,单纯依靠安全产品无法满足安全需求,需要配合安全服务工作。燃气工控的安全服务主要针对 SCADA 系统设备 PLC/RTU、网络架构、安全分区、边界安全性、完整性等进行安全检查、漏洞分析和风险评估,对现阶段可行的安全改造与持续性的安全维护提供建议方案,明确采取何种有效措施,帮助企业降低威胁事件发生的可能性,或者减小威胁事件造成的影响,将风险降低到可接受的水平,有效保障企业工控系统网络安全。

8.3 石油化工行业案例

石油、化工是国家的重要支柱产业,除了为各部门提供发展原动力外,石油和化工业本身就是国民经济的支柱产业,其产品在国民经济产业链中占有举足轻重的地位。

8.3.1 石油化工行业工控网络安全分析

随着互联网技术的发展以及石油化工企业集团信息化整合的加强、企业网络应用的范围不断扩大,石化企业普遍采用了基于 ERP/SCM、MES 和 PCS 三层架构的管控一体化信息模型。工业控制网络中大量采用了通用 TCP/IP 技术,PCS 网络和企业信息网的联系越来越紧密。然而,传统工业控制系统采用专用的硬件、软件和通信协议,设计之初基本没有考虑互联互通会带来的通信安全问题。在当前“两化融合”的应用需求下,工控系统开放的同时减弱了工业控制系统与企业信息系统、外部互联网络的有效隔离,工业控制系统与企业信息系统也必然存在数据交互的需求,随之引发的工控系统安全问题就越发明显。

1. 石油化工行业的安全现状

石油和化工业将在国民经济中占据越来越重要的地位，主要体现在以下几个方面：

(1) 为经济发展供应能源

石油炼制生产的汽油、煤油、柴油、重油以及天然气是当前主要能源的主要供应者。目前，全世界石油和天然气消费量约占总能耗量的 60%。石油化工提供的能源主要用作汽车、拖拉机、飞机、轮船等交通运输燃料，部分用作化工生产原料，生产乙烯、丙烯及其下游三大合成材料产品，为各部门发展提供动力。

(2) 支撑材料工业发展

材料工业是各行各业发展的基础，而石油化工则是材料工业的支柱。目前，我国石油化工提供的三大合成材料产量已居世界第二位，合成纤维产量居世界第一位。除合成材料外，石油化工还提供了绝大多数的有机化工原料。我国已是仅次于美国的世界第二大石油、化工产品大国，氮肥、磷肥、农药、染料、轮胎、合成纤维、聚氯乙烯等产品产量已排名世界第一，原油加工、乙烯、合成树脂产量已居世界第二。

(3) 促进农业发展

农业是我国国民经济的基础产业。农、林、牧、渔业主要以消费柴油为主，其柴油消费量占柴油总消费量的 1/5 左右。石油、化工工业还为农业生产提供化肥、农药和农用塑料薄膜。石油、化工工业提供的氮肥占化肥总量的 80%，农用塑料薄膜的推广使用，加上农药的合理使用以及大量农业机械所需各类燃料，形成了石油、化工工业支援农业的主力军。

(4) 为工业部门提供动力

现代交通工业的发展与燃料供应息息相关，可以毫不夸张地说，没有燃料就没有现代交通工业。金属加工、各类机械毫无例外地需要各类润滑材料及其他配套材料，消耗了大量石油、化工产品。建材工业是石油、化工产品的新领域，如塑料型材、门窗、铺地材料、涂料、管材被称为化学建材。轻工、纺织工业是石油、化工产品的传统用户，新材料、新工艺、新产品的开发与推广无不有石油、化工产品的身影。当前，高速发展的电子工业以及诸多的高新技术产业，对石油、化工产品，尤其是以石油、化工产品为原料生产的精细化工产品提出了新要求，这对发展石油、化工工业是一个巨大的促进。

2. 石油化工行业安全趋势分析

石油化工企业是典型的资金和技术密集型企业，生产的连续性很强，装置和重要设备的意外停产都会导致巨大的经济损失，因此生产过程控制大多采用 DCS 等先进的控制系统，DCS 控制系统的供应商主要有霍尼韦尔、艾默生、横河电机、中控科技等。

在早期,由于信息化程度水平有限,控制系统与信息管理层处于隔离状态。因此,石化企业的信息化建设首先从信息层开始,经过十多年的建设积累,石油、化工行业信息层的信息化建设已经有了较好的基础,涉及了石油勘探、开发、炼油、化工、储运、销售、数据管理等诸多研究领域。随着信息化和工业化两化融合技术的深入发展,企业普遍开始采用基于 ERP/SCM、MES 和 PCS 三层架构的管控一体化信息模型思想,在管理层的指挥、协调和监控能力,上传下达的实时性、完整性和一致性都有很大提升,工业控制网络和企业信息网络的联系越来越紧密,企业在提高公司运营效率、降低企业维护成本的同时,也带来了更多的安全问题。

此外,一直以来企业更多关注的是物理安全、生产安全,对信息化发展所需的安全防护体系建设却相对滞后。近几年来,工业控制系统因感染病毒、网络攻击而引起的安全事故屡有发生,给企业造成了巨大的经济损失。再加上国家关键基础设施的很多核心工业控制系统多采用国外设备,这些设备都存在严重的漏洞和固件后门,核心技术受制于人,增加了诸多不可控因素。

8.3.2 石油化工行业工控网络安全解决方案

石油化工行业在我国经济建设中占据重要地位,长期以来,其发展受到诸多关注,这一行业的高危性使得解决其生产过程中出现的安全问题成为当务之急。

1. 需求分析

在我国石油化工行业中,主要工业控制系统包括分布式控制系统(DCS)、安全仪表系统(SIS)、压缩机控制系统(CCS)、可燃气报警系统(GDS)、各种可编程逻辑器件(PLC)等。现场的主要控制功能都是由 DCS 来完成的,其他系统的集中控制在某种程度上可以完全由 DCS 监控,DCS 含有大量的数据接口,是构建企业信息化的数据来源与执行机构。大型石油、化工企业 DCS 采用大型局域网架构,网络架构较为复杂,通常包含基础控制网、生产网、管理网等。

石油化工企业典型网络结构如图 8-5 所示。

与传统基于 TCP/IP 协议的网络与信息系统的的核心安全相比,我国 ICS 的安全保护水平明显偏低,长期以来没有得到关注。大多数 ICS 在开发时,由于传统 ICS 技术的计算资源有限,在设计时只考虑效率和实时等特性,并未将安全作为一个主要的指标考虑。随着信息化的推动和工业化进程的加速,越来越多的计算机和网络技术应用于工业控制系统,在为工业生产带来极大推动作用的同时,也带来了 ICS 的安全问题。

目前石油化工行业存在的安全风险有如下几个方面。

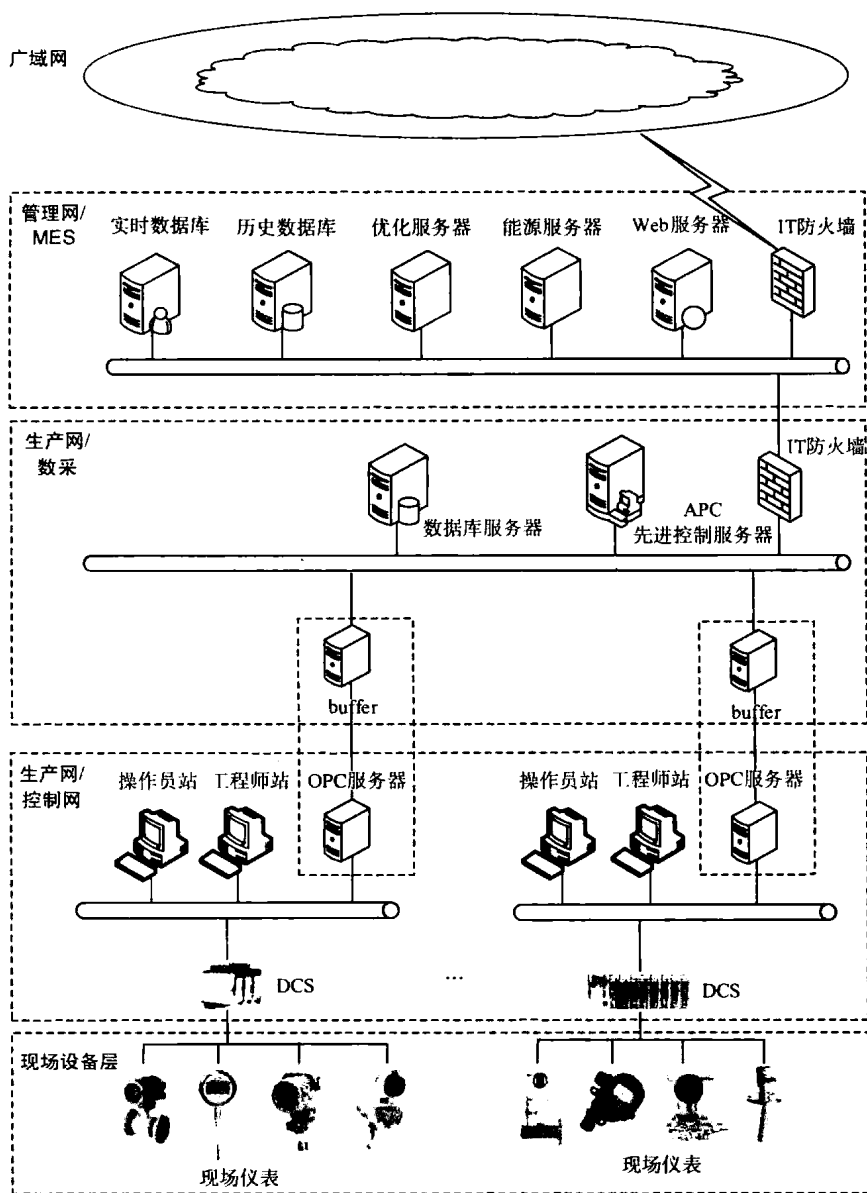


图 8-5 炼化厂生产控制系统的网络拓扑图

（1）通信协议漏洞

随着两化融合的深入发展，使得 TCP/IP 协议、OPC 协议、PC 和 Windows 操作系统等通用技术和通用软硬件产品被广泛地用于石油、化工等工业控制系统，随之而来的通信协议漏洞问题也日益突出。相对于传统 IT 软件，工业控制系统组态软件、PLC 嵌入式系统等在设计过程中主要考虑可用性、实时性，对安全性考虑不足；工控系统通信协议缺乏认证授权和加密、对用户身份的鉴别和认证等安全机制，因此确保工业控制系统的安全性和可

靠性给企业带来了极大的挑战。

（2）操作系统漏洞

在石油、石化行业中，大部分工业控制系统的工程师站、操作员站、HMI 以及服务器都是基于 Windows 平台的。为了保证过程控制系统的相对独立性，同时考虑系统的稳定运行，通常情况下我们的企业不会对这些已经在正常运行的系统安装任何补丁的，这些没有安装补丁的系统就存在被攻击、被入侵的可能，从而埋下安全隐患，为我们企业的安全生产带来风险。

（3）应用软件漏洞

由于应用软件多种多样，很难形成统一的防护规范以应对安全问题；另外当应用软件面向网络应用时，就必须开放其应用端口。因此常规的 IT 防火墙等安全设备很难保障其安全性。互联网攻击者很有可能会利用一些大型工程自动化软件的安全漏洞获取诸如污水处理厂、天然气管道以及其他大型设备的控制权，一旦这些控制权被不良意图黑客所掌握，那么后果不堪设想。

（4）工业病毒

为了保证工业控制系统的正常运行，许多石油、石化等行业的控制系统操作站通常不会安装杀毒软件。即使安装了杀毒软件，在使用过程中也有很大的局限性，原因在于杀毒软件的使用、病毒库的更新等方面。要保证杀毒软件能够及时发现并清除系统中的病毒，除了要让杀毒软件实时、正常运行以外，还必须保持病毒库的及时升级和更新，这一要求尤其不适合于工业控制环境。因为大部分企业的工业控制系统和互联网是不相通的，这就会导致杀毒软件病毒库长期没有更新，无法对新的病毒进行有效检测和清除。病毒的泛滥大家有目共睹，全球范围内每年都会发生数次大规模的病毒爆发，所以石油、石化等行业工业控制系统面临巨大的安全风险。

（5）网络互联带来的安全风险

在企业实际应用环境中，许多控制网络都是“敞开的”，不同的子系统和区域之间都没有有效的划分与隔离，重要系统和数据存在被恶意操作、被破坏等风险。在各控制系统和区域边界缺乏有效的安全审计、入侵监控等策略和机制，无法实时发现和应对来自系统内部和外部的非法访问和恶意攻击。尤其是基于 OPC、Modbus 等开放通信协议的工业控制网络，黑客一旦控制该系统，对系统造成一些参数的修改，就可能导致生产运行的瘫痪，这意味着黑客可能利用被感染的控制中心系统破坏生产过程，切断整个城市的供电系统，恶意污染饮用水，甚至是破坏核电站的正常运行。随着近些年来越来越多的控制网络接入到互联网当中，这种可能性已经越来越大。

(6) 管理流程和安全策略缺失

为了保证生产,只注重系统的可用性而不关心系统的安全,是很多企业存在的普遍现象。一个企业如果缺乏有效的管理制度、管理流程以及相应的安全策略,必然会给企业工业控制系统信息安全带来一定的风险。例如,网络中设备的准入管理、非法外联管理;工业控制系统中外设接入管理,如U盘、移动硬盘等设备的授权使用;各区域、系统之间的访问控制策略等方面,如果没有有效的管理手段和控制措施,势必会给企业工业控制系统以及安全生产带来风险。

随着两化融合在石油和化工行业中的加速发展,石油和化工企业普遍采用了高度自动化的生产技术装备和高度信息化的运营管理手段,极大地提升了生产效率。与此同时,严峻的网络安全风险也如影随形。一旦恐怖组织、商业间谍、内部不法人员、外部非法入侵者利用系统上的漏洞或管理上的疏漏侵入企业生产控制系统,都有可能造成系统停车、机密信息泄露甚至系统的运行被恶意控制等问题。石油、化工这个关乎国计民生的特殊行业,每一次事件都代表着广大人群的生活、生产受到巨大影响,经济遭受重大损失,甚至会直接威胁国民经济的发展和社会的安定。

2. 解决方案设计

我国石油化工业工控网络面临各种风险,仅仅采用被动防御和修补是不可靠的,需要的是整体解决方案。针对石油化工业工控系统的特点,由内而外设计,与工控厂商结合,着眼于健壮性的机制,从石油化工业工控系统“自生长”出来保护方案。如图8-6所示。

组件		工控系统安全服务
①物理环境安全	风险评估与安全管理咨询	安全建议与实施支持
②安全策略与流程		
③安全域划分	安全防护方案	
④安全防护方案	区域隔离和控制	定制化、模块化的安全解决方案
⑤系统安全加固	安全事件管理和分析	
⑥应用安全管理	安全入侵防护	
⑦终端安全加固	应用数据安全加固	可管理的安全服务
⑧持续性风险管理	终端安全、白名单环境	
安全加固、监控与优化		

图 8-6 石油化工业工控系统保护方案

全生命周期的解决方案:

1) 安全覆盖石油化工业工控系统整个生命周期的解决方案。

- 2) 通过多种手段提高石油化工行业工控系统的整体安全性。
- 3) 源自石油化工行业工控系统内部, 并非外部补偿性措施。
- 4) 监测与防御相结合, 产品与服务相补充。

3. 方案所解决的安全问题

结合全生命周期的整体解决方案, 针对石油化工行业提出如下解决方案。

(1) 风险评估服务

对炼化厂生产系统的风险评估应该是制定全面解决方案的前提条件。评估的过程应遵循适度安全、标准性、规范性、最小影响、可控性、保密性等原则, 以国内外相关行业规范为标准, 以专门针对工控系统开发的相关评估工具(威胁评估平台)、漏洞挖掘工具(漏洞挖掘平台)为依托, 开展相关的威胁评估工作。

通过收集的相关资料, 对炼化厂控制系统信息安全进行分析并得出分析结论, 信息安全分析的目标在于发现系统中可能存在的威胁、脆弱点, 其中安全分析分两个方面, 分别是在线分析和离线分析。

1) 在线分析。

- 系统资产评估。炼化厂控制系统资产评估包括资产识别和资产赋值两部分内容, 其中资产赋值需要在对业务系统进行充分了解和分析的基础上进行。资产评估中采用以业务系统为主线的方法, 将每一项炼化厂控制系统资产按照所属业务系统进行归类, 在业务系统划分的基础上评估系统的安全性。
- 系统威胁评估。利用炼化厂控制系统安全威胁列表, 通过现场访谈和观察等方式, 对当前炼化厂控制系统所面临的主要安全威胁进行判定。
- 安全分区合理性评估。参照相关标准的分区要求, 对炼化厂控制系统安全区的划分是否合理、各安全区业务系统网络架构是否合理等进行检查。
- 边界完整性评估。对 PCS 控制层、MES 层、ERP 管理层等各区域之间的边界连接情况进行审核。确定在规定的边界点处没有短路情况。
- 节点通信关系评估。通过对炼化厂控制系统的业务数据流和业务网络结构的审核, 对炼化厂控制系统节点之间通信关系进行分析, 以确定某一安全区中的哪些业务系统功能模块需要同其他安全区进行通信, 以及这些通信间的安全要求。
- 边界安全性评估。对安全区边界点的防护强度、访问控制力度和粒度进行审核, 以确定安全区边界的防护是否符合要求。
- 炼化厂控制系统安全配置核查。对系统中现有的主机配置、数据库配置、控制软件配置、网络配置等进行核查。

2) 离线分析。

离线分析的主要内容分为以下 3 个方面：

- 现场控制设备 PLC、DCS 安全漏洞检测挖掘。
- 检查监控系统软件可能存在的安全漏洞。
- 检查网络设备等网络基础设施可能存在的安全漏洞。

分析的方向分为两点，分别是漏洞扫描和漏洞挖掘，以实现炼化厂控制系统中的设备 PLC、DCS、工程师站、网络设备等进行全面的风险评估。其中，炼化厂控制系统漏洞挖掘工具用于发现系统中可能存在但尚未发现的漏洞；漏洞扫描工具用于检测炼化厂控制系统中是否存在已公布的安全漏洞。

3) 结果分析。

将资产调查、威胁分析、脆弱性分析中采集到的数据按照风险计算的要求进行分析和整理。例如，针对具体的资产，整理脆弱性列表，并进行管理、运营和技术的分析，分析其产生原因和被利用的后果。

通过对炼化厂控制系统各个方面的安全分析、威胁评估、脆弱性评估，可以得到炼化厂控制系统安全脆弱点的分布情况，以及炼化厂控制系统安全防护措施的现状，并提供炼化厂控制系统总体风险评估报告。

4) 安全建议。

根据风险处理计划，结合资产面临的威胁和存在的脆弱性，经过合理的统计归纳，形成安全解决方案建议报告。安全建议报告包括安全建议阶段的所有工作内容，如下所示。

- 需求分析：根据风险分析的结论将炼化厂控制系统的防护需求进行归纳和总结，并根据评估结果进行现状分析、可行性分析和紧迫性分析。
- 安全建议：根据需求分析的结论针对不同评估节点提出安全防护措施。
- 实施计划：根据可行性分析和紧迫性分析结论提出安全建议的实施计划。

(2) 基于产品防护的整体方案

建立在风险评估分析以及对企业现有系统的深刻理解上，提出基于工控安全防护产品的整体防护方案，如图 8-7 所示。

部署说明及意义：

1) 安全管理产品。通过部署安全管理产品，可以实现对整个系统中安全防护设备进行集中监控与管理，完成设备实时信息收集，实时监测终端设备的通信流量和安全事件。

2) 网络审计产品。通过在管理网、生产网旁路部署网络审计产品，通过特定的安全策略，快速识别出炼化企业控制系统中非法操作、异常事件、外部攻击等，并实时报警。

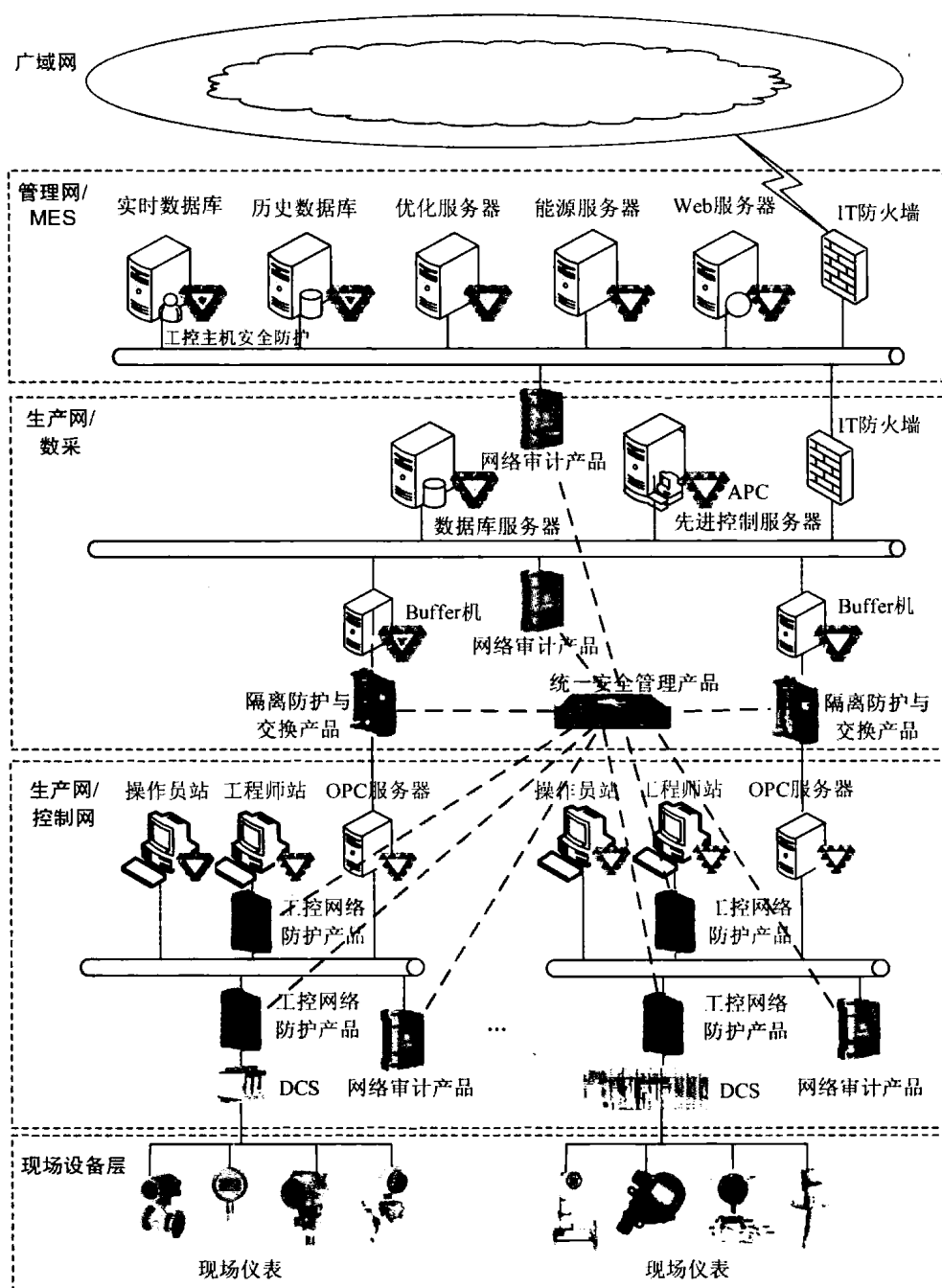


图 8-7 炼化厂整体安全防护解决方案示意图

3) 隔离防护与交换产品。通过在 OPC 服务器与数据汇聚层之间部署隔离防护与交换产品, 对 DCS 管理的关键区域部署安全策略, 实现分层次的安全防护, 抵御已知威胁。

4) 工控网络防护系统。通过在控制层的 DCS、工程师站前部署工控网络防护系统,对工控专有协议进行深度分析,确保数据包的合法性,实现工控网络的深度防护。

5) 工控主机安全防护。通过在管理网、生产网、控制网的工程师站、操作员站、OPC 服务器以及其他各类服务器上部署工控主机安全防护,通过应用程序、网络、USB 移动存储的白名单策略,防止用户的违规操作和误操作,阻止不明程序、移动存储介质和网络通信的滥用,有效提高工控网络的综合“免疫”能力。

8.4 本章小结

本章先后以先进制造业、城市燃气行业、石油化工这三个典型行业为例,通过对这三大行业的现状、发展趋势以及行业安全发展趋势进行分析,深入剖析了三大行业所面临的工控安全需求,最后根据各行业的特点给出切实有效的工控安全防护解决方案设计思路,以及最终在实践运用中达到的良好防护效果。

本章内容将有助于读者对工控行业安全发展趋势、现状分析以及安全解决方案的合理灵活运用有一个全面的认识和提高。

8.5 本章习题

1. 我国制造业数控加工方式主要表现出哪几种形态?
2. 先进制造业数控机床联网运行会存在哪些安全隐患?
3. 列举城市燃气工控系统技术发展趋势。
4. 城市燃气行业工控网络有哪些安全性问题?
5. 燃气行业工控网络安全防护措施的设计指导方针、原则是什么?全生命周期的解决方案主要包含哪些方面?
6. 石油化工行业有哪些主要的工控系统?
7. 列举石油化工行业存在的安全风险。
8. 针对石油化工行业工控网络面临的各种风险,请用概括性语言描述工控网络安全解决方案的设计思路。

国内外工控系统典型攻击事件

在信息技术与传统工业融合的过程中，工业控制正面临越来越多的网络安全威胁，2014 年工控用户在生产中发生网络安全事故的比例有所提升，受网络安全事件影响的企业由 2013 年的 25% 上升到 2014 年的 28.6%，因病毒事件造成的工业控制网络停机的企业高达 19.1%。

工业控制网络安全事件在近几年呈现稳步增长的趋势，2015 年被 ICS-CERT 收录的攻击事件达到了 295 件。

工业控制系统网络安全事件统计如图 A-1 所示。

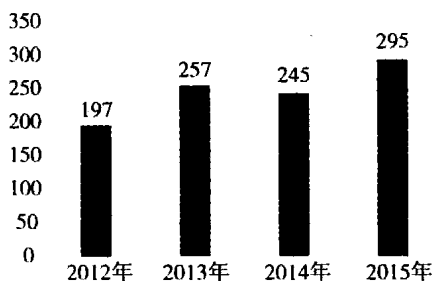


图 A-1 工业控制系统网络安全事件统计

2015 年，ICS-CERT 收集的涉及关键基础设施的安全事件如图 A-2 所示，关键制造业、能源、水处理成为被攻击最多的三个行业。这些数据由个人、团体、第三方 / 研究机构和

美国政府多方提供。不过，这些数据虽然为工业控制网络管理者们提供了一些参考，但也有人指出统计结果与实际情况可能会有较大差距，并不是所有的组织都会选择与 ICS-CERT 分享关于关键基础设施安全事件的信息。

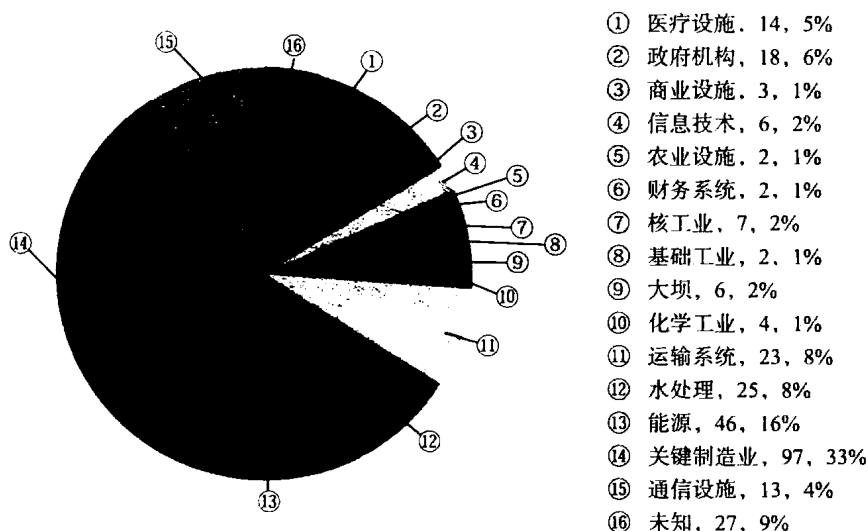


图 A-2 2015 年各行业攻击事件统计图

2015 年有 97 起安全事件是关于关键制造业的，占到全部事件的 33%，关键制造业成为 2015 年受攻击最多的行业（2014 年是能源行业）。

另外，ICS-CERT 还对工业控制网络攻击方式进行了统计，如图 A-3 所示。

通过对图 A-3 进行分析可知 2015 年鱼叉攻击方式的比例高达 37%。系统架构设计不合理、不完善导致工控设备直接或间接地与互联网连接，就会使鱼叉攻击极易成功。

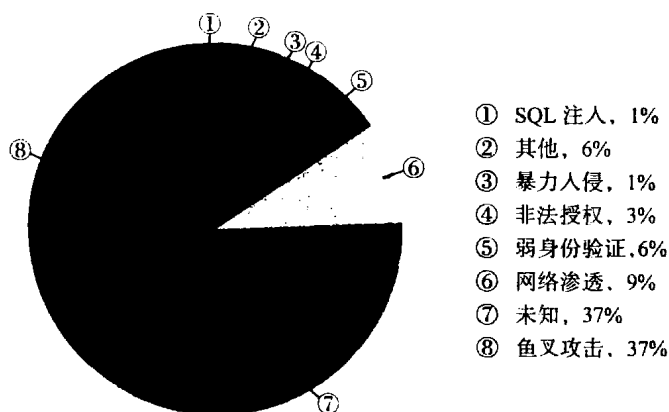


图 A-3 工业控制网络攻击方式

ICS-CERT 反复强调网络安全监测和入侵检测技术的重要性，但仍有 37% 的网络安全攻击在事后调查中没有被甄别出是如何实现的。

鱼叉攻击是一种相对容易的攻击手段，其多利用 E-mail 附件传播木马程序进行攻击。与 2014 年相比，网络渗透攻击的数量虽然急剧下降，但这种下降并不意味着真实攻击数量的减少，而是因为部分关键基础设施的所有者具备了成熟处理这种攻击的能力，从而减少了向 ICS-CERT 请求支持的报告。

另外，ICS-CERT 的统计数据显示出资产所有者有能力保护自己的设备，大量的攻击最终都以失败告终。统计显示，有 69% 的攻击没有入侵成功，而在 2014 年这一数据是 49%。不过，2015 年有 12% 的攻击入侵到了工业现场级的控制系统，这一数据要高于 2014 年的 9%。

表 A-1 和表 A-2 分别整理了一些典型的国内和国外工业控制网络安全事件，作为大家学习的参考。

表 A-1 国内工业控制网络安全事件

序号	安全事件	事件描述	事发原因	安全隐患
1	因信号系统受干扰，深圳地铁发生暂停故障	2012 年 7 月，深圳地铁蛇口线和环中线列车陆续因信号系统受干扰发生暂停故障。11 月，由于发生次数频繁，引发了各界对地铁安全运行问题的普遍关注	乘客随身携带的无线路由器（MIFI）。开展的测试表明：便携式无线路由器打开，信号系统指令异常，列车急停；便携式无线路由器关闭，信号系统正常	基于无线通信技术的 CBTC 系统车 - 地通信通常采用基于 IEEE 802.11 标准的无线局域网技术。基于无线通信的列车自动控制系统通常采用 IEEE 802.11 协议实现轨旁定向天线与车载天线之间的通信。目前大多使用 2.4 GHz 频段频率，最大发射功率为 200 毫瓦（其他无线网络设备为 100 毫瓦）。由于 CBTC 系统车 - 地通信使用的频率和普通无线网络设备相同，发射功率仅比普通设备大 1 倍，因此，如果乘客在地铁列车上使用无线路由器，很有可能对其通信造成干扰
2	某电力公司感染 Welchia 蠕虫病毒	2015 年 3 月，某南方电网部分无人值守变电站出现数据采集中断告警的现象，该公司对其现网数据进行分析，发现其流量中存在着大量的 TCPRST 报文和异常的 ICMP 的 PING 流量	通过分析异常流量，发现其业务网络中的终端服务器上的 Windows 系统感染了 Welchia 蠕虫病毒。该病毒利用特殊 ICMP 的 PING 来发现局域网中的其他存活主机，并尝试传播感染。该病毒影响的系统为 Windows XP 和 Windows 2000 等基于 NT 内核的操作系统，涉及电力行业变电与配电的工控主机	该病毒溯源为 Welchia 蠕虫，全名 W32.Welchia.Worm。它会利用 DCOM RPC 的漏洞 MS03-026、MS03-039 来攻击目标机的 TCP 135 端口，并利用 WebDav 的漏洞 MS03-007 来攻击 TCP 80 端口。Welchia 蠕虫试图清除冲击波蠕虫，它会试图下载并安装来自微软升级网站的补丁程序并重启计算机，这会导致网络速度减慢甚至瘫痪

(续)

序号	安全事件	事件描述	事发原因	安全隐患
3	某石化企业感染 Conficker 蠕虫病毒	2015 年 3 月, 某石化 3# 酮苯装置 Honeywell (霍尼韦尔) TPS 工业控制网络, 从实时在线运行的石化行业典型 DCS (分布式控制系统) 中捕获通信数据进行深入解析, 在不影响该系统正常运行的情况下发现 Conficker 蠕虫病毒。所幸的是由于该病毒尚未与互联网上的病毒服务器交互成功, 故没有进行通过网络的传播行为, 也尚未产生严重危害	Conficker 蠕虫病毒以微软的 Windows 操作系统为攻击目标。它借助互联网或 USB 设备传播, 其 C&C 服务器 (远程命令和控制服务器) 多数位于美国。如果病毒满足通信外联条件, 如管理疏忽插入 U 盘、使用无线网卡等, 甚至是正常的远程调试, 即可接受互联网上病毒服务器的指令, 进行病毒传播、关键数据盗取等一系列恶意操作	值得注意的是, 该生产过程是石化系统生产过程中不可或缺的关键环节, 具有普遍性。在石化行业因感染该病毒对工控系统造成危害的并非个案, 国内多家石化企业曾由于感染该病毒, 导致部分服务器和控制器通信中断, 对生产造成了巨大影响
4	海康威视安全事件	2015 年 3 月 1 日, 国内著名网络摄像头生产制造企业海康威视遭遇“黑天鹅”安全门事件, “监控设备存在严重安全隐患, 部分设备已经被境外 IP 地址控制”	海康威视安防监控设备容易被黑客在线扫描发现。黑客至少可以通过 3 种方式探索发现海康威视安防监控产品: 通过百度、Google 等网页搜索引擎检索其产品后台 URL 地址, 通过 Shodan 等主机搜索引擎检索海康威视产品 HTTP/Telnet 等传统网络服务端口关键指纹信息, 通过自主研发的在线监测平台向海康威视产品私有视频通信端口发送特定指令获取设备详细信息	设备中弱口令问题普遍存在, 易被远程利用。据监测统计, 有超过 60% 的海康威视产品的 root 口令和 Web 登录口令均为默认口令。并且, 产品自身存在安全漏洞。海康威视产品在处理 RTSP 协议 (实时流传输协议) 请求时缓冲区大小设置不当, 被攻击后可导致缓冲区溢出甚至被执行任意代码。此次事件凸显了安防行业乃至整个工控行业面临的严峻的网络安全挑战
5	某石化 SCADA 系统安全事件	2015 年 5 月 23 日, 上海市奉贤区人民法院宣判了一起破坏中石化华东公司 SCADA 系统的案件	一名犯罪嫌疑人为中石化华东公司 SCADA 系统设计了一套病毒程序。而另一名犯罪嫌疑人则利用工作便利, 将此病毒程序植入华东公司 SCADA 系统的服务器中, 并最终导致病毒爆发, 系统无法正常运行	软件公司先后安排十余名中外专家前来维修都无功而返。此时, 两名嫌疑人再里应外合, 由公司内部的嫌疑人推荐开发病毒程序的嫌疑人前来“维修”, 从而赚取高额维修费用, 实现非法牟利。此次事件充分暴露出工控现场网络安全管理制度、防护措施的严重缺乏以及相关工作人员网络安全技术水平、防范意识不足等一系列问题

表 A-2 国外工业控制网络安全事件

序号	安全事件	事件描述	事发原因	安全隐患
1	日本三菱旗下军工企业遭黑客入侵	2011年9月20日, 中新网爆出日本企业三菱重工旗下打造潜舰、生产导弹以及制造核电站零组件等工厂的计算机网络遭到黑客攻击, 导致有些资料可能外泄, 这是日本国防产业首度成为黑客攻击目标。8月中旬, 三菱重工发现部分服务器中毒, 邀请网络保安公司调查	这些计算机最早在7年前就已经被感染病毒。据有关人士声称: 现在对已发现带有病毒的83台计算机依次进行分析所得出的结果显示, 比9月19日所发表的8种病毒大幅增加, 病毒种类的感染达到50种以上。其中1台计算机被28种病毒感染。在这些病毒之中, 能窃取用户资料的蠕虫病毒AGOBOT早在2004年4月就已经被发现, 并提醒注意。而能盗取银行账号密码的SPYEYE也在2011年7月得到过警告	可以看出, 早在此次遭受黑客攻击前三菱重工就已经发现了内部计算机感染了类似病毒, 但之前的病毒感染事件显然未引起三菱重工内部人员的足够重视, 信息安全意识淡薄直接导致了本次黑客攻击事件的发生
2	美国供水系统遭黑客破坏	2011年11月, 美国一家网络安全监控机构提交报告, 国外网络黑客几天前攻击美国一处地方水利系统。报告说, 这是国外黑客首次瞄准美国工业设施网络监控系统	黑客从一家软件公司获得授权信息, 11月8日侵入伊利诺伊州首府斯普林菲尔德以西一处农村地区水利控制系统。“攻击者利用一款远程监控水泵的软件系统, 一台水泵受损。”水利系统采用多水源和水泵系统, 所以攻击没有造成供水中断。供水机构覆盖当地2200家用户	网络监控人员认为, 攻击表明全美“监控和数据采集系统”(SCADA)存在漏洞。美国伊利诺伊州供水系统遭攻击后导致供水系统故障的事件再次唤起了公众对于工业控制信息安全的关注。传统意义上的黑客攻击往往针对金融机构、政府网站、知名企业等, 但人们往往忽视了对于基础设施建设工业控制信息安全的关注
3	“火焰”病毒入侵多个中东国家	卡巴斯基实验室2012年5月28日发布报告, 确认新型计算机病毒“火焰”入侵伊朗等多个中东国家。病毒用于窃取信息, 部分特征与先前攻击伊朗核设施计算机系统的“震网”(Stuxnet)蠕虫病毒相似, 但其结构更复杂, 造成的损害更大	“火焰”之所以拥有如此强大的间谍功能, 是因为它的程序构造十分复杂, “火焰”所包含的代码数量相当于之前发现的“震网”病毒或“毒区”病毒(Duqu)的20倍, 此前从未有病毒能达到这种水平。它可以通过USB存储器以及互联网进行复制和传播, 并能接受来自世界各地多个服务器的指令。一旦完成收集数据任务, 这些病毒还可自行毁灭, 不留踪迹	虽然这种病毒是在2012年才被发现的, 但很多专家认为它可能已经存在5年之久了, 包括伊朗、以色列、黎巴嫩、沙特和埃及在内的成千上万台计算机都已感染了这种病毒。而且这种病毒的攻击活动不具规律性, 个人计算机、教育机构、各类民间组织和国家机关都曾被其“光顾”过。电子邮件、文件、消息、内部讨论等都是其收集的对象
4	计算机病毒攻击全球最大天然气生产商	2012年8月, 全球最大天然气生产商之一卡塔尔拉斯天然气公司(RasGas)遭受严重计算机病毒攻击。此前, 全球最大原油生产商和受政府支持的沙特阿美石油公司(Saudi Aramco)也遭到了计算机病毒攻击	工控企业受到电脑病毒攻击, 主要原因是这些机构或企业网络的办公区域未从安全软件、安全设备、管理制度等方面采取多重防护措施, 不能做到病毒爆发前的预防与病毒爆发后的限制	国有企业拉斯天然气公司和沙特阿美表示, 病毒仅影响办公室计算机, 未影响运行油气生产的孤立系统。两家公司都表示生产和出口未受影响

(续)

序号	安全事件	事件描述	事发原因	安全隐患
5	贡德雷明根核电站发现病毒	根据德国 BR24 通讯社的报道, 贡德雷明根核电站的一个系统中发现了病毒。专家做出了初步评估, 这个病毒没有对核电站的关键部分造成影响, 也不会构成重大威胁	审计表明, 与 Stuxnet 不同, 这款病毒不是为核电站设计的, 而是一款普通的病毒。病毒可能的感染渠道之一就是某个员工所使用的 U 盘被带入贡德雷明根核电站	IT 专家 Thomas Wolf 对此事评论道, 恶意软件的威胁还是会存在于断网的系统中, 任何有数据交换的环节都可能成为传染渠道。Wolf 还指出, 即使在一个具有“全面病毒保护和先进安全管理”的环境下, 病毒仍能轻易传播, 针对核电站和工控系统的网络攻击可能是黑客所造成的灾难中后果最为严重的了, 全面提高所有相关人员的安全意识是必不可少的
6	黑客入侵纽约水坝	2012 年据美国官员和专家介绍称, 黑客入侵了距离纽约市不到 20 英里 (合 32 千米) 处的一个小型水坝控制系统, 引发的担忧蔓延至白宫。这一事件此前并未公开披露	据分析, 这一黑客入侵事件引发了公众对“网络战”的担忧	随着世界进入一个数字化的国与国冲突时代, 仍是机密的水坝系统遭到入侵成为美国官员的头等担忧: 美国的电网、工厂、管道、桥梁和水坝系统都是“数字部队”的主要攻击目标, 它们在基本没有防护的情况下暴露在互联网上。而且不同于传统战争, 有时很难知道一个系统是否已遭到入侵或哪里遭到入侵, 就此次水坝入侵来说, 联邦调查人员最初认为黑客的目标可能是俄勒冈州的一个更大规模的水坝。2011 年以来, 美国国土安全部公开提醒工业企业必须在工控系统联网时更加审慎, 许多工业设备保护措施不够, 进一步加大了有针对性的黑客攻击的风险

参考文献

- [1] 现场总线技术在应用中存在的问题 [DB/OL]. <http://gongkong.ofweek.com/2012-08/ART-310007-11001-28635695.html>.
- [2] 全国信息安全标准化技术委员会秘书处. 国内外工业控制系统信息安全标准及政策法规介绍 [Z]. 2012.
- [3] 工业控制系统 (ICS) 概述和与 IT 系统的比较 [DB/OL]. <http://www.chinabaike.com/t/9541/2014/0427/2119362.html>.
- [4] 张冠男, 蒋昕昊. 中国企业如何在工控领域紧跟国际脚步——工业控制系统行业现状及发展建议 [J]. 工业设计, 2016 (5): 162-163.
- [5] 夏春明, 刘涛, 王华忠, 等. 工业控制系统信息安全现状及发展趋势 [J]. 信息安全与技术, 2013, 4 (2): 13-18.
- [6] 陈章平, 杨泽. 西门子 S7-300/400 PLC 控制系统设计与应用 [M]. 北京: 清华大学出版社, 2009.
- [7] 李宁. 可编程自动化控制器 [J]. 世界仪表与自动化, 2004 (5): 26-28.
- [8] OFweek 工控网. 新一代可编程控制器 PAC 有哪些主要优势? [EB/OL]. <http://gongkong.ofweek.com/2013-12/ART-310012-11001-28760209.html>.
- [9] 全球五金网. PAC 技术现状及应用前景分析 [EB/OL]. http://wenku.baidu.com/link?url=w4UFHhjnlzpa3SHBSx72aBAuDUDvI4PtOWXU_nMRTutuUQTAm6asbJ49cj1Llw6kwjMRtPaRBCQMGMHxpyxPPfnfHHIAunakIK_j99GcHDBa.
- [10] 王勇. 嵌入式远程终端单元的研究与设计 [D]. 太原: 太原理工大学, 2010.
- [11] 祝常红. 数据采集与处理技术 [M]. 北京: 电子工业出版社, 2008.
- [12] 段传宗. 无人值班变电所及农网综合自动化 [M]. 北京: 中国电力出版社, 1998.
- [13] 周建芳. 线路供电水情测报终端的设计 [D]. 南京: 河海大学, 2006.
- [14] 高翔. 数字化变电站应用技术 [M]. 北京: 中国电力出版社, 2008.
- [15] 马伟民. 基于组件技术的人机界面 (HMI) 研究 [D]. 杭州: 杭州电子科技大学, 2009.
- [16] 郁汉琪, 王华. 可编程自动化控制器 (PAC) 技术及应用·基础篇 [M]. 北京: 机械工业出版社, 2010.
- [17] 潘铁洋. 欧姆龙 CPM 系列小型 PLC 讲座第 2 讲: 基本编程要求及基本指令 (一) [J]. 电世界,

2006, 47 (9): 42-44.

- [18] 张妍. PLC 通信技术 [J]. 西部广播电视, 2015 (14): 250-250.
- [19] 常州 PLC 培训中心. PLC 通信技术讲解 [EB/OL]. <http://www.houxue.com/news-104799/>.
- [20] 张洪利, 吴群. 工控环境下的网络架构 [J]. 网友世界·云教育, 2014 (23): 33-33.
- [21] 绿盟. 2014 工业控制系统的安全研究与实践 [EB/OL]. http://wenku.baidu.com/link?url=uYqu6wzm8Sy--qMc3_R3HX9YKofu3DTH0C5MEK06Oh2suYZFOq8vlnN8FJXMMZNNBtB_7ygUqdepDaiGcPxiVLUIkVJqWeLFR01fqIwcaAhe.
- [22] Soumenkov I. The Mystery of Duqu Framework Solved[EB/OL]. <https://securelist.com/blog/research/32354/the-mystery-of-duqu-framework-solved-7/>.
- [23] Yang D, Usynin A, Hines J. Anomaly-Based Intrusion Detection for SCADA Systems[C]. In 5th Intl. Topical Meeting on Nuclear Plant Instrumentation, Control and Human Machine Interface Technologies (NPIC&HMIT 05), 2005: 12-16.
- [24] Hadiosmanovic D, Bolzoni D, Hartel P, et al. MELISSA: Towards Automated Detection of Undesirable User Actions in Critical Infrastructures[C]. In 2011 Seventh European Conference on Computer Network Defense. Washington, DC: IEEE, 2011: 41-48.
- [25] Peterson D. Quickdraw : Generating Security Log Events for Legacy SCADA and Control System Devices[C]. In Proc. Cybersecurity Appl. Technol. Conf. Homeland Security (CATCH), Washington, DC, USA: IEEE, 2009, 227-229.
- [26] Papa S M. A Behavioral Intrusion Detection System for SCADA Systems[J]. Dissertations & Theses - Gradworks, 2013.
- [27] D'Antonio S, Oliviero F, Setola R. High-Speed Intrusion Detection in Support of Critical Infrastructure Protection[C]. In First International Workshop on Critical Information Infrastructures Security (CRITIS'06). Berlin: Springer, 2006: 222-234.
- [28] Linda O, Vollmer T, Manic M. Neural Network Based Intrusion Detection System for Critical Infrastructures[C]. In 2009 International Joint Conference on Neural Networks. Washington, DC : IEEE, 2009: 1827-1834.
- [29] Dussel P, Gehl C, Laskov P. Cyber-Critical Infrastructure Protection Using Real-Time Payload-Based Anomaly Detection[C]. In 4th International Workshop on Critical Information Infrastructures Security (CRITIS'09) Berlin: Springer, 2010: 85-97.
- [30] Goldenberg N Wool A. Accurate Modeling of Modbus/TCP for Intrusion Detection in SCADA Systems[J]. International Journal of Critical Infrastructure Protection, 2013, 6 (2): 63-75.
- [31] Amit Kleinmann, Avishai Wool. A Statechart-Based Anomaly Detection Model for Multi-Threaded SCADA Systems[J]. CRITIS, 2015: 132-144.

- [32] Premaratne U K, Samarabandu J, Sidhu T S, et al. An Intrusion Detection System for IEC61850 Automated Substations[J]. IEEE Transactions on Power Delivery, 2000, 25 (4): 2376-2383.
- [33] Sridhar S, Manimaran G. Data Integrity Attacks and Their Impacts on SCADA Control System[C]. PES 2010: IEEE Power and Energy Society General Meeting. Washington, DC: IEEE, 2010: 1-6.
- [34] Giani A, Bent R, Hinrichs M, et al. Metrics for Assessment of Smart Grid Data Integrity Attacks[C]. PES 2012 : IEEE Power and Energy Society General Meeting. Washington, DC : IEEE, 2012: 1-8.
- [35] Xie Le, Mo Yilin, Sinopoli B. Integrity Data Attacks in Power Market Operations[J]. IEEE Trans. On Smart Grid. 2011, 2 (4): 659-666.
- [36] Jia Liguan, Thomas R J, Tong Lang. Malicious Data Attack on Real-time Electricity Market[C]. ICASSP 2011 : Acoustics, Speech and Signal Processing. Washington, DC : IEEE, 2011 : 5922-5955.
- [37] Cui S, Han Z, Kar S, et al. Coordinated Data-injection Attack and Detection in the Smart grid : A Detailed Look at Enriching Detection Solutions[J]. IEEE Signal Processing Magazine, 2012, 29 (5): 106-115.
- [38] Mo Y, Sinopoli B. Secure Control Against Replay Attacks[C]. Proceedings of IEEE 47th Annual Allerton Conference on Communication, Control, and Computing. 2009: 911-918.
- [39] Rdenas A A, Amin S, Sastry S. Research Challenges for the Security of Control Systems[C]. USENIX Association Conference on Hot Topics in Security. Berkeley, CA: ACM, 2008: 6.
- [40] Amin S, Rdenas A A, Sastry S S. Safe and Secure Networked Control Systems under Denial-of-Service Attacks[C]. Proceedings of 12th ACM International Conference on Hybrid Systems : Computation and Control. Berlin: Springer, 2009: 31-45.
- [41] Wright A K, Kinast J A, Mccarty J. Low-Latency Cryptographic Protection for SCADA Communications[C]. Proceedings of Second International Conference on Applied Cryptography and Network Security. Boston, MA: Springer, 2004: 263-277.
- [42] Tsang P P, Smith S W. YASIR : A Low-Latency, High-Integrity Security Retrofit for Legacy SCADA Systems[C]. Proceedings of 23rd International Information Security Conference (SEC 2008) co-located with IFIP World Computer Congress 2008. Boston, MA: Springer, 2008: 445-459.
- [43] Solomakhin R, Tsang P, Smith S. High Security with Low Latency in Legacy SCADA System[M]. Berlin Heidelberg: Springer, 2010: 63-79.
- [44] Swaminathan P, Padmanabhan k, Ananthi S, et al. The Secure Field Bus (SecFB) protocol-network Communication Security for Secure Industrial Process Control[C]. IEEE Region 10 Conference, TENCOM 2016. Washington, DC: IEEE, 2016: 1-4.

- [45] He Xingze, Pun M O, Kuo C C J. Secure and Efficient Cryptosystem for Smart Grid using Homomorphic Encryption[C]. Proceedings of PES 2012. Washington, DC: IEEE, 2012: 1-8.
- [46] Zhang Liping, Tang Shanyu, Jiang Yijing, et al. Robust and Efficient Authentication Protocol Based on Elliptic Curve Cryptography for Smart Grid[C]. Proceedings of IEEE International Conference on Green Computing and Communications (GreenCom 2013). Washington, DC : IEEE, 2013: 2089-2093.
- [47] Kumar V, Hussain M. Secure Communication for Advance Metering Infrastructure in Smart Grid[C]. Proceedings of INDICOM 2014. Washington, DC: IEEE, 2015: 1-6.
- [48] Beaver C L, Gallup D R, Neumann W D, et al. Key Management for SCADA[R]. Office of Scientific & Technical Information Technical Reports, 2002.
- [49] Robert D, Colin B, Ed D, et al. SKMA—A Key Management Architecture for SCADA Systems[C]. Proceedings of 4th Austral. Inf. Security Workshop, 2006 (54): 183-192.
- [50] Donghyun C, Ilakman K, Dongho W, et al. Advanced Key-Management Architecture for Secure SCADA Communications[J]. IEEE Transactions on Power Delivery. 2009 (24): 1154-1163.
- [51] Donghyun C, Sungjin L, Dongho W, et al. Efficient Secure Group Communications for SCADA[J]. IEEE Transactions on Power Delivery, 2010 (25): 714-722.
- [52] Davis C M. SCADA Cyber Security Testbed Development[C]. 2006 38th North American Conference on Power Symposium: Washington, DC: IEEE, 2006: 483-488.
- [53] Reaves B, Morris T. An Open Virtual Testbed for Industrial Control System Security Research[J]. International Journal of Information Security, 2012, 11 (4): 215-229.
- [54] Queiroz C. Building a SCADA Security Testbed[C]. 2009 Third International Conference on Network and System Security. Washington, DC: IEEE, 2009: 357-364.
- [55] Morris T. A Testbed for SCADA Control System Cybersecurity Research and Pedagogy[C]. CSIIRW'11 Proceedings of the Seventh Annual Workshop on Cyber Security and Information Intelligence Research. New York: ACM, 2011.
- [56] Fovino I N, et al. An Experimental Platform for Assessing SCADA Vulnerabilities and Countermeasures in Power Plants[C]. 2010 3rd Conference on Human System Interactions (HSI). Washington, DC: IEEE, 2010: 679-686.
- [57] Modbus Organization Inc. Modbus_Application_Protocol_V1_1b3 [EB/OL]. <http://www.modbus.org/docs/Modbus-Applcation-Protocol-V1-1b3.pdf>.
- [58] Zhu xian qing. Modbus Protocol and Programing[J]. Electronic Engineer, 2005, 7: 16.
- [59] 左卫, 程永新. Modbus 协议原理及安全性分析 [J]. 通信技术, 2013 (12): 66-69.
- [60] 孙大林, 蒋大明. Modbus/TCP 的安全性及其在工业监控系统中的应用 [J]. 中国安全生产科学技

术, 2006, 2 (2): 92-95.

- [61] Curtis K. A DNP3 Protocol Primer[J]. DNP User Group, 2005: 1-8.
- [62] Lee D, Kim H, Kim K, et al. Simulated Attack on DNP3 Protocol in Scada System[C]. Proceedings of the 31th Symposium on Cryptography and Information Security. Kagoshima, Japan: SCIS, 2014: 21-24.
- [63] Majdalawieh M, Parisi-Presicce F, Wijesekera D. DNPsec : distributed network protocol version 3 (DNP3) security framework[M]//Advances in Computer, Information, and Systems Sciences, and Engineering. Netherlands: Springer, 2007: 227-234.
- [64] 陈国华. 远动 IEC 60870-5-104 网络通信协议及其安全防护技术 [J]. 电工技术, 2004 (6): 7-8.
- [65] Ju Y, Zhang H G. Design and Application of IEC 60870-5-104 Telecontrol Protocol[J]. Relay, 2006, 34 (17): 55-58.
- [66] OPC Overview[Z]. OPC Foundation, 1998.
- [67] Mahnke W, Leitner S H, Damm M. OPC Unified Architecture[M]. Berlin : Springer Science & Business Media, 2009.
- [68] 尚文利, 赵剑明, 万明, 等. 基于动态跟踪技术的 OPC 协议的安全防护方法: 中国, 104734903A[P]. 2015-06-24.
- [69] Stouffer K, Falco J, Scarfone K. Guide to Industrial Control Systems (ICS) Security[J]. NIST Special Publication, 2011, 800 (82): 16-16.
- [70] 于长奇. 工控设备漏洞挖掘技术研究 [D]. 北京: 北京邮电大学, 2015.
- [71] 王欢欢. 工控系统漏洞扫描技术的研究 [D]. 北京: 北京邮电大学, 2015.
- [72] 万明. 工业控制系统信息安全测试与防护技术趋势 [J]. 自动化博览, 2014 (9): 68-71.
- [73] 熊琦, 王婷, 彭勇, 等. 工控网络协议 Fuzzing 测试技术研究进展 [C]. 信息安全漏洞分析与风险评估大会. 2013.
- [74] Butts J, Sheno S. Identifying Vulnerabilities in Scada Systems Via Fuzz-Testing[C]. Critical Infrastructure Protection V, IFIP AICT, 2011 (367): 57-72.
- [75] 凌从礼. 工业控制系统脆弱性分析与建模研究 [D]. 杭州: 浙江大学, 2013.
- [76] Formaggio Y. Attacking VxWorks: from Stone Age to Interstellar[EB/OL]. <https://44conlondon2015.sched.com/event/la80325a56d480692972823db57e34fc>.
- [77] Softpanorama. Event correlation technologies[EB/OL]. http://www.softpanorama.org/Admin/Event_correlation/.
- [78] A. Chunvakin. Content Aware SIEM[EB/OL]. <http://www.sans.org/Security-resources/idfaq/vlan.php>.
- [79] B Singer. Correlating Risk Events and Process Trends[C]. Proceedings of the SCADA Security Scientific Symposium (S4). Sunrise, FL: Kenexis Security Corporation and Digital Bond Press, 2010.